Secure By Design — US-Source Infrastructure Design Reference Compendium

Windows / Active Directory enterprise design, organized by design area, from United States sources

Assembled for review — October 19, 2026

Table of Contents

How to read this compendium....6

Shared method and scope....6

How the five interlock (cross-service dependency map)....6

Consolidated US-source landscape....7

Cross-cutting agreements and conflicts (across all five)....8

Consolidated caveats....8

Part I — US Design Reference: Active Directory Forest, Domain, and Organizational Unit Design (as of October 2026)....10

Summary....10

Authoritative design-source overview....11

1. Forest design....14

2. Domain design....15

3. Trust design....16

4. OU design....17

5. Group Policy design (coupled to OU design)....18

6. Administrative tiering design....18

Where authorities agree, differ, or conflict....20

Caveats and items that could not be verified....21

Part II — US Design Reference: DNS for Windows / Active Directory Enterprise Environments (as of October 2026)....22

TL;DR....22

Authoritative design-source overview....23
1. Namespace design....27
2. Zone design....28
3. Resolution and forwarding design....29
4. Dynamic update and record-management design....31
5. DNSSEC and integrity design....32
6. Availability and placement design....33
7. Hardening-by-design (architectural security choices)....34
8. Logging and monitoring design....34
Where authorities agree, differ, or conflict....35
Caveats and items that could not be verified....37
Part III — NTP / Time Synchronization in Windows and Active Directory: US-Source Design Reference (October 2026)....39
TL;DR — design baseline....39
Authoritative design-source overview....40
1. Time hierarchy design....45
2. External upstream source selection design....46
3. Accuracy and performance design....47
4. Kerberos skew dependency design....48
5. Virtualized domain controller time design....49
6. Time authentication design....49
7. Secure Time Seeding design....50
8. Monitoring, logging, and leap-second design....51
Where authorities agree, differ, or conflict....52
Caveats and items that could not be verified....53
Part IV — US Design Reference: Windows Enterprise PKI with Active Directory Certificate Services (AD CS) (as of October 2026)....54
TL;DR....54

Authoritative design-source overview....55
1. CA hierarchy design....60
2. CA type and role design....60
3. Cryptographic design....61
4. Validity and renewal design....62
5. Revocation and publication design (CDP/AIA)....63
6. Certificate template design....63
7. Enrollment and endpoint design....64
8. Identity binding and authentication design....64
9. CA protection, role separation, auditing and key-backup design....65
10. Logging and monitoring design....66
Where authorities agree, differ or conflict....66
Caveats and items that could not be verified....68
Part V — DHCP in Windows Server and Active Directory: US-Source Design Reference (October 2026)....69
1. TL;DR — design baseline....69
2. Authoritative design-source overview....69
3. Design areas....75
4. Where authorities agree, differ, or conflict....82
5. Caveats and items that could not be verified....83
Part Two — Annotated US Source & Guideline Catalogs....85
US-Only Reference Collection: Active Directory Design, OU Structure, and Tiered Administration (as of October 2026)....86
TL;DR....86
1. Guidance landscape overview....87
2. Section A — Official Microsoft guidance....88
3. Section B — US government and standards guidance....96
4. Topic crosswalk....100

5. Where authorities agree, differ, or conflict....103
6. Caveats and items not verified....103
US Reference Collection: DNS Security and Deployment (Windows/Enterprise), October 2026 105
TL;DR....105
1. Overview of the guidance landscape....105
2. Section A: Microsoft official guidance (by topic)....106
3. Section B: Government and standards guidance....112
4. Topic crosswalk....115
5. Where authorities agree, differ, or conflict....117
6. Caveats and items not verified....118
US Reference Collection: NTP and Time Synchronization for Windows/Enterprise Environments (verified October 2026)....119
1. TL;DR....119
2. Guidance landscape overview....120
3. Section A: Microsoft official guidance by topic....122
4. Section B: US government and standards guidance by publisher....126
5. Topic crosswalk....130
6. Agreements, differences and conflicts....133
7. Caveats, corrections and unverified items....134
US Reference Collection: Certificate Authority Design and Implementation with Microsoft AD CS (Windows PKI) — Status as of October 2026....136
1. TL;DR — summary of the US guidance baseline....136
2. Guidance landscape overview....136
3. Section A — Microsoft official guidance (by topic)....140
4. Section B — US government and standards guidance (by publisher)....146
5. Topic crosswalk....150
6. Where authorities agree, differ, or conflict....154

7. Caveats and items that could not be verified....155

DHCP for Windows/Enterprise Environments: US-Only Verified Reference Collection (as of October 2026)....157

TL;DR....157

Guidance landscape overview....157

Section A — Microsoft official guidance by topic....160

Section B — US government and standards guidance....164

Section B6 — Akamai practitioner research (US company; NON-GOVERNMENTAL)....167

Topic crosswalk....168

Agreements, differences and conflicts....170

Caveats and unverified items....171

DISA STIGs and DISA STIG GPO Packages: A US-Only Reference Collection (verified as of October 19, 2026)....172

1. TL;DR — the US guidance baseline....172

2. Guidance landscape overview....172

3. Section A — DISA's own artifacts and tooling....175

4. Section B — Related US government and standards guidance....180

5. Topic crosswalk....183

6. Where authorities agree, differ, or conflict....184

7. Caveats and items that could not be verified....185

This compendium gathers the whole body of work into one volume, in two parts. **Part One** is the five **design references** — Active Directory (forest, domain, OU), DNS, NTP / time synchronization, PKI (AD CS), and DHCP — each organized by *design decision* rather than by source. **Part Two** is the six **annotated source & guideline catalogs** — the curated lists of official Microsoft documentation and US-government guidelines (with dates, versions, status, licensing, and consensus/crosswalk notes) that the design references were built from. Everything draws only on United States sources (Microsoft, NIST, CISA/OMB/NSA, DISA, CIS, the IETF, and ICANN), with non-US government guidance (ANSSI, BSI, NCSC-UK, ASD/ACSC, CCCS, ENISA) excluded; Five Eyes products are included only where CISA/NSA co-sealed them, with authorship noted. Everything is environment-agnostic: none is tailored to a specific lab, domain name, or network.

How to read this compendium

The five parts are ordered by their **build and dependency order**, not the order they were written:

1. **Part I — Active Directory (forest, domain, OU).** The identity foundation. The forest is the security boundary; everything else sits inside it.
2. **Part II — DNS.** AD cannot function without DNS, and the AD domain name *is* a DNS name, so namespace design is shared with Part I.
3. **Part III — NTP / time.** Kerberos, certificate validity, and log correlation all depend on synchronized time.
4. **Part IV — PKI (AD CS).** Depends on identity (Part I), name resolution (Part II), and time (Part III) before it can issue or validate anything.
5. **Part V — DHCP.** Addresses endpoints and, through dynamic update, writes into DNS (Part II); its security leans on the switch layer and on AD authorization.

Each part keeps its own structure: a TL;DR, an authoritative source table, one section per design area, a "where authorities agree, differ, or conflict" section, and its own caveats. This front section adds only the connective tissue — it does not replace any part.

Shared method and scope

- **Organized by design area.** Each part walks the real decisions (e.g., "how many forests," "AD-integrated vs file-based zones," "failover vs split-scope"), the realistic options, what each US authority recommends, the trade-offs, and the conflicts — rather than cataloging sources.
- **US sources only.** Microsoft for the Windows implementation; NIST, CISA/NSA, DISA, and CIS for the security overlay; the IETF (and ICANN for DNS) for the protocols. Clearly-labeled US-company practitioner research (SpecterOps, Trimarc, Mandiant, Akamai) is included as non-governmental.
- **Verification posture varied by part.** Some parts were produced with full Research; others (where Research was unavailable in-session) were built from direct source checks plus the project's earlier research and are flagged accordingly in their own caveats. Treat every STIG release number, CIS benchmark version, and draft-NIST date as "confirm before relying on it," since those change after any given cutoff.

How the five interlock (cross-service dependency map)

The references are not independent documents that happen to share a format; they describe one system. The seams that matter:

- **Time underpins everything.** Part III (NTP) is a prerequisite for Part I's Kerberos 5-minute skew tolerance, for Part IV's certificate `notBefore/notAfter` and CRL validity windows, and for the log-correlation requirement (NIST AU-8 / SC-45) that recurs in every part. The forest-root PDC emulator is the single external time boundary and also a Part I FSMO role — so a PDC-emulator move touches both references.
- **The forest is the blast radius.** Part I establishes that the *forest*, not the domain, is the security boundary. That is exactly what Part IV's "treat every CA as Tier 0," Part IV's

NTAuth/strong-mapping enforcement, and Part I's own administrative-tier model all exist to protect. Compromise of Tier 0 anywhere is forest-wide.

- **Namespace is one decision shared by two parts.** The AD domain name (Part I) and the DNS zone name (Part II) are the same string: use a registered subdomain or ICANN's `.internal`, never `.local`. Read Part I §2 and Part II §1 together.
- **DHCP writes into DNS.** Part V's DHCP–DNS dynamic-update design (the DnsUpdateProxy problem, Name Protection/DHCID, the dedicated registration credential) is the same seam as Part II's dynamic-update and scavenging design. The Akamai DDSpoof and "DHCP Administrators → Domain Admins" findings live at this seam and tie Part V back to Parts I and II.
- **PKI binds identity.** Part IV's domain-controller certificates (Kerberos Authentication template), strong certificate mapping (KB5014754), and NTAuth chaining (KB5057784) are the mechanism behind Part I's certificate-based authentication — and both now depend on Microsoft's enforcement, which removed the registry bypasses in 2025.

Consolidated US-source landscape

Which authorities drive which parts (● primary, ○ supporting/context):

Authority	AD (I)	DNS (II)	NTP (III)	PKI (IV)	DHCP (V)
Microsoft (Learn / Support / MSRC)	●	●	●	●	●
NIST (SP 800-53/-81r3/-57/-63B; FIPS)	○	●	●	●	○
CISA / NSA (joint CSIs, AD-compromise guide)	●	●	○	●	○
DISA (STIGs)	●	●	●	●	● (logging)
CIS (Controls v8.1; Windows benchmarks)	○	○	●	○	○
IETF (RFCs)	○	●	●	●	●
ICANN	—	●	—	—	—
US practitioner (SpecterOps/Trimarc/Mandiant/Aka	●	○	—	●	●

mai)

The pattern worth noting: **no US-government body publishes a DHCP-specific or NTP-specific *standard***. For those two, the IETF defines the protocol, Microsoft defines the Windows behavior, DISA supplies one hard rule each (DHCP log retention; the forest-root external-time requirement), and the security load shifts to the switch layer (DHCP) or to a non-Microsoft layer (authenticated NTP).

Cross-cutting agreements and conflicts (across all five)

Where the US authorities consistently agree: - The forest is the security boundary; isolate and tier the identity control plane (Tier 0). - Prefer the fewest moving parts that meet the requirement (single forest, single domain, dedicated-but-minimal servers). - Synchronized time is mandatory, and logs must carry UTC timestamps for correlation. - Centralize and retain security-relevant logs; forward them off-box.

The conflicts that recur across parts: - **Dedicated servers vs co-location with domain controllers.** NIST prefers dedicated DNS (Part II) and keeping roles off DCs (recurs for DHCP in Part V and CAs in Part IV); Microsoft's model co-locates DNS on DCs and historically co-located DHCP on DCs. The defensible middle ground differs per service and is stated in each part. - **DISA hard rules vs Microsoft defaults.** DISA mandates things Microsoft leaves optional or ships off by default — internal-zone DNSSEC with NSEC3 (Part II), the external DoD time source (Part III), CA-manager approval for SAN-suppliable templates (Part IV), and 30-day-online/1-year-offline DHCP log retention (Part V). DoD systems follow DISA; others treat these as benchmarks. - **The authenticated-time gap.** The IETF, NSA, and CISA call for authenticated time (Part III), but the Windows Time Service cannot authenticate to any external NTP server — so this has to be solved on routers, appliances, or a non-Windows time layer. This gap quietly affects the integrity of everything time-dependent above. - **The post-quantum clock.** NIST and NSA set deprecation dates for SHA-1 (by 2030) and quantum-vulnerable RSA/ECDSA (draft: after 2030/2035), and AD CS on Windows Server 2025 can now issue ML-DSA certificates (Part IV) — but existing CAs can't be converted, so this is a parallel-hierarchy pilot, not a migration.

Consolidated caveats

- **This is review material, not published guidance.** It is here for the owner's review before anything is used in the training library, website, or app.
- **Verification is per-part.** Each part's own "Caveats" section is authoritative for what was and wasn't confirmed in that part. Common threads: DISA STIG release numbers were often read from third-party mirrors rather than cyber.mil; some CIS benchmark versions and draft-NIST dates were not re-verified; a few Microsoft default values come from documentation not re-fetched for that edition.
- **Currency.** Everything is stated as of October 2026. Protocol and product facts (RFC 9915 replacing RFC 8415, Windows Server 2025 functional level and ML-DSA, strong-mapping/NTAuth enforcement, the October 2026 CGPM leap-second decision) are current to that date and should be re-checked over time.

Part I — US Design Reference: Active Directory Forest, Domain, and Organizational Unit Design (as of October 2026)

US guidance on Active Directory design splits cleanly. Microsoft owns the structural logic (how many forests and domains, how to lay out OUs and Group Policy); CISA/NSA, DISA and NIST own the security overlay (tiered administration, privileged-access isolation, and the controls that keep a forest from falling in one move). The single fact they all agree on is that **the forest, not the domain, is the security boundary**, so forest and tiering decisions set the blast radius for an identity compromise. The two points of real movement in 2026 are the retirement of the old "Red Forest" (ESAE) design in favor of the Enterprise Access Model, and Windows Server 2025's delegated Managed Service Accounts, which created a new Tier 0 concern (BadSuccessor / CVE-2025-53779).

This reference parallels the companion DNS, PKI, NTP and DHCP design references: organized by design area, US sources only, ending with where the authorities agree, differ, or conflict.

- **US sources only:** Microsoft, NIST, CISA/NSA, DISA, CIS, and (minimally) the IETF for the underlying Kerberos and LDAP protocols. US-company practitioner research (SpecterOps, Trimarc, Mandiant, Akamai) is included and labeled as non-governmental.
- **Removed:** non-US government guidance — ANSSI (France), BSI (Germany), NCSC (UK), ASD/ACSC (Australia), CCCS (Canada), ENISA (EU).
- **Design spine:** forest, domain, and OU, plus the design areas tied to them — trusts, Group Policy, and administrative tiering.

Summary

- **Forest:** Prefer a single production forest unless a hard isolation or autonomy requirement forces more. Microsoft states the forest is "the security and administrative boundary for all objects that reside within the forest," and that co-ownership of one forest by two autonomous IT organizations "is not recommended." A separate administrative ("Red") forest is no longer the default — ESAE was retired on December 15, 2020 and replaced by the Enterprise Access Model — but tiering itself was not retired.
- **Domain:** Prefer a single domain per forest. The domain is a replication and administrative boundary, **not** a security boundary. Add domains only for replication, administrative, or policy reasons, never for security isolation. The AD domain name is a DNS name, so namespace choice is a joint AD/DNS decision (use a registered subdomain or ICANN's `.internal`, never `.local` or a single label).
- **OU:** Design OUs for exactly two purposes — delegation of administration and Group Policy application — not replication. Delegate with least privilege, redirect the default `Users` and `Computers` containers so GPOs reach new objects, and build a Tier 0/1/2 OU structure for administrative separation.
- **Group Policy:** Keep GPOs few and well-scoped. Understand LSDOU processing, link order, Block Inheritance vs Enforced, security and WMI filtering, and loopback. Deliver security baselines (DISA STIG GPOs, Microsoft security baselines, CIS build kits) through GPOs linked to the right OUs, tested first.

- **Administrative tiering:** Treat the directory's control plane as Tier 0 (domain controllers, AD CS, AD FS, Microsoft Entra Connect, and the accounts, groups and workstations that manage them). Use privileged access workstations and the clean-source principle, put privileged accounts in Protected Users with authentication policies/silos, set `ms-DS-MachineAccountQuota` to 0, and restrict OU write permissions so the dMSA/BadSuccessor path is closed.

Authoritative design-source overview

Status as of October 19, 2026. Access is free unless noted. Reuse: US federal works (NIST, CISA, NSA, DISA) are generally public domain in the US, excluding third-party content and logos; Microsoft Learn/Support is under the Microsoft Terms of Use (Learn text is also on GitHub under CC BY 4.0, verify per page); CIS Controls/Benchmarks are free for non-commercial use under CC BY-NC-SA 4.0 (commercial use and CIS-CAT Pro/build kits need SecureSuite membership); IETF RFCs fall under the IETF Trust Legal Provisions; practitioner papers are author-copyrighted.

Publisher	Key document / tool	Date / version	Status	Design areas
Microsoft Learn	Tier model for AD DS	ms.date 2026	Current	1, 4, 6
Microsoft Learn	Securing privileged access / Enterprise Access Model	Published Dec 15, 2020; maintained	Current	1, 6
Microsoft / GitHub	microsoft/ ActiveDirectory TierModel repo + deployment docs	Active (v1.3.x)	Current	6
Microsoft Learn	Best Practices for Securing Active Directory	Maintained	Current	1, 3, 6
Microsoft (TechNet archive)	Determining the Number of Forests Required; Creating a New Forest; Determining the Number of Domains; AD DS Design Guide	Windows Server 2003/2008-era	Legacy, still the canonical design logic	1, 2
Microsoft Learn	Selecting the Forest Root	Maintained / archived	Mixed	2

Publisher	Key document / tool	Date / version	Status	Design areas
	Domain; Assigning Domain Names; determine number of domains			
Microsoft Learn	Creating an OU design; Delegating administration by using OU objects; redirusr/redircmp	Maintained / archived	Current guidance	4
Microsoft Learn	Group Policy processing and precedence; security filtering; WMI filtering; loopback; Central Store	Maintained	Current	5
Microsoft Learn	FSMO roles; transfer/seize operations master roles	Maintained	Current	2
Microsoft Learn	Forest and domain trusts; SID filtering; selective authentication	Maintained	Current	3
Microsoft Learn / what's-new	What's new in AD DS in Windows Server 2025 (new functional level; dMSA; 32k database page)	2024–2026	Current	1, 2, 6
Microsoft Learn	Protected Users security group; Authentication policies and silos	Maintained	Current	6

Publisher	Key document / tool	Date / version	Status	Design areas
Microsoft MSRC	CVE-2025-53779 (“BadSuccessor”) Windows Kerberos EoP via dMSA	Disclosed May 21, 2025; patched Aug 12, 2025	Current	6
NIST	SP 800-53 Rev 5 (AC-2, AC-5, AC-6 and enhancements, IA-2) — Release 5.2.0	Sept 2020; 5.2.0 Aug 27, 2025	Current	4, 6
NIST	SP 800-63B Digital Identity Guidelines (authentication)	800-63B-4 (2025)	Current	6
NIST	SP 800-207 Zero Trust Architecture	Aug 2020	Current (context)	6
CISA / NSA (Five Eyes, ASD-led)	Detecting and Mitigating Active Directory Compromises (17 techniques)	Sept 2024	Current (US co-author source)	1, 3, 6
NSA	Defend Privileges and Accounts (CSI)	2019	Current	6
DISA	Active Directory Domain STIG (EA/DA/SA membership CAT I; Protected Users V-243477; PAW for AD management)	V3 series (2026)	Current	2, 4, 6
DISA	Active Directory Forest STIG (trust SID filtering/selective auth; V-269098/V-269099 for AD CS)	V3 series	Current	1, 3

Publisher	Key document / tool	Date / version	Status	Design areas
CIS	CIS Controls v8.1 (Control 4; 5.4 dedicated admin accounts; 6.x MFA)	v8.1 (2024)	Current	4, 6
CIS	CIS Microsoft Windows Server Benchmarks	Per-OS (WS2025, 2026)	Current	5, 6
IETF	RFC 4120 (Kerberos v5); RFC 4511 (LDAP)	2005/2006	Current (underlying protocols)	2, 3
SpecterOps (practitioner)	BloodHound; “Establish security boundaries in your on-prem AD and Azure”; BadSuccessor analysis	2022–2025	Current research	1, 3, 6
Trimarc (practitioner)	Sean Metcalf — AD security and tiering guidance	Current	Current research	1, 6
Mandiant / Google Cloud (practitioner)	AD hardening and attack-path guidance	Current	Current research	3, 6

1. Forest design

Decision at stake: how many forests to run, how to treat the forest security boundary, how to build the forest root domain, which forest functional level to choose, and whether a separate administrative forest is warranted.

Realistic options: single forest with a single domain (simplest, most common); single forest with multiple domains (one security boundary, several administrative/replication boundaries); multiple forests (account/resource or organizational forests for isolation/autonomy); a dedicated administrative forest (the former ESAE/“Red Forest”, now niche).

What the US authorities say: - **Microsoft (structural):** - “A forest is the security and administrative boundary for all objects that reside within the forest. In contrast, a domain is the administrative boundary for managing objects.” The domain was the security boundary in the Windows NT era; that changed with Active Directory. - Determining the number of forests means evaluating isolation and autonomy requirements; “isolation requirements limit your design choices,” and the decision “involves balancing costs against benefits.” - All objects in one forest are in the global catalog, so “no synchronization across forests is required.” Co-ownership

of a single forest by two autonomous IT organizations “is not recommended.” - Collapsing forests later is much harder than adding them, so get the count right at the start. - **Forest functional level:** Windows Server 2025 introduces a new domain and forest functional level (the first since 2016); a new forest requires at least the 2016 level. The 2025 level enables the optional 32k database page size and the delegated Managed Service Account (dMSA) feature. - **Forest root domain:** either a dedicated/empty root (holding the forest-wide Enterprise Admins and Schema Admins groups, isolating them) or a single regional domain that is also the root. - **Microsoft (security) and practitioners:** - ESAE (the “Red Forest”) was retired as the default recommendation on December 15, 2020, when Microsoft published the Enterprise Access Model. SpecterOps confirms Microsoft “retired ESAE and took down their old recommendations,” and that the equivalent control is now the Enterprise Access Model plus the administrative tier model. - A dedicated administrative forest (and Microsoft’s PAM/MIM pattern) still exists for the highest-assurance or legacy on-prem cases, but most organizations should implement tiering and PAWs within the production forest rather than stand up a separate forest. - **CISA/NSA and NIST:** treat the forest as the identity control plane’s outer edge. The Sept 2024 CISA/NSA guidance frames AD compromise as the primary objective for attackers; because the forest is the security boundary, Tier 0 isolation (Section 6) is what limits damage. NIST SP 800-207 reframes identity as the control plane, the conceptual basis for isolating it. - **DISA:** forest-level rules live in the AD Forest STIG — SID filtering and selective authentication on trusts (Section 3), restrictions on anonymous access to forest data, and the AD CS rules (V-269098/V-269099).

Trade-offs: - **More forests** give real isolation (separate schemas and security boundaries; a compromise in one does not automatically cross), at the cost of synchronization (no shared global catalog; you need Entra Connect / MIM / trusts), duplicated administration, and a worse cross-forest user experience. - **A single forest** is cheaper and simpler but concentrates risk: a Tier 0 compromise anywhere in the forest is a whole-forest compromise. - **A dedicated admin forest** maximizes credential isolation but is expensive and complex; Microsoft retired it as the default for that reason.

Conflicts: the main one is “when is a separate administrative forest still justified?” Microsoft now answers “rarely — use the Enterprise Access Model in-forest,” while practitioners note the tier model persists and a hardened admin forest remains defensible for specific high-assurance or heavily legacy estates. There is no US-government mandate for a separate admin forest.

2. Domain design

Decision at stake: how many domains per forest, how to treat the domain boundary, single vs multiple trees/namespaces, whether to use an empty forest-root domain, the domain functional level, and FSMO placement.

Realistic options: single domain (preferred); multiple domains in one tree (contiguous namespace); multiple trees (disjoint namespaces) in one forest; an empty forest-root domain plus one or more child domains.

What the US authorities say: - **Microsoft:** - The domain is “the administrative boundary for managing objects,” not a security boundary. “Only one instance of an Active Directory domain should exist at any time.” - Microsoft’s long-standing guidance favors the fewest domains

possible, and a single domain wherever it meets requirements. Extra domains are justified by replication control, decentralized administration, distinct account/password or policy requirements, or replication scale — **not** by a desire for security isolation, because domain admins in one domain can reach others through known forest-internal paths. - The AD domain name is simultaneously a DNS name (e.g., `corp.contoso.com`), so domain naming is a joint decision with DNS: use a registered subdomain or ICANN's reserved `.internal`, and avoid single-label names and `.local` (see the DNS design reference). - **Empty forest-root domain:** a dedicated root domain that holds the forest-wide groups (Enterprise Admins, Schema Admins) and little else, to protect those groups and decouple the root from any region. It adds domain controllers to build and maintain. - **Domain functional level:** governs per-domain features; raising it requires all domain controllers at that OS level or higher. - **FSMO roles:** five operations master roles — Schema Master and Domain Naming Master are forest-wide; PDC Emulator, RID Master, and Infrastructure Master are per-domain. Place the PDC Emulator on a reliable, well-connected DC (it is also the default authoritative time source — see the NTP reference); keep the Infrastructure Master off a global catalog server unless every DC is a GC. Seize a role only after unrecoverable failure. - **IETF:** Kerberos (RFC 4120) and LDAP (RFC 4511) are the protocols the domain exposes; design choices (trust transitivity, referrals) rest on them.

Trade-offs: - **Single domain:** simplest administration, one Group Policy and replication scope, easiest recovery. It offers no internal administrative separation beyond OUs and delegation. - **Multiple domains:** administrative and replication separation, but **not** security isolation, plus more DCs, trusts to manage, and cross-domain Group Policy complexity. - **Empty root:** protects forest-wide groups and gives a stable root, at the cost of extra infrastructure; modern guidance leans toward single-domain for most organizations.

Conflicts: single vs multiple domains, and whether an empty root is worth it. Microsoft historically recommended an empty root for large enterprises; current practice leans single-domain. No US authority treats a domain as a security boundary — a common and dangerous misconception the sources explicitly correct.

3. Trust design

Decision at stake: which trust relationships to create, their direction and transitivity, and how to contain the risk they add.

Realistic options: - **Intra-forest trusts** — created automatically between all domains in a forest; two-way and transitive; Kerberos. - **External trust** — to a single domain in another forest; non-transitive. - **Forest trust** — between two forest root domains; transitive across each forest. - **Realm trust** — to a non-Windows Kerberos realm (e.g., MIT Kerberos). - **Shortcut trust** — to optimize authentication paths within a large forest.

What the US authorities say: - **Microsoft:** - Documents trust types, transitivity and direction, and that **SID filtering (quarantine)** is enabled by default on external and forest trusts to drop SIDs from outside the trusted domain's own domain, defeating SID-history injection. - **Selective authentication** can be set on external/forest trusts so that only explicitly allowed users can authenticate to specific resources across the trust. - A forest trust is a convenience, not a security guarantee: a compromise in a trusted forest can threaten the trusting forest, so a forest trust should not be treated as a security boundary against a compromised partner. - **DISA**

(AD Forest STIG): SID filtering must be enabled on inter-forest/external trusts, and selective authentication applied where cross-forest access must be limited. - **CISA/NSA:** the Sept 2024 guidance covers trust-account abuse, SID-history injection, and cross-forest Kerberoasting among its techniques; the practical message is that trusts widen the attack surface and must be minimized and filtered.

Trade-offs: trusts enable resource and identity sharing across boundaries, but every trust enlarges the reachable attack surface. SID filtering can break legacy migrations that rely on SID history; selective authentication adds per-resource management overhead.

Conflicts: default SID filtering vs migration needs (filtering must sometimes be relaxed temporarily, which is risky). And the framing of a forest trust: Microsoft and CISA/NSA are clear it is not a security boundary against a compromised trusted forest, even though it is often treated as one in practice.

4. OU design

Decision at stake: how to structure organizational units, how to delegate administration, where to place objects, and how to ensure Group Policy reaches everything.

Legitimate drivers (only two): delegation of administration and Group Policy application. OUs are **not** a replication or security boundary (that is domains/forests and sites).

Realistic structure models: - **By object type** — top-level OUs for Users, Computers, Groups, Service Accounts. - **By function/role** — e.g., Servers, Workstations, by business function. - **By geography/location** — regional OUs for delegated regional admins. - **Hybrid** — top level by function or geography, then subdivided by object type (the most common real-world pattern). - **Tiered-administration OUs** — a Tier 0 / Tier 1 / Tier 2 structure overlaid for administrative separation (Section 6).

What the US authorities say: - **Microsoft:** - Build the OU design to delegate administration and to apply Group Policy; structure follows those two needs rather than the org chart. - Delegate with the Delegation of Control Wizard or custom ACLs, granting the minimum rights needed and documenting them; review delegated permissions over time. - **Redirect the default containers:** the built-in `CN=Users` and `CN=Computers` containers cannot have GPOs linked to them. Use `redirusr.exe` and `redircmp.exe` to redirect newly created user and computer objects into OUs where GPOs apply. This is a near-universal first step so default-created objects are not left ungoverned. - Protect OUs from accidental deletion, and avoid unnecessarily deep nesting (it complicates both delegation and Group Policy processing). - **DISA / CIS:** both assume a tiering OU layout; Tier 0 objects live in protected OUs with inheritance controlled so lower-tier policy does not weaken them.

Trade-offs: - **By object type** is the cleanest for Group Policy targeting; **by geography** suits delegated regional administration; a **hybrid** balances both. - Too many OUs or deep nesting slows and obscures Group Policy processing and makes delegation hard to audit. - Container redirection is a one-time action but essential; skipping it leaves default-created accounts outside GPO scope.

Conflicts: OU-by-function vs OU-by-geography — both valid, and the right choice depends on who delegates administration and what policy varies. And whether to use Block Inheritance on an OU (see Section 5).

5. Group Policy design (coupled to OU design)

Decision at stake: how to scope and order GPOs, how to handle inheritance and exceptions, how to filter, and how to deliver security baselines.

What the US authorities say: - **Microsoft (processing model):** - GPOs apply in **LSDOU** order — Local, then Site, then Domain, then OU (deepest OU last) — so a setting applied later wins unless overridden. - **Link order** within a container: the link with the lowest number is processed last and therefore wins among that container's GPOs. - **Block Inheritance** (set on an OU) stops inherited GPOs; **Enforced** (set on a link) overrides Block Inheritance and wins. Microsoft discourages routine use of both because they obscure the effective policy. - **Security filtering:** since the 2016-era change, the computer or user account needs both Read and Apply Group Policy, and `Authenticated Users` must retain at least Read for a GPO to process. Scope with security groups carefully. - **WMI filtering** applies GPOs conditionally (e.g., by OS); it adds per-refresh evaluation cost. - **Loopback processing** (merge or replace) applies user policy based on the computer object, for shared, kiosk, RDS/session-host, and Tier 0 machines. - Use **Starter GPOs**, a Central Store for ADMX templates, consistent naming, and the fewest GPOs that do the job. - **Baseline delivery (cross-reference the DISA STIG/GPO reference):** deliver security baselines — DISA STIG GPO packages, Microsoft security baselines from the Security Compliance Toolkit, or CIS build kits — as GPOs linked to the appropriate OUs, and test them in a representative OU before wider linking. Tier 0 systems get the strictest baselines, scoped by the tiering OUs.

Trade-offs: fewer, well-named, well-scoped GPOs mean faster logon/boot and far easier troubleshooting. Block Inheritance and heavy security/WMI filtering make the effective-policy picture hard to reason about; over-blocking is a common cause of baseline drift.

Conflicts: Block Inheritance (discouraged — it hides policy) vs Enforced (use sparingly for must-apply security settings); and security-group filtering vs OU-based targeting as the primary scoping method.

6. Administrative tiering design

Decision at stake: how to isolate privileged access — the tier model and the Enterprise Access Model, what belongs in Tier 0, how to use privileged access workstations and the clean-source principle, and how to protect privileged accounts and the newest attack primitives.

What the US authorities say: - **Microsoft (current tier model page):** - The AD DS tier model "separates administrative identities, workstations, and managed assets into trust tiers" — Tier 0, Tier 1, Tier 2 — with privileged access workstations (PAWs) enforcing the boundaries. - **Tier 0** contains everything that directly or indirectly controls the directory: domain controllers; identity services including **Microsoft Entra Connect, Microsoft Entra application proxy, AD FS, and AD CS**; and Tier 0 administrative accounts and groups, "including built-in Active Directory groups such as Backup Operators and Server Operators." - The tier model fits inside the broader **Enterprise Access Model** (EAM), which spans on-

premises, multiple clouds, user access, and application access via a control plane, management plane, and data/workload plane. The model and deployment guidance are in the `microsoft/ActiveDirectoryTierModel` repository. - **Clean source principle:** administer a tier only from a device of equal or higher trust (manage Tier 0 only from a Tier 0 PAW). - **Protected Users** security group hardens privileged accounts (no NTLM, no DES/RC4, no unconstrained delegation, no long-term Kerberos keys, no credential caching). **Authentication policies and silos** restrict where privileged accounts can authenticate. - **ESAE → EAM:** Microsoft retired ESAE/the Red Forest on December 15, 2020 and replaced it with the Enterprise Access Model; the **tier model itself was not retired** — a frequent point of confusion. - **NIST SP 800-53 Rev 5:** AC-2 (account management), AC-5 (separation of duties), AC-6 least privilege with AC-6(2) (non-privileged access for nonsecurity functions) and AC-6(5) (privileged accounts restricted to named personnel), and IA-2(1) (MFA for privileged accounts). SP 800-63B(-4) sets authenticator assurance; SP 800-207 establishes identity as the control plane. - **CISA/NSA (Sept 2024, 17 techniques):** Kerberoasting, AS-REP roasting, DCSync, Golden/Silver Ticket, AD CS abuse, unconstrained delegation, SID-history injection, GPO abuse, and more. Mitigations include tiering, PAWs, Protected Users, MFA, least privilege, and setting the machine-account quota to zero. It treats AD CS, AD FS and Entra Connect as Tier 0. - **DISA (AD Domain STIG):** CAT I rules restrict membership of Enterprise Admins, Domain Admins and Schema Admins (Enterprise Admins and Schema Admins are typically kept empty except when a specific change requires them); V-243477 requires privileged domain accounts to be in the Protected Users group; and AD remote management must come from a PAW/Tier 0. - **CIS:** Controls v8.1 Safeguard 5.4 (dedicated administrative accounts) and the MFA safeguards; the Windows Server benchmarks harden the hosts. - **`ms-DS-MachineAccountQuota`:** the default of 10 lets any authenticated user join 10 computers (machine accounts), which enables several escalation primitives; the common hardening is to set it to 0. - **dMSA / BadSuccessor (CVE-2025-53779):** Windows Server 2025 introduced delegated Managed Service Accounts to migrate legacy service accounts. The BadSuccessor technique (Akamai, Yuval Gordon; disclosed May 21, 2025; patched August 12, 2025) abuses them: in any forest with at least one Windows Server 2025 domain controller and a KDS root key, an attacker who can create a dMSA — or who merely has write permission to any OU, plus the ability to set the dMSA's migration attributes (e.g., `msDS-ManagedAccountPrecededByLink`) — can impersonate a privileged account and reach domain, then forest, compromise. Notably the domain does **not** need to be at the 2025 functional level or using dMSAs. Design implications: apply the patch to all Windows Server 2025 DCs, restrict OU write permissions, and ensure **only Tier 0 can create or manage dMSAs and their migration attributes**. Akamai notes the patch mitigates much of the risk but the technique "lives on" in some scenarios.

Trade-offs: strict tiering is the single highest-value AD security control, but it is operationally heavy — dedicated accounts per tier, PAWs, and discipline about never signing a Tier 0 credential into a lower-tier host. The cost is hardware and process; the payoff is that a workstation or server compromise no longer yields the directory.

Conflicts: - **Scope of protection:** DISA's CAT I rules target Enterprise Admins / Domain Admins / Schema Admins specifically, while Microsoft's tier model protects **all** Tier 0 groups (including Backup Operators, Server Operators, AD CS, AD FS, Entra Connect). DISA compliance alone therefore does not equal full tier isolation. - **Cloud vs platform-neutral:** Microsoft's current guidance pushes cloud-era tooling (the Enterprise Access Model, Microsoft Defender

for Identity, Entra PIM), while DISA and NIST remain platform-neutral and on-prem-centric. - **Coverage gap:** as of this writing, no US-government source addresses dMSA/BadSuccessor directly; the Tier 0 guidance for dMSAs comes from Microsoft's CVE response and practitioners (SpecterOps, Akamai, Tenable).

Where authorities agree, differ, or conflict

Topic	Agreement	Difference / conflict
Security boundary	Microsoft, CISA/NSA, DISA, NIST all treat the **forest** as the security boundary; the domain is not	None — the clearest consensus, and the one most often misunderstood in practice
Number of forests	Fewer is better; single forest unless isolation/autonomy forces more	No authority sets a number; "when is a separate admin forest justified?" is unsettled post-ESAE
Admin forest after ESAE	ESAE retired Dec 15, 2020; use the Enterprise Access Model + tier model	Microsoft says in-forest EAM for most; practitioners keep a hardened admin forest as a niche option
Number of domains	Single domain preferred; domain is **not** a security boundary	Single vs multi-domain, and whether an empty forest root is still worth it
Trust as a boundary	A forest trust is not a security guarantee; minimize and filter trusts	Default SID filtering vs legacy migration needs (temporary relaxation is risky)
OU drivers	OUs exist for delegation and Group Policy, not replication or security	OU-by-function vs OU-by-geography — both valid, context-dependent
Group Policy exceptions	Keep GPOs few and well-scoped	Block Inheritance (discouraged) vs Enforced (sparingly); filtering vs OU targeting
Tier 0 scope	Isolate the identity control plane; use PAWs, Protected Users, MFA, MAQ=0	DISA protects EA/DA/SA specifically; Microsoft protects **all** Tier 0 groups — STIG compliance ≠ full tiering
dMSA / BadSuccessor	Patch WS2025 DCs; restrict OU write; Tier 0 only for dMSA management	No US-government guidance yet; direction comes from Microsoft's CVE response and practitioners

Caveats and items that could not be verified

- **Research mode was unavailable for this document**, so it was assembled from direct source checks plus the project's earlier AD/OU research. Verified this session on primary or reported sources: the forest-as-security-boundary wording and forest/domain-count logic (Microsoft TechNet/Learn), the ESAE retirement date (December 15, 2020) and the Enterprise Access Model, the current Microsoft "Tier model for AD DS" page and its Tier 0 contents, and BadSuccessor/CVE-2025-53779 (patched August 12, 2025).
- **Legacy Microsoft design pages:** "Determining the Number of Forests/Domains," "Creating a New Forest," and the AD DS Design Guide are Windows Server 2003/2008-era TechNet archive content. The design logic (isolation/autonomy, boundary definitions, single-domain preference) remains Microsoft's canonical guidance, but confirm against the current AD DS planning pages for version-specific detail.
- **DISA STIG specifics** (AD Domain STIG V3 series and its EA/DA/SA CAT I rules, Protected Users rule V-243477, the PAW-for-AD-management rule; AD Forest STIG SID-filtering/selective-authentication and V-269098/V-269099) are drawn from the project's earlier research and third-party STIG mirrors, not re-fetched from cyber.mil this session. Confirm the current release and rule IDs at public.cyber.mil.
- **CIS versions** (Controls v8.1 Safeguards 5.4 and the MFA safeguards; the current Windows Server 2025 Benchmark version) were not re-verified this session.
- **NIST control text** (AC-2, AC-5, AC-6 and enhancements, IA-2(1)) is paraphrased; confirm the SP 800-63B-4 (2025) and SP 800-53 Release 5.2.0 (Aug 27, 2025) details against csrc.nist.gov.
- **Windows Server 2025 functional-level details** (first new level since 2016; new forests require the 2016 level or higher; the optional 32k database page; dMSA) come from Microsoft's "what's new" material and the BadSuccessor coverage; confirm specifics on the current Microsoft Learn page.
- **The CISA/NSA "Detecting and Mitigating Active Directory Compromises" guidance** (Sept 2024) is an ASD-led Five Eyes product; under this reference's scope it is treated only as a CISA/NSA (US) source. A 2026 revision may exist and was not confirmed here.
- **Group Policy security-filtering behavior** (the Authenticated Users Read requirement) reflects the post-2016 change; confirm exact wording on the current Microsoft Learn Group Policy pages.
- **Practitioner sources** (SpecterOps, Trimarc, Mandiant, Akamai, Tenable) are non-governmental and labeled as such; they are cited for the ESAE/EAM history, tiering practice, and the dMSA/BadSuccessor analysis rather than as authority.
- **Licensing statements** are general; confirm per-document terms before republishing excerpts.

Part II — US Design Reference: DNS for Windows / Active Directory Enterprise Environments (as of October 2026)

US authorities agree on a common DNS baseline for Active Directory, and they disagree in a few specific places. The baseline: name the forest under a domain you have registered. Use AD-integrated zones that accept only secure dynamic updates. Run DNS as at least two fault-tolerant servers that keep internal and external roles apart. Send all outbound resolution through an authorized, policy-enforcing (Protective DNS) forwarder, and block every other path to the internet. Turn off LLMNR, NetBIOS name resolution and mDNS. Log DNS centrally on synchronized time. The authorities disagree on DNSSEC for internal zones, on NSEC versus NSEC3, on whether DNS should run on domain controllers or on dedicated servers, and on how to build split-brain DNS. NIST SP 800-81r3 (March 2026) and the DISA Windows DNS STIG are the two US documents that most often pull in opposite directions.

TL;DR

- **Baseline:** Name the forest as a subdomain of a domain you have registered, or use ICANN's reserved `.internal`. Never use `.local` or single-label names. Store zones in AD with "Secure only" updates. Run at least two DNS servers on different network segments. Resolvers should forward only to an approved Protective DNS service, outbound port-53, DoT and DoH should be blocked for everything else, and recursion should be off on any authoritative server that faces the internet. Disable LLMNR, NetBIOS and mDNS. Send DNS analytic and audit logs to a SIEM on synchronized time.
- **Integrity and confidentiality:** NIST SP 800-81r3 recommends DNSSEC for zones that face the internet. It advises *against* signing internal zones unless a policy requires it, and it prefers NSEC to NSEC3. The DISA STIG requires DNSSEC records, NSEC3 for all internal zones, and client validation enforced through the NRPT. Signing with SHA-1 is now prohibited (RFC 9905, November 2025); use ECDSA P-256/P-384 or RSA/SHA-256 with keys of 2048 bits or more. Windows Server 2025 DNS has supported client-facing DoH since the June 2026 security update, but traffic to forwarders, zone transfers and dynamic updates is still unencrypted.
- **Where authorities conflict:** NIST says DNS should run on dedicated servers, while Microsoft's AD-integrated design puts DNS on domain controllers. DISA wants split DNS on separate internal and external servers, while Microsoft supports split-brain through DNS policies on a single server. Root-hint fallback conflicts with the federal rule that all outbound DNS goes through Protective DNS. Read each control in light of the authority that applies to you: FCEB (CISA/OMB), DoD (DISA), or general enterprise (Microsoft/NIST/CIS).

Authoritative design-source overview

Publisher	Key document / tool	Date / version	Status	Access / licence	Design areas informed
NIST	SP 800-81r3, *Secure Domain*	Published March 19, 2026;	Current. The 800-81-2 and the April	Free; US federal work, generally not	1, 3, 4, 5, 6, 7, 8

Publisher	Key document / tool	Date / version	Status	Access / licence	Design areas informed
	Name System (DNS) Deployment Guide (Rose, Liu, Gibson; csrc.nist.gov/pubs/sp/800/81/r3/final; doi 10.6028/NIST.SP.800-81r3)	replaces SP 800-81-2 (Sept 2013). An errata planning note was posted 07/10/2026.	2025 draft are superseded/ withdrawn.	subject to US copyright	
NIST	SP 800-53 Rev. 5 (SC-20, SC-21, SC-22, AU-8, SC-45, AU family, CM)	Release 5.2.0, August 27, 2025	Current (replaces 5.1.1)	Free; US federal work	5, 6, 7, 8
CISA	*Encrypted DNS Implementation Guidance* v1.0 (FCEB)	Dated April 2024; released May 16, 2024	Current	Free, TLP:CLEAR; US federal work	3
NSA / CISA	*Selecting a Protective DNS Service* (CSI)	First issued March 2021; PDF v1.3 March 2025	Current	Free; US federal work	3, 8
ASD (lead), with CISA, NSA and Five Eyes partners	*Detecting and Mitigating Active Directory Compromises*	September 2024	Current. Under this reference's scope rules, CISA/NSA co-authorship counts as the US source.	Free. Joint work; non-US co-author material may carry partner copyright terms.	4, 7, 8 (AD context)
DISA	Microsoft Windows Server DNS STIG	V2R4 (2026-02-23) and V2R5 (2026-06-03) seen on STIG mirrors. A DISA announceme	Current (check the latest release on cyber.mil)	Free, public STIG content; DoD-mandatory for DoD systems	2, 3, 4, 5, 6, 7, 8

Publisher	Key document / tool	Date / version	Status	Access / licence	Design areas informed
		nt lists “Ver 2, Rel 6”.			
DISA	Microsoft Windows Server 2025 STIG (and 2022 STIG)	WS2025 V1R1 (Feb 2026) up to V1R4 (DISA announcements); WS2025 SCAP benchmark approved August 2026	Current	Free	7 (LLMNR/NetBIOS/OS hardening)
CIS	CIS Critical Security Controls v8.1 (Safeguards 4.9, 8.4, 8.6, 8.9, 8.10, 9.2)	v8.1 (2024); v8.1.2 guide dated March 2025	Current	Free after registration. CIS licence (Controls are distributed under a Creative Commons non-commercial/no-derivatives licence; check current terms).	3, 8
CIS	CIS Microsoft Windows Server 2022 Benchmark v4.0.0 (and the WS2025 benchmark)	v4.0.0 for WS2022; current WS2025 version not verified	Current	Free PDF for non-commercial use; CIS licence terms apply	7
Microsoft	Learn: *Selecting the Forest Root Domain*; *Assigning Domain Names*;	Living documents	Current	Free. Microsoft Terms of Use (some docs are also published on GitHub under	1

Publisher	Key document / tool	Date / version	Status	Access / licence	Design areas informed
	Name computers, domains, sites, and OUs			open licences; verify per page).	
Microsoft	Learn: *Best practices for DNS client settings*; BPA rule "should include the loopback address, but not as the first entry"; *DNS Server becomes an island*	BPA article is WS2008 R2-era (legacy archive) but still applied	Current guidance; some pages are legacy	Free; Microsoft terms	3, 6
Microsoft	Learn: *Manage DNS zones*; *Dynamic DNS Update*; *DNS aging and scavenging* (updated 2026-08-14); *Deploying a GlobalNames Zone* (legacy)	Living / legacy	Mixed	Free; Microsoft terms	2, 4
Microsoft	Learn: *Use DNS Policy for Split-Brain DNS Deployment* and *...in Active Directory*	WS2016 and later	Current	Free; Microsoft terms	3, 7
Microsoft	Learn: *DNS encryption using DNS over HTTPS*; Networking	Preview in the Feb 10, 2026 update; GA with the 2026-06	Current	Free; Microsoft terms	3

Publisher	Key document / tool	Date / version	Status	Access / licence	Design areas informed
	blog: *Secure DNS with DoH: Public Preview for Windows DNS Server*	security update KB5094125 (page updated 2026-06-12)			
Microsoft	Learn: *Enable DNS Logging and Diagnostics*; Sentinel *Windows DNS Events via AMA*	Living	Current	Free; Microsoft terms	8
Microsoft	Legacy TechNet: *DNS Cache Locking*, *DNS Socket Pool*	WS2008 R2 era	Legacy, but the features are still present	Free; Microsoft terms	7
IETF	RFC 1034/1035 (1987), 1912 (1996), 2181 (1997), 2317 (1998, BCP 20), 4033–4035 (2005), 6303 (2011, BCP 163), 6761 (2013), 6781 (2012), 7766 (2016), 8020 (2016), 9364 (2023, BCP 237), 9499 (2024, BCP 219), 9904 and 9905 (Nov 2025)	As listed	Current unless obsoleted. RFC 9905 updates 4034/5155.	Free; IETF Trust Legal Provisions (BCP 78)	1, 2, 3, 5
ICANN	Board Resolution	July 29, 2024	Current	Free; ICANN website	1, 3

Publisher	Key document / tool	Date / version	Status	Access / licence	Design areas informed
	2024.07.29.06 reserving `.INTERNAL`; SAC113; root hints / root server system			terms	

1. Namespace design

Decision at stake. You must choose the DNS name of the forest root domain and decide how it relates to your public namespace. Changing it later is hard, because the forest root name becomes the name of the forest.

Realistic options. - **Split-brain (same name inside and out):** for example, `contoso.com` is used both internally and publicly. - **Delegated or undelegated subdomain of a registered domain:** for example, `corp.contoso.com` or `ad.contoso.com`. - **A separate registered domain** used only internally. - **A reserved private-use name:** `.internal` (ICANN) or `home.arpa` (RFC 8375, residential). - **An unregistered or ambiguous suffix** such as `.local`, `.corp`, `.lan` or a single label (not recommended).

What US authorities say. - **Microsoft.** - Use DNS names registered with an internet authority, and do not use single-label DNS names. - If the organization has an internet presence, use names relative to the registered name. The example given is `corp.contoso.com` under `contoso.com`. - Avoid “names that are used in internet-standard special features, such as .local,” and avoid top-level internet names on an intranet because of resolution errors. - Since Windows Server 2008 R2, Dcpromo has not allowed single-label domain names. - Keep the NetBIOS domain name the same as the DNS prefix where possible. - **ICANN.** - Board Resolution 2024.07.29.06 (July 29, 2024) permanently reserves `.INTERNAL` from delegation in the root zone “to provide for its use in private-use applications”. This follows SSAC advice SAC113. - The accompanying ICANN-authored Internet-Draft says organizations should either use subdomains of a name they control or use `.internal`. - The 2018 Board resolution stopped the `.corp`, `.home` and `.mail` applications because of name collision. This shows such strings are unsafe, but it does not reserve them for private use. - **IETF.** - RFC 6761 lists special-use names (`.test`, `.example`, `.invalid`, `.localhost`, and `.local` for mDNS via RFC 6762). `.test` and `.example` are reserved for testing and documentation, so they must not be used as production namespaces. - RFC 9499 defines “split DNS”/“split horizon” terminology. - **NIST SP 800-81r3.** - NIST does not prescribe a naming scheme. - For DNSSEC and mobile hosts it notes that “network administrators can avoid this problem by using different names for internal and external zones”. If internal zones are signed, it recommends a separate delegation from the external parent so a chain of trust exists, while acknowledging that this leaks the delegation name.

Trade-offs. - **Split-brain** keeps user principal names and URLs identical inside and out. The cost is maintaining two copies of the same zone. Public records must be mirrored internally, or internal clients cannot reach the public site. - **A subdomain of a registered name** is unambiguous, can get publicly trusted certificates, and gives a clean chain of trust for DNSSEC. Its weakness is that internal names may leak in queries to public resolvers unless outbound DNS is controlled. - **`.internal`** is guaranteed never to collide. However, no public CA can issue certificates for it, and it cannot chain to the root for DNSSEC. - **`.local`** conflicts with mDNS (RFC 6762). **`.corp` and other unregistered strings** are at risk of collision and leakage. - **Disjoint namespace** (a computer's primary DNS suffix differs from its AD domain name) is supported but adds SPN, registration and suffix-search complexity. Use it only when an existing DNS structure requires it. - **Single vs multiple namespaces:** - One forest with one contiguous tree is simplest. - Several trees, or forests linked by trust, need conditional forwarders or stub/secondary zones (see §2–3). - Microsoft notes that DCs cannot forward-resolve the other forest's names if those names are not registered.

Conflicts. - None of the US authorities endorse `.local`. - Microsoft prefers a subdomain of a registered domain. ICANN now offers `.internal` as an alternative that never collides. These two do not contradict each other, but Microsoft's AD naming pages do not yet mention `.internal`; that absence was not verified on every page.

2. Zone design

Decision at stake. How zones are stored and replicated, who can write to them, and how other namespaces are reached.

Realistic options. - **AD-integrated primary zones.** Replication scope can be: - all DNS servers on DCs in the forest (ForestDnsZones), - all DNS servers on DCs in the domain (DomainDnsZones, the default), - all DCs in the domain (the legacy Windows 2000-compatible domain partition), or - a custom application directory partition. - **File-based standard primary/secondary zones** using AXFR/IXFR. - **Stub zones, conditional forwarders, or secondary zones** for reaching other namespaces. - **The GlobalNames zone** for single-label names. - **Delegation** of child-domain zones.

What US authorities say. - **Microsoft.** - AD-integrated zones replicate through AD rather than zone transfer. Secure dynamic update is supported *only* for AD-integrated zones and is their default. - Use forest scope when names must be resolvable across domains, for example the `_msdcs` forest zone. - Reverse zones can be created AD-integrated by network ID (for example `10.1.0.0/24`). - For trusts, the remote domain's DNS records must be resolvable, through forwarders or secondary/stub zones. - GlobalNames holds static CNAMEs for important servers. Dynamic updates cannot register names in it. Support must be enabled on each DNS server. Microsoft describes it as "not designed to be a complete replacement for WINS". - **DISA STIG.** - Secondary servers must cryptographically authenticate zone transfers. The STIG states that for AD-integrated zones this authenticity "is accomplished by AD replication". - Primaries must send transfers only to listed secondaries. - NS records must point to active authoritative servers. - All authoritative servers must hold the same zone version. - Zone records must be validated annually. - No zone may contain IPv6 link-local addresses, and AAAA records are only for hosts that are actually dual-stack. - **NIST SP 800-81r3.** - Restrict zone transfers with ACLs and authenticate them with TSIG (or SIG(0)). ZONEMD can verify

zone integrity, and TLS (XoT) adds confidentiality. - Disable transfers on secondaries unless they feed other secondaries. - Keep NOTIFY on. - Tune SOA refresh between roughly 1200 s and 86400 s to avoid “zone drift/thrash”. - Check delegations regularly for lameness. - **IETF.** - RFC 2317 (BCP 20) defines classless in-addr.arpa delegation using CNAMEs for subnets smaller than /24. - RFC 6303 (BCP 163) says resolvers should serve locally the reverse zones for private and special address space (for example RFC 1918 ranges), so those queries do not leak to the public DNS. - RFC 1912 lists classic configuration errors, such as missing PTRs and CNAMEs at the zone apex.

Trade-offs. - **AD-integrated** zones are multi-master and their replication is secured by AD. This satisfies DISA’s authenticated-transfer rule without TSIG. The catch is that the zone can only live on DCs, which ties DNS availability to DC availability (§6). - **File-based secondaries** allow DNS servers that are not DCs, but transfers then need ACLs and TSIG. *The Windows DNS server’s support for standard RFC 8945 TSIG on zone transfers was not verified in this research.* Windows uses GSS-TSIG for secure dynamic update. - **Stub zones** follow changes to the target’s NS set automatically. - **Conditional forwarders** are simple and can be AD-replicated, but they depend on fixed IP addresses. - **Secondary zones** give full local copies and resilience, but they need the partner to allow transfers. - **Reverse zones:** for each private range, host an internal reverse zone. If you don’t, PTR lookups leak to the public DNS.

Conflicts. NIST frames zone protection in terms of TSIG and ACLs, while Microsoft relies on AD replication. DISA explicitly accepts AD replication as equivalent, so the guidance is consistent in practice.

3. Resolution and forwarding design

Decision at stake. How internal resolvers reach internal partner namespaces and the internet, and which servers are allowed to recurse.

Realistic options. - **External resolution:** root hints, forwarders (including a Protective DNS service), or forwarders with root-hint fallback. - **Partner and split namespaces:** conditional forwarders. - **Recursion:** enabled, disabled (authoritative-only servers), or selectively controlled with recursion-scope policies. - **Fully closed (air-gapped)** designs with no external resolution. - **Client transport:** encrypted (DoH/DoT/DoQ) or traditional port 53.

What US authorities say.

DC resolver order (Microsoft). - On a DC that runs DNS, list a replication partner first and the loopback (127.0.0.1 / ::1) second or third, never first. - The BPA warns that if loopback is first, “Active Directory might be unable to find its replication partners”, and that a DC pointing only to itself can become an “island”. - The first DC in a new forest points to itself. - Never point DCs at an ISP’s DNS servers. - Some Microsoft Q&A answers argue the opposite (self first). The BPA rule is the authoritative published position.

Recursion and role separation. - **NIST SP 800-81r3:** - An instance that the internet can reach should be authoritative *or* recursive, not both. - Purely internal servers may combine the two roles, which it calls “acceptable and practical”. - Recursive servers should accept queries only from internal clients. - Enable QNAME minimization where supported. - **DISA:** - Prohibit recursion on authoritative servers that have no forwarders configured. - Restrict caching

servers to known client ranges. - Implement internal/external role separation. - Forwarders on an authoritative Windows DNS server must point only to an internal, non-AD-integrated DNS server or to DoD Enterprise Recursive Services. - Servers authoritative for local zones must point root hints only at the internal root. - **NIST SP 800-53 SC-22** requires the name-resolution service to be fault-tolerant and to implement internal/external role separation.

Protective DNS and egress. - **NIST SP 800-81r3:** - "Employ protective DNS wherever technically feasible". - It prefers a hybrid of cloud and on-premises RPZ/DNS firewall where feasible, so that a cloud outage that fails open still leaves local protection. - Block outbound DNS (UDP/TCP 53) from everything except authorized forwarders. Block unauthorized DoT (TCP 853), DoQ (UDP 853) and DoH (RPZ plus firewall). - Use MDM/EMM so users cannot configure unapproved resolvers. - **CISA:** FCEB agencies are *required* to route all DNS traffic leaving agency networks to CISA's Protective DNS, which supports DoH and DoT over IPv4 and IPv6. - **NSA/CISA PDNS CSI:** - It sets selection criteria such as blocking malware and phishing domains, high availability, logging, and handling of roaming clients. - It warns that the provider can see all your queries, so you must understand how it uses the data. - It explicitly does not endorse any vendor. - **CIS Controls v8.1:** Safeguard 4.9 configures trusted DNS servers on enterprise assets; Safeguard 9.2 uses DNS filtering services.

Encrypted DNS. - **NIST** says to encrypt internal and external DNS "wherever feasible", while making sure browsers' own DoH does not bypass the enterprise resolvers. - **CISA** requires encrypted DNS between FCEB endpoints and agency DNS infrastructure where technically supported, and allows DNS proxies for legacy endpoints. - **Microsoft:** - Windows Server 2025 DNS gained DoH for client-facing traffic in the February 10, 2026 update (preview). It became generally available with the 2026-06 security update KB5094125. - Microsoft states that upstream traffic (forwarders, conditional forwarders, authoritative servers), zone transfers and dynamic updates "remain unencrypted". Policies that filter on transport protocol do not match DoH queries. - Microsoft Learn's "Secure DNS Client over HTTPS (DoH)" page says not to enable "Require DoH" on domain-joined computers, because AD DS relies heavily on DNS and the Windows DNS Server service did not support DoH queries; it suggests IPsec connection security rules for encrypting AD DNS traffic instead. That page predates the 2026 server-side DoH feature.

Split-horizon resolution. - **Microsoft** supports split-brain on a single server through zone scopes and query-resolution policies, including in AD. The zone scopes replicate through AD, but the *policies do not* and must be copied to each server. - **DISA** requires internal and external records to be kept separate. With separate servers, the internal server must be unreachable from outside and the external server unreachable from inside resolvers.

Air-gapped and segmented networks. - No US source recommends root hints in closed networks. - DISA's internal-root rule and NIST's egress blocking both point to: no direct external resolution, with an internal root or forwarder hierarchy instead. - ICANN/IANA publish the root hints for internet-connected resolvers.

Trade-offs. - **Root hints** remove dependence on a third party, but they bypass Protective DNS and egress control. - **Forwarding only to PDNS** centralizes policy and logging, but it becomes a single dependency. Fail-open designs reintroduce bypass, which is why NIST suggests on-premises backup protection. - **DoH to Windows DNS** protects the client-to-resolver hop. It

adds certificate management, needs NTP-accurate time, and makes passive network monitoring harder. It does nothing for traffic between the DC and its forwarders.

Conflicts. See the conflicts section below: root-hint fallback versus PDNS mandates; whether internal DoH is required or optional; and split-brain on separate servers versus DNS policy.

4. Dynamic update and record-management design

Decision at stake. Who is allowed to create and change records, how stale records are removed, and how DHCP registrations are secured.

Realistic options. - **Update mode:** "Secure only", "Nonsecure and secure", or "None". - **Who registers:** client self-registration, or DHCP registering on the client's behalf. - **Infrastructure hosts:** static or dynamic records. - **Scavenging:** aging and scavenging on or off. - **DHCP Name Protection** on or off.

What US authorities say. - **Microsoft:** - Secure dynamic update is available only for AD-integrated zones and is the default after conversion. Standard primary zones accept unsecured updates. - A DHCP server that registers on a client's behalf becomes the *owner* of that record. - To avoid ownership and stale-record problems, configure DHCP with a dedicated, low-privilege credential for DNS updates and use the DnsUpdateProxy group carefully. Records created by members of DnsUpdateProxy are not secured. - DHCP Name Protection (which uses DHCID records) stops non-Windows clients from taking over names already registered. - Aging and scavenging are disabled by default. The no-refresh and refresh intervals are 7 days each, and the default scavenging period is 7 days. Both server-level scavenging and zone-level aging must be enabled. - **NIST SP 800-81r3:** - Accept updates only from authorized senders (TSIG or ACL); TSIG timestamps help against replay. - Use dedicated hidden primaries for zones that accept dynamic updates, because floods of updates can starve query service. - Keep a history of DHCP leases for incident response. - **DISA:** - Restrict dynamic updates to known clients and protect their authenticity through transaction signing. - Record who added, modified or deleted zone data. - The DNS server's own IP address must be static. - Validate zone records annually.

Trade-offs. - **Static records** for DCs, DNS servers and other infrastructure avoid accidental scavenging and spoofed registration, but they have to be maintained by hand. Note that DCs register their own SRV records dynamically, and that must keep working. - **Aggressive scavenging** cuts stale records, which are a source of spoofing and dangling records. Set too short relative to DHCP lease length, it deletes live records. A common rule of thumb is no-refresh plus refresh greater than or equal to the DHCP lease; that rule is not stated in the sources reviewed here.

Conflicts. - NIST's hidden-primary model does not fit AD's multi-master model, where every DC hosting the zone is a writable primary. - DISA's "transaction signing" is satisfied by Windows GSS-TSIG secure updates.

5. DNSSEC and integrity design

Decision at stake. Whether to sign zones (external and/or internal), with which algorithm and denial-of-existence method, where the private keys are kept, and whether resolvers and clients validate.

Realistic options. - Sign external zones only, sign both external and internal, or sign nothing. - Online signing (keys on the server, which allows dynamic updates) or offline signing. - A KSK/ZSK split or a combined signing key. - NSEC or NSEC3. - RSA/SHA-256 or ECDSA P-256/P-384 (Ed25519/Ed448 are listed by NIST). - Validation on the resolver only, or with clients enforcing it through the NRPT.

What US authorities say.

NIST SP 800-81r3. - Deploy DNSSEC to protect integrity. - Signing internal zones "is not recommended" unless something (for example, a government requirement) mandates it. The reasons: - It is hard to build a chain of trust without extra trust anchors. - Dynamically updated zones must be re-signed constantly. - It is pointless when the same servers are both authoritative and recursive, which is the usual AD pattern. - Algorithms (Table 1, from RFC 8624, SP 800-57 and SP 800-131A): - RSA/SHA-256 (alg 8) with 2048-bit keys or larger - ECDSA P-256 (13) - ECDSA P-384 (14) - Ed25519 (15) - Ed448 (16) - ECDSA and EdDSA are preferred because their responses are smaller. - 112-bit security strength is acceptable until 2030, after which 128-bit is required. - Keys have a maximum lifetime of 1–3 years. - Store the KSK in an HSM where practical. - Keep DNSKEY RRSIG validity short (about 5–7 days). - Avoid TTLs of 30 s or less on signed data. - Prefer NSEC. If NSEC3 is used, set its parameters per RFC 9276. - Signers and validators need authenticated time (for example NTS). - Validating resolvers should configure the root trust anchor and enable automated RFC 5011 rollover.

DISA STIG. - Enable DNSSEC records, and validate the authentication chain. - Use NSEC3 for all internal zones, changing the salt at every full re-sign. - The signature algorithm must be FIPS-compatible. - RRSIG validity on DNSKEY and DS should be between 2 days and 1 week. - Keep the ZSK private key only on a server that supports dynamic updates. - If the primary does not take dynamic updates, keep both the KSK and ZSK private keys off it (offline signing). - Export trust anchors and distribute them to validating servers, and enable automatic trust-anchor update. - Use Group Policy NRPT to make clients require DNSSEC validation.

NIST SP 800-53. - SC-20 requires authoritative responses to carry origin-authentication and integrity artifacts and a verifiable parent–child chain. SC-20(1) has been withdrawn and folded into SC-20. - SC-21 requires resolvers to request and perform that verification.

IETF. - RFC 9364 (BCP 237) is the DNSSEC roadmap. - RFC 4033–4035 are the core specifications. - RFC 6781 covers operational practice: KSK/ZSK roles, rollovers, and algorithm rollover ordering. - RFC 9905 (November 2025) makes RSASHA1 and RSASHA1-NSEC3-SHA1 "MUST NOT" for signing and SHA-1 DS digests "MUST NOT". Validators should still accept them during the transition. - RFC 9904 moves algorithm recommendations to the IANA registry.

Trade-offs. - Windows' online signing of AD-integrated zones keeps dynamic updates working, but the signing keys stay on DCs. That runs against NIST's HSM preference and DISA's offline-key rules for static zones. - NSEC3 slows zone walking. NIST points out that it can often still be reversed and adds CPU cost. - ECDSA keeps responses below fragmentation limits. RSA has wider legacy support. - Note that NSEC3 itself hashes with SHA-1. RFC 9905 deprecates SHA-1 *signature* algorithms, not the NSEC3 hash, and NIST says to migrate once a replacement is specified.

Conflicts. - Internal signing: NIST says generally don't; DISA says do. - NSEC versus NSEC3. - On algorithms, DISA's "FIPS-compatible" requirement overlaps with NIST's table: RSA/SHA-256 and ECDSA are both FIPS 186 algorithms. Microsoft Learn's "Sign DNS Zones with DNSSEC" page lists RSA/SHA-256 (default), ECDSA P-256/SHA-256, ECDSA P-384/SHA-384, RSA/SHA-512 and the SHA-1 variants, but not Ed25519 or Ed448; its default DS generation includes SHA-1, which RFC 9905 now prohibits.

6. Availability and placement design

Decision at stake. Whether DNS runs on DCs or on dedicated servers, and how many DNS servers to deploy and where.

Realistic options. - AD-integrated DNS on every DC, or on some DCs. - Dedicated (appliance or Windows) resolvers in front of DCs. - Caching-only resolvers at branch sites. - Anycast resolver addresses. - Cloud resolvers.

What US authorities say. - **NIST SP 800-81r3:** - "Deploy dedicated DNS servers to reduce attack surfaces". If that is not feasible, co-locating with related core services such as DHCP may be acceptable. - Every zone needs a primary and one or more secondaries. At least two authoritative servers should sit on different network segments and in different places. - Use a hidden primary. - Stubs should be configured with at least two recursive servers. Anycast can hide the loss of a single server, which matters for applications that use only one server. - Remove DNS server software from hosts that are not name servers. - **NIST SP 800-53 SC-22 Discussion:** at least two authoritative servers in two geographically separated subnetworks. - **DISA:** - Authoritative servers must be geographically dispersed and on different network segments. - There must be a documented procedure to re-role a secondary as primary. - Administrators must be notified when a component fails. - **Microsoft:** - Run DNS on DCs with AD-integrated zones so the DC locator works and replication is secured. - Configure DCs as in §3. - Point member servers and clients only at internal DNS servers. - **CIS 4.9:** assets use enterprise-controlled or reputable DNS servers.

Trade-offs. - **DNS on DCs:** simpler, gives multi-master AD-secured replication, and keeps locator records local. On the other hand, a compromise of DNS or a DC affects both services, and DCs then process untrusted recursive traffic. - **Dedicated resolvers** (forwarding internal AD zones to DCs): smaller attack surface on the DCs, room for PDNS/RPZ and DoH capacity, and alignment with NIST and DISA role separation. The costs are more infrastructure and the need for conditional forwarding or stub zones toward the DCs. - **Caching-only branch resolvers** cut WAN traffic but add another layer of caching and TTL to manage.

Conflicts. NIST's "dedicated DNS" recommendation and Microsoft's DNS-on-DC model are the main tension (see below).

7. Hardening-by-design (architectural security choices)

Decision at stake. Which protective features are built in from the start.

What US authorities say. - **RRL.** DISA requires Windows DNS response rate limiting to be enabled (V-259417), and requires that the server cannot be used to launch DoS attacks. NIST lists DoS and resource exhaustion as threats. - **Cache locking and socket pool (Microsoft).** -

Cache locking prevents cached records from being overwritten for a percentage of their TTL. The default is 100%. - The socket pool randomizes source ports. It is on by default with 2,500 sockets, configurable from 0 to 10,000. - Both defend against cache poisoning. Keep the defaults. - **Recursion off on authoritative servers.** NIST and DISA (§3). - **Zone transfers.** Disable or limit them to listed secondaries, and authenticate them (NIST, DISA). For AD-only zones, transfers can usually be turned off entirely. - **Information leakage.** - NIST says to keep HINFO, RP, LOC and similar records out of zones that face the internet, and to judge TXT records case by case. - DISA says HINFO, RP, TXT and LOC must not be used in the zone SOA, and the server must refuse version queries. - Disable WINS lookups on the DNS server (DISA). - **Policy-based controls.** Microsoft DNS policies support split-brain, recursion scopes (selective recursion by interface or subnet) and query filtering. DoH queries cannot be matched by transport-protocol filters. - **LLMNR, NetBIOS and mDNS.** - The CIS Windows Server 2022 Benchmark v4.0.0 sets: - 18.6.4.1 "Configure multicast DNS (mDNS) protocol" = Disabled - 18.6.4.2 "Configure NetBIOS settings" = Disable NetBIOS name resolution on public networks - 18.6.4.4 "Turn off multicast name resolution" = Enabled (disables LLMNR) - Older CIS text adds that NetBIOS over TCP/IP should also be disabled per NIC to fully mitigate name-resolution poisoning. - DISA Windows Server STIGs contain equivalent OS hardening; the exact rule IDs for the DNS client were not verified in this research. - Removing these fallbacks means DNS must be complete. For legacy single-label needs, use GlobalNames or DNS suffix search lists rather than WINS. Microsoft Support KB5071836 (November 2025) states that Windows Server 2025 will be the final LTSC release to include and support WINS, with standard support through November 2034. - **Platform.** NIST says to harden the host operating system. DISA requires zone files and keys to be writable only by the DNS service and administrators, and requires FIPS-validated cryptography.

Trade-offs. - RRL can drop legitimate bursts from NATed clients, so tune exemptions. - Fully disabling NetBIOS can break legacy applications. CIS's "public networks only" setting is a compromise; stricter environments disable it everywhere.

Conflicts. CIS's partial NetBIOS setting is less strict than the full disable that hardening guides commonly recommend. Organizations covered by both CIS and DISA should adopt the stricter one.

8. Logging and monitoring design

Decision at stake. What DNS telemetry to capture, how long to keep it, and how to correlate it.

What US authorities say. - **Microsoft:** - DNS *audit* events (configuration changes to zones, records and server) are on by default and have negligible cost. - *Analytic* events (every query and response, via ETW) are off by default. Microsoft Learn's "Enable DNS Logging and Diagnostics" page cites a 5% performance degradation at 100,000 QPS on modern hardware and "no apparent performance impact" at 50,000 QPS or below. - Legacy *debug* logging to a file is heavier and is meant for troubleshooting. - DoH has its own analytic events. - The Sentinel "Windows DNS Events via AMA" connector streams only analytic events. - **NIST SP 800-81r3:** - Log current and historical DNS traffic for incident response. - *Always* log queries and responses that protective DNS classifies as malicious. - You may filter known-good domains before sending to the SIEM, but keep a complete log for forensics. dnstap or selective logging are options at scale. - Correlate with DHCP lease history. - Integrate PDNS logs with the SIEM. -

Check validator logs for DNSSEC failures. - Use authenticated time (NTS) on signers, validators and encrypted-DNS servers. - **NIST SP 800-53:** - AU-8 requires timestamps from internal clocks, in UTC or with a fixed or recorded offset. AU-8(1) and AU-8(2) have been moved to SC-45(1) and SC-45(2). - SC-45 requires clocks to be synchronized; SC-45(1) adds an authoritative source and SC-45(2) a secondary source in another region. - SC-45 is not in the 800-53B baselines; it appears in the SP 800-82r3 OT overlays. - **DISA:** - The DNS server log must be enabled. - The "Manage auditing and security log" right is limited. - Record who changed zone data. - Back up audit records at least every seven days to a different system. - Notify administrators of DNSSEC/TSIG failures and anomalies in signed transfers. - **CIS v8.1:** 8.4 standardizes time synchronization, 8.6 collects DNS query audit logs, 8.9 centralizes logs, and 8.10 retains them.

Trade-offs. - Analytic logging on busy DCs costs CPU and storage, and the default circular ETL behaviour can drop events. Forward events in near real time with an agent rather than relying on local retention. - Logging at the PDNS forwarder catches egress but loses client attribution behind the forwarder. NIST discusses putting RPZ "closest to the client" versus "closest to the internet" for this reason. - Encrypted DNS removes passive network visibility, so log at the resolver.

Conflicts. None of substance. The sources differ only in prescriptiveness: DISA sets a fixed 7-day backup interval, while NIST and CIS leave retention to organizational policy.

Where authorities agree, differ, or conflict

Issue	Position A	Position B	Assessment
DNSSEC on internal (AD) zones	NIST SP 800-81r3: not recommended unless required; of limited value where servers are both authoritative and recursive	DISA STIG: DNSSEC records required, NSEC3 for internal zones, NRPT validation; NIST SP 800-53 SC-20(2) (internal artifacts) is optional and in no baseline	A real conflict. DoD systems follow DISA; others can follow NIST.
NSEC vs NSEC3	NIST: NSEC is "more prudent"	DISA: NSEC3 mandatory internally	A direct conflict.
DNS on DCs vs dedicated	Microsoft: AD-integrated DNS on DCs (secure update only works there)	NIST: dedicated DNS servers; DISA: role separation, and authoritative servers forward only to non-AD-integrated resolvers or DoD ERS	Common middle ground: DCs remain authoritative for AD zones, and clients use dedicated resolvers or PDNS that conditionally forward to the DCs.
Root hints vs mandated PDNS	Microsoft default: root hints, with fallback when	CISA: FCEB must route all outbound DNS to CISA PDNS;	For regulated networks, disable root-hint fallback

Issue	Position A	Position B	Assessment
	forwarders fail	NIST: block outbound DNS except authorized forwarders; DISA: root hints only to the internal root	("use root hints if no forwarders are available") and block egress on port 53, 853 and known DoH endpoints.
Internal DoH on vs off	NIST: encrypt internal and external "wherever feasible"; CISA: required for FCEB where technically supported	Microsoft: WS2025 DoH is client-facing only; upstream, transfers and updates remain cleartext; Microsoft Learn's DoH client page advises not enabling "Require DoH" on domain-joined computers	Treat DoH as an add-on to Do53 for now. Plan certificate and NTP dependencies, and keep resolver-side logging.
Split-brain mechanism	Microsoft: a single server with zone scopes and policies (policies not AD-replicated)	DISA: separate internal and external servers, each unreachable from the other side; NIST: internet-facing instances must not be both authoritative and recursive	In DoD settings, use separate servers. Elsewhere, policies are allowed, but you must replicate them to every server yourself.
SHA-1 / algorithm timeline	RFC 9905 (Nov 2025): MUST NOT sign with RSASHA1 / RSASHA1-NSEC3-SHA1, while validation is still RECOMMENDED	NIST: RSA ≥2048/SHA-256 or ECDSA, 112-bit strength until 2030 then 128-bit; DISA: FIPS-compatible	Broad agreement. Avoid RSA-2048 for new long-lived keys if you expect to pass 2030 without rolling over (an inference from the 800-57 strength schedule). NSEC3's SHA-1 hash is not covered by RFC 9905.
DC resolver order	Microsoft BPA: partner first, loopback second	Some Microsoft Q&A answers: self first	Follow the BPA.
NetBIOS	CIS WS2022 v4.0.0: disable on public networks	Common hardening guidance: disable NetBT on all NICs	Choose the stricter option where legacy dependencies allow.

Issue	Position A	Position B	Assessment
Namespace	Microsoft: subdomain of a registered domain	ICANN: `.internal` reserved for private use	These are complementary. Both reject `.local` and unregistered TLDs.

Caveats and items that could not be verified

- **DISA DNS STIG release.** Mirrors show V2R4 (2026-02-23) and V2R5 (2026-06-03). A DISA announcement listing mentions "Ver 2, Rel 6". The official cyber.mil page would not render, so confirm the current release and any changed rule IDs (V-259xxx) on cyber.mil before citing them.
- **The Five Eyes AD guide.** Its DNS-specific recommendations were not extracted and checked line by line here. Its lead author is ASD; only the CISA/NSA co-authorship is treated as the US source.
- **Statements not confirmed on primary pages:**
  - Microsoft's advice against "Require DoH" on domain-joined clients (Microsoft Learn DoH client page) predates the 2026 server-side DoH feature and may be revised; the WINS end-of-support statement is confirmed by Microsoft Support KB5071836.
  - Whether Windows DNS supports standard TSIG for zone transfers was not confirmed; Microsoft Learn's DNSSEC signing page lists no Ed25519/Ed448 option.
- **Benchmark and control versions:**
  - The current version of the CIS Windows Server 2025 Benchmark was not verified, and no CIS benchmark specifically for the Microsoft DNS Server role was identified.
  - The CIS 8.10 retention minimum and the exact CIS licence terms should be checked against current CIS pages.
- **SP 800-53 control text.** It was taken from consistent mirrors of Release 5.2.0, not from the CPRT pages directly.
- **RFC 8624 (cited by NIST).** Algorithm recommendations have since moved to the IANA registry under RFC 9904. The IANA "DNS Security Algorithm Numbers" registry currently lists RSASHA256 (8) and ECDSAP256SHA256 (13) as RECOMMENDED for signing, ECDSAP384SHA384 (14) as MAY, and RSASHA1 (5) and RSASHA1-NSEC3-SHA1 (7) as MUST NOT for signing.
- **Licensing.**
  - US federal works (NIST, CISA, NSA, DISA) are generally not subject to US copyright. Joint international products may include foreign-copyright material.
  - Microsoft Learn content falls under the Microsoft Terms of Use.
  - IETF RFCs fall under the IETF Trust Legal Provisions.
  - CIS content is free for non-commercial use under CIS's licence.
- **Applicability.** This reference does not tailor anything to an environment. Mandates (CISA PDNS, DISA STIG) bind only FCEB and DoD systems respectively; for everyone else they are best-practice benchmarks.

Part III — NTP / Time Synchronization in Windows and Active Directory: US-Source Design Reference (October 2026)

The US authorities agree on a single baseline. The forest-root PDC emulator is the only domain controller that takes time from outside the forest. It should use several traceable upstream sources (NIST, USNO, or a GPS/stratum-1 appliance traceable to them). Every other machine follows the domain hierarchy (NT5DS). The Kerberos skew limit stays at 5 minutes or less. Hypervisor time sync and Secure Time Seeding are turned off on domain controllers. Where the authorities part ways is authentication. The IETF, NSA and CISA call for authenticated time, but W32Time cannot authenticate to any external NTP server: it has no NTS and no symmetric-key client. Authenticated upstream time on an all-Windows estate therefore has to come from a non-Windows layer, such as a network device, an appliance, or a non-Microsoft NTP service.

TL;DR — design baseline

- **Hierarchy and sources.** Keep the default AD time hierarchy. The forest-root PDC emulator is set to `Type=NTP` and marked reliable, and points at several diverse upstream sources. Everything else stays NT5DS. The "how many sources" numbers differ:
  - CIS Safeguard 8.4, NSA and CISA: at least two.
  - Microsoft: three or more, or two with one marked fallback.
  - RFC 8633: four or more.

  DoD systems must use USNO or another approved DoD source (DISA V-243504 and WN25-00-000440). Federal civilian agencies are encouraged to use sources traceable to USNO or NIST (OMB M-26-14).
- **Protect the hierarchy.**
  - Kerberos "Maximum tolerance for computer clock synchronization" stays at 5 minutes, which is both the default and the DISA requirement.
  - Virtualized DCs must not take time from the host. Disable the Hyper-V Time Synchronization integration service, or set `VMICTimeProvider Enabled=0`.
  - Disable Secure Time Seeding (`UtilizeSslTimeData=0`) on Windows Server 2016–2022 DCs and VM hosts. It is already off by default on Windows Server 2025.
  - Monitor drift with `w32tm /monitor` and `/stripchart`, the W32Time events, and Kernel-General Event 1.
- **Accuracy and authentication are the open decisions.**
  - The default W32Time configuration only promises Kerberos-grade, loosely accurate time. The 1 s / 50 ms / 1 ms tiers require Windows 10 / Server 2016 or later plus strict latency, stratum, hop and CPU limits (Microsoft's support boundary, formerly KB939322).
  - Authenticated upstream time is only available from: NIST's registered symmetric-key service (IPv4 only, written request); USNO's DoD NIPRNet symmetric-key service; NTS (RFC 8915) on non-Windows components.
  - W32Time supports none of these, so authentication must be terminated on routers, firewalls or time appliances.

Authoritative design-source overview

Publisher	Document / tool	Date / version (as verified Oct 2026)	Status	Design areas	Access; licence / reuse
Microsoft	Support boundary for high accuracy time (formerly KB939322)	Last updated 2026-02-12; applies to "Windows Server (All supported versions)" incl. Azure Stack HCI and supported Windows client	Current	3, 1	Free, Microsoft Learn; Microsoft Terms of Use (not public domain)
Microsoft	Configuring systems for high accuracy; Accurate Time for Windows Server 2016	Applies to Server 2016–2025, Windows 10/11	Current	3, 7	Free; Microsoft Terms of Use
Microsoft	Windows Time service tools and settings (w32tm, registry, GPO reference)	Last updated 2025-09-18; applies to Server 2016–2025, Windows 10/11, Azure Local	Current	1, 2, 3, 7, 8	Free; Microsoft Terms of Use
Microsoft	Windows Time Service technical reference / How the Windows Time Service Works	Legacy Server 2003-era text, partly re-hosted on current Learn	Current hub with legacy subpages	1, 6	Free; Microsoft Terms of Use
Microsoft	Secure Time Seeding recommenda	Last updated 2026-02-12	Current	7, 8, 1	Free; Microsoft Terms of Use

Publisher	Document / tool	Date / version (as verified Oct 2026)	Status	Design areas	Access; licence / reuse
	tions for Windows Server				
Microsoft	Maximum tolerance for computer clock synchronization (Kerberos policy)	Server 2008–2012 R2-era policy reference; setting unchanged in later versions	Legacy page, current setting	4	Free; Microsoft Terms of Use
Microsoft	Virtualizing domain controllers with Hyper-V; AskDS “VMICTimeProvider vs AD” (Tech Community, 2024)	Current Learn page; 2024 blog	Current	5	Free; Microsoft Terms of Use
Microsoft	Support for the leap second (KB2722715)	Archived under previous-versions; last dated 2026-02-12	Legacy (archived)	8	Free; Microsoft Terms of Use
NIST (Time and Frequency Division)	NIST Internet Time Service server list (tf.nist.gov/tf-cgi/servers.cgi)	Live page, checked Oct 2026	Current	2	Free; US federal work (public domain in the US)
NIST	NIST Authenticated NTP Service	Created 2010-02-10; updated 2026-09-17	Current	6, 2	Free; registration by written request (US mail or fax); public domain text

Publisher	Document / tool	Date / version (as verified Oct 2026)	Status	Design areas	Access; licence / reuse
NIST	SP 800-53 Rev 5 (AU-8 Time Stamps; SC-45 System Time Synchronization)	Rev 5, Sept 2020; release 5.2.0	Current	8, 2	Free; public domain
NIST	SP 800-92 Guide to Computer Security Log Management	13 Sept 2006 (Final); Rev 1 Initial Public Draft, 11 Oct 2023	2006 version Final and current until Rev 1 is finalized; Rev 1 still Draft per NIST CSRC	8	Free; public domain
USNO, hosted by CNMOC	Network Time Protocol pages: public Eastern and Mountain servers, “DoD Customer Servers”	Live pages, checked Oct 2026	Current; NTS “coming soon” text is stale	2, 6	Free web; DoD authenticated service by signed-email request; US federal work
CISA	Time Guidance for Network Operators, CIOs, and CISOs	“June” edition (PDF re-posted Feb 2023)	Current	2, 6, 8	Free; public domain
CISA / NSA / FBI (with ASD ACSC as lead author)	Best Practices for Event Logging and Threat Detection	Aug 2024	Current	8	Free; government work (multi-national co-seal)
NSA	Network Infrastructure Security Guide (CTR)	June 2022	Current	2, 6	Free; public domain
DISA	Active	V3R2, 02 Jul	Current	1, 2	Free from

Publisher	Document / tool	Date / version (as verified Oct 2026)	Status	Design areas	Access; licence / reuse
	Directory Forest STIG, V-243504 (AD.0295)	2025; rule SV-243504r1026204 (Medium)			DoD Cyber Exchange public area; public domain
DISA	Windows Server 2025 STIG: WN25-00-000440 / V-278029 (time source, Low); WN25-DC-000060 / V-278137 (Kerberos skew, Medium)	V1R3, 10 Aug 2026 confirmed; V1R4 listed but its details unconfirmed	Current	2, 4	Free; public domain
DISA	Windows Server 2022 STIG: WN22-00-000440 / V-254281; WN22-DC-000060 / V-254390	V2R10, 10 Aug 2026	Current	2, 4	Free; public domain
DISA	Windows Server 2019 STIG (WN19-00-000440 / V-205800); Windows Server 2016 STIG (WN16-00-000450 / V-224862)	2019: V3R9, 01 Jul 2026. 2016: V2R10 (2025) is the latest confirmed	Current	2	Free; public domain
OMB	M-26-14, Ensuring Effective and Efficient Agency Logging and	22 May 2026; rescinds M-21-31	Current (M-21-31 superseded)	8, 2	Free; public domain; does not apply to national security systems or

Publisher	Document / tool	Date / version (as verified Oct 2026)	Status	Design areas	Access; licence / reuse
	Network Visibility…				DoD/IC systems under 44 U.S.C. § 3553(e)
CIS	CIS Controls v8.1, Safeguard 8.4 “Standardize Time Synchronization”	v8.1, June 2024	Current	2, 8	Free download with registration; CC BY-NC-ND 4.0
CIS	CIS Microsoft Windows Server Benchmarks (Windows Time Service section)	Version-specific; numbering not verified for this report	Current	1, 2	Free PDF for non-commercial use with registration; CC BY-NC-SA 4.0; CIS-CAT/Build Kits are paid (SecureSuite)
IETF	RFC 5905 NTPv4	June 2010, Proposed Standard	Current (obsoletes RFC 1305 and 4330)	1, 2, 6	Free; IETF Trust Legal Provisions
IETF	RFC 8633 NTP Best Current Practices (BCP 223)	July 2019	Current	2, 6	Free; IETF Trust
IETF	RFC 8915 Network Time Security (NTS)	Sept 2020, Proposed Standard	Current	6	Free; IETF Trust
IETF	RFC 7822 (NTPv4 extension fields); RFC 9109 (NTPv4	Mar 2016; Aug 2021; both update RFC 5905	Current	6, 1	Free; IETF Trust

Publisher	Document / tool	Date / version (as verified Oct 2026)	Status	Design areas	Access; licence / reuse
	port randomization)				
IETF	RFC 5906 Autokey	June 2010, Informational	Deprecated in practice: RFC 8633 says "SHOULD NOT be used"	6	Free; IETF Trust
IETF	RFC 4330 SNTPv4	2006	Obsoleted by RFC 5905	1	Free; IETF Trust
Community (non-government; context only)	pool.ntp.org	n/a	n/a	2	Free; volunteer-run, no US-government standing

1. Time hierarchy design

Design decision. Which machine is the authoritative internal clock, and how does time flow down to DCs, member servers, clients and child domains?

Realistic options. - **(a) Default AD hierarchy.** The forest-root PDC emulator is `Type=NTP`, synced to external sources and marked reliable. All other domain-joined machines are `NT5DS`. - **(b) Dedicated internal stratum-1 appliances (GPS or PTP).** The forest-root PDC emulator syncs from them, and the AD hierarchy continues below it. - **(c) Flat manual peer lists (`Type=NTP`) on members.** This bypasses the domain hierarchy. - **(d) `AllSync`.** All available mechanisms are used.

What the sources say. - **Microsoft (Tools and Settings).** Most domain-joined computers use NT5DS and sync from the domain hierarchy. The exception is the forest-root PDC emulator, which "is configured to synchronize time with an external time source." The `Type` values are NTP, NT5DS and AllSync. `AnnounceFlags` bits are 0x01 always time server, 0x02 automatic, 0x04 always reliable and 0x08 automatic reliable; the default is 10 (0x0A). `w32tm /config /reliable:yes` marks a DC as a reliable time source and "is only meaningful on domain controllers." - **Microsoft (STS article).** Within AD, most machines discover their time server dynamically; the exception is DCs marked "Good Time Server," and the forest-root PDC defaults to this role. - **DISA (AD Forest STIG V-243504).** The forest-root PDC emulator is "the normal default to provide the authoritative time source for the entire forest" and must get its time from an external DoD time source. The rule is N/A for other DCs. "Clients and lower-level servers will synchronize with an authorized time server in the hierarchy." Windows Server STIG checks treat NT5DS on domain members as compliant and flag `Type=NTP` systems

(including the PDC emulator) that point at a non-DoD server. - **CISA.** Document the timing topology, including which servers distribute time and their traceability to stratum-1.

Child domains and members. Members and member servers sync from a DC in their domain; DCs sync from DCs, including the PDC emulator of their own domain; a child domain's PDC emulator syncs up the hierarchy into the parent or forest root. Only the forest-root PDC emulator, or an explicitly configured reliable DC or appliance, should hold an external peer list.

PDC emulator role transfer. The W32Time settings that make the forest-root PDC emulator authoritative are local registry or GPO values on that server; they do not travel with the FSMO role. After a transfer or seizure, the design must point the new role holder at external peers (`/syncfromflags:manual`, `/reliable:yes`), return the old holder to `NT5DS` with `/reliable:no` (or reset it with `w32tm /unregister` and `/register`), and check with `w32tm /query /source` and `/monitor`. A common pattern is a GPO scoped by a WMI filter to the current PDC emulator; this is community practice, with no Microsoft or DISA mandate for it.

Trade-offs. The default hierarchy needs almost no configuration and gives Kerberos-grade consistency; its weak point is one key server that must be reconfigured whenever the role moves. Manual peer lists on members break the "single source of truth" and trigger STIG findings unless the peers are DoD-approved. AllSync has no clear design rationale in the sources and is rarely used.

Conflicts. None of substance. Microsoft and DISA describe the same hierarchy, and DISA adds the DoD-source constraint.

2. External upstream source selection design

Design decision. What does the top of the hierarchy sync from, and how many sources?

Realistic options. - **(a) NIST ITS public servers** — `time.nist.gov` (round-robin) or named servers (Gaithersburg `time-a-g`…`time-f-g`; WWV Fort Collins `time-a-wwv`…`time-e-wwv`; Boulder `time-a-b`…`time-e-b`), some with IPv6. - **(b) NIST authenticated servers** — `ntp-b`, `ntp-wwv`, `ntp-d.nist.gov`, registered users only. - **(c) USNO public stratum-1 servers** — Eastern: `tick`, `tock`, `ntp2.usno.navy.mil`; Mountain: `tick`, `tock.usnogps.navy.mil`; plus authenticated servers for DoD NIPRNet customers only. - **(d) An on-premises GPS/GNSS-disciplined stratum-1 appliance**, optionally combined with network sources. - **(e) A protective or filtering upstream** (routers/firewalls/appliances that authenticate to NIST or USNO and re-serve internally). - **(f) The community pool.ntp.org, or vendor services such as `time.windows.com`** (`time.windows.com` is Microsoft's default `NtpServer` value).

What the sources say. - **NIST.** Use the generic name `time.nist.gov`; hard-coding a particular server name/address is "a bad practice"; clients must never query more than once every 4 seconds. - **USNO/CNMOC.** The stratum-1 servers are open to stratum-2 servers in the same time zone; individual users should use public stratum-2 servers. USNO "strongly recommend[s]" picking one or more nearby servers plus others for redundancy. DoD entities should use only the DoD authenticated USNO servers, not the public hosts. USNO notes Windows lacks a symmetric-key NTP client and advises authenticating to USNO on

routers/firewalls and having Windows sync from those devices. - **DISA.** The forest-root PDC emulator and any `Type=NTP` system must use a DoD time source; the fix text points to the USNO/CNMOC NTP pages. - **OMB M-26-14.** Network time must be synchronized "to a traceable time source designated within the agency"; agencies are encouraged to use sources traceable to USNO or NIST where feasible. The memo excludes national security systems and DoD/IC systems. - **CISA (Time Guidance).** UTC(USNO) and UTC(NIST) are the principal official US time sources; use "at least two or more traceable time sources with the lowest possible stratum"; diversify receiver types and sources. - **NSA (Network Infrastructure Security Guide).** Network devices should use at least two NTP servers, with NTP authentication enabled. - **CIS Controls v8.1, Safeguard 8.4.** "Configure at least two synchronized time sources across enterprise assets, where supported" (IG2/IG3). Version 7.1 had asked for three. - **IETF RFC 8633.** Use at least four independent, diverse sources; two cannot resolve a disagreement between them. - **Microsoft.** Since Server 2016's algorithm changes, use three or more time servers; with only two, flag one `UseAsFallbackOnly` (0x2). The STS article adds that "an odd number of comparable time servers (more than one)" helps redundancy.

pool.ntp.org. A volunteer, community service with no US-government standing; under DISA rules not a DoD source, and it does not give the documented traceability OMB asks for. Common in non-regulated environments.

Trade-offs. NIST/USNO public servers give documented traceability at no cost but are unauthenticated over the internet and rate-limited (and USNO restricts its stratum-1 servers to stratum-2 servers). A GPS appliance gives internet independence and low stratum but brings GNSS spoofing/jamming risk and firmware-lifecycle work (CISA cites the 2019 GPS week-rollover failures). More sources improve fault detection but need more firewall egress and monitoring.

Conflicts. Source count: two (CIS, NSA, CISA), three/odd (Microsoft), four (IETF). DoD vs civilian: DoD must use USNO or an approved DoD source; civilian agencies under OMB are only "encouraged" toward USNO/NIST traceability.

3. Accuracy and performance design

Design decision. What accuracy does the estate need, and what will it cost to support?

Options. Default Kerberos-grade time; 1 s; 50 ms; 1 ms. Beyond 1 ms, non-W32Time solutions (PTP-capable third-party software or appliances) are needed.

What Microsoft says (Support boundary page, updated 2026-02-12). - **Before Windows 10 1607 / Server 2016:** W32Time only gave Kerberos-grade, "loosely accurate" time; tighter accuracy was unsupported. - **Windows 10 / Server 2016 and newer:** can deliver 1 s, 50 ms or 1 ms "under the right operating conditions." Accuracy depends on an accurate, stable stratum-1 root and the end-to-end path; asymmetry or high CPU load degrades it. - **1 s tier:** Windows 10 / Server 2016+; an NTP hierarchy ending in a highly accurate, Windows-compatible source; every node configured per "Configuring Systems for High Accuracy"; cumulative one-way latency of 100 ms or less. - **50 ms tier:** latency under 5 ms to the source; stratum 5 or less; six or fewer hops; one-day average CPU of 90% or less on every stratum (and the host for VMs). - **1 ms tier:** latency under 0.1 ms; stratum 5 or less; four or fewer hops; CPU 80% or less (including host). - **Default ("Configuring systems for high accuracy").** "most customers don't require highly

accurate time." The default aims to satisfy Kerberos v5 and loosely accurate time; higher tiers require registry/GPO changes (polling intervals, update rates).

Other sources. CISA: validate whether applications really need time and at what accuracy relative to UTC(NIST)/UTC(USNO) (its example: trading firms timestamping within 50 µs). USNO: typical internet NTP accuracy is 1–30 ms. NIST SP 800-53 AU-8: leaves timestamp granularity to the organization.

Stratum depth. Each AD tier (forest-root PDC, child PDC, DC, member) adds a stratum; a deep multi-domain forest can hit the stratum-5 limit for the 50 ms and 1 ms tiers. Shallow hierarchies or appliances near consumers address this.

Trade-offs. Higher tiers need tighter polling (more traffic and DC load), latency engineering, CPU headroom and monitoring. Regulated sectors (finance, telecom, energy) are the usual drivers; for most AD estates, the default plus good sources and monitoring is enough.

Conflicts. None. Other authorities leave the accuracy target to the organization and do not contradict Microsoft's tiers.

4. Kerberos skew dependency design

Design decision. What clock-skew tolerance is acceptable, and how does time sync protect authentication?

What the sources say. - **Microsoft.** "Maximum tolerance for computer clock synchronization" sets the maximum difference Kerberos v5 tolerates between client and KDC clocks; Microsoft advises 5 minutes (also the default). It lives in the Default Domain Policy under Account Policies > Kerberos Policy. W32Time was originally built to meet the Kerberos requirement that clocks be synchronized. - **DISA.** WS2022: V-254390 / WN22-DC-000060 (Medium). WS2025: V-278137 / WN25-DC-000060 (Medium). Both require the setting to be 5 minutes or less; the Windows Server STIG time rules justify time sync as "essential for authentication and auditing purposes." - **DISA (V-243504 rationale).** Inaccurate forest time can cause access to resources on computers with accurate time to be denied, and weakens audit data as forensic evidence.

Dependencies. Kerberos ticket issuance and replay protection depend on time, and so does everything built on Kerberos (Group Policy, LDAP and SMB authentication). X.509 certificate validity windows and token lifetimes depend on it too. Separately, large backward time jumps on DCs can cause replication problems (Microsoft's virtualization guidance cites lingering objects and replication stopping).

W32Time correction behavior. `MaxPosPhaseCorrection/MaxNegPhaseCorrection`: default 172,800 s (48 h) on DCs and 0xFFFFFFFF on domain members (corrections larger than these are logged rather than applied). `MaxAllowedPhaseOffset`: default 300 s on domain members (offsets above it are stepped rather than slewed).

Trade-offs. Raising the tolerance hides time faults and widens the replay window; lowering it below 5 minutes increases authentication failures when time degrades.

Conflicts. None. Microsoft's default and DISA's maximum are the same.

5. Virtualized domain controller time design

Design decision. Should virtualized DCs take time from the hypervisor or from the AD hierarchy?

Options. - **(a) Fully disable host time sync.** In Hyper-V, clear the "Time synchronization" integration service with the VM off. - **(b) "Partially disable."** Leave the integration service on (guest gets correct time at boot/restore) but set `HKLM\SYSTEM\CurrentControlSet\Services\W32Time\TimeProviders\VMICTimeProvider\Enabled = 0` so W32Time ignores the host as a source. - **(c) Leave host sync on.** Not recommended for DCs.

Other hypervisors have equivalent "sync guest time with host" settings.

What the sources say. Microsoft (Virtualizing DCs with Hyper-V): disable time sync between host and guest for VMs acting as DCs so the DC syncs from the domain hierarchy. Microsoft AskDS (2024): disable `VMICTimeProvider` on DCs and other VMs that should follow the AD hierarchy; check with `w32tm /query /source` ("VM IC Time Synchronization Provider" in the output means the host is the source). Microsoft (STS article): VM hosts are time-sensitive machines where STS should be disabled, and the host's own clock should come from a reliable source. Older Microsoft guidance suggested leaving host sync on and later moved to "partial disable"; the current Learn page resolves this by recommending host sync be disabled for DCs.

Trade-offs. Full disable removes the conflict between two time authorities but the VM may boot with a stale clock after save/restore until W32Time corrects it within phase-correction limits. Partial disable keeps boot-time seeding but Windows updates or integration-service resets can re-enable the provider, so it needs monitoring. The forest-root PDC emulator as a VM is a special case: it must not take host time, and its host should itself be synced to a reliable source.

Conflicts. None among current documents; the conflict is only historical.

6. Time authentication design

Design decision. How is the integrity of time protected, inside the forest and at the external boundary?

Mechanisms. Symmetric-key NTP (RFC 5905 MAC) — pre-shared key/key ID with MD5, SHA-1 or SHA-2 digest, manual key management. NTS (RFC 8915) — TLS-based key establishment (NTS-KE on TCP 4460), then authenticated NTP on UDP 123, automatic key management, scales. Autokey (RFC 5906) — known vulnerabilities; RFC 8633 says "Autokey SHOULD NOT be used." Inside AD, W32Time protects time samples with domain security extensions (MS-SNTP using the Netlogon secure channel); Microsoft describes AD as "NTP augmented with ADDS security extensions within the AD domain/forest," and "typically bridged outside the AD forest through standard plaintext NTP."

What W32Time can do. It does not implement NTS; it does not implement symmetric-key client authentication to standard NTP servers (USNO states this explicitly). So any external peer configured on the forest-root PDC emulator is unauthenticated.

US-government authenticated options. - **NIST Authenticated NTP.** Free, symmetric key, IPv4 only; request by US mail or fax listing up to four static IPv4 addresses; key types MD5, SHA1, SHA256, HMAC-SHA256, SHA3-256; NIST never sends keys by email; unused keys (no use over a 30-day window at the annual survey) are deleted without notice; NAT/proxies complicate registration; NIST does not support Autokey and does "not yet" support NTS-KE. - **USNO.** Symmetric-key authentication offered only to DoD on NIPRNet, by signed-email request (SHA256 recommended; MD5/SHA1 legacy); the public service has no authentication. The DoD page still says NTS is "coming soon," projected for NIPRNet in "1QTR 2025" — a date that has passed with no update, so current availability is unconfirmed.

Policy drivers. NSA: enable NTP authentication on all network devices, strong unique keys, at least two servers. CISA: have an authentication scheme to verify time comes from legitimate servers, and block non-authenticated ports at the perimeter. RFC 8633: do not use Autokey; NTS is the replacement.

What is achievable on an all-Windows estate. (1) Rely on AD's built-in authenticated distribution inside the forest. (2) Terminate authenticated upstream time on a non-Windows component the forest-root PDC emulator then syncs from over plaintext NTP on a trusted segment — routers/firewalls with NIST/USNO or other symmetric keys; GPS/stratum-1 appliances; Linux chrony/NTPsec using NTS or symmetric keys (USNO itself recommends this pattern). (3) Add egress filtering so only designated time hosts reach external UDP 123. (4) Monitor for time jumps.

Trade-offs. Symmetric keys are mature but need manual key handling and IPv4 registration with NIST; NTS scales but neither W32Time nor (yet) NIST/USNO public service supports it; the intermediary pattern adds components that must be inventoried and patched (CISA stresses timing devices in lifecycle management).

Conflict. IETF, NSA and CISA expect authenticated time, but the Microsoft time service cannot provide it externally. This is the main standing gap in this reference.

7. Secure Time Seeding design

Design decision. Should STS be enabled on servers?

What STS is. A heuristic in W32Time that estimates the current time from metadata in outbound SSL/TLS connections and uses it to correct large clock errors. Controlled by `UtilizeSslTimeData` (registry or GPO under Windows Time Service > Global Configuration Settings); needs a reboot to change.

Defaults (Microsoft, updated 2026-02-12). Enabled by default on all editions of Windows Server 2016, 2019 and 2022, and on Windows 10 1511+ and Windows 11 clients. Disabled by default on Windows Server 2025, "based on customer feedback." The Tools and Settings registry reference confirms default 1 everywhere except Server 2025 (0); domain membership does not change it. Note: the GPO "Global Configuration Settings" default table still lists `UtilizeSslTimeData = 1` when the policy is enabled, so enabling that GPO on Server 2025 without setting the value explicitly could re-enable STS (an inference from the published defaults, not a Microsoft statement).

Microsoft's recommendation. Disable STS on Windows Server machines with time-sensitive workloads, explicitly including AD DS domain controllers and VM hosts; consider disabling it on all Windows Server machines even if no problems have been seen. The reported failures were random time jumps of days to years (some self-corrected, some persisted). Roll out gradually, test first, and confirm the setting through events 257, 260 or 263, or the W32Time debug log; put time monitoring in place (e.g., Kernel-General Event 1) before and after. The guidance is not extended to client SKUs.

Design pattern. Server 2016–2022: explicitly set `UtilizeSslTimeData=0` by GPO, at minimum on DCs and hypervisor hosts. Server 2025: verify the value rather than assume it. Clients: leave STS at default unless problems appear (some devices, e.g., with flat CMOS batteries, rely on STS to recover).

Trade-offs. Disabling STS removes a source of unexplained time jumps on servers; it also removes a recovery path for machines that boot with grossly wrong time and cannot reach NTP, so monitoring compensates.

Conflicts. None among US authorities. STIG and CIS coverage of STS was not verified for this report.

8. Monitoring, logging, and leap-second design

Design decision. How is time health monitored, how are log timestamps standardized, and how are leap seconds handled?

Monitoring tools (Microsoft). `w32tm /monitor` (domain-wide offsets; prefix a computer name with * to treat it as PDC); `w32tm /stripchart /computer:<target>`; `w32tm /query /status /verbose`; `w32tm /query /source`, `/configuration`, `/peers`; `w32tm /debug` private logging.

Event sources. Microsoft-Windows-Time-Service events (source changes logged by default, `EventLogFlags`=2); events 257, 260 and 263 record configuration including STS state; Kernel-General Event 1 records every system-time change and the process that made it; commonly cited W32Time warnings include no-usable-source and unsynchronized-for-extended-period events (exact IDs not verified against a current Microsoft page); `TimeJumpAuditOffset` and `ClockAdjustmentAuditLimit` tune auditing.

Logging requirements. NIST SP 800-53 Rev 5 AU-8: audit records carry timestamps from internal clocks at an organization-defined granularity, using UTC, a fixed UTC offset, or an embedded offset; the synchronization enhancements AU-8(1)/(2) were withdrawn and moved to SC-45(1) (authoritative source) and SC-45(2) (secondary authoritative source). DISA maps its time rules to AU-8(1)/SC-45(1). CIS Control 8.4 treats time sync as part of audit log management. OMB M-26-14 Appendix B: logs "must include a consistently accurate timestamp"; network time via NTP or equivalent to an agency-designated traceable source, preferably traceable to USNO or NIST. CISA/NSA/FBI joint event-logging guidance (Aug 2024): set up an accurate, trustworthy time source and use it consistently, with the same date-time format everywhere; use multiple sources where possible; prefer UTC. CISA: timestamps and correctly correlated offsets are critical to reconstructing intrusion timelines. NIST SP 800-92: broader log-management planning, including clock consistency across log sources.

Leap seconds. Windows: W32Time historically "does not implement a leap second" — it passes the NTP Leap Indicator downstream but does not insert the second and corrects through normal sync; the same archived Microsoft page (KB2722715) states WS2019 and Windows 10 October 2018 Update support leap seconds in the platform. Dissemination: NIST and USNO disseminate leap-second information, and NTP carries leap warnings (NIST lists this as a protocol feature); NIST publishes a leap-seconds data file (current location not re-verified). CISA: test before and after known time events such as leap seconds and DST, and document how systems handle them. CGPM status: in 2022 the 27th CGPM (Resolution 4) decided to raise the UT1–UTC tolerance by or before 2035; at the 28th CGPM on 15 October 2026, delegates adopted Resolution 5 ("On the technical actions needed to ensure the continuity of UTC"), under which "continuous UTC will become effective on 20 May 2027" and the maximum |UT1–UTC| becomes 3,600 seconds (1 hour), per the BIPM-published resolution text. The last leap second was 31 December 2016; no negative leap second has ever been applied.

Design implications. Monitor and alert on offset against designated references, and on time-jump events; standardize log timestamps on UTC; keep leap-second handling in test plans until May 2027, then treat leap seconds as a legacy concern while keeping code paths tolerant.

Conflicts. None material. The authorities differ only in how strongly they mandate UTC: CISA/NSA prefer it, while NIST also allows a fixed or embedded offset.

Where authorities agree, differ, or conflict

Agree. The forest-root PDC emulator is the external boundary (Microsoft, DISA). Time must be traceable to national standards; UTC(NIST) and UTC(USNO) are the official US references (CISA, OMB, DISA). Use more than one upstream source. Kerberos tolerance stays at 5 minutes or less (Microsoft, DISA). Synchronized time is required for logging and forensics (NIST, OMB, CISA/NSA, CIS, DISA). Virtualized DCs must not take host time (Microsoft). Autokey should not be used (IETF; NIST does not support it).

Differ. Number of sources: CIS, NSA and CISA say at least two; Microsoft says three or more (or an odd number), with two as a fallback configuration; IETF says four or more. Default accuracy vs high accuracy: Microsoft's default only promises Kerberos-grade time; CISA and NIST leave granularity to the organization; regulated workloads need the 50 ms or 1 ms tiers and their conditions. Direct NIST/USNO vs internal hierarchy: NIST encourages `time.nist.gov` and discourages hard-coding; USNO restricts its stratum-1 servers to stratum-2 servers; DISA requires DoD sources; all three favor syncing only the top of an internal hierarchy externally. pool.ntp.org: acceptable as community context but not a US-government source (does not satisfy DISA; weaker documented traceability than OMB prefers). Leap seconds: NIST and USNO historically disseminate them, while Windows historically does not insert them; the October 2026 CGPM decision ends new leap seconds from 20 May 2027.

Conflict. W32Time vs authenticated-time guidance: NSA and CISA call for authenticated NTP, and IETF points to NTS; NIST offers only symmetric-key (and no NTS yet); USNO offers authentication only to DoD; W32Time supports neither symmetric-key nor NTS to external servers. USNO's own workaround (authenticate on network devices) is the only US-government-documented answer. Secure Time Seeding defaults: Microsoft ships STS enabled

on Server 2016–2022 but recommends disabling it on servers; it changed the default only in Server 2025; meanwhile the GPO default table still shows 1, a source of configuration drift.

Caveats and items that could not be verified

- **DISA versions.** Taken from third-party STIG mirrors (cyber.trackr.live, stigviewer, stigaview, NIST NCP), not opened on cyber.mil directly. Windows Server 2025 V1R4 is listed but its date and rule revisions are unconfirmed; the Windows Server 2016 STIG is confirmed only to V2R10 (2025); recent releases change titles to "DoW time source"; the V-278137 revision ID was not found.
- **USNO.** The NTS "coming soon (1QTR 2025)" statement is stale, and current NTS availability on NIPRNet is unknown. The exact timeline of the post-2023 migration of USNO web content to CNMOC-hosted pages (and retirement of tycho.usno.navy.mil URLs) was not reconstructed; some older STIG and Tenable content still cites dead USNO URLs.
- **Leap seconds.** The 15 Oct 2026 CGPM decision (Resolution 5; effective 20 May 2027; maximum |UT1–UTC| of 3,600 s) is taken from the BIPM-published resolution text; NIST/USNO post-decision notices were not checked.
- **CIS Benchmark.** Specific W32Time recommendation numbers and values were not verified for this report; they are commonly "Enable Windows NTP Client = Enabled," with the NTP Server setting varying by profile. Check the current benchmark for your OS version.
- **NIST SP 800-92.** NIST CSRC lists Rev 1 as an Initial Public Draft (11 Oct 2023) that will replace the 2006 Final version once finalized.
- **W32Time event IDs.** Apart from 257/260/263 and Kernel-General 1, the specific event IDs were not verified against current Microsoft pages.
- **PDC role transfer.** That the W32Time external configuration does not follow a PDC role transfer is standard practice and follows from W32Time being configured per machine; no single current Microsoft page states it verbatim. GPO/WMI-filter automation is community practice.
- **OMB M-26-14.** Applies to federal civilian agencies; national security systems and DoD/IC systems are excluded, so DoD estates follow DISA/USNO instead. CISA published the Logging Reference Architecture in August 2026 (reported 20 Aug 2026), which puts Agency Logging Plans due within 90 days (about 18 Nov 2026); its contents were not reviewed for this report.
- **Lead authorship.** The joint event-logging guide was led by Australia's ASD ACSC and co-sealed by CISA, NSA and FBI; it is used here only as a US co-authored source.
- **Licensing.** Microsoft Learn content is under Microsoft Terms of Use; some MicrosoftDocs repositories carry open licences, which were not verified per page. CIS licences are as stated by CIS for v8.1 and the Benchmarks. US federal works are generally not subject to US copyright.

Part IV — US Design Reference: Windows Enterprise PKI with Active Directory Certificate Services (AD CS) (as of October 2026)

The US design baseline for AD CS across Microsoft, CISA/NSA and DISA comes down to five points: build at least a two-tier hierarchy with an offline standalone root; treat every CA and its backups as Tier 0 assets; keep CA keys in an HSM; tightly scope certificate templates (no enrollee-supplied subject for authentication certificates unless a CA manager approves the request); and design certificate-based logon around strong (SID-based) mapping and NTAuth chaining, both of which Microsoft now enforces with no registry bypass. Microsoft supplies the architecture mechanics, CISA/NSA the threat-driven controls, and DISA the binary compliance rules. NIST and NSA set the cryptographic clock: SHA-1 out by 2030, quantum-vulnerable RSA/ECDSA deprecated after 2030 and disallowed after 2035 (still a draft), and CNSA 2.0 for National Security Systems. That clock now meets a real product milestone, because AD CS on Windows Server 2025 gained ML-DSA issuance in May 2026.

TL;DR

- **Architecture baseline:**
  - Use an offline standalone root CA, plus one or more online enterprise subordinate (issuing) CAs.
  - Add a policy/intermediate tier only when there is a concrete policy, legal or delegation need. Microsoft-published guidance calls the middle tier “often never utilized”.
  - Configure CDP/AIA (HTTP first) before the first certificate is issued.
  - Renew CA certificates at half-life. Avoid delta CRLs on offline roots.
- **Security baseline (Microsoft + CISA/NSA + DISA agree):**
  - Treat AD CS as Tier 0 and manage it only from Tier 0 PAWs/jump hosts with dedicated CA admin accounts (DISA V-269099, CAT I).
  - Protect CA keys with an HSM, which CISA/NSA list as a control that “should be implemented”.
  - Encrypt CA backups and restrict them to Backup Administrators.
  - Turn on full CA auditing and forward the logs centrally.
  - Remove the “enrollee supplies subject” flag from authentication templates, or require CA certificate manager approval for them. DISA V-269098 (CAT I) makes manual approval mandatory for certain EKUs.
  - Mitigate ESC8 relay with HTTPS + Extended Protection for Authentication and by disabling NTLM (KB5005413).
- **Identity and crypto clock:**
  - Strong certificate mapping (KB5014754) has been fully enforced since September 9, 2025.
  - NTAuth chaining for Kerberos certificate logon (KB5057784 / CVE-2025-26647) has been enforced with no bypass since October 14, 2025.
  - Use SHA-256 or stronger. NIST’s draft SP 800-131A Rev. 3 would disallow SHA-1 after 2030.

- Plan new hierarchies for crypto-agility: RSA-3072/4096 or P-384 today, and a parallel ML-DSA hierarchy for testing. NIST IR 8547 (draft) proposes deprecating quantum-vulnerable algorithms after 2030 and disallowing them after 2035. NSA CNSA 2.0 requires ML-DSA-87 for National Security Systems.

Authoritative design-source overview

Status is as of October 19, 2026. Licence notes: US federal works (NIST, CISA, NSA, DISA) are generally public domain in the US, though third-party content and logos are excluded. Microsoft Learn/Support content falls under Microsoft Terms of Use; Microsoft Learn documentation text is also published on GitHub under CC BY 4.0, but verify per page. CIS Controls/Benchmarks are free for non-commercial use under CC BY-NC-SA 4.0, with commercial use requiring CIS SecureSuite membership. IETF RFCs fall under the IETF Trust Legal Provisions, which allow free reproduction of the full text. CA/Browser Forum documents are freely published under the Forum's IPR policy. Practitioner papers are copyrighted by their authors. Everything listed is free to access unless noted.

Publisher	Key document / tool (URL)	Date / version	Status	Design area(s) informed
Microsoft Learn	PKI design considerations using AD CS — learn.microsoft.com/windows-server/identity/ad-cs/pki-design-considerations	ms.date Aug 2023; applies to WS2016–WS2025	Current	1, 2, 3, 4, 5
Microsoft Learn	What is AD CS? (overview incl. ML-DSA/PQC support)	Updated 2026	Current	2, 3, 7
Microsoft (TechNet Wiki archive)	Public Key Infrastructure Design Guidance (hierarchy option table)	Archived community/MS content	Legacy (archived)	1, 2
Microsoft	Securing Public Key Infrastructure (PKI) white paper (Komar-era hardening text) and WS2012 R2 Test Lab Guide: Two-	2014 / 2012–2013	Legacy, still widely cited	1, 2, 5, 9

Publisher	Key document / tool (URL)	Date / version	Status	Design area(s) informed
	Tier PKI Hierarchy			
Microsoft Learn	CAPolicy.inf syntax; Install-AdcsCertificationAuthority cmdlet; Online Responder; certificate templates; autoenrollment; NDES	Varies	Current	2, 4, 5, 6, 7
Microsoft Support	KB5014754 Certificate-based authentication changes on Windows DCs	Released May 10, 2022; Full Enforcement Sept 9, 2025	Current (enforced)	6, 8
Microsoft Support	KB5057784 Protections for CVE-2025-26647 (Kerberos Authentication)	Audit Apr 8, 2025; enforced-by-default Jul 8, 2025; bypass removed Oct 14, 2025	Current (enforced)	8
Microsoft MSRC / Support	ADV210003 and KB5005413 Mitigating NTLM Relay Attacks on AD CS (PetitPotam/ESC8)	Jul 23, 2021; updated Jul 28, 2021	Current	7
Microsoft MSRC	CVE-2022-26923 (Certifried); CVE-2024-49019 (EKUwu/ESC15)	May 2022; Nov 12, 2024	Patched; design lessons current	6, 8
Microsoft TechCommunity (Core Infra and Security blog)	Secure Configuration and Hardening of AD CS	Oct 22, 2025	Current (blog, not formal doc)	6, 8, 9
Microsoft Learn	Windows Hello for Business hybrid key	Current	Current	8

Publisher	Key document / tool (URL)	Date / version	Status	Design area(s) informed
	trust / on-prem certificate trust deployment guides			
Microsoft	AD CS ML-DSA support, Windows Server 2025 update KB5087539	May 12, 2026	Current (GA; documented on Microsoft Learn)	3
CISA / NSA (with Five Eyes co-authors)	Detecting and Mitigating Active Directory Compromises (AD CS + Golden Certificate sections)	Sept 2024	Current	6, 9, 10
NSA	CNSA 2.0 advisory and FAQ	Sept 2022; FAQ updated since	Current	3
NSA	Eliminating Obsolete TLS Protocol Configurations	Jan 2021	Current	3, 7
DISA	Active Directory Forest STIG (V-269098, V-269099)	V3R2 (V3 dated May 15, 2025 on mirrors); rules introduced in V3R1	Current	6, 9
DISA	Windows Server 2022 STIG (V-254442 DoD Root CA certs) and WS2025 STIG (V-278192 Root CA certs; V-278159 DC PKI server certificate); AD Domain STIG V-269097 (Kerberos logging on DCs with AD CS)	WS2022 V2R10 and WS2025 V1R3 per third-party mirror (Aug 2026)	Current	8, 10

Publisher	Key document / tool (URL)	Date / version	Status	Design area(s) informed
DoD	DoDI 8520.02 PKI and PKE; DoD Cyber Exchange “Microsoft Certificate Strong Mapping” page	DoDI 2011 (as amended); page 2025	Current (US-government context)	8
NIST	SP 800-57 Part 1 Rev. 5 Recommendation for Key Management	May 4, 2020	Current	3, 4
NIST	SP 800-131A Rev. 2 (final, Mar 21, 2019); Rev. 3 initial public draft	Rev. 3 ipd Oct 21, 2024	Rev. 2 current; Rev. 3 draft	3
NIST	IR 8547 Transition to Post-Quantum Cryptography Standards	Initial public draft Nov 12, 2024	Draft (not finalized as of Oct 2026)	3
NIST	FIPS 186-5 (Digital Signature Standard); FIPS 204 (ML-DSA); SP 800-208 (LMS/XMSS)	Feb 2023; Aug 13, 2024; Oct 2020	Current	3
NIST NCCoE	SP 1800-16 Securing Web Transactions: TLS Server Certificate Management	Final, June 2020 (Vols A–D)	Current	4, 10
NIST	SP 800-32 Introduction to Public Key Technology and the Federal PKI Infrastructure	Feb 2001	Legacy	1 (bridge/cross-cert context)

Publisher	Key document / tool (URL)	Date / version	Status	Design area(s) informed
NIST	SP 800-53 Rev. 5 (IA-5(2), SC-12, SC-17, AU-8, SC-45, AU family)	Rev. 5 (2020) with later patch releases	Current	3, 9, 10
US Executive Branch	EO 14412 Securing the Nation Against Advanced Cryptographic Attacks; OMB M-26-15	June 22 and June 24, 2026	Current (federal agencies)	3
CIS	CIS Controls v8.1; CIS Microsoft Windows Server Benchmarks	v8.1 June 2024; benchmarks versioned per OS	Current (registration required for benchmark PDFs)	9, 10
IETF	RFC 5280 (PKIX), RFC 6960 (OCSP), RFC 5019 (lightweight OCSP), RFC 4556 (PKINIT), RFC 8894 (SCEP), RFC 8555 (ACME)	2008; 2013; 2007; 2006; 2020; 2019	Current standards (RFC 8894 Informational)	1, 4, 5, 7, 8
CA/Browser Forum	TLS Baseline Requirements; Ballot SC-081v3	Adopted April 2025; 200 days from Mar 15, 2026	Current (public trust only)	4 (contrast)
SpecterOps (practitioner, non-governmental)	Certified Pre-Owned whitepaper; Certify tool (ESC1–ESC16)	June 2021; Certify 2.0 docs 2025	Current research	6, 7, 8
Mandiant / Google Cloud (practitioner)	Active Directory Certificate Services: Modern Attack Paths, Mitigations, and Hardening	c. 2023–2024	Current research	6, 7, 9, 10

1. CA hierarchy design

Decision at stake: how many trust tiers to build, how many issuing CAs to run, and which constraints to put on subordinate CAs.

Realistic options: - **Single-tier:** an online enterprise root that also issues certificates. - **Two-tier:** an offline standalone root plus online enterprise issuing CAs. - **Three-tier:** root, then offline policy/intermediate CAs, then issuing CAs. - **Cross-certification / bridge:** relevant mainly in federal and DoD interoperability contexts.

What the US authorities say: - **Microsoft (current Learn):** determine "how many CAs you need and in what configuration before you install any CA." The page frames the first decision as enterprise vs standalone root and approval/revocation handling. It does not prescribe a tier count. - **Microsoft (archived design-guidance table and Test Lab Guides):** an online root is "more susceptible to compromise" and cannot be revoked if compromised; an offline enterprise root is "Not recommended"; two-tier has "no unnecessary offline systems"; in three-tier, the middle tier is "often never utilized and is wasted." The WS2012 TLG builds a standalone offline root plus an enterprise issuing CA as the reference model. Community summaries of Microsoft training describe single-tier as not recommended for production. - **CISA/NSA:** do not prescribe a tier count. They treat the AD CS root CA as a Tier 0 computer object and require securing "both root and subordinate CAs" against Golden Certificate theft. - **IETF RFC 5280:** supplies the constraint mechanics — basicConstraints pathLenConstraint; nameConstraints; certificate policies / policy constraints — set in AD CS through CAPolicy.inf. - **NIST SP 800-32 (legacy):** describes hierarchical vs mesh/bridge trust models (background for the Federal Bridge).

Trade-offs: two-tier keeps the root key off the network and allows revoking a compromised issuing CA, at the cost of an offline-root operating process. Three-tier adds policy separation but another offline system and more CRLs. More issuing CAs add availability and separation but enlarge the Tier 0 footprint.

Conflicts: none among US authorities. The question is emphasis: Microsoft optimizes for operational simplicity (two-tier); DoD's own PKI is a much larger multi-tier/bridge model that internal enterprises are not expected to replicate.

2. CA type and role design

Decision at stake: standalone vs enterprise CA; root vs subordinate; online vs offline; domain membership.

Options: `Install-AdcsCertificationAuthority -CAType` accepts StandaloneRootCA, StandaloneSubordinateCA, EnterpriseRootCA and EnterpriseSubordinateCA.

What the authorities say: - **Microsoft:** enterprise CAs integrate with AD DS (publish configuration to AD, use templates, support autoenrollment). Standalone CAs do not use templates; their CRLs and CA certificates "must be manually published into Active Directory." An offline root should therefore be standalone and non-domain-joined; the archived table rates an offline enterprise root as an uncommon configuration "with no known benefit." - **CISA/NSA:** CAs should do nothing but AD CS — "do not install any non-security-related services or applications" — and should use application control. These favour dedicated servers

over co-locating the CA role with domain controllers; Microsoft's archived table likewise lists "Enterprise root CA on a domain controller" as the weakest option. - **DISA:** V-269099 requires AD CS servers to be managed only from Tier 0 PAWs, implying enterprise (domain-joined) issuing CAs sit inside the Tier 0 boundary.

Trade-offs: enterprise CAs bring automation (templates, autoenrollment, SID extension, NTAuth publication) but also AD-wide attack surface (template ACLs, the ESC paths). Standalone CAs reduce AD dependency but need manual approval and publication. CA naming is effectively permanent — renaming the server after install invalidates issued certificates; the CA common name should not be the FQDN or the computer name.

3. Cryptographic design

Decision at stake: key algorithm and size; hash algorithm; provider and key protection; CA key lifetime relative to algorithm strength; FIPS; post-quantum readiness.

Realistic options: RSA-2048/-3072/-4096; ECDSA P-256/P-384 via a CNG KSP; SHA-256/-384/-512; software KSP, network/PCIe HSM, or TPM-backed keys for end entities; ML-DSA-44/-65/-87 on WS2025.

What the authorities say: - **Microsoft:** choose the provider, hash and key length after checking "what cryptographic options the applications and devices that you intend to use can support." Legacy CSPs support only SHA-1/MD-family hashes; the Microsoft Software KSP supports SHA-256/384/512 and ECDSA — so new CAs should use a CNG KSP. An HSM must be installed before the CA is configured if CA keys are to live on it. Microsoft's sample root CAPolicy.inf uses `RenewalKeyLength=4096`. - **NIST SP 800-57 Pt 1 Rev. 5:** suggests "a maximum cryptoperiod of about one to three years" for a private signature key; for certified keys, the cryptoperiod ends at the notAfter of the last certificate issued for that key, and the validity periods of the original and all renewed certificates "shall not extend beyond" the key's cryptoperiod. NIST calls these "rough order-of-magnitude guidelines." The 1–3-year figure is far shorter than typical 10–20-year root lifetimes; no NIST document sets a separate CA-key cryptoperiod. - **NIST SP 800-131A:** Rev. 2 (final) governs 112-bit minimum security (RSA-2048/P-224+). The Rev. 3 draft would deprecate SHA-1 and 224-bit hashes "through December 31, 2030" and disallow them thereafter, moving toward 128-bit security. NIST's 2022 announcement says SHA-1 will be retired for all applications by December 31, 2030. - **NIST IR 8547 (initial public draft, Nov 12, 2024; still draft):** proposes deprecating quantum-vulnerable public-key algorithms at 112-bit strength after 2030 and disallowing all quantum-vulnerable public-key algorithms after 2035. - **FIPS 186-5** (current signature standard) and **FIPS 204** (ML-DSA, Aug 13, 2024) define approved algorithms; **SP 800-208** covers stateful hash-based signatures (LMS/XMSS), suited to firmware signing, not general CA use. - **NSA CNSA 2.0 (National Security Systems):** ML-DSA-87 for signatures, ML-KEM-1024, AES-256, SHA-384/512, LMS/XMSS for software/firmware signing. New NSS acquisitions must be CNSA 2.0-compliant from January 1, 2027; most categories must use CNSA 2.0 exclusively by 2033, with all NSS quantum-resistant by 2035. Secondary summaries say ML-DSA-44/-65 are not acceptable for NSS. - **EO 14412 / OMB M-26-15 (June 2026, federal civilian agencies):** secondary analyses report EO 14412 requires agencies to migrate their most sensitive systems to PQC for key establishment by December 31, 2030 and to PQC for digital signatures by December 31, 2031, with M-26-15 setting a January 2, 2030 deadline for TLS 1.3; agency migration plans are

due within 120 days of M-26-15 (reported as about October 22, 2026). These bind federal agencies, not private enterprises. - **Microsoft PQC:** AD CS on Windows Server 2025 supports ML-DSA. Microsoft Learn gives the minimum version as "Windows Server 2025 with the 2026-05 Security update (KB5087539) or later," supports all three ML-DSA parameter sets in pure mode, and states existing RSA/ECC CAs cannot be converted: "ML-DSA doesn't support in-place migration of existing CAs. Build a new CA hierarchy in parallel with your existing hierarchy." PQC is available only through CNG providers. - **CISA/NSA:** "Use a HSM to protect key material for AD CS CAs … the private key for CAs cannot be backed up and exfiltrated." - **NSA (obsolete TLS guidance)** and the DISA Windows Server STIGs govern protocol/algorithm configuration of the hosts; they do not set CA key sizes.

Trade-offs: RSA-4096 roots and RSA-2048/3072 issuing CAs maximize compatibility; P-384 is smaller and CNSA 1.0-aligned, but some legacy devices and smart cards lack ECC support. Larger keys and HSMs add cost and latency. ML-DSA certificates are much larger (per Microsoft Learn, an ML-DSA-87 signature is 4,627 bytes vs 2,420 for ML-DSA-44), clients need Windows 11 24H2/25H2 with the 2025-10 update, and NDES enrollment "isn't currently available" — so parallel ML-DSA hierarchies are a test/pilot track in 2026, not a replacement.

4. Validity and renewal design

Decision at stake: CA certificate lifetimes; when to renew and whether to re-key; end-entity lifetimes; how CRL periods interact with renewal.

What the authorities say: - **Microsoft:** "CAs can't issue certificates that are valid beyond their own validity period." "A best practice is to renew the CA certificate when half of its validity period is expired." CAPolicy.inf controls renewal (`RenewalValidityPeriod`, `RenewalKeyLength`); Microsoft's sample root uses 20 years. An issuing CA's effective issuance window shrinks as its own certificate approaches expiry; renewal at half-life preserves full-length end-entity issuance. - **NIST SP 800-57:** renewing a CA certificate on the same key cannot extend total validity beyond that key's cryptoperiod — so the design favours re-keying at renewal over indefinite key reuse. - **NIST SP 1800-16:** for TLS server certificates, maintain an inventory, monitor continuously, automate renewal; executives should "establish formal TLS server certificate management programs." - **CA/Browser Forum (context only):** Ballot SC-081v3 caps publicly trusted TLS certificates at 200 days from March 15, 2026, 100 days from March 15, 2027 and 47 days from March 15, 2029. Internal AD CS hierarchies that are not publicly trusted are not bound; browsers enforce the limits only for roots in public trust programs. - **IETF RFC 5280:** defines validity semantics; does not set lifetimes.

Trade-offs: long internal lifetimes reduce renewal churn but lengthen exposure if a key is compromised; short lifetimes require autoenrollment, CES/CEP, ACME-style tooling or similar automation. Re-keying at CA renewal creates a new CA certificate and key-index CRLs; clients need both chains during overlap.

5. Revocation and publication design (CDP/AIA)

Decision at stake: CRL only, CRL plus delta CRL, or CRL plus OCSP (Online Responder); HTTP vs LDAP publication and ordering; CRL validity and overlap periods.

What the authorities say: - **Microsoft:** configure AIA and CDP extensions "before the CA issues any certificates" — changing a URL affects only newly issued certificates. "Avoid publishing delta CRLs on offline root CAs" (the WS2012 TLG sets `CRLDeltaPeriodUnits=0`). Publish an HTTP CRL location for external and non-Windows clients. "Windows clients always retrieve the list of URLs in sequential order until a valid CRL is retrieved," so URL order is a latency/availability decision; common practice lists HTTP before LDAP. Microsoft's Online Responder implements OCSP and on WS2025 can sign responses with ML-DSA. - **IETF:** RFC 5280 defines CRLs, delta CRLs, CDP and AIA; RFC 6960 defines OCSP; RFC 5019 defines a lightweight, cache-friendly OCSP profile. - **CISA/NSA:** stress that rogue or attacker-obtained certificates "remain valid until they are revoked"; revocation must be part of incident response. - **No US authority reviewed here mandates OCSP for internal enterprise PKI.** OCSP is optional, justified mainly where CRL size/latency is a problem or relying parties require it.

Trade-offs: delta CRLs give fresher data but more publication jobs and failure points; OCSP gives low-latency checks but responder availability and signing-certificate management become their own dependency; LDAP CDPs suit domain clients only and can create site-unaware lookups. On an offline root, CRL validity and overlap must outlast the interval between ceremonies (long root CRL periods are standard; issuing-CA CRLs are typically days).

6. Certificate template design

Decision at stake: which template schema versions to use; who can enroll; whether subjects are built from AD or supplied in the request; issuance requirements (manager approval, authorized signatures); EKU/application-policy scope; template lifecycle.

What the authorities say: - **Microsoft:** version 2+ templates are editable and support autoenrollment; template permissions (Read, Enroll, Autoenroll) define who can obtain certificates; superseding templates migrate holders (e.g., DC certificates). Archived guidance says to remove unneeded templates from the moment the issuing CA is stood up and to document each template's issuance requirements and enrollment groups. The TechCommunity hardening blog: "Never allow 'Enrollee Supplied Subject' without manager approval." - **Microsoft (patched flaw):** CVE-2024-49019 (EKUwu/ESC15, patched Nov 12, 2024) — on schema-version-1 templates that allow a supplied subject, a requester could inject application policies that override the template EKU. Design lesson (practitioner-sourced): avoid publishing v1 templates; duplicating a v1 template creates a v2+ template. - **CISA/NSA:** an ESC1-vulnerable template has four properties — low-privilege enrollment, an authentication EKU, a supplied SAN, no manager approval. Mitigations: remove the Enrollee Supplies Subject flag; restrict write permissions on templates; remove the CA flag EDITF_ATTRIBUTESUBJECTALTNAME2; require CA Certificate Manager approval where a SAN can be supplied; remove authentication EKUs where not needed. Templates enrollable by Domain Computers are a pathway if attackers can create machine accounts. - **DISA V-269098 (CAT I):** templates with certain EKUs must require manual CA approval in all cases, including Smart Card Logon and subordinate-CA certificates; templates with authentication-relevant EKUs that allow "Supply in the request" must also require manual approval. Not a finding if "Supply in the request" is not selected and enroll permissions are limited to a select group. - **SpecterOps (practitioner):** the ESC1–ESC16 taxonomy. Template-level paths include ESC1/2/3 (supplied subject; any-purpose EKU; enrollment-agent abuse), ESC4 (writable template ACLs), ESC9/10 (weak mapping or no security extension), ESC13 (issuance-policy-to-group links), ESC15 (EKUwu). CA-level paths

include ESC6 (SAN flag), ESC7 (CA ACLs), ESC8/11 (relay) and ESC16 (SID security extension disabled CA-wide). Certify 2.0 enumerates ESC1–ESC16.

Trade-offs: manager approval is strong but does not scale for high-volume templates; tight enrollment ACLs plus AD-built subjects scale through autoenrollment but depend on ACL hygiene; unpublishing v1 defaults can break legacy workflows unless duplicates are issued first.

7. Enrollment and endpoint design

Decision at stake: which enrollment interfaces to expose (GPO autoenrollment; CA Web Enrollment; CES/CEP; NDES/SCEP; third-party ACME/EST gateways); whether to require key attestation.

What the authorities say: - **Microsoft:** autoenrollment (template permissions plus a GPO) is the native domain path; CES/CEP serve non-domain or off-network clients; NDES implements SCEP for devices; TPM key attestation can be required on v4 templates. - **Microsoft ADV210003 / KB5005413 (ESC8/PetitPotam):** Web Enrollment and CES accept NTLM by default and are relay targets. Primary mitigations: “enabling EPA and disabling HTTP on AD CS servers” (enable Extended Protection for Authentication and Require SSL — EPA is ineffective without Require SSL). Further: restrict incoming NTLM on AD CS servers by GPO, disable NTLM in IIS for these role services, and disable NTLM domain-wide where possible. - **CISA/NSA:** disable NTLM wherever possible; otherwise enable LDAP channel binding, EPA and SMB signing. Install only the AD CS functions that are needed (remove unused role services such as Web Enrollment). - **IETF:** RFC 8894 (SCEP, Informational) documents weak requester authentication (a shared challenge password), so NDES deployments need tightly scoped templates and challenge handling. RFC 8555 (ACME) is the modern automation model behind public-trust renewal; AD CS has no native ACME server. - **SpecterOps:** ESC8 (HTTP relay) and ESC11 (RPC relay where the CA does not enforce request encryption) are endpoint-design issues, not template issues.

Trade-offs: each additional enrollment endpoint widens the attack surface and the Tier 0 boundary; NDES enables device enrollment but concentrates a registration-authority credential (avoid where an MDM/connector with better authentication is available); key attestation raises assurance but requires TPM-capable clients and attestation trust configuration.

8. Identity binding and authentication design

Decision at stake: how certificates map to AD accounts; which CAs are trusted for logon; how domain controllers obtain KDC certificates.

What the authorities say: - **KB5014754 (strong mapping):** enterprise CAs embed the account SID in a new security extension (OID 1.3.6.1.4.1.311.25.2). DCs moved to Full Enforcement by default in February 2025; the `StrongCertificateBindingEnforcement` key stopped being honored with the September 9, 2025 update. Weak implicit mappings now fail; alternatives are certificates carrying the SID extension, strong explicit altSecurityIdentities mappings, or (for offline/third-party CAs) adding the SID via a URL-tag SAN. The DoD Cyber Exchange publishes “name-based strong mappings” guidance for DoD PKI certificates. - **KB5057784 / CVE-2025-26647 (NTAuth):** audit phase from April 8, 2025; enforced by default July 8, 2025; from October 14, 2025 `AllowNtAuthPolicyBypass` is no longer supported (“all

certificates must be issued by authorities that are a part of NTAuth store"). The risk scenario is a CA trusted in the root store but absent from NTAuth, combined with an SKI on a privileged account. Design rule: publish only the logon-issuing CAs to NTAuth, and treat NTAuth membership as a Tier 0 control. - **CVE-2022-26923 (Certifried):** machine-account dNSHostName spoofing yielded DC-impersonating certificates; fixed by the SID extension and mapping changes above. - **CISA/NSA:** monitor KDC events 39/40/41 (no strong mapping; certificate predates the account; SID mismatch) and 4768 with PreAuthType 16 (certificate-based TGT). Set MachineAccountQuota to zero. - **Microsoft (Windows Hello for Business):** each DC should have a certificate based on the Kerberos Authentication template, used as a baseline for an updated "Domain Controller Authentication (Kerberos)" template, which should supersede Domain Controller and Domain Controller Authentication. Key trust needs a PKI for DC certificates but not client certificates; cloud Kerberos trust is now Microsoft's recommended WHfB model over key trust. - **DISA:** the WS2025 STIG requires DCs to have a PKI server certificate (V-278159); the OS STIGs require DoD root CA certificates in the Trusted Root store (WS2022 V-254442; WS2025 V-278192, now worded "DoW"). - **IETF:** RFC 4556 (PKINIT) defines certificate-based Kerberos pre-authentication; DCs need the KDC Authentication EKU for it, and the same DC certificates support LDAPS.

Trade-offs: strong mapping breaks legacy, MDM-issued and third-party smart-card flows that lack the SID (explicit mappings scale poorly); minimizing NTAuth membership reduces risk but requires inventorying every CA used for logon.

9. CA protection, role separation, auditing and key-backup design

Decision at stake: tier placement; physical and offline protection; administrative role separation; audit settings; backup handling of the CA key and database.

What the authorities say: - **CISA/NSA (Golden Certificate):** an attacker with CA admin access can extract the CA certificate and private key (built-in backup tools or Mimikatz/SharpDPAPI) and forge authentication certificates for any user. Mitigations: MFA for privileged users; application control; an HSM; limiting CA access to a subset smaller than Domain Admins; restricting access paths to jump servers/SAWs; single-purpose CA servers; encrypting backups and limiting them to Backup Administrators; central log analysis. Detection "is difficult": event 4876 fires only for full database backups; enable CAPI2 event 70 (private-key export) and watch 1102 (log cleared) and PowerShell 4103/4104. - **DISA V-269099 (CAT I):** set aside one or more PAWs for AD CS management. "A dedicated AD CS/CA Admin account that is only usable on tier 0 PAW or the ADCS server must be used to manage the certificate authority and approve requests." - **Microsoft:** Common Criteria role separation (CA Administrator, Certificate Manager, Auditor, Backup Operator), enforced with `certutil -setreg CA\RoleSeparationEnabled 1`; separate Certificate Manager and Key Recovery Agent roles where key archival is used; a two-person key-recovery process (archived guidance). The TechCommunity hardening blog urges role separation and using "an offline root and HSMs, if financially feasible." The legacy "Securing PKI" paper covers physical security and ceremonies for the offline root (its specific text was not re-verified here). - **Microsoft auditing mechanics:** enable "Audit Certification Services" (object access); set the CA audit filter to all categories (`certutil -setreg CA\AuditFilter 127`), yielding the 4870–4900 event range, including 4886/4887 (request/issue), 4898 (template loaded), 4899 (template updated) and 4900 (template security updated). - **NIST SP 800-53 Rev. 5:** SC-12 (key establishment and

management); SC-17 (PKI certificates issued under an approved policy); IA-5(2) (PKI-based authentication: validate certification paths, enforce access to private keys, map identities). - **CIS Controls v8.1:** asset inventory, secure configuration, privileged-account management and audit-log management apply generically. Neither CIS Controls nor the CIS Windows Server Benchmarks contain AD CS-specific design guidance comparable to DISA's.

Trade-offs: HSMs prevent key export but add cost and need HSM-specific backup/DR; role separation blocks a single administrator from both configuring and approving but can be heavy for small teams; offline roots need disciplined ceremonies and media custody.

10. Logging and monitoring design

Decision at stake: what to collect from CAs and DCs; where to send it; what to alert on.

What the authorities say: - **CISA/NSA:** centrally log and analyze, "in a timely manner": CA events 4886, 4887, 4899, 4900, 4876, 1102 and CAPI2 70; DC events 39, 40, 41, 4768 (PreAuthType 16) and 4674 (template security-descriptor operations). Hunt for Client Authentication certificates whose subject differs from the requester. - **Mandiant (practitioner):** detection guidance using events 39, 41 and 4887 to spot SID mismatches and CVE-2022-26923-style abuse. - **DISA:** the AD Domain STIG V-269097 requires Kerberos logging on DCs in domains hosting AD CS. - **Microsoft:** Enterprise PKI (pkiview.msc) shows chain, AIA and CDP health and expiry for every CA in the forest; Microsoft Defender for Identity's AD CS sensor surfaces template and CA misconfigurations (cited by CISA/NSA). - **NIST SP 800-53:** AU-8 (time stamps) and SC-45 (system time synchronization) underpin cross-source correlation; DISA's AD Forest STIG requires the forest-root PDC Emulator to take time from an authoritative external source (V-243504). - **NIST SP 1800-16 and SP 800-57 (Section 9.2.2):** maintain certificate inventories with assigned owners and continuous status monitoring.

Recommended alert set (synthesized): template ACL or settings changes (4899/4900/4674); CA backups and private-key exports (4876, CAPI2 70); audit-log clearing (1102); issuance where the SAN or subject does not match the requester; KDC 39/41; changes to NTAuth or CA configuration flags; expiring CA or CRL objects.

Where authorities agree, differ or conflict

Topic	Agreement	Difference / conflict
Hierarchy	All sources that address it favour an offline root and online issuing CAs	No US authority mandates a tier count. Microsoft's archived guidance is skeptical of a third tier
Internal validity vs public trust	Microsoft and NIST tie validity to CA lifetime and key cryptoperiod	CA/B Forum's 200-day (2026) → 47-day (2029) caps apply only to publicly trusted TLS. Internal PKI is not bound, but its automation gap widens as public lifetimes shrink
CA key lifetime	NIST says renewed validity	NIST's suggested private-

Topic	Agreement	Difference / conflict
	must not exceed the key's cryptoperiod	signature-key cryptoperiod is about 1–3 years, while Microsoft's sample root uses 20-year renewal. NIST calls its figures rough guidelines, which is the main tension
OCSP	RFCs define it; Microsoft provides Online Responder	No US authority reviewed mandates OCSP for internal PKI. CRL-only is acceptable
HSM	All see value	CISA/NSA list an HSM among controls that "should be implemented". Microsoft treats it as optional ("if financially feasible")
Enrollee-supplied subject	All see it as the core ESC1 risk	DISA requires manual approval (CAT I) for specified EKUs. CISA/NSA prefer removing the flag, with approval as the fallback. Microsoft's broader model relies on tight permissions plus autoenrollment, which trusts ACL hygiene
Hash and algorithms	SHA-256+ everywhere; SHA-1 ends by 2030 (NIST)	SP 800-131A Rev. 3 and IR 8547 are still drafts, so their dates are proposals. CNSA 2.0 (NSS) is stricter (ML-DSA-87, exclusive use by 2033). EO 14412 sets 2030/2031 for federal high-value systems
Post-quantum	All direct planning now	Microsoft shipped ML-DSA in AD CS (May 2026) and states it "doesn't support in-place migration of existing CAs." Ecosystem client support lags
Attack-path hardening: design vs patch	Patches closed Certifried, EKUwu and the mapping/NTAuth bypasses	CISA/NSA and DISA treat AD CS security as configuration and architecture (Tier 0, templates, NTLM). Microsoft's enforcement KBs make some outcomes mandatory. ESC1/4/6/8 remain design issues that no

Topic	Agreement	Difference / conflict
		patch fixes

Caveats and items that could not be verified

- **ML-DSA GA:** Microsoft Learn ("What is ML-DSA support in AD CS?", May 12, 2026) documents the May 2026 KB5087539 requirement and all three parameter sets. The "no in-place migration" point is also Microsoft-documented.
- **NIST drafts:** IR 8547 (Nov 2024) and SP 800-131A Rev. 3 (Oct 2024) were still initial public drafts as of this review, per NIST CSRC pages relayed by a research subagent. One third-party site claiming a finalized IR 8547 contradicts NIST and was disregarded.
- **NIST SP 800-57:** the 1–3-year figure is NIST's general private-signature-key guidance; NIST gives no separate CA-key cryptoperiod, and figures such as "10–20 years" attributed to NIST by third parties are not NIST text.
- **DISA versions:** AD Forest STIG V3R2 is confirmed; whether a manual V3R3 exists was not resolved. The Windows Server STIG versions (WS2022 V2R10, WS2025 V1R3) come from third-party mirrors, not DISA Cyber Exchange.
- **EO 14412 / OMB M-26-15:** details come from secondary analyses (Zscaler, PostQuantum.com) rather than the Federal Register text.
- **The September 2024 AD guidance** was co-authored with non-US agencies; per scope it is treated here only as a CISA/NSA source. The 2026 ASD-hosted revision was not used.
- **Microsoft "single-tier not for production":** this wording appears in community summaries and archived Microsoft material; the current Learn design page does not state a tier recommendation.
- **The legacy "Securing PKI" white paper, the CAPolicy.inf, Online Responder, NDES and Install-AdcsCertificationAuthority pages, the CIS Controls/Benchmark specifics, the NSA TLS guidance and the IETF RFC details** are summarized from established knowledge and were not re-fetched during this review.
- **The Microsoft TechCommunity hardening blog** is a field-engineer post, not formal product documentation; its page body did not render on fetch, so its points are drawn from search extracts.
- **Licensing statements** are general. Confirm per-document terms before republishing excerpts.

Part V — DHCP in Windows Server and Active Directory: US-Source Design Reference (October 2026)

The defensible US-source baseline for enterprise Windows DHCP is: run DHCP on dedicated, AD-authorized member servers (not domain controllers), make it highly available with a two-server DHCP failover relationship, have the DHCP server register DNS records with a dedicated low-privilege credential plus Name Protection rather than via the DnsUpdateProxy group, treat the DHCP Administrators group as a privileged tier, and put the actual anti-rogue/anti-spoofing load on the switch layer (DHCP snooping, Dynamic ARP Inspection, IP Source Guard, RA Guard/DHCPv6-Shield) and on log retention. No US government body publishes a DHCP-specific standard; the IETF RFCs define the protocol, Microsoft defines the Windows implementation, DISA supplies the only hard numeric DHCP rule (log retention), and US practitioner research (Akamai) supplies most of the AD-specific threat analysis.

1. TL;DR — design baseline

- **Placement, HA and identity:** Deploy Windows DHCP on dedicated domain-member servers authorized in AD (authorization requires Enterprise Admins or delegated rights on the NetServices container); avoid domain controllers, because a DHCP service on a DC inherits DC rights over AD-integrated DNS records and turns "DHCP Administrators" into a path to domain compromise. Use DHCP failover (load balance for co-located partners, hot standby for hub-and-spoke), which current Microsoft Learn documents as requiring Windows Server 2016 or later on both partners; keep split-scope (80/20) only for DHCPv6 or legacy cases.
- **DNS integration:** If the DHCP server must register DNS on clients' behalf, configure one dedicated, non-privileged DNS-registration credential identical on all DHCP servers, enable Name Protection (DHCID, RFC 4701), keep zones "secure only", and keep DnsUpdateProxy empty; if DHCP-driven registration is not needed, Akamai's research recommends disabling it outright.
- **Security and evidence:** Message-level DHCP authentication (RFC 3118) is effectively unused, so rogue-server and spoofing protection belongs to the switch and hypervisor (DHCP snooping, DAI, IP Source Guard, Hyper-V DHCP Guard/Router Guard, RA Guard/DHCPv6-Shield); log hostname, MAC, IP and time, and retain DHCP logs 30 days online and 1 year offline — DISA Network Infrastructure Policy STIG V10R7 (2 Aug 2024), rule V-251361 / NET0198 (medium severity), whose fix text reads "Store the logs for a minimum of thirty days online and then offline for one year" — far beyond Windows' default seven-day rolling audit files.

2. Authoritative design-source overview

#	Publisher / author	Document or tool	Date / version (as verified Oct 2026)	Status (Oct 2026)	Design areas	Access; licence / reuse
1	IETF (R. Droms)	RFC 2131, Dynamic Host	March 1997	Current (Draft Standard;	2, 3, 6	Free; IETF Trust (BCP 78/79)

#	Publisher / author	Document or tool	Date / version (as verified Oct 2026)	Status (Oct 2026)	Design areas	Access; licence / reuse
		Configuration Protocol		updated by later RFCs)		
2	IETF (S. Alexander, R. Droms)	RFC 2132, DHCP Options and BOOTP Vendor Extensions	March 1997	Current	3, 4	Free; IETF Trust
3	IETF (M. Patrick)	RFC 3046, DHCP Relay Agent Information Option (Option 82)	January 2001	Current	4, 6	Free; IETF Trust
4	IETF (R. Droms, W. Arbaugh)	RFC 3118, Authentication for DHCP Messages	June 2001	Current on paper; little or no deployment; not supported by Windows DHCP	6	Free; IETF Trust
5	IETF	RFC 4701 (DHCID RR), RFC 4702 (Client FQDN option), RFC 4703 (resolving FQDN conflicts)	October 2006	Current	5	Free; IETF Trust
6	IETF	RFC 6939, Client Link-Layer Address Option in	May 2013	Current	7	Free; IETF Trust

#	Publisher / author	Document or tool	Date / version (as verified Oct 2026)	Status (Oct 2026)	Design areas	Access; licence / reuse
		DHCPv6				
7	IETF	RFC 8415, DHCPv6	November 2018	**Obsoleted by RFC 9915**	7	Free; IETF Trust
8	IETF (Mrugalski, Volz, Richardson, Jiang, Winters)	RFC 9915, DHCPv6	January 2026 (STD 102); “obsoletes RFC 8415”; drops IA_TA and Server Unicast	Current	7	Free; IETF Trust
9	IETF	RFC 7610, DHCPv6-Shield; RFC 7513 (SAVI for DHCP); RFC 7039 (SAVI framework)	Aug 2015; May 2015; Oct 2013	Current	6, 7 (context)	Free; IETF Trust
10	Microsoft	Microsoft Learn: DHCP server role, DHCP failover overview, Dynamic DNS update, DhcpServer PowerShell module, legacy failover/split-scope/Name Protection	Failover overview ms.date 2025-03-11 (WS2016–WS2025); Dynamic update ms.date 2025-02-13; many pages “previous-versions”	Current pages current; previous-versions pages legacy but the only Microsoft source for some topics	1–8	Free; Microsoft Learn terms (docs repo text CC BY 4.0, code MIT)

#	Publisher / author	Document or tool	Date / version (as verified Oct 2026)	Status (Oct 2026)	Design areas	Access; licence / reuse
		/DHCP groups pages				
11	Microsoft	Hyper-V: features and terminology; Set-VMNetworkAdapter (-DhcpGuard, -RouterGuard)	Current Learn pages (WS2016–WS2025)	Current	6	Free; Microsoft terms
12	NIST	SP 800-81r3, Secure DNS Deployment Guide	Final, 19 March 2026; supersedes SP 800-81-2 (Sept 2013)	Current	5, 8	Free; US federal work (public domain in the US)
13	NIST	SP 800-53 Rev. 5 (AU-8 time stamps, AU-11 retention, CM-6 configuration settings, SC-7 boundary protection, AC-6 least privilege, SC-20/21/22 name resolution)	Rev. 5 (2020) with later patch releases	Current	6, 8	Free; public domain
14	NIST	SP 800-189,	December	Current	6 (context)	Free;

#	Publisher / author	Document or tool	Date / version (as verified Oct 2026)	Status (Oct 2026)	Design areas	Access; licence / reuse
		Resilient Interdomain Traffic Routing (BGP security and source-address validation)	2019	(context only; inter-domain, layer 3)		public domain
15	NSA (with CISA)	Network Infrastructure Security Guide (CTR U/OO/118623-22)	Version 1.2, October 2023	Current	6	Free; US federal work, public domain
16	ASD (lead), CISA, NSA, CCCS, NCSC-NZ, NCSC-UK	Detecting and Mitigating Active Directory Compromises (CTR)	First published September 2024; NSA lists a September 2026 update	Current (2026 update not reviewed)	1, 6 (context only — see Caveats)	Free; joint product — US agency portions public domain
17	DISA	Network Infrastructure Policy STIG (V-251361 DHCP logging; V-251362 SIPRNet lease ≥30 days)	Version 10 Release 7, 2 Aug 2024 (latest located)	Current as far as verified	3, 8	Free (public STIGs on cyber.mil); US federal work
18	DISA	Layer-2 switch STIGs (e.g., Cisco IOS Switch L2S:	Vendor-specific releases (e.g., L2S v2r4, 2024)	Current	6	Free; US federal work

#	Publisher / author	Document or tool	Date / version (as verified Oct 2026)	Status (Oct 2026)	Design areas	Access; licence / reuse
		DHCP snooping on user VLANs, DAI, IP Source Guard)				
19	CIS	CIS Controls v8.1 (Safeguard 1.4 DHCP logging for asset inventory; 8.x audit log management; 12.x/13.x network infrastructure)	v8.1, June 2024	Current	6, 8	Free with registration; CC BY-NC-ND 4.0
20	CIS	CIS Microsoft Windows Server Benchmarks	2022 v5.1.0; 2025 v2.1.0 per CIS Sept 2026 update	Current	1, 6 (indirect — no DHCP/DnsUpdateProxy item located)	Free PDF for non-commercial use with registration; CC BY-NC-SA 4.0
21	Akamai Technologies (Ori David) — US company, **practitioner research, non-governme**	“Spoofing DNS Records by Abusing DHCP DNS Dynamic Updates” (DDSpoof); Black Hat Europe 2023 talk;	7 December 2023; 20 March 2024	Current research; Microsoft stated no fix planned	1, 5, 6	Free; Akamai copyright (blog); Invoke-DHCPCheckup under Apache 2.0

#	Publisher / author	Document or tool	Date / version (as verified Oct 2026)	Status (Oct 2026)	Design areas	Access; licence / reuse
	ntal	"Abusing the DHCP Administrators Group…"; Invoke-DHCPCheckup / DDSpoof tools				

Scope summaries in brief. IETF (1–9) define protocol behavior: RFC 2131 the lease state machine and the client/server/relay model; RFC 2132 the option codes (3 router, 6 DNS servers, 15 domain name, 42 NTP servers, 51 lease time, 66/67 TFTP server/bootfile); RFC 3046 relay-inserted Option 82 for location-aware policy and spoofing defense; RFC 3118 an authentication option that is defined but practically unused; RFC 4701–4703 the DHCID record and the client FQDN option that govern who updates A/PTR records; RFC 9915 is now the DHCPv6 base specification. Microsoft (10–11) is the only authority for Windows implementation behavior. NIST (12–14) has **no DHCP-specific Special Publication**; SP 800-81r3 addresses dynamic-update misuse and recommends correlating DNS logs with DHCP lease data; SP 800-53 supplies control language; SP 800-189 is inter-domain routing context only. NSA/CISA (15–16) provide network-device hardening and AD-compromise guidance; the AD guide does not, in the September 2024 text, address DHCP directly. DISA (17–18) gives the only numeric DHCP requirement (logging content and retention) and switch-level snooping rules; there is **no standalone DISA "Windows DHCP Server" STIG**. CIS (19–20) contributes an asset-inventory safeguard that names DHCP logging; benchmarks harden the host OS but contain no located DHCP-role or DnsUpdateProxy recommendation. Akamai (21) is the principal public analysis of AD-specific DHCP attack paths; it is vendor research, not guidance from a standards or government body.

3. Design areas

3.1 Server placement and authorization design

Decision at stake. Where the DHCP Server role runs, how many servers exist, and how AD controls which servers may answer clients.

Realistic options. (a) Dedicated domain-member DHCP servers; (b) DHCP co-located on domain controllers; (c) DHCP co-located with DNS on non-DC infrastructure servers; (d) network-appliance or router DHCP outside AD's authorization model; (e) workgroup (non-domain) Windows DHCP.

What the authorities say. - **Microsoft** lists "DHCP server authorization" as a core feature that "allows you to authorize DHCP servers in Active Directory, preventing unauthorized servers

from providing IP addresses to clients." Authorization is stored in the forest configuration partition (CN=NetServices,CN=Services,CN=Configuration), so by default only Enterprise Admins can authorize, though the right can be delegated on that container. An unauthorized domain-member Windows DHCP server does not lease addresses; workgroup servers do not need authorization. Members of DHCP Administrators cannot authorize or unauthorize servers because their rights are local. - **Microsoft (Dynamic update page)** states that when installed on a domain controller, the DHCP Server service "inherits the security permissions of the domain controller", giving it authority to update or delete any record in a secure AD-integrated zone, and instructs that on a DC the DHCP server be configured with a dedicated user account's credentials so it does not inherit and possibly misuse DC privileges. - **Akamai (practitioner)** reports in its 20 March 2024 blog that Microsoft DHCP server "was observed running in 40% of the networks monitored by Akamai," and that "among the networks that we observed using Microsoft DHCP server, 57% have a DHCP server installed on a DC." Its research shows that when DHCP runs on a DC, members of DHCP Administrators can reach domain-admin privileges; its mitigation is to identify DHCP on DCs with Invoke-DHCPCheckup and "if possible, disable the DHCP server service on all DCs." - **NIST SP 800-81r3** (a DNS document) recommends dedicated DNS infrastructure but describes combining DNS with closely related services such as DHCP as acceptable where full separation is impractical — this addresses DNS/DHCP co-location, not DC co-location. - **DISA/CIS:** no DHCP-placement rule was located; host hardening for any DHCP server comes from the applicable Windows Server STIG and CIS benchmark.

How many servers. Microsoft's failover model is strictly pairwise (a relationship is always between two servers, though one server may hold many relationships), which drives the common pattern of two servers per site or a regional pair plus hub standby. No US authority sets a numeric count; capacity, WAN topology and relay design decide it.

Trade-offs. DC co-location saves a server and was historically common in branches, but it couples a broadcast-facing, unauthenticated service to Tier 0 and enlarges the blast radius of DHCP Administrators membership. Dedicated servers cost licences and patching effort but keep DHCP compromise out of Tier 0. AD authorization only governs Windows DHCP servers; a rogue Linux box, router or VM ignores it.

Conflicts. Practice (57% on DCs per Akamai) diverges sharply from current Microsoft and Akamai guidance; Microsoft's own legacy step-by-step guides used a DC as a DHCP failover partner in examples, while current Microsoft text warns about DC co-location.

3.2 High-availability design

Decision at stake. How DHCP service survives a server or link failure without duplicate addressing.

Realistic options. (a) DHCP failover, load-balance mode; (b) DHCP failover, hot-standby mode; (c) split-scope (classically 80/20) across two independent servers; (d) Windows Failover Clustering of the DHCP role (shared storage); (e) single standalone server with backup/restore.

What the authorities say (Microsoft). - **Failover model:** Failover "replicates IP address leases and settings" for DHCPv4 scopes from a primary to a partner; both servers hold the whole scope and maintain separate synchronized lease databases — scopes are replicated, not

pre-split. Microsoft's implementation is based on the IETF DHCP Failover Protocol draft (draft-ietf-dhc-failover-12), not on a published RFC; load balancing uses the RFC 3074 MAC-hash bucket mechanism. Partners keep a persistent TCP connection on port 647. - **Minimum version:** The current Microsoft Learn failover overview (WS2016–WS2025 and Azure Local) states partners "must both be running at least Windows Server 2016." Legacy Microsoft pages for WS2012/2012 R2 say Windows Server 2012 or later, because the feature was introduced in Windows Server 2012. (Consistent once read as "introduced in 2012; currently documented support floor is 2016.") - **Modes:** Load balance is the default (50:50, adjustable 0–100%) and "best suited" to partners at the same site; hot standby (default 5% reserve for the standby) suits a central standby backing remote-site servers. Only one mode per relationship/scope; a server may hold relationships in both modes. - **MCLT and state switchover:** The Maximum Client Lead Time is the maximum time one server can extend a lease beyond what its partner knows; a partner that cannot reach its peer renews existing clients only for MCLT and takes over the full pool only after entering PARTNER DOWN and waiting MCLT. The state switchover interval (automatic transition from COMMUNICATION INTERRUPTED to PARTNER DOWN) is optional; without it an administrator must declare partner down manually. Microsoft cmdlet examples use MCLT of 2 hours and a 2-hour auto-switchover. - **Shared secret:** Optional message authentication between partners; when used with a clustered partner it must be manually replicated to every cluster node. - **Operational rules:** Changes to failover scopes must be manually replicated (replication overwrites the partner); replicate from the newer-OS partner; clocks must agree within one minute or the wizard halts; both partners must use the same DNS registration credential. - **Split-scope:** Microsoft retains split-scope as the HA answer for DHCPv6 (failover supports DHCPv4 only) and describes it as viable because DHCPv6 scopes rarely run at high utilization; the 80/20 split-scope wizard dates from Windows Server 2008 R2 SP1-era tooling. - **Clustering:** Supported and can be combined with failover (a cluster counts as one failover partner, addressed by cluster name/IP).

Trade-offs. Failover gives full-scope availability with lease-state sharing, but adds a replication discipline and a time-sync dependency (cross-reference the NTP design reference). Split-scope needs no inter-server protocol but strands addresses (the 20% server can exhaust) and has no shared lease state. Clustering protects against node failure but not storage or site failure and adds cluster complexity. A long MCLT reduces duplicate-address risk during partitions but delays full-pool takeover; a short one does the reverse.

Conflicts. None between authorities; the main documented "conflict" is the version floor (2012 vs 2016) across Microsoft's own legacy and current pages.

3.3 Scope and address-plan design

Decision at stake. How subnets map to scopes, which addresses are excluded or reserved, lease duration, option placement, and how to handle multinets and multicast.

Realistic options and Microsoft guidance. - **One scope per subnet/VLAN**, served via relay agents (ip helper) for remote subnets; exclusion ranges for statically addressed infrastructure; reservations (MAC/client-ID bound) for devices needing stable addresses while still receiving centrally managed options. - **Superscopes** group multiple scopes for a single physical segment carrying multiple logical subnets (multinet), or during renumbering. - **Multicast scopes (MADCAP)** allocate multicast group addresses to MADCAP-aware applications; rarely used in

modern enterprises. - **Option inheritance:** Server-level options apply to all scopes; scope options override server options; policy/class-based options override scope options for matching clients; reservation options are most specific and win. - **Lease duration:** Windows defaults to 8 days for new IPv4 scopes. Shorter leases suit high-churn segments (guest Wi-Fi, conference areas) and shrink stale-record windows but raise renew traffic and dependency on server availability; longer leases suit stable wired desktops and survive longer outages. In failover, renewals during a partition are capped at MCLT regardless of scope lease time. - **DISA:** V-251362 requires DHCP servers within SIPRNet infrastructure to use a minimum lease duration of 30 days, to support traceability — a classified-network-specific rule, not general guidance.

Trade-offs. Many small scopes improve segmentation and Option 82/policy precision but multiply administration; large flat scopes ease management but enlarge broadcast and spoofing domains. Short leases interact with DNS: the dynamic-update page notes DHCP-registered records use a 15-minute TTL by default and that stale A/PTR records require aging/scavenging (cross-reference the DNS design reference).

Conflicts. DISA's 30-day SIPRNet floor favors attribution; general Microsoft and practitioner guidance favors shorter leases for mobile segments. These are context-dependent, not contradictory.

3.4 DHCP options design

Decision at stake. Which configuration DHCP pushes, at what level, and to which client groups.

Core options (RFC 2132 numbering). 003 Router; 006 DNS Servers (internal AD-integrated resolvers for domain clients); 015 DNS Domain Name; 042 NTP Servers (cross-reference the NTP design reference — domain-joined Windows clients normally use the AD domain hierarchy, not option 42); 051 lease time; 066/067 Boot Server Host Name / Bootfile Name for PXE (with modern PXE/WDS/ConfigMgr designs often using IP helpers or policies keyed on vendor class instead of global 066/067); 252 WPAD (proxy auto-discovery; a site-local private-use code, not an IANA standard option); Option 81 client FQDN (RFC 4702) governs DNS registration (§3.5); Option 82 relay agent information (RFC 3046) carries circuit/remote IDs.

Policies and classes (Microsoft). DHCP policies (Windows Server 2012 and later) let administrators group clients by vendor class, user class, client identifier, MAC address, relay agent information or FQDN and assign IP ranges and options per group; failover replicates policies with scopes. User classes (client-set, e.g., via `ipconfig /setclassid`) and vendor classes (e.g., "MSFT 5.0", PXE client identifiers) remain the classic conditional-delivery mechanisms.

Trade-offs. Server-level options minimize duplication but propagate mistakes everywhere; policy-based options give precision at the cost of debugging complexity. Policies keyed on MAC or vendor class are spoofable by the client, so they are configuration conveniences, not security boundaries. Option 252/WPAD and 066/067 are attractive attack targets; Akamai's escalation research shows that whoever can change options (e.g., the DNS Servers option) can redirect or coerce clients and the server, so option-change rights are security-relevant.

Conflicts. None between authorities; the risk is under-appreciating that option authority equals traffic-steering authority.

3.5 DHCP–DNS dynamic update integration design

Decision at stake. Who registers and owns A and PTR records for DHCP clients, with what credential, and how ownership is protected.

Realistic options. (1) Client registers A, server registers PTR (Windows default, Option 81 flag 0). (2) Server always registers A and PTR ("Always dynamically update DNS records", flag 3), including for non-Windows/legacy clients. (3) Server registers using its machine account (default when no credential configured). (4) Server registers using a dedicated DNS-registration user credential (DHCP > IPv4 > Advanced > Credentials, or `Set-DhcpServerDnsCredential`). (5) DnsUpdateProxy membership (records created unsecured so another server or the client can later take ownership). (6) Name Protection (DHCID-based, introduced in Windows Server 2008 R2). (7) Disable DHCP-driven DNS updates entirely.

What the authorities say. - **Microsoft (Dynamic update):** Members of DnsUpdateProxy register names unsecured, so "the first user to modify the set of records associated with a DNS name becomes its owner"; Microsoft says not to use the group in secure-only AD-integrated zones "without taking additional steps." It recommends a dedicated standard user account whose credentials multiple DHCP servers can share, and states it must be used when DHCP runs on a DC. It warns that if the credential belongs to a DnsUpdateProxy member, the next registrant becomes owner, and that the DNS credential is not backed up with the DHCP database and must be re-entered after restore. It also advises `ipconfig /renew`, not `ipconfig /registerdns`, for DHCP-managed Windows clients, because the latter can reset ownership so the DHCP server can no longer update the record. - **Microsoft (Failover):** Both failover partners must use the same DNS credential or updates by the surviving partner fail. - **Microsoft (Name Protection):** With Name Protection, the server writes a DHCID record and checks it before updating, preventing name squatting by other clients; settings for "discard A and PTR records when lease is deleted" and "dynamically update for clients that do not request updates" sit on the same DNS tab. - **IETF RFC 4701/4703:** Define the DHCID RR and the conflict-resolution procedure that Name Protection implements. - **Akamai (practitioner, December 2023):** Demonstrated unauthenticated DNS spoofing via DHCP DNS dynamic updates in the default configuration, including overwriting arbitrary records when DHCP runs on a DC (ENTERPRISE DOMAIN CONTROLLERS has write permission on every record in the zone). Microsoft told Akamai a fix is not planned. Mitigations: disable DHCP DNS dynamic updates if not needed; do not use DnsUpdateProxy; use the same weak (non-privileged) DNS credential on all DHCP servers; enable Name Protection (not enabled by default on new scopes); avoid DHCP on DCs. Akamai also notes Name Protection can be partially bypassed (e.g., spoofed DHCP Release) and that the Windows DHCID value is brute-forceable — it raises cost, not certainty. - **NIST SP 800-81r3:** Treats dynamic-update misuse as a DNS threat, recommends restricting dynamic updates to authorized sources, and recommends correlating DNS query logs with DHCP lease history for incident response. - **CISA/NSA:** No DHCP-dynamic-update-specific guidance was located in the reviewed AD-compromise guide text (see Caveats).

Trade-offs. DnsUpdateProxy is convenient — any DHCP server or upgraded client can take over records — but leaves records unsecured. A dedicated credential gives clean ownership but

becomes a sensitive secret shared across servers and is lost on restore. Server-always-updates gives consistent records for non-Windows devices but means the DHCP server will register names asserted by unauthenticated clients. Disabling DHCP updates removes the attack path but leaves non-Windows devices unregistered.

Conflicts. Older community guidance (widely circulated, including Microsoft-hosted TechNet wiki/forum posts) recommends both DnsUpdateProxy membership and credentials; current Microsoft Learn and Akamai recommend credentials without DnsUpdateProxy.

3.6 Security and hardening design

Decision at stake. How to prevent rogue servers, spoofed clients, and privilege escalation through DHCP administration.

Controls and authorities. - **AD authorization as anti-rogue control (Microsoft):** Only stops rogue *Windows domain-member* DHCP servers; it is not a network control. - **DHCP Administrators vs DHCP Users (Microsoft):** DHCP Users have read-only console access; DHCP Administrators can change any DHCP setting, including export/import of configuration and database, but only on the local server and cannot authorize servers. Groups are created at role install (or with `Add-DhcpServerSecurityGroup` / `netsh dhcp add securitygroups`); on a DC they are domain-local groups. - **DHCP Administrators → Domain Admins (Akamai, March 2024):** DHCP Administrators can abuse legitimate features (option configuration, DNS Server option plus a coercion scope, relay-agent option) to coerce the DHCP server's machine account into authenticating to an attacker and relay it (e.g., Kerberos relay to AD CS web enrollment). On a DC this yields domain compromise; the same configuration can serve as stealthy persistence that requires no credentials once set up. Mitigations: treat DHCP Administrators as a high-value group and monitor it; disable DHCP on DCs; harden AD CS against relay (EPA/HTTPS, disable NTLM where possible); block RPC to DHCP servers from non-admin endpoints; block DHCP traffic to/from the internet; watch for DNS anomalies. - **Layer-2 controls (NSA Network Infrastructure Security Guide; DISA switch STIGs):** DHCP snooping (trusted uplink ports only; rate-limit on access ports), Dynamic ARP Inspection validated against the snooping binding table, IP Source Guard, port security, and 802.1X/NAC. DISA's Cisco L2 switch STIG requires DHCP snooping on all user VLANs to validate DHCP messages from untrusted sources. These are switch features, not DHCP-server features. - **Hypervisor controls (Microsoft):** Hyper-V DHCP Guard drops DHCP server messages from VMs not authorized to act as DHCP servers; Router Guard drops router advertisements and redirects. Both are off by default because of a small performance cost. - **Option 82 / SAVI context (IETF):** RFC 3046 lets relays tag requests with circuit IDs for policy and anti-spoofing; RFC 7513/7039 frame source-address validation that DHCP snooping/IP Source Guard implement; NIST SP 800-189 applies the same source-address-validation principle at inter-domain layer 3. - **MAC filtering (Microsoft allow/deny lists):** Useful hygiene, weak security, because MACs are trivially spoofed. - **RFC 3118 authentication:** Defined but essentially unimplemented in mainstream clients and servers, including Windows; RFC 9915 retains only Reconfigure-key authentication for DHCPv6. Message authentication is therefore not a practical design control. - **NIST SP 800-53 Rev. 5:** CM-6 (configuration settings) and CM-7 (least functionality — disable unneeded roles such as DHCP on DCs), AC-6 (least privilege for DHCP Administrators), SC-7 (boundary protection — block DHCP/RPC exposure), SI-4

(monitoring). - **CIS Controls v8.1:** Network-infrastructure and access-control safeguards (e.g., 12.x secure network infrastructure; 13.9 port-level access control) support snooping/802.1X.

Trade-offs. Snooping/DAI/IPSG are the most effective controls but require consistent switch configuration, static-binding exceptions for statically addressed hosts, and trusted-port discipline; misconfiguration causes outages. Tightening DHCP Administrators membership reduces escalation risk but may require new delegation workflows.

Conflicts. None in substance; the gap is that no US authority publishes a Windows-DHCP-server hardening baseline, so the server side is covered by generic host baselines plus vendor research.

3.7 DHCPv6 and dual-stack design

Decision at stake. Whether hosts get IPv6 addresses via SLAAC, stateless DHCPv6 (options only) or stateful DHCPv6, and how rogue RAs and rogue DHCPv6 servers are blocked.

Options and authorities. - **IETF RFC 9915** is the current DHCPv6 base specification, obsoleting RFC 8415; it applies verified errata and obsoletes temporary-address assignment (IA_TA) and the Server Unicast option. DHCPv6 can operate "in place of or in addition to" SLAAC. Router Advertisement M (Managed) and O (Other configuration) flags signal stateful vs stateless DHCPv6 to hosts. - **Identity:** DHCPv6 identifies clients by DUID, not MAC; RFC 6939 lets relays supply the client link-layer address so MAC-based reservations, logging and correlation remain possible. - **Option differences:** DHCPv6 has no default-gateway option (gateways come from RAs); DNS servers and search lists are DHCPv6 options; option codes differ from DHCPv4. - **Microsoft:** Windows DHCP supports stateful and stateless DHCPv6 scopes, but **DHCP failover does not support DHCPv6**; Microsoft recommends identical option configuration on two servers for stateless HA and split-scope for stateful HA. Audit logs for IPv6 are written separately (DhcpV6SrvLog-.log). - **First-hop protection:** RFC 7610 DHCPv6-Shield blocks DHCPv6 server messages on untrusted switch ports; RA Guard blocks rogue RAs; Hyper-V Router Guard drops ICMPv6 type 134 RAs from VMs.

Trade-offs. SLAAC is simplest but weakens address-to-host attribution; stateful DHCPv6 improves attribution and DNS registration control but lacks Windows failover. Dual-stack doubles the rogue-server surface: an attacker answering DHCPv6 or sending RAs can capture DNS on IPv4-oriented networks, so IPv6 first-hop controls matter even where IPv6 is "not used."

Conflicts. None between authorities; the main currency risk is citing RFC 8415 instead of RFC 9915.

3.8 Logging, monitoring, and database design

Decision at stake. What DHCP evidence is kept, for how long, how capacity is monitored, and how the DHCP database is protected and migrated.

Microsoft behavior. - **Audit log:** Enabled by default on modern Windows Server; written to %SystemRoot%as DhcpSrvLog-.log (IPv4) and DhcpV6SrvLog-.log (IPv6); each weekday's file is overwritten the following week, so native retention is about seven days. Configure with `Get-/Set-DhcpServerAuditLog` (path, MaxMBFileSize, DiskCheckInterval,

MinMBDiskSpace); logging pauses when disk space falls below the minimum. Event channels (DHCP-Server operational/admin, failover events) supplement text logs. - **Conflict detection:** Server-side ping before offering (attempts 0–5, default 0), useful when importing scopes or after failures, at a small latency cost. - **Database:** ESE/JET database (dhcp.mdb) with automatic backups (default every 60 minutes to the dhcpfolder); `Backup-DhcpServer/Restore-DhcpServer` for database backups; `Export-DhcpServer/Import-DhcpServer` (XML, optionally with leases) for migration and consolidation; `netsh dhcp server export/import` remains for legacy. DNS registration credentials are not included in backups. - **Monitoring:** Scope statistics (`Get-DhcpServerv4ScopeStatistics`), failover state events, and performance counters support utilization alerting.

Authority requirements. - **DISA Network Infrastructure Policy STIG V10R7 (2 Aug 2024), V-251361 (NET0198, SV-251361r853649_rule, CAT II/medium, CCI-001902):** DHCP audit and event logs must record hostname and MAC address in addition to IP and date/time; the fix text reads "Store the logs for a minimum of thirty days online and then offline for one year." (The same STIG's V-251374 imposes the same retention on syslog.) - **NIST SP 800-53 AU-8:** Time stamps mapped to UTC from an authoritative source — directly relevant because failover also requires partner clocks within one minute; AU-11 audit retention; AU-6 review. - **NIST SP 800-81r3:** Correlate DNS logs with DHCP lease history in the SIEM. - **CIS Controls v8.1 Safeguard 1.4:** "Use DHCP logging on all DHCP servers or Internet Protocol (IP) address management tools to update the enterprise's asset inventory," reviewing logs "weekly, or more frequently"; Control 8 covers collecting, centralizing and retaining audit logs.

Trade-offs. Forwarding audit logs to a SIEM satisfies retention and correlation but adds pipeline dependencies; relying on local files violates DISA retention by design. Larger MaxMBFileSize avoids silent pauses but consumes disk. Export-based migration is fast but must be followed by credential re-entry and failover re-establishment.

Conflicts. None; Windows defaults simply fall far short of the DISA requirement.

4. Where authorities agree, differ, or conflict

- **Failover vs split-scope.** Agreement: Microsoft positions failover as the default DHCPv4 HA mechanism and split-scope as the DHCPv6/legacy fallback. Difference: Microsoft's own pages state different version floors (2012 legacy vs 2016 current). No government authority expresses a preference.
- **DHCP on a domain controller.** Strong agreement among Microsoft's current dynamic-update guidance and Akamai's research that DC co-location is risky; Akamai recommends disabling it outright; Microsoft prescribes a dedicated credential if it must occur. Conflict with practice: Akamai observed a DHCP server on a DC in 57% of the networks it saw using Microsoft DHCP. NIST SP 800-81r3 accepts DNS+DHCP co-location, which is a different question.
- **DnsUpdateProxy: convenience vs risk.** Microsoft documents the group's purpose (record takeover across servers/clients) and its risk (unsecured records); Akamai says not to use it. Older community and archived Microsoft-hosted guidance recommending "DnsUpdateProxy plus credentials" conflicts with current guidance.

- **Short vs long leases.** Context-driven: DISA mandates ≥30 days on SIPRNet for traceability; Microsoft defaults to 8 days; practitioner norms favor hours for guest/wireless. No authority sets a general enterprise value.
- **Is message-level DHCP authentication practical?** Effectively all sources agree it is not: RFC 3118 is defined but unused, Windows does not implement it, and RFC 9915 keeps only Reconfigure-key authentication. Security therefore shifts to layer 2 and to AD authorization.
- **No US-government DHCP standard.** NIST has no DHCP SP; DISA has no Windows DHCP STIG; CIS has no located DHCP/DnsUpdateProxy benchmark item. The security load is carried by switch controls (NSA guide, DISA switch STIGs), generic controls (SP 800-53, CIS Controls), one DISA logging rule, Microsoft documentation and Akamai research.
- **Disable DHCP DNS updates vs secure them.** Akamai favors disabling where not required; Microsoft documents secure use (credential plus Name Protection). Both are defensible; the choice depends on whether non-Windows devices need DHCP-registered names.

5. Caveats and items that could not be verified

- **CISA/NSA "Detecting and Mitigating Active Directory Compromises" DHCP content.** The September 2024 text reviewed (through Appendix B, about page 58) contains no DHCP, DnsUpdateProxy, dynamic-update or DHCP Administrators content; "coerce" appears only regarding the Print Spooler on DCs. The request's premise that this guide covers the DHCP-coerce escalation and DHCP DNS spoofing could not be confirmed; those attack paths are documented by Akamai, not by this guide. The guide is ASD-led and co-sealed by non-US agencies; it is included only for its CISA/NSA co-authorship. NSA lists a September 2026 update that could not be reviewed; it may or may not add DHCP content.
- **Akamai dates and figures.** The DDSpoof research is dated 7 December 2023 (confirmed). The DHCP Administrators escalation blog is dated **20 March 2024**, not February 2024. The 40% figure is "networks monitored by Akamai." The 57% figure's denominator is stated in Akamai's 20 March 2024 blog: "among the networks that we observed using Microsoft DHCP server, 57% have a DHCP server installed on a DC" — press restatements as 57% of all monitored networks are inaccurate.
- **NSA Network Infrastructure Security Guide wording.** Version 1.2 (October 2023) was confirmed, but the PDF could not be retrieved (bot-blocked), so its exact layer-2 recommendations (DHCP snooping, DAI, IP Source Guard) are not quoted here and should be checked against the document.
- **DISA currency.** The latest Network Infrastructure Policy STIG located is V10R7 (2 Aug 2024), from third-party mirrors; cyber.mil was not checked directly, so a newer release cannot be excluded. No Windows Server STIG rule specific to DHCP or DnsUpdateProxy membership was located.
- **CIS Benchmarks.** No DnsUpdateProxy or DHCP-role recommendation was located in CIS Windows Server benchmarks (2022 v4.0.0–v5.1.0; 2025 v1.0.0–v2.1.0); the only DHCP mention found is profile applicability. Full-text verification of current releases was not possible.

- **NIST SP 800-189 revision status**, Windows default values (8-day lease, 60-minute database backup, conflict-detection default 0) and the WS2016 “What’s New in DHCP” contents are stated from Microsoft/IETF/NIST documentation knowledge and were not all re-fetched for this edition; RFC 9915 (January 2026, STD 102) and CIS Controls v8.1 Safeguard 1.4 wording were verified.
- **Microsoft licence terms.** Microsoft Learn content is copyrighted under Microsoft’s terms of use; the open-source docs repositories carry CC BY 4.0 (text) and MIT (code), but reuse should follow the specific repository’s licence file.
- **Neutrality.** This reference is environment-agnostic; values such as MCLT, lease duration and failover mode must be set from local topology, client mix and compliance regime.

Part Two — Annotated US Source & Guideline Catalogs

Part One organized each topic by *design decision*. Part Two is the other half of the work: the **annotated catalogs of the underlying guidance** — the curated lists of official Microsoft documentation and US-government guidelines, each with its publication date and version, status (current / superseded / legacy), access and licensing, a short scope summary, and (per topic) consensus principles and a cross-authority crosswalk. These catalogs were built *before* the Part One design references and are the evidence base the design references draw on; included here so the full picture lives in one document.

Scope. Like Part One, these catalogs use US sources only: official Microsoft guidance, and US-government guidelines (NIST, CISA, OMB, NSA, DISA, and the US nonprofit CIS), together with the US-based IETF and ICANN for the protocols. Where a Five Eyes joint product appears (for example "Detecting and Mitigating Active Directory Compromises" or "Best Practices for Event Logging and Threat Detection"), it is included only because CISA and/or NSA co-authored and co-sealed it, and its joint authorship is noted in place — consistent with how Part One treats the same documents.

A few notes on these catalogs as originally authored: - **Titles vary slightly** ("US Reference Collection…" vs "US-Only … Reference Collection…"); they are kept as written. - **The DNS catalog** here was scoped down to US sources from a broader multi-country collection, because the standalone US-only DNS source document could not be reached from this session to merge in; its scope note records this. The other five are the US-only collections as authored. - **Verification varied**, and each catalog's own "Caveats" section is authoritative for what was and wasn't confirmed in it — most often DISA STIG release numbers read from third-party mirrors, and a few unverified CIS/NIST versions.

The six catalogs, in the same order as Part One (with DISA STIGs & GPO Packages, which is cross-cutting, last):

- Active Directory Design, OU Structure, and Tiered Administration
- DNS Security and Deployment
- NTP and Time Synchronization
- Certificate Authority (Microsoft AD CS / Windows PKI)
- DHCP (Windows / Enterprise)
- DISA STIGs and DISA STIG GPO Packages

US-Only Reference Collection: Active Directory Design, OU Structure, and Tiered Administration (as of October 2026)

The US guidance baseline treats Active Directory administration the same way across all authorities checked: Microsoft's current tier model, Microsoft's tooling, DISA STIGs, CIS, and the CISA/NSA joint guidance all require separating privileged identities by tier. That means dedicated admin accounts, privileged access workstations (PAWs), and rules that block higher-tier credentials from lower-tier systems. Only the separate "Red Forest" (ESAE) admin-forest architecture was retired, in December 2020. Tiering itself was not. NIST supplies the control language (AC-2, AC-5, AC-6(5), IA-2) without naming AD. DISA turns the model into mandatory, auditable rules. IETF RFCs supply only protocol background.

TL;DR

- **Microsoft's current baseline** is the Learn page "Tier model for Active Directory Domain Services" (ms.date 2026-05-21; last updated 2026-07-01).
  - It has three tiers. Tier 0 is the identity control plane: DCs, AD FS, AD CS, Entra Connect, and the systems and agents that manage them. Tier 1 is servers and applications. Tier 2 is end-user devices and help desk.
  - Each tier requires its own PAW.
  - It lists five anti-patterns.
  - It points to the MIT-licensed microsoft/ActiveDirectoryTierModel repo for deployment (latest release seen: v1.3.1).
  - ESAE/Red Forest was retired as the default recommendation, but Microsoft says PAWs, MFA for admins, and least-privilege tiering remain "good cyber hygiene."
- **US government guidance agrees in substance but differs in form.**
  - NIST SP 800-53 Rev. 5 (current catalog Release 5.2.0, August 27, 2025) gives framework-neutral controls.
  - The CISA/NSA joint "Detecting and Mitigating Active Directory Compromises" (September 2024, co-authored with five foreign agencies) catalogs 17 attack techniques plus mitigations.
  - DISA's Active Directory Domain STIG (Ver 3, Rel 8, in the October 6, 2026 quarterly release) and AD Forest STIG (V3R2) make tiering-related controls mandatory for DoD. Examples: CAT I rules restricting Enterprise/Domain Admins membership, and a CAT I rule requiring that AD CS be managed from a "PAW tier 0."
- **CIS adds hardening benchmarks and safeguards.**
  - The CIS Windows Server 2025 Benchmark v2.1.0 (September 2026) has Domain Controller profiles.
  - CIS Controls v8.1 Safeguard 5.4 requires dedicated admin accounts; 6.5 requires MFA for admin access.
  - IETF RFC 4120 (Kerberos) and RFC 4511 (LDAP) are protocol background only. AD-specific extensions such as the PAC are Microsoft Open Specifications, not IETF standards.

---

1. Guidance landscape overview

Publisher (US)	Key document(s)	Date / version	Status (Oct 2026)
Microsoft	Tier model for AD DS (Learn)	ms.date 2026-05-21; updated 2026-07-01	Current
Microsoft	microsoft/ ActiveDirectoryTier Model (GitHub, MIT)	v1.0.0 (May) → v1.3.1 (Aug 18; year not shown on releases page, believed 2026)	Current, actively released
Microsoft	Enterprise Access Model (Learn)	Maintained page	Current
Microsoft	ESAE mainstream retirement (Learn)	ms.date 2023-02-14; last updated 2024-01-29; retirement announced Dec 2020	Current (documents a legacy architecture)
Microsoft	Best Practices for Securing Active Directory + Appendices B–I	Maintained Learn pages (content originated 2013–2014)	Current but older-origin; partly superseded by tier-model page
Microsoft	AD DS design guides (OU design, delegation)	Learn pages derived from Windows Server 2003/2008 deployment guides	Maintained; legacy in origin
Microsoft	Protected Users; Authentication Policies & Silos; dMSA overview; service accounts	Learn pages	Current
Microsoft	KB5014754 (strong certificate mapping)	Revised 9/10/2025	Current; enforcement completed
Microsoft (MSRC)	CVE-2025-53779 “BadSuccessor”	August 12, 2025 Patch Tuesday	Patched
NIST	SP 800-53 Rev. 5	Release 5.2.0, Aug 27, 2025	Current
NIST	SP 800-63B-4, “Digital Identity Guidelines: Authentication and Authenticator Management”	July 31, 2025 (DOI 10.6028/NIST.SP.800-63b-4)	Current; supersedes SP 800-63B
NIST	SP 800-207 Zero Trust Architecture	August 2020	Current
CISA / NSA (+ foreign co-authors)	Detecting and Mitigating Active	September 2024 (US-hosted PDF)	Current; a co-author site lists an August

Publisher (US)	Key document(s)	Date / version	Status (Oct 2026)
	Directory Compromises		2026 revision, not verified on a US host
CISA / NSA	Top Ten Cybersecurity Misconfigurations (AA23-278A)	October 2023	Current (advisory)
DISA	Active Directory Domain STIG	Ver 3, Rel 8 (October 6, 2026 quarterly release)	Current
DISA	Active Directory Forest STIG	Ver 3, Rel 2 (released July 2, 2025)	Current
DISA	Windows Server 2022 STIG; Windows Server 2025 STIG; Windows PAW STIG	WS2022 V2R10 (Aug 10, 2026); WS2025 V1R3 (Aug 10, 2026), possibly V1R4 now; PAW STIG V3R2	Current
CIS	CIS Microsoft Windows Server 2025 Benchmark	v2.1.0 (Sept 2026); v2.0.0 dated Feb 24, 2026	Current
CIS	CIS Controls	v8.1 (v8.1.2 guide, March 2025)	Current
IETF	RFC 4120 (Kerberos V5); RFC 3961/3962 (Kerberos crypto); RFC 4511 (LDAP); RFC 5929 (TLS channel bindings)	2005; 2005; 2006; 2010	Current standards (background)
SpecterOps (practitioner, non-governmental, US company)	Certified Pre-Owned; BloodHound Tier Zero table	2021; maintained table	Practitioner reference

2. Section A — Official Microsoft guidance

A1. AD DS design and planning (forest, domain, OU design)

Creating an Organizational Unit Design - **Publisher / URL:** Microsoft Learn, https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/creating-an-organizational-unit-design - **Status:** Maintained Learn page whose content descends from the Windows Server 2003 deployment kit. It still points to a 2003 “Job Aids” worksheet, so treat it as legacy in origin but still published. - **Access:** Free. - **Licence:** Microsoft copyright under Learn Terms of Use. The public MicrosoftDocs GitHub source repos generally publish docs under CC

BY 4.0 and code under MIT; check the specific repo's LICENSE before reuse. - **Scope:** Who designs OUs and what kinds of OUs to create. - **Key points:** - Forest owners are responsible for OU designs in their domains. The design covers OU structure, assigning the OU owner role, and creating account and resource OUs. - The structure should first be designed to "enable delegation of administration." Additional OU structures for Group Policy application and for limiting object visibility come afterward. - Account OUs contain user, group, and computer objects. Resource OUs contain resources and the accounts that manage them. - The OU design should be documented.

Reviewing OU Design Concepts / Designing OUs for Delegation of Administration / Delegating Administration of Account and Resource OUs - **Publisher:** Microsoft Learn (previous-versions library: Windows Server 2003/2008 R2). - **Status:** Legacy/archived but still the most detailed Microsoft OU-design text. - **Key points:** - The OU hierarchy "does not need to reflect the departmental hierarchy." - OUs exist for delegation of administration, Group Policy application, or limiting object visibility. - OUs are administrative boundaries. - Owners of resource OUs may not create OUs. - Placing a computer account in a resource OU gives control over the object, not administrator rights on the computer.

Forest and domain design. Microsoft's AD DS design guide (the same Learn "plan" section) covers forest models (organizational, resource, restricted-access), single- vs. multi-domain models, and the forest as the security boundary. These were not individually re-fetched for this collection (see Caveats). DISA's AD Domain STIG separately sets rules for trusts, for example documenting every trust and enabling Selective Authentication on outbound forest trusts.

A2. Delegation of administration

- **What Microsoft says:** Delegation is done by granting permissions on OUs, typically with the Delegation of Control Wizard in Active Directory Users and Computers, to groups rather than individuals.
- **The constraint:** The AdminSDHolder/SDProp mechanism (A7) overrides delegated permissions on protected accounts and groups. Delegated OU permissions therefore do not reach Tier 0 principals.
- **The tier-model page:** It adds that delegated rights must stay inside a tier, and that "Tier 1 migration" is "not just moving objects between OUs."
- **Repo implementation:** The microsoft/ActiveDirectoryTierModel repo implements delegation as code (A4).

A3. The tier model (current Microsoft page)

Tier model for Active Directory Domain Services - **URL:** https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/tier-model - **Author / date:** robinharwood (Microsoft); ms.date 2026-05-21; last updated 2026-07-01. - **Applies to:** Windows Server 2016–2025. Page metadata marks it "ai-assisted." - **Status:** Current. Free. - **Scope and lineage:** The model separates identities, workstations, and assets into trust tiers based on identity privilege rather than network segmentation. Microsoft calls the two "complementary." The page cites the Biba integrity model and the Mitigating Pass-the-Hash white papers (v1/v2) as lineage. It places the tier model as a component of the Enterprise Access Model.

Tier contents:

Tier	Scope	Examples (per Microsoft)	Required PAW
Tier 0	Identity control plane	DCs and core directory components; AD FS; AD CS; Entra Connect; Entra application proxy; Tier 0 admin accounts and groups, including built-in Backup Operators and Server Operators; systems that operate or manage Tier 0 (backup, monitoring, patching, hypervisor, antivirus, EDR, or “any agent with direct operating system-level or AD-object-level control”)	Tier 0 PAW
Tier 1	Enterprise servers and applications	Member servers, Exchange, SharePoint, SQL Server, LOB apps, IT management tooling for Tier 1, server admin accounts	Tier 1 PAW
Tier 2	End-user devices and accounts	Workstations, help desk, device support, end-user account admin roles	Tier 2 PAW

Design principles: - Least privilege within each tier. - No shared credentials across tiers. - No line-of-business (LOB) workloads in Tier 0. - Separation of duties among operators, approvers, and auditors. - Containment, not perimeter, is the boundary: “The credential and the keyboard define the tier, not the IP address.”

Listed anti-patterns: 1. Collapsing everything into Tier 0. 2. Daily work with Domain Admins. 3. Monitoring, backup, or EDR agents with Domain Admins rights. 4. Shared service accounts across tiers. 5. Treating jump servers as a separate tier. A jump server used to reach DCs is a Tier 0 asset.

PAW requirement: - The model "only works" when sessions start from a PAW matching the target tier. - PAWs must be hardened and dedicated to admin work, with no email or web browsing, verified supply-chain provenance, and physical security. - For cloud management, Microsoft names a "PAWCSM." - The "reach-back model" and six supported access paths (physical PAW, jump server, vault, cloud PAW to virtual PAW) all keep any intermediary in the same tier as the target.

Keeping Tier 0 small: - A "common target" is fewer than five humans with Domain Admins-equivalent access. - No Domain Admins service accounts.

Adoption steps: 1. Scope and sponsorship. 2. Inventory and classify. 3. Operating model. 4. Implement OUs, groups, GPOs, and restrictions. 5. Phased pilot (Tier 0 → 1 → 2). 6. Continuous validation and drift detection.

Post-deployment hardening includes Security Hardening Framework (SHF) baselines, legacy GPO cleanup, PAW deployment, and DC OS hardening.

A4. microsoft/ActiveDirectoryTierModel (GitHub)

- **URL:** https://github.com/microsoft/ActiveDirectoryTierModel
- **Docs site:** microsoft.github.io/ActiveDirectoryTierModel
- **Licence:** MIT. The README's "License: MIT" was confirmed via a fork's metadata; confirm against the LICENSE file before redistribution.
- **Releases:** v1.0.0 (May 6) through v1.3.1 (August 18, marked "Latest"). The releases page did not show the year; the context suggests 2026.
- **What it is:** A "declarative PowerShell framework to deploy and audit an Active Directory Tier Model" from one version-controlled JSON configuration file.
- **What it creates and audits:** OUs, groups, users, ACL delegations, GPOs, ADMX templates, MSA/gMSA/dMSA permissions, and Windows LAPS permissions.
- **Features:**
  - WhatIf planning and idempotent re-runs.
  - Drift detection with hash provenance.
  - Pester tests.
  - Entry scripts Deploy-TierModel.ps1 and Audit-TierModel.ps1.
  - An optional Microsoft Sentinel monitoring solution (KQL analytics rules and a workbook) maintained in the Azure/Azure-Sentinel repo.
- **Note:** The Learn tier-model page links to this repo as the deployment reference. Microsoft's warning applies here: enforcement GPOs linked in the wrong order can lock administrators out, so test outside production.

A5. Enterprise Access Model (EAM)

- **URL:** https://learn.microsoft.com/en-us/security/privileged-access-workstations/privileged-access-access-model
- **Status:** Current; free.
- **Planes:**
  - **Control plane:** centralized identity and access control, supplemented by network access control for older systems such as OT.

  - **Management plane:** enterprise-wide IT management.
  - **Data/workload plane:** per-workload management, where business value lives.
- **Mapping from legacy tiers:**
  - Tier 0 "expands to become the control plane" and covers all aspects of access control, including networking where it is the only access control option.
  - Tier 1 splits into the management plane and the data/workload plane.
  - Tier 2 becomes user access and app access.
- **Related current pages:**
  - "Design an enterprise access architecture" (Zero Trust adoption guidance) restates the mapping.
  - The Entra "privileged roles and permissions" page says privileged intermediaries (PAM, jump hosts, automation runbooks) are control-plane (Tier 0) assets.
- **Relationship to the tier model:** The AD DS tier model remains the AD-specific implementation within the EAM.

A6. ESAE / Red Forest retirement

- **URL:** https://learn.microsoft.com/en-us/security/privileged-access-workstations/esae-retirement
- **Dates:** ms.date 2023-02-14; last updated 2024-01-29. The retirement was announced in December 2020, alongside the December 15, 2020 republication of the privileged-access guidance.
- **What was retired:** ESAE, "often referred to as red forest, admin forest, or hardened forest." This is a dedicated hardened administrative forest for AD admin identities. It is no longer the default recommendation and is now "a custom configuration suitable only for exception cases." The replacement is the modern privileged access strategy and RaMP, toward Zero Trust.
- **Why:**
  - ESAE was designed more than 10 years earlier for on-premises AD.
  - It relies on macro-segmentation and does not adequately cover hybrid or cloud environments.
  - It protects only on-premises AD admins.
  - Cloud-based solutions deploy faster, cover more roles, and are less complex and costly.
- **Continued-use cases:**
  - Isolated or disconnected environments such as critical infrastructure or OT, though "air-gapped ICS/SCADA segments … don't typically utilize their own Active Directory."
  - Microsoft itself still runs a similar architecture internally.
  - Existing ESAE deployments: "no urgency to retire" if operated as designed.
- **What remains good hygiene:**
  - PAWs for all admin activity.
  - Token-based or MFA authentication for admin credentials.
  - Least-privilege administration with regular membership review.

- **On-premises AD best practices listed:**
  - A tiered least-privilege model, time-based privileged roles, and full auditing of privileged identities.
  - PAW hygiene: don't administer a PAW from a less-trusted host, use MFA, maintain physical security, run a supported OS.
  - Eliminating password reuse.
  - Reducing applications on DCs.
  - Immutable AD backups.
  - An annual AD security assessment.
  - Microsoft Defender for Identity as a supplement.

A7. Securing privileged access, RaMP, PAWs, intermediaries

- **Pages:** Privileged access strategy, the Security Rapid Modernization Plan (RaMP), privileged access devices/PAW overview, and intermediaries, all in the "privileged-access-workstations" Learn section linked from the ESAE page.
- **What they cover:**
  - RaMP is the prioritized rollout plan that replaced ESAE as the default approach.
  - The device pages define security levels for enterprise, specialized, and privileged devices.
  - The intermediaries guidance treats VPNs, jump servers, and PAM/PIM systems as part of the privileged path that must be secured at the level of what they reach.
- **Verification:** These pages are named and linked from verified pages but were not individually fetched (see Caveats).

A8. Credential protection features

Protected Users security group - **URL:** https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/protected-users-security-group - **Restrictions on members:** - No NTLM, Digest, or CredSSP default credential delegation. - Kerberos with AES only; no DES or RC4. - No delegation. - Kerberos TGT lifetime hard-set to 240 minutes (4 hours). - **Warnings:** - Never add service or computer accounts; authentication will fail. - Restrictions cannot be bypassed even for highly privileged users. - **Exception:** The built-in domain Administrator (RID 500) is always exempt from authentication policies.

Authentication Policies and Authentication Policy Silos - **URLs:** - https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/authentication-policies-and-authentication-policy-silos - https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/how-to-configure-protected-accounts - **Requirements:** Windows Server 2012 R2 domain functional level or higher. - **What they do:** - Policies set TGT lifetime and access-control conditions restricting which hosts an account can sign in from. - They apply to user, computer, and service accounts. - Silos (objectClass msDS-AuthNPolicySilos) group accounts and restrict a group of admins to a defined set of hosts, which enforces tier isolation at the KDC. - They "complement" Protected Users.

Windows LAPS - Microsoft's current local administrator password solution is built into Windows and Windows Server. - It can store passwords in AD (encrypted) or Entra ID. - It is the recommended way to avoid shared local admin passwords across tiers. - The tier-model repo configures Windows LAPS permissions per tier. - The Learn pages were not re-fetched for this collection (see Caveats).

Service accounts: sMSA, gMSA, dMSA - **URLs:** - https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/understand-service-accounts - …/delegated-managed-service-accounts/delegated-managed-service-accounts-overview - **gMSA:** Windows generates and rotates the password; usable across multiple servers. - **dMSA:** New in Windows Server 2025. - It migrates a traditional service account to a machine-bound account with "managed and fully randomized keys" and disables the original account's password. - Authentication is tied to device identity. - Microsoft says it helps prevent Kerberoasting. - It requires a Windows Server 2025 DC and a KDS root key. - You can't migrate from an MSA or gMSA to a dMSA. - **Tiering rule:** Per the tier model, a service account must live in one tier only.

AdminSDHolder and protected groups (Appendix C) - **URL:** https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/appendix-c–protected-accounts-and-groups-in-active-directory - **How it works:** - AdminSDHolder, in the System container of every domain, provides "template" permissions. - SDProp periodically resets the ACLs of protected accounts and groups to match it. - Inheritance is disabled on protected objects. - AdminSDHolder is owned by Domain Admins. - **Related appendices:** - Appendix I explains granting designated management accounts membership-management rights via AdminSDHolder. - The "Active Directory security groups" page lists which built-in groups are protected (e.g., Account Operators: "Protected by AdminSDHolder? Yes") and which are not safe to delegate. - DISA's Protected Users rule (V-243477) applies to the same group set.

A9. "Deny log on" user rights for tier isolation

- **Microsoft's approach:** Tier isolation is implemented with GPO User Rights Assignment. Higher-tier admin groups are added to "Deny access to this computer from the network," "Deny log on locally," "Deny log on as a batch job," "Deny log on as a service," and "Deny log on through Remote Desktop Services" on lower-tier computers.
- **Where this appears:** The tier-model page names "access restrictions" via group policies as step 4 of adoption; the repo ships these GPOs.
- **DISA and CIS:** Both prescribe concrete Deny-right memberships (Section B).
- **Caution:** Microsoft warns that misordered GPO links can lock out domain admins everywhere, including on DCs.

A10. Best Practices for Securing Active Directory and appendices

- **URL:** https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory
- **Status:** Still maintained and linked from the tier-model page as related content. The content originated in 2013–2014, so some tooling references are dated.
- **Contents:**

  - Reducing the AD attack surface, including privileged groups and AdminSDHolder ownership.
  - Monitoring for signs of compromise.
  - Planning for compromise.
- **Appendices:**
  - B: privileged accounts and groups.
  - C: protected accounts and groups.
  - D: securing built-in Administrator.
  - E: securing Enterprise Admins.
  - F: securing Domain Admins.
  - G: securing Administrators.
  - H: local Administrator accounts.
  - I: management accounts for protected groups.
- **Key prescriptions:** Keep EA/DA groups empty or minimal except during build or recovery. Use GPOs to deny privileged groups logon to member servers and workstations.

A11. Microsoft Security Baselines (Security Compliance Toolkit)

- **What it is:** The Security Compliance Toolkit (SCT) publishes Microsoft-recommended GPO baselines per Windows/Windows Server release, including a Domain Controller baseline and a Member Server baseline, plus tools such as Policy Analyzer and LGPO.
- **Access:** Free download from the Microsoft Download Center.
- **Relevance to tiering:** The baselines harden DCs but do not implement tier-specific Deny-logon assignments, which depend on the environment. The tier-model page lists baseline hardening (SHF baselines) as a post-deployment activity.
- **Verification:** The Windows Server 2025 baseline version and date were not verified in this collection (see Caveats).

A12. Microsoft Defender for Identity (MDI)

- **Type:** Paid, cloud-connected service, licensed as part of Microsoft 365 E5/Defender suites.
- **What it does:** Uses on-premises AD and Entra ID signals to detect identity threats and to visualize lateral-movement paths.
- **Microsoft's positioning:** The ESAE page lists it as a supplemental capability and notes it "does require a cloud-based connection."

A13. CVEs and advisories

CVE-2025-53779 "BadSuccessor" - **Classification:** Windows Kerberos elevation of privilege; CVSS 7.2; CWE-23 relative path traversal. - **Timeline:** Disclosed by Akamai researcher Yuval Gordon on May 21, 2025; patched August 12, 2025 (Patch Tuesday). - **What it abused:** The Windows Server 2025 dMSA feature. A principal with rights to create or modify a dMSA could set msDS-ManagedAccountPrecededByLink and inherit a high-privilege account's privileges. - **Prerequisite:** At least one Windows Server 2025 DC. - **Lesson for OU delegation:** Broad "create child object" rights on OUs became a Tier 0 path. - **After the patch:** In the Akamai blog

“BadSuccessor Is Dead, Long Live BadSuccessor(?)”, Yuval Gordon wrote that the patch was “effective in mitigating a significant part of the risk … the technique lives on and remains relevant in certain scenarios.” - **Sources:** The Akamai research is the primary source. Help Net Security (Aug 13, 2025) quotes Tenable’s Satnam Narang that “only 0.7% of AD domains had met the prerequisite at the time of disclosure.” The MSRC entry is https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-53779.

KB5014754: certificate-based authentication on DCs (strong certificate mapping) - **Origin:** May 10, 2022 update (CVE-2022-26923/34691/34692) changed KDC certificate validation. - **Timeline:** - Full Enforcement became the default with the February 11, 2025 update; rollback to Compatibility was allowed until September 2025. - The KB was revised 9/10/2025, correcting the date to September 9, 2025. - In Full Enforcement, certificates that cannot be strongly mapped are denied. - **Relevance:** This matters for AD CS–based authentication abuse such as ESC-style attacks, which CISA/NSA and DISA both treat as Tier 0.

Other relevant Microsoft advisories - ADV190023 (LDAP channel binding and LDAP signing). - CIS and DISA now include DC settings for “LDAP server channel binding token requirements” and “LDAP server signing requirements Enforcement” (CIS WS2025 benchmark sections 2.3.5.3–2.3.5.4).

A14. Windows Server 2025 AD DS changes relevant to tiering

- **dMSA:** See above. Note the BadSuccessor lesson that dMSA creation rights must be treated as privileged.
- **DISA Windows Server 2025 STIG:** Exists (V1R3, released August 10, 2026). Its DC Deny-logon rules are V-278168, V-278171, and V-278174.
- **CIS:** Publishes WS2025 DC profiles.
- Other Windows Server 2025 AD changes (e.g., new functional level, LDAP and Kerberos defaults) were not verified here.

A15. Practitioner (non-governmental, US-origin) material, labeled as such

- **SpecterOps, “Certified Pre-Owned” (2021, Schroeder and Christensen):** The AD CS abuse taxonomy (ESC1…). This is the basis for treating AD CS as Tier 0.
- **SpecterOps BloodHound “Tier Zero” table:** A public, maintained list of AD and Entra assets considered Tier Zero.
- **Status:** Neither is government or standards guidance. Both are widely cited, including by the CISA/NSA joint document’s AD CS section.

---

3. Section B — US government and standards guidance

B1. NIST

SP 800-53 Rev. 5, Security and Privacy Controls - **URL:** csrc.nist.gov (CPRT). - **Version:** Release 5.2.0, August 27, 2025, adding software-update and integrity controls. Earlier patch 5.1.1 (November 2023) added IA-13. - **Status:** Current. - **Access and licence:** Free; US government work, not subject to US copyright. - **Relevant controls (paraphrased):** - **AC-2 Account Management:** define account types, approvals, monitoring, and disabling. - **AC-5 Separation**

of Duties: divide duties to prevent malevolent activity without collusion. Maps to Microsoft's "operators, approvers, auditors." - **AC-6 Least Privilege:** - AC-6(1) authorize access to security functions. - AC-6(2) non-privileged accounts for nonsecurity functions. Maps to separate admin accounts. - AC-6(5) restrict privileged accounts to designated personnel. - AC-6(7) review privileges. - AC-6(9)/(10) log and prohibit privileged-function misuse. - **IA-2 Identification and Authentication (Organizational Users):** IA-2(1) MFA for privileged accounts. - **IA-5 Authenticator Management.** - **Limits:** NIST does not name AD, tiers, or PAWs. DISA STIG rules map back to these controls via CCIs (e.g., the AD Forest schema rule V-243506 maps to AC-6).

SP 800-63B (Digital Identity Guidelines: Authentication) - NIST SP 800-63B-4, "Digital Identity Guidelines: Authentication and Authenticator Management" (author Justin Richer), was published July 31, 2025 (DOI 10.6028/NIST.SP.800-63b-4). Its CSRC page says it "defines technical requirements for each of the three authenticator assurance levels" and "supersedes NIST Special Publication (SP) 800-63B." - It defines authenticator assurance levels (AAL1–3) and phishing-resistant authenticators. - It is not AD-specific. It is relevant to choosing MFA strength for administrative access, which CISA/NSA and CIS 6.5 require.

SP 800-207 Zero Trust Architecture (August 2020) - Treats identity and per-request policy decisions as core, with no implicit trust based on network location. - Consistent with Microsoft's "credential and keyboard, not the IP address" principle. 800-207 does not prescribe AD tiering.

NIST and privileged access management (PAM): No dedicated NIST SP on AD PAM was identified. The NCCoE's draft SP 1800-18, "Privileged Account Management for the Financial Services Sector" (initial public draft September 28, 2018; author Devin Wynne, MITRE), is now listed on CSRC as "Withdrawn," with the planning note "NIST has ceased further development of this draft publication" (07/22/2022).

B2. CISA / NSA

Detecting and Mitigating Active Directory Compromises - **Authors:** ASD's ACSC (lead), CISA, NSA, CCCS, NCSC-NZ, NCSC-UK. Treated here as a US (CISA/NSA) source with joint authorship noted. - **URLs:** - US-hosted PDF: https://media.defense.gov/2024/Sep/25/2003553985/-1/-1/0/CTR-DETECTING-AND-MITIGATING-AD-COMPROMISES.PDF - CISA alert of September 26, 2024: https://www.cisa.gov/news-events/alerts/2024/09/26/asds-acsc-cisa-and-us-and-international-partners-release-guidance-detecting-and-mitigating-active - NSA announcement: October 1, 2024. - **Status:** "First published: September 2024." A co-author's (non-US) site lists an August 2026 revision; no US-hosted revision was verified. - **Access and licence:** Free; TLP:CLEAR. US agency content is US government work, but the multi-national co-authorship means foreign Crown copyright may apply to portions, so verify before verbatim reuse. - **Scope:** 17 techniques against AD DS, AD FS, and AD CS, each with an explanation, mitigations, and detection (Windows event IDs): 1. Kerberoasting 2. AS-REP roasting 3. Password spraying 4. MachineAccountQuota compromise 5. Unconstrained delegation 6. GPP password compromise 7. AD CS compromise 8. Golden Certificate 9. DCSync 10. Dumping ntds.dit 11. Golden Ticket 12. Silver Ticket 13. Golden SAML 14. Microsoft Entra Connect compromise 15. One-way domain trust bypass 16. SID History compromise 17. Skeleton Key - **Key recommendations**

(paraphrased): - Limit privileged-account use and apply a tiered administrative model with PAWs. - Use gMSAs, AES-only Kerberos, and Protected Users. - Treat AD CS, AD FS, and Entra Connect servers as Tier 0. - Reset KRBTGT, and reset trust (TDO) passwords after a suspected compromise. - Use canary objects for detection. This is noted as effective against Kerberoasting, AS-REP roasting, and DCSync, because most compromises begin with enumeration tools such as SharpHound. - **Appendices:** Consolidated AD security controls (Appendix A) plus detection and event tables. - **Caveat:** The PDF body was not fully retrieved for this collection (bot-blocked). Technique list and themes are from the CISA, NSA, and press summaries plus known document structure.

CISA/NSA "Top Ten Cybersecurity Misconfigurations" (AA23-278A, October 2023) - Verified on CISA's AA23-278A page. The non-prioritized list of 10 puts "Improper separation of user/administrator privilege" second. - The page notes "Many of the assessments were of Microsoft® Windows® and Active Directory® environments" and recommends: "Reduce, restrict, audit, and monitor administrative accounts and privileges."

NSA "Defend Privileges and Accounts" (Top Ten Mitigation Strategies series): an older NSA fact sheet. Its current availability and status were not verified.

B3. DISA (DoD Cyber Exchange; public STIGs are unclassified and free to download)

Active Directory Domain STIG - **Current release:** Ver 3, Rel 8, listed in DISA's October 2026 Quarterly Release announcement (October 6, 2026). - **Prior releases:** V3R7 (February 11, 2026) and V3R5 (September 13, 2024) each had 36 rules: 5 CAT I, 27 CAT II, 4 CAT III. The V3R8 count and changes were not verified. - **Key rules (titles from V3R5/V3R7):** - **V-243466 (CAT I):** Enterprise Admins membership restricted to accounts used only to manage the forest. - **V-243467 (CAT I):** Domain Admins membership restricted to accounts used only to manage the domain and DCs. - **V-243468 / V-243469 (CAT II):** Separate admin accounts specifically for managing member servers and workstations. This is DISA's codification of Tier 1/Tier 2 account separation. - **V-243470 (CAT I):** Delegation of privileged accounts prohibited. - **V-243472:** Separate smart cards for EA/DA accounts. - **V-243473:** Separate accounts for public-facing servers. - **V-243475:** DCs blocked from internet access. - **V-243477 (CAT II):** Domain-level admin accounts must be members of Protected Users. This covers EA, DA, Schema Admins, Administrators, Account Operators, and Backup Operators; one account may be excluded for availability. - **Trust rules:** Documentation of trusts, Selective Authentication on outbound forest trusts, and SID filtering. - **V-269097 (added in V3R5):** Kerberos logging on DCs with AD CS. - **PAW rule:** "Only systems dedicated for the sole purpose of managing Active Directory must be used to manage Active Directory remotely" (legacy ID AD.MP.0001; current V-ID not verified). - **OU ACLs:** OU and Domain Controllers OU permission requirements appear in the Windows Server DC STIGs (e.g., WN12-AD-000004-DC / -000005-DC historically; WS2025 has "Active Directory Domain Controllers Organizational Unit (OU) object must have the proper access control permissions"). Current V-IDs were not verified.

Active Directory Forest STIG - **Release:** Ver 3, Rel 2 (released July 2, 2025; NCP lists a publication date of September 14, 2026 for the checklist entry, so dates conflict). - **Rules:** 7 in total, 3 CAT I. - V-243502: Schema Admins membership limited. - V-243503: anonymous access above rootDSE disabled. - V-243504: forest-root PDC Emulator uses an external time source. - V-243505: schema changes go through configuration management. - **V-243506 (CAT I, AC-6):**

Schema update access restricted. - **V-269098 (CAT I):** AD CS must enforce CA certificate-manager approval for certificate requests. - **V-269099 (CAT I):** AD CS "must be managed by a PAW tier 0." The check is that one or more PAWs are set aside for remote management of AD CS.

Windows Server 2022 / 2025 STIGs (DC hardening and user rights) - **Versions:** WS2022 STIG V2R10 (August 10, 2026; 278 rules: 31 CAT I, 235 CAT II, 12 CAT III). WS2025 STIG V1R3 (August 10, 2026; 291 rules). A V1R4 may now be current (see Caveats). - **Deny-logon rules:** - On DCs they require only Guests/unauthenticated access. WS2025: V-278168 (network), V-278171 (locally), V-278174 (RDS). WS2022: V-254421, V-254424. - On domain-joined member servers they require Enterprise Admins, Domain Admins, and Guests (plus "Local account" for network and RDS). WS2025: V-278187 (locally). WS2022: V-254435 (network). - PAWs dedicated to AD management are exempt from denying EA/DA. - Workstation STIGs (e.g., Windows 11) apply the same EA/DA Deny rights. - **Other DC rules:** AD data file, SYSVOL, and GPO permissions; anonymous-access restrictions; Directory Service Access auditing.

Windows Privileged Access Workstation STIG (V3R2) - Administrative accounts of high-value resources must be assigned to a specific administrative tier (WPAW-00-000400). - The domain must restrict privileged admin accounts from logging on to lower-tier hosts (WPAW-00-001200). - A PAW that manages DCs must not manage other high-value resources (WPAW-00-001300). - PAWs must enforce two-factor authentication.

B4. CIS (Center for Internet Security, US nonprofit)

CIS Microsoft Windows Server 2025 Benchmark - **Versions:** v2.1.0 (announced in CIS's September 2026 update); v2.0.0 dated February 24, 2026. - **Profiles:** Level 1 and Level 2 Domain Controller, Level 1 and Level 2 Member Server, and an optional "Next Generation Windows Security" DC/MS profile. - **Access and licence:** Free PDF registration for non-commercial use under CIS terms (Creative Commons BY-NC-SA for Benchmarks). Build kits and CIS-CAT Pro require SecureSuite membership. - **Relevant content:** - DC-only settings such as LDAP server channel binding and signing enforcement, Netlogon secure channel, and "Allow server operators to schedule tasks." - User Rights Assignment with "(DC only)" and "(MS only)" variants, including Deny rights that exclude Domain/Enterprise Admins from member servers. - **Limits:** CIS does not define tiers.

CIS Controls v8.1 (guide v8.1.2, March 2025; licence CC BY-NC-ND 4.0) - **Safeguard 5.4 (IG1):** Restrict admin privileges to dedicated admin accounts. Use the primary non-privileged account for browsing, email, and productivity. Maps to NIST AC-6(2) and AC-6(5). - **5.5:** Inventory of service accounts. - **5.6:** Centralize account management through a directory service. - **6.5 (IG1):** Require MFA for administrative access. - **6.7:** Centralize access control. - **6.8:** Define and maintain role-based access control. - **Control 8:** Audit logs (e.g., 8.9 centralize).

B5. IETF (background only)

- **RFC 4120, Kerberos V5 (July 2005):** Core protocol for AD authentication. AD extends it with the PAC, defined in Microsoft's [MS-PAC] and [MS-KILE] Open Specifications, not IETF.

- **RFC 3961 / 3962 (February 2005):** Kerberos encryption/checksum framework and AES for Kerberos. This is the basis for "AES-only" requirements in Protected Users and the CISA/NSA guidance.
- **RFC 4511 (June 2006), LDAP protocol** (part of the RFC 4510 series).
- **RFC 5929 (July 2010), TLS channel bindings:** The basis for LDAP channel binding, which Microsoft implements per ADV190023.
- **Licence:** IETF Trust Legal Provisions. RFCs are freely available; reuse of text is permitted with conditions.

4. Topic crosswalk

Topic	Microsoft	NIST	CISA/NSA	DISA	CIS	IETF
Forest/ domain design	Forest as security boundary; forest/dom ain models in AD DS design guide	Not addressed	Trust risks (one-way trust bypass, SID History); TDO reset	Forest STIG: schema, PDC time; Domain STIG: trust documenta tion, Selective Authentica tion, SID filtering	Not addressed	Kerberos cross-realm (RFC 4120) backgroun d
OU design for delegation	Primary purpose of OU structure; account vs. resourc e OUs; OU owners	Not addressed (AC-6 generic)	Not addressed in detail	OU/DC-OU ACL requireme nts (Windows Server DC STIG rules)	Not addressed	Not addressed
OU design for GPO	Secondary OU subtrees for GPO application	Not addressed	GPP passwords in SYSVOL as a technique	GPO and SYSVOL permission rules	Benchmar ks delivered as GPO settings (DC vs. MS)	Not addressed
Delegation of administra tion	Delegation of Control Wizard; delegate to groups; AdminSDH	AC-5, AC-6	Over-permissive ACLs as an enumerati on target	Privileged account delegation prohibited (V-243470)	6.8 RBAC	Not addressed

Topic	Microsoft	NIST	CISA/NSA	DISA	CIS	IETF
	older overrides					
Tier model / Tier 0 definition	Tier 0 = identity control plane (DC, AD FS, AD CS, Entra Connect, managing systems)	Not addressed by name	Tiered admin model; AD CS/AD FS/Entra Connect as Tier 0	Tiers named in PAW STIG; EA/DA restrictions	Not addressed	Not addressed
PAWs	Required, one per tier; PAWCSM for cloud	Not addressed by name	Recommended	Required: AD remote management from dedicated systems; V-269099 AD CS via PAW tier 0; PAW STIG	5.4 (separate browsing/email from admin)	Not addressed
Separate admin accounts per tier	No shared credentials across tiers	AC-6(2), AC-6(5)	Recommended	V-243466/67/68/69, V-243473	5.4	Not addressed
Deny-logon / logon restrictions	GPO user-rights restrictions; Authentication Policy Silos	AC-6 generic	Restrict privileged logons	WS STIG Deny rights (EA/DA on member servers and workstations); PAW STIG WPAW-00-001200	Deny rights in DC/MS profiles	Not addressed
Protected Users	Recommended for privileged users; never services or computers	Not addressed	Recommended	Required for domain-level admins (V-243477)	Not addressed (verify current benchmark)	AES (RFC 3962) background

Topic	Microsoft	NIST	CISA/NSA	DISA	CIS	IETF
Authentication policies/silos	Restrict admin sign-in to defined hosts; TGT lifetime	Not addressed	Not verified	Not addressed directly	Not addressed	Not addressed
Service accounts (gMSA/dMSA)	gMSA; dMSA (WS2025); single-tier service accounts; no DA service accounts	AC-2	gMSA against Kerberoasting	V-243474 password-change rule removed in V3R5	5.5 inventory	Not addressed
AdminSDHolder / protected groups	Appendix C; SDProp	Not addressed	Not verified	Covered indirectly via privileged group rules	Not addressed	Not addressed
LAPS	Windows LAPS; tier-model repo sets permissions	Not addressed	Recommended (unique local admin passwords)	Required in Windows STIGs (not verified here)	LAPS settings in benchmarks	Not addressed
Credential theft defenses	Tiering, PAWs, Protected Users, Credential Guard	IA-2, IA-5	Mitigations for each of 17 techniques	Smart cards for EA/DA; DC internet blocking	6.5 MFA	Kerberos crypto RFCs
Monitoring/ detection	Audit privileged identities; MDI (paid); Sentinel solution for repo	AU family; AC-6(9)	Detection per technique; canaries	Kerberos logging on AD CS DCs (V-269097); DS Access auditing	Control 8	Not addressed
ESAE/Red Forest status	Retired Dec 2020 as default; exception	Not addressed	Not addressed	Not addressed	Not addressed	Not addressed

Topic	Microsoft use only	NIST	CISA/NSA	DISA	CIS	IETF

5. Where authorities agree, differ, or conflict

- **ESAE retired, tiering retained.** Microsoft retired the separate admin forest, not the tier concept. Its 2026 tier-model page and the GitHub framework expand tiering. DISA (PAW STIG "administrative tier," V-269099 "PAW tier 0") and CISA/NSA still use tier language. Training content should not present "Red Forest" as current Microsoft guidance, nor present tiering as deprecated.
- **NIST maps onto the tier model without naming it.**
  - AC-5 corresponds to Microsoft's "operators, approvers, auditors."
  - AC-6(2) and AC-6(5) correspond to dedicated, tier-scoped admin accounts.
  - IA-2(1) corresponds to MFA for admins.
  - NIST is outcome-based; Microsoft and DISA supply the AD mechanisms.
- **DISA is prescriptive; Microsoft provides a framework.**
  - DISA fixes group names (EA/DA) in Deny rights and requires Protected Users membership. These are binary, auditable checks.
  - Microsoft frames tiers by control scope and accepts organizational variation, such as Tier 0 membership beyond DA and the "common target" of fewer than five admins.
  - DISA's Deny rights target EA/DA specifically. Microsoft's model applies to any Tier 0 or Tier 1 group, so DISA compliance alone does not achieve full tier isolation.
- **Tier 0 scope.** Microsoft explicitly includes backup, monitoring, patching, hypervisor, and EDR systems that manage Tier 0. DISA codifies only parts (AD CS via PAW). CISA/NSA emphasize AD CS, AD FS, and Entra Connect. These positions are compatible, but Microsoft's is the broadest.
- **Cloud emphasis.** Microsoft's ESAE rationale and EAM push toward cloud-based controls (MDI, PIM, cloud PAWs). DISA and NIST are platform-neutral; DoD environments may be disconnected, which is one of Microsoft's own ESAE exception cases.
- **Service accounts.** Microsoft promotes dMSA, but BadSuccessor (CVE-2025-53779) showed that dMSA object rights become a Tier 0 path. CISA/NSA's gMSA advice predates dMSA. No US government source verified here addresses dMSA directly.

6. Caveats and items not verified

- **Pages not fetched directly.** The following were identified via search snippets or links from verified pages but not opened in full:
  - Microsoft Learn: forest/domain design, Delegation of Control Wizard, AD DS permissions, RaMP, PAW overview, intermediaries, Windows LAPS, gMSA overview, Security Compliance Toolkit (WS2025 baseline version/date), MDI.

  - Fully fetched: the tier-model and ESAE pages. The Enterprise Access Model, OU design, Appendix C, Protected Users, Authentication Policies, dMSA, and KB5014754 were verified from search-result extracts of the official pages.
- **CISA/NSA joint guide.** The PDF body was bot-blocked. The 17-technique list and appendix structure come from official CISA/NSA announcements, the PDF snippet, and known document structure. An "August 2026" revision appears on the Australian co-author's site (an excluded source); its existence on a US host was not confirmed.
- **DISA AD Domain STIG V3R8.** The release is confirmed. Its date, rule count, and changes are not; the details above come from V3R5–V3R7. The OU-ACL rule V-ID and the current PAW-rule V-ID were not verified. The AD Forest STIG V3R2 date conflicts between sources (July 2, 2025 vs. NCP's September 14, 2026). Whether WS2025 V1R3 or V1R4 is current is unconfirmed. Several Deny-logon V-IDs (WS2022 DC RDS, member-server locally/RDS; WS2025 member-server network/RDS) were not verified.
- **Rule-detail sources.** STIG rule details come from third-party STIG viewers (cyber.trackr.live, stigviewer, Tenable audit listings) mirroring DISA content, because cyber.mil pages did not render. Verify against the official ZIP before publishing rule text.
- **Not re-verified this session:** NSA "Defend Privileges and Accounts" status and Windows Server 2025 AD changes beyond dMSA.
- **GitHub repo.** The release year (May–August) was inferred, and the MIT licence was confirmed only via fork metadata and the README.
- **BadSuccessor technical details** come from Akamai's own research blog plus security-vendor and press reporting (Tenable, Help Net Security). The MSRC entry itself was not fetched.
- **Licensing.** Microsoft Learn text is Microsoft-copyrighted; GitHub source repos may carry CC BY 4.0 (docs) and MIT (code). The CIS licence terms are as commonly published. Confirm each before reusing text in commercial training.

US Reference Collection: DNS Security and Deployment (Windows/Enterprise), October 2026

> **Scope note.** This DNS source collection has been scoped to US sources — official Microsoft guidance plus US government guidance (NIST, CISA/OMB/NSA, DISA, CIS) and the US-based IETF and ICANN — to match the rest of this compendium. Non-US government source sections (UK NCSC, Australia ASD/ACSC, Canada/CCCS, France ANSSI, Germany BSI, EU ENISA) and their crosswalk columns were removed from the broader multi-country collection they were drawn from. A separate standalone US DNS source document also exists but could not be merged from this session.

There is now a clear common baseline across the authorities. NIST SP 800-81r3 (final, March 2026), US federal mandates, DISA and Microsoft's own documentation all point to five things: DNSSEC, restricted recursion, protected dynamic updates and zone transfers, protective DNS/filtering, and query logging. They split mainly on how to encrypt DNS (DoH vs DoT, and whether to encrypt inside the network) and on how much logging is required. This collection verifies the preliminary items against publisher pages where possible, corrects several of them, and states plainly what could not be re-verified.

TL;DR

- **Microsoft's platform caught up in 2026.** Server-side DNS over HTTPS for the Windows Server 2025 DNS Server role became generally available with the June 9, 2026 update (KB5094125). It covers client-to-server traffic only: forwarders, zone transfers and dynamic updates stay unencrypted. An older Microsoft Learn page still warns against "Require DoH" on domain-joined clients because the DNS Server role "doesn't support DoH queries", which is now outdated.
- **Corrections to the preliminary pass:**
  - Protective DNS there is one of three acceptable mitigations, not a standalone mandate.
  - RFC 9904 obsoletes RFC 8624.
  - Third-party mirrors list the Windows Server DNS STIG at V2R5 (2026-06-03), but this was not confirmed on DISA's own site.

---

1. Overview of the guidance landscape

Publisher	Key DNS document(s)	Latest verified date / version	Status
NIST (US)	SP 800-81r3 *Secure DNS Deployment Guide*	March 2026 (released 19 Mar 2026); errata planning note 07/10/2026	Current; supersedes SP 800-81-2
NIST (US)	SP 800-53 Rev 5 SC-20/21/22	Rev 5 (wording unchanged through 5.1.1/5.2.0 per	Current

Publisher	Key DNS document(s)	Latest verified date / version	Status
		mirrors)	
CISA (US)	Encrypted DNS Implementation Guidance v1.0	Document dated April 2024; published May 16, 2024	Current; federal civilian (FCEB) audience
OMB (US)	M-22-09	January 26, 2022	Current policy driver
DISA (US DoD)	Microsoft Windows Server DNS STIG	V2R4 (Q1 2026) confirmed via mirrors; V2R5 (2026-06-03) listed by third-party viewer	Current; 2012 DNS STIG (V2R7) is "Sunset"
CIS	CIS Controls v8.1 Safeguards 8.6, 9.2	v8.1	Current
ICANN	Board Resolution 2024.07.29.06 (.INTERNAL), SAC113	29 July 2024; SAC113 18 Sept 2020	Current
IETF	RFC 9904, RFC 9905 (Nov 2025); RFC 9364 (BCP 237) etc.	See Section B	Current
Microsoft	Learn docs, MSRC, KBs, TechCommunity	DoH GA June 2026; DoH concept page updated 2026-06-12	Current

General reuse note: - US federal works (NIST, CISA, NSA, OMB, DISA) are generally not subject to US copyright. DISA STIGs are distributed via DoD Cyber Exchange. - IETF RFCs are under IETF Trust Legal Provisions. - CIS Controls are CC BY-NC-ND 4.0. - Microsoft Learn content is under Microsoft's Terms of Use. Some documentation repositories carry CC BY 4.0, so check per page.

---

2. Section A: Microsoft official guidance (by topic)

A1. DNS Server role overview and "what's new"

- **"What is Domain Name System (DNS)?"** (Microsoft Learn, `learn.microsoft.com/windows-server/networking/dns/dns-overview`), free.
  - Lists the DNS Server features: AD integration, dynamic updates, DNSSEC, forwarding/conditional forwarding, caching, monitoring/logging, DNS policies, Anycast.
  - Notes that DNS is installed automatically with a new AD forest/domain and is the DC location mechanism.

- **What's new.** The Windows Server 2016 "what's new" page is the last to give a dedicated DNS Server section: DNS policies, RRL, DANE (RFC 6394/6698), unknown record support (RFC 3597), IPv6 root hints, and PowerShell support.
- **Windows Server 2022.** DNS *client* support for DoH.
- **Windows Server 2025.**
  - DC Locator improvements; mailslots are not used for DC discovery because of the WINS/mailslot deprecation.
  - Server-side DoH, delivered via the June 2026 update (see A11).

A2. AD-integrated zones and replication scope

- **"Active Directory-Integrated DNS Zones"** (Learn, `.../identity/ad-ds/plan/active-directory-integrated-dns-zones`).
  - Zone data replicates via AD replication, so no separate zone-transfer topology is needed.
  - Any DC running DNS can write updates (multi-master), and secure dynamic updates are supported.
  - Zones are stored in application directory partitions created at AD DS install: forest-wide **ForestDnsZones** and per-domain **DomainDnsZones**.
  - Custom application partitions can also be used as replication scope (Microsoft troubleshooting article on custom application directory partitions).

A3. Secure dynamic updates

- **"Dynamic update"** (Learn, `.../networking/dns/dynamic-update`).
  - Secure update is available only for AD-integrated zones.
  - After a zone becomes AD-integrated, Windows DNS servers default to **secure only**. File-backed zones default to no dynamic updates.
  - Clients try a nonsecure update first, then fall back to secure. Negotiation uses TKEY and signs with TSIG over Kerberos.
- **KB 816592** "How to configure DNS dynamic updates in Windows".
  - Repeats these defaults.
  - Warns that when a DHCP server performs secure updates on behalf of clients, records can become stale or owned by the DHCP server.
- **Supporting standards.** RFC 2136 (and GSS-TSIG).

A4. Aging and scavenging

- KB 816592 describes aging/scavenging as the DNS Server feature that "can scan and remove records that are no longer required." The Microsoft Learn dnscmd reference gives the server defaults: no-refresh and refresh intervals of 0xA8 (168 hours, i.e., 7 days) each, and scavenging disabled by default (`/defaultagingstate` 0).

A5. Forwarders, conditional forwarders, root hints, recursion control

- **"DNS forwarding in Windows Server"** (Learn, `.../networking/dns/forwarding`).

  - **Order of resolution.** Server-level forwarders handle names not covered by a hosted zone, conditional forwarder or delegation. Without forwarders, the server uses root hints when recursion is enabled.
  - **Dynamic Forwarder Reordering** is on by default. Microsoft Learn says it "resets the list to the configured order approximately every 15 minutes" (no more precise figure is published). A response slower than 1 second counts as slow, and three consecutive slow responses or timeouts move a forwarder to the end of the list.
  - **Windows Server 2022+ behaviour.** If no forwarder responds, the server uses only the first one until the service restarts. Disable reordering to restore cycling through all forwarders.
  - **Fallback to root hints** happens by default when recursion is allowed and `UseRootHint` is `$true`.
  - **Security guidance:** "Allow recursive queries only from trusted clients and networks, and don't expose recursive DNS service to untrusted networks."
- **Recursion scopes.** These are part of DNS policies (A6).

A6. DNS policies

- **DNS Policy Scenario Guide** (linked from the WS2016 what's new page).
  - Policies select responses by client subnet, time of day, transport, query type and other criteria.
  - Use cases include split-brain DNS, query filtering, recursion scopes and traffic management/load balancing.
- **DoH caveat.** Policies with a Transport Protocol filter do not match DoH queries, and you cannot write a filter that matches only DoH (DoH concept page, 2026).

A7. Response Rate Limiting

- **Set-DnsServerResponseRateLimiting** (PowerShell reference, WS2025 view).
  - Parameters: ResponsesPerSec, ErrorsPerSec, WindowInSec, IPv4/IPv6PrefixLength, LeakRate, TruncateRate, MaximumResponsesPerWindow, and Mode (LogOnly/Enable/Disable). - `ResetToDefault` restores defaults.
  - LeakRate example: at 3, the server answers one in three dropped queries. TruncateRate example: at 2, one in two receives a truncated response.
- **Defaults.** The cmdlet page does not list the numeric defaults. Microsoft's Open Specifications [MS-DNSP] (DNS_RPC_RRL_PARAMS) give them: 5 responses/sec, 5 errors/sec, a 5-second window, LeakRate 3, TruncateRate 2, IPv4 prefix /24, IPv6 prefix /56, and 1,024 total responses per window (MaximumResponsesPerWindow). Microsoft's DNS team blog "Response Rate Limiting in Windows DNS Server" states that RRL is disabled by default.

A8. Socket pool and cache locking

- **Microsoft Learn training module "Secure Windows Server DNS"** (unit 5):
  - Cache locking prevents cached records from being overwritten for a percentage of their TTL. The **default is 100 (%)**.

  - The socket pool randomises source ports and is enabled by default. The **default size is 2,500**.
  - Configure with `Set-DnsServerCache -LockingPercent` and the socket pool setting (`dnscmd /config /socketpoolsize`, range 0–10,000 per long-standing Microsoft guidance).

A9. Global Query Block List (GQBL)

- **dnscmd reference / Set-DnsServerGlobalQueryBlockList.**
  - The default block list contains **isatap** and **wpad**, described as "two commonly deployed protocols that are particularly vulnerable to hijacking."
  - The service may remove either name on first start if it finds that name in an existing zone.
  - `Set-DnsServerGlobalQueryBlockList` replaces the whole list.

A10. DNSSEC (signing, algorithms, NSEC/NSEC3, Key Master, trust anchors, validation, NRPT)

- **"What is DNSSEC?"** (Learn).
  - Covers the record types: RRSIG, NSEC, NSEC3, NSEC3PARAM, DNSKEY, DS.
  - A zone uses NSEC or NSEC3, never both. NSEC3 prevents zone walking.
  - Trust anchors on DCs are stored in the forest directory partition and can replicate forest-wide. On standalone servers they are stored in `TrustAnchors.dns`.
- **"Sign DNS zones with DNSSEC"** (Learn).
  - **Algorithms offered:** RSA/SHA-256 (default), ECDSAP256/SHA-256, ECDSAP384/SHA-384, RSA/SHA-1, RSA/SHA-1 (NSEC3), RSA/SHA-512.
  - **Keys:** KSK default 2048-bit with a 755-day rollover. ZSK default 1024-bit with a 90-day rollover.
  - **Rollover methods:** double-signature for KSK, prepublish for ZSK.
  - **Defaults:** DNSKEY/DS signature validity 168 h, zone record validity 240 h, DS digests SHA-1 and SHA-256.
  - The wizard labels **NSEC3 as "recommended."**
  - Private keys must use the Microsoft Software KSP if they are to be distributed via AD.
  - The SHA-1 options sit uneasily with RFC 9905, which says MUST NOT sign with them (see Section 5).
- **Key Master.**
  - "Transfer Key Master role" covers online transfer and offline seizure.
  - After seizure, re-sign the zone and replace trust anchors.
- **Validation.**
  - "Validate and secure DNS responses using DNSSEC" covers RFC 5011 automatic trust-anchor update, supported since Windows Server 2012.
  - Clients request validation through the **Name Resolution Policy Table (NRPT)** in Group Policy. The DISA STIG requires this (V-259381).

A11. DNS over HTTPS (client and server)

- **Client:** "Secure DNS Client over HTTPS (DoH)" (Learn).
  - Supported from Windows Server 2022 and Windows 11.
  - Group Policy setting: *Configure DNS over HTTPS (DoH) name resolution*.
  - Works only with servers on the known-DoH list or ones you add.
  - The page still says not to enable "Require DoH" on domain-joined computers "because the Windows Server DNS Server service doesn't support DoH queries". This statement predates server GA.
- **Server:** "DNS encryption using DNS over HTTPS" (Learn, updated 2026-06-12) and "Enable DNS over HTTPS in DNS Server".
  - Available from the 2026-06 Security Update **KB5094125** for Windows Server 2025.
  - **Not encrypted:** upstream traffic (forwarders, conditional forwarders, authoritative servers), zone transfers, and dynamic updates (by default).
  - Classic port-53 DNS keeps working unless disabled.
  - **Prerequisites:** a certificate with Server Authentication EKU and a SAN that matches the URI template, a TCP 443 firewall rule, and `Set-DnsServerEncryptionProtocol -EnableDoh $true -UriTemplate ….`
  - Microsoft describes DoH and DNSSEC as complementary.
- **TechCommunity Networking Blog**, "DoH is now generally available on Windows DNS Server". GA is for "client-to-server DNS traffic". The public preview was announced Feb 9, 2026, and Zero Trust DNS for Windows 11 on Nov 18, 2025.

A12. Windows DNS client

- "DNS queries and lookups" (Learn) covers caching from the HOSTS file and TTL.
- It recommends configuring every client with more than one DNS server for fault tolerance.
- The DoH, NRPT and DNSSEC client behaviours are covered in A10 and A11.

A13. LLMNR / NetBIOS / mDNS status (as of 2026)

- **"Aligning on mDNS: ramping down NetBIOS name resolution and LLMNR"** (TechCommunity Networking Blog, Apr 22, 2022).
  - Says both protocols "are rarely used today" and needlessly expand attack surface.
  - NetBIOS name resolution was off by default on cellular interfaces and in "learning mode" (fallback only) in Insider builds.
  - "The default LLMNR behavior has not been changed in Windows yet."
  - The stated goal is mDNS as the only multicast name-resolution protocol on by default.
- **Status in 2026.**
  - No Microsoft source found in this pass states that LLMNR is disabled by default in shipping Windows.
  - Microsoft's policy documentation says LLMNR remains enabled unless the *Turn off multicast name resolution* policy is enabled.

  - Secondary summaries report that Windows Server 2025 DC Locator does not permit NetBIOS-based DC discovery by default, and that WINS is deprecated. Treat both as reported but not re-verified here.

A14. DnsAdmins, CVEs and advisories

- **CVE-2021-40469** (MSRC, Oct 12, 2021): "Windows DNS Server Remote Code Execution Vulnerability".
  - CVSS 3.1 base score 7.2 with PR:H (high privileges required). MSRC says it is exploitable only if the server is configured as a DNS server.
  - Third-party analysis (0patch) links it to the long-known DnsAdmins → ServerLevelPluginDll DLL-loading path. MSRC itself does not describe the mechanism.
  - Practical implication: membership of **DnsAdmins** should be treated as privileged.
- **CVE-2020-1350 "SIGRed"** (MSRC, July 14, 2020; CVSS 10, wormable).
  - **KB4569509** workaround: set `HKLM\SYSTEM\CurrentControlSet\Services\DNS\Parameters\TcpReceivePacketSize` (DWORD) to **0xFF00**, then restart the DNS service.
  - Side effect: TCP responses over 65,280 bytes are dropped.
  - Microsoft advises removing the workaround after patching.
  - CISA issued Emergency Directive 20-03 for it.
- **2023–2026 Windows DNS Server CVEs.** These could not be enumerated from MSRC in this pass. Use the MSRC Security Update Guide, filtered on "Windows DNS Server".

A15. Security baselines (Security Compliance Toolkit)

- Not re-verified in this pass. The Microsoft security baselines in the Security Compliance Toolkit configure DNS Client settings such as *Turn off multicast name resolution*. Check the current Windows Server 2025 and Windows 11 baseline spreadsheets for exact DNS-related values.

A16. AD namespace guidance

- **"Selecting the Forest Root Domain"** (Learn):
  - Use a registered DNS suffix with a new prefix (e.g., `corp.contoso.com`).
  - "Do not use single-label DNS names."
  - Microsoft does "not recommend using unregistered suffixes, such as .local".
  - Prefix: Internet-standard characters only, 15 characters or fewer so it matches the NetBIOS name.
- **"Naming conventions in Active Directory…"** (support):
  - Lists single-label domain problems: they can't be registered, need extra configuration, and members don't dynamically update single-label zones by default.
  - Advises against using public TLDs or `.local` internally.
- **"Disjoint Namespace"** (Learn):

- Disjoint namespaces are supported. DCs still register SRV records in the zone that matches the AD domain.
- They are unsupported if the disjoint suffix matches an AD domain name in this or another forest (this breaks Kerberos name-suffix routing), or if the same suffix is used in another forest.
- Test applications before deploying.

---

3. Section B: Government and standards guidance

B1. NIST (US)

SP 800-81r3, *Secure Domain Name System (DNS) Deployment Guide* - **Authors:** S. Rose (NIST), C. Liu and R. Gibson (Infoblox). - **URL:** `csrc.nist.gov/pubs/sp/800/81/r3/final` (DOI 10.6028/NIST.SP.800-81r3). - **Dates:** final March 2026 (released March 19, 2026). The initial public draft (April 10, 2025) is withdrawn. A NIST errata planning note is dated 07/10/2026. - **Status and access:** supersedes SP 800-81-2. Free; US government work. - **Executive-summary recommendations:** - Employ protective DNS "wherever technically feasible". It blocks malicious traffic, filters by policy, supplies query/response data for DFIR, and integrates with zero trust. - "Encrypt internal and external DNS traffic wherever feasible." - Deploy DNSSEC. - Deploy dedicated DNS servers. - Follow the technical guidance. - **Body topics:** - Restricting zone transfers. - Lame delegations and zone drift. - Securing dynamic updates and NOTIFY. - Dangling CNAMEs and look-alike domains. - TTL recommendations. - DNSSEC key parameters and RRSIG validity periods. - NSEC3 and compact denial-of-existence as an alternative. - Algorithm migration and signing internal zones. - Authoritative time sources. - Encrypted DNS and blocking non-approved public DoH/encrypted resolvers (for example via MDM). - QNAME minimisation and exfiltration detection. - DNSSEC validation and trust-anchor maintenance. - Stub resolver threats. - **Terminology note:** "protective DNS" in this document means the general service, not CISA's programme. - **Minor anomaly:** the PDF's citation line reads "Rose S, Liu C, Nodurft R", while the title page lists Ross Gibson.

SP 800-81-2 (Sept 2013). Superseded/legacy; earlier SP 800-81 (2006) is withdrawn.

SP 800-53 Rev 5. Verbatim wording comes from mirrors of the NIST catalogue; the NIST PDF §3.18 is the formal source. - **SC-20, Secure Name/Address Resolution Service (Authoritative Source):** - (a) Provide "additional data origin authentication and integrity verification artifacts" with authoritative responses to external queries. - (b) Indicate child-zone security status and enable chain-of-trust verification. - SC-20 is in the Low, Moderate and High baselines. - **SC-20(2)** extends this to internal queries and is in no baseline. - **SC-21, Recursive or Caching Resolver:** "Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources." In other words, DNSSEC validation, either on the client or over authenticated channels to validating resolvers. In the Low, Moderate and High baselines. - **SC-22, Architecture and Provisioning:** "Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external

role separation." The discussion recommends at least two authoritative servers on geographically separated subnets. In the Low, Moderate and High baselines.

SP 800-207 and SP 1800/NCCoE. Not re-verified in this pass. NIST lists a "High Assurance Domains project" as supplemental material to 800-81r3.

B2. CISA / OMB / NSA (US)

- **CISA Encrypted DNS Implementation Guidance** (v1.0, document dated April 2024, published May 16, 2024; free; FCEB audience).
  - Implements OMB **M-22-09**, which requires encrypted DNS "where technically supported".
  - Reminds agencies they must use **CISA Protective DNS** for all egress resolution under M-22-09 and 6 U.S.C. § 663 note.
  - Covers DoH, DoT and DoQ, tunnelling to Protective DNS, endpoint configuration, and blocking applications that silently enable encrypted DNS.
- **CISA Protective DNS.** Available only to federal agencies, per the above.
- **Not re-verified in this pass:**
  - Emergency Directive 19-01 (January 2019, DNS infrastructure tampering).
  - OMB M-21-31 (August 2021, event logging including DNS).
  - NSA "Adopting Encrypted DNS in Enterprise Environments" (January 2021).
  - NSA/CISA "Selecting a Protective DNS Service" (March 2021).

B3. DISA (US DoD)

- **Microsoft Windows Server DNS STIG**, Version 2.
  - V2R4: 81 rules (5 CAT I, 76 CAT II, 0 CAT III), released Q1 2026 per mirrors. A third-party viewer lists V2R5 dated 2026-06-03 with the same counts.
  - Download is free via DoD Cyber Exchange. The public version needs no CAC.
  - The Windows 2012 DNS STIG (V2R7) is sunset.
- **Representative requirements** (severity per rule not confirmed here):
  - Restrict recursion to known clients, and prohibit recursion on authoritative servers without forwarders.
  - Forward only to internal non-AD-integrated servers or DoD Enterprise Recursive Services.
  - Allow zone transfers only to specified secondaries, authenticated by TSIG (AD replication suffices for AD-integrated zones).
  - Enable DNSSEC with FIPS-compatible algorithms.
  - **NSEC3 for all internal zones**, with the salt changed on each full re-sign.
  - RRSIG validity between 2 days and 1 week.
  - Distribute trust anchors with automatic update.
  - Use NRPT to require DNSSEC validation.
  - Internal/external role separation, and geographically dispersed servers on different segments.
  - Disable WINS lookups.
  - Enable the DNS log.

  - Refuse version queries.
  - Restrict dynamic updates to known clients and protect them with transaction signing.
  - Validate zone records annually.
  - Use DNS Notify.
- **BIND 9.x STIG, Infoblox STIG and DNS SRG.** Not re-verified in this pass.

B4. CIS

- **CIS Controls v8.1** (CC BY-NC-ND 4.0; free).
  - **Safeguard 9.2 "Use DNS Filtering Services":** "on all end-user devices, including remote and on-premises assets, to block access to known malicious domains." IG1–IG3. The v8 wording said "all enterprise assets".
  - **Safeguard 8.6 "Collect DNS Query Audit Logs":** "on enterprise assets, where appropriate and supported." IG2–IG3.
- **CIS Benchmarks** are a separate product under CC BY-NC-SA 4.0. Their DNS content (e.g., the Windows DNS Client settings) was not re-verified.

B11. ICANN / SSAC

- **SAC113** (18 Sept 2020) recommended reserving one private-use TLD that is never delegated.
- **Board Resolution 2024.07.29.06** (29 July 2024) reserves **.INTERNAL** permanently from delegation in the root zone "to provide for its use in private-use applications".
  - The reservation is held in IANA's reserved-domain registry, not the IETF special-use registry.
- The IETF draft (draft-davies-internal-tld) documents this. It is an Internet-Draft, not an RFC.
- **Name-collision and KSK-rollover guidance.** Not re-verified.

B12. IETF (IETF Trust terms; all free)

- **Core:** RFC 1034/1035. RFC 9499 (DNS terminology, BCP 219).
- **DNSSEC:**
  - RFC 4033–4035 (core) and RFC 6840 (clarifications).
  - **RFC 9364** (BCP 237, Feb 2023), the umbrella BCP for DNSSEC.
  - **RFC 9904** (Nov 2025) obsoletes **RFC 8624** and moves algorithm requirement levels into the IANA DNSSEC registries.
  - **RFC 9905** (Nov 2025) updates RFC 4034/5155: RSASHA1 and RSASHA1-NSEC3-SHA1 are **MUST NOT** for signing (validation still MUST be implemented), and SHA-1 DS digests are MUST NOT for delegation.
  - RFC 9906 (Nov 2025) deprecates ECC-GOST.
- **Encrypted transports:** DoT RFC 7858, DoH RFC 8484, DoQ RFC 9250.
- **Updates and transfers:** RFC 2136, RFC 3007 (secure dynamic update) and RFC 8945 (TSIG).
- **Special-use names:**
  - RFC 6761 (special-use domain names).

  - RFC 8375 (home.arpa).
  - RFC 9476 (.alt).
- **Resilience and transport:**
  - RFC 5452 (forgery resilience: ID and port randomisation).
  - RFC 8806 (local root).
  - RFC 7766 (DNS over TCP).
  - RFC 9210 (TCP as a requirement, BCP 235).
  - RFC 8767 (serve-stale).
- **Privacy and caching:** RFC 9156 (QNAME minimisation). RFC 8198 (aggressive use of DNSSEC-validated cache).
- **RRL.** No standards-track IETF RRL specification was identified; RRL is an implementation practice.
- *Titles and numbers above other than RFC 9904/9905/9906 were not individually re-fetched in this pass.*

---

4. Topic crosswalk

"NV" = not verified in this pass; "—" = not addressed in sources reviewed.

Topic	Microsoft	NIST	CISA/ NSA/OMB	DISA	CIS	IETF
Namespace selection	Registered suffix + new prefix; no single-label; avoid .local	Look-alike/ dangling-record hygiene	—	Zone data must reflect environment	—	RFC 6761/8375/ 9476; ICANN .internal
Secure dynamic updates	Secure-only default for AD zones (Kerberos/ TSIG)	Secure dynamic updates (Sec 3.3)	—	Restrict to known clients; TSIG	—	RFC 2136/3007 /8945
Zone transfer restriction	AD replication replaces transfers	Restrict transfer entities	—	Specified secondaries; TSIG	—	RFC 8945
Recursion / open resolvers	Recursion only for trusted clients	Separate roles	—	Restrict to known clients; none on authoritative-only servers	—	—

Topic	Microsoft	NIST	CISA/ NSA/OMB	DISA	CIS	IETF
Cache poisoning defences	Socket pool (2,500), cache locking (100%)	DNSSEC validation	—	DNSSEC; secured against pollution	—	RFC 5452
DNSSEC signing	RSA/SHA-256 default; ECDSA offered; SHA-1 still offered	Deploy DNSSEC; algorithm migration; sign internal zones	—	Required; FIPS algorithms; RRSIG 2 days–1 week	—	RFC 9364/9904/9905
DNSSEC validation	NRPT; RFC 5011 trust anchors	Enable validation; maintain trust anchors	—	Required + NRPT	—	RFC 4035; SC-21 equivalent
Encrypted DNS	DoH client (WS2022+) and server (WS2025, June 2026); upstream unencrypted	Encrypt internal and external	M-22-09: where technically supported; DoH/DoT/DoQ	Integrity of transmitted information	—	RFC 7858/8484/9250
Protective DNS / filtering	GQBL; DNS policies query filters	Employ PDNS wherever feasible	Federal agencies must use CISA PDNS	Forward to DoD ERS	9.2 DNS filtering (IG1)	—
Logging & monitoring	Audit log on by default; analytic log optional; debug log temporary	Query/ response data for DFIR	M-21-31 (NV)	DNS log enabled; who changed zones	8.6 DNS query logs (IG2)	—
Server hardening	Dedicated features; patching (SIGRed)	Dedicated DNS servers	ED 19-01 (NV)	Version refusal; file ACLs; WINS off	Benchmarks (NV)	—
Multicast/	Ramp	—	—	WINS	NV	RFC 6762

Topic	Microsoft	NIST	CISA/ NSA/OMB	DISA	CIS	IETF
legacy name resolution	down LLMNR/NetBIOS; mDNS preferred			lookups disabled		(mDNS)
Privileged DNS administration	DnsAdmins risk (CVE-2021-40469)	—	—	Restrict key/zone file access	—	—
Resilience / availability	≥2 DNS servers per client; forwarder reordering	Resiliency and high availability (Sec 2.3.2)	—	Geographic dispersion; separate segments	—	RFC 7766/9210/8767/8806
Rate limiting	RRL (WS2016+)	NV	—	Prevent use for DoS	—	No RRL RFC identified

5. Where authorities agree, differ, or conflict

1. **Encrypted DNS.**
   - NIST says to encrypt internal and external traffic wherever feasible. OMB M-22-09 and CISA require encryption where technically supported, using any of DoH, DoT or DoQ.
   - The common thread is control and visibility. Every authority opposes endpoints or browsers bypassing the enterprise resolver with self-selected DoH. NIST and CISA both recommend blocking non-approved encrypted resolvers.
2. **Root hints versus forwarding to protective DNS.**
   - Microsoft's default falls back to root hints when forwarders fail (`UseRootHint $true`).
   - The two conflict directly. Microsoft's dnscmd `/isslave 1` setting reconciles them: per the Microsoft Learn dnscmd reference, the server then "terminates the search and sends a failure message to the resolver" if the forwarder doesn't respond (the default is 0).
3. **DNSSEC algorithms and NSEC3.**
   - RFC 9905 makes RSA/SHA-1 signing MUST NOT, yet Windows still offers RSA/SHA-1 algorithms and generates SHA-1 DS records by default (SHA-1 plus SHA-256).
   - DISA requires FIPS-compatible algorithms and **NSEC3 for all internal zones**. Microsoft's wizard calls NSEC3 "recommended".

  - NIST 800-81r3 adds compact denial-of-existence as an NSEC3 alternative. RFC 9276 (not fetched here) separately constrains NSEC3 iterations and salt, which may conflict with DISA's salt-rotation rule.

4. **Logging scope.**
   - CIS 8.6 applies only "where appropriate and supported" and starts at IG2.
   - DISA focuses on server/audit logs and change attribution.
   - Microsoft Learn ("Enable DNS Logging and Diagnostics") notes that a server receiving 100,000 QPS "can experience a performance degradation of 5%" with analytic logs enabled, with no apparent impact at 50,000 QPS and lower, and recommends debug logging only temporarily.
5. **Internal/external separation.** NIST SC-22 and DISA require role separation. Microsoft's split-brain DNS policies offer a single-server alternative, which these frameworks do not endorse.
6. **Microsoft's internal inconsistency.** The DoH client page still says the DNS Server role does not support DoH, which the June 2026 GA contradicts.

---

6. Caveats and items not verified

- **Not re-verified against publisher pages in this pass:**
  - NSA's two CSIs, the NSA/CISA PDNS paper, CISA ED 19-01, the CISA DNS resources page, and OMB M-21-31.
  - DISA's BIND, Infoblox and DNS SRG documents.
  - The CIS Benchmark DNS content.
  - ICANN name-collision and KSK guidance.
  - NIST SP 800-207 and the NCCoE projects.
  - Microsoft security baselines.
  - 2023–2026 Windows DNS CVEs.
  - Most RFC titles other than 9904, 9905 and 9906.
- **DISA STIG version.** The current release (V2R4 versus V2R5) comes from third-party mirrors (stigviewer, cyber.trackr.live), which disagree on dates. Confirm on DoD Cyber Exchange.
- **NIST SP 800-53 wording** comes from consistent third-party mirrors, not the NIST catalogue page itself.
- **Corrections to the preliminary list:**
  - RFC 9904 obsoletes RFC 8624.
  - The CISA PDF is internally dated April 2024 even though it was published in May 2024.

US Reference Collection: NTP and Time Synchronization for Windows/Enterprise Environments (verified October 2026)

The US baseline is consistent across sources. Inside an Active Directory forest, time flows down a hierarchy from the forest-root PDC emulator, and that PDC emulator should take time from an authoritative external source such as NIST, USNO (US Naval Observatory), GPS or a stratum-1 appliance. Kerberos tolerates 5 minutes of clock skew. Most items from the prior pass held up, but several were wrong or out of date: STIG severities, NIST authenticated-server details, the leap-second timeline, how W32Time authenticates, and the USNO page URLs.

1. TL;DR

- **Microsoft's baseline:**
  - The domain hierarchy is NT5DS. The forest-root PDC emulator is the root and syncs to an external NTP source.
  - The Kerberos skew policy is 5 minutes.
  - Secure Time Seeding (STS) is on by default in Server 2016/2019/2022 and off by default in Server 2025. Microsoft recommends disabling it on time-sensitive servers such as DCs and VM hosts, and suggests considering it for all Windows Server machines.
  - Up to 1 ms accuracy is supported only on Windows 10 / Server 2016 or later, and only under strict network, stratum and CPU conditions.
  - W32Time documents no support for NTS (RFC 8915). Its only built-in authentication works inside the domain and is signed with Kerberos/Net Logon session keys. Manually configured external peers are unauthenticated.
- **The US government baseline is "sync to an authoritative source, with redundancy":**
  - NIST SP 800-53 Rev. 5 AU-8 covers timestamps. Synchronization moved from AU-8(1)/(2) to SC-45(1)/(2).
  - OMB Memorandum M-26-14 (22 May 2026) rescinded M-21-31. It requires log timestamps synchronized by NTP or equivalent "to a traceable time source designated within the agency", and encourages sources traceable to USNO or NIST.
  - DISA STIGs require a DoD source. AD Forest V-243504 (forest-root PDC external source) is CAT II. The Windows Server 2022/2025 "DOD time source" rules are CAT III (Low).
  - CIS Safeguard 8.4 requires at least two synchronized time sources.
  - NSA recommends at least two NTP servers plus NTP authentication on network devices.
- **Live services, checked on publisher pages:**
  - NIST ITS lists 20+ stratum-1 hostnames behind time.nist.gov and a "never more than once every 4 seconds" rule.
  - NIST's symmetric-key authenticated servers are ntp-b, ntp-wwv and ntp-d. They are free but need a mailed or faxed request and registered static IPv4 addresses.

- USNO publishes tick/tock/ntp2.usno.navy.mil as public servers on its CNMOC site. It tells DoD entities not to use them and to use its authenticated DoD servers instead.
- On 15 October 2026 the 28th CGPM (the General Conference on Weights and Measures) adopted Resolution 5, which makes UTC continuous from 20 May 2027. This ends leap seconds earlier than the 2022 "by 2035" resolution. A BIPM statement by CCTF President Noël Dimarcq says "continuous UTC will take effect on 20 May 2027" and sets "a long-term limit of one hour" for UTC–UT1.

2. Guidance landscape overview

Publisher	Document / service	Date / version (as seen Oct 2026)	Status	Access
Microsoft	Support boundary for high accuracy time (legacy KB939322)	Last updated 2026-02-12	Current	Free, web
Microsoft	Secure Time Seeding recommendations for Windows Server	Last updated 2026-02-12	Current	Free, web
Microsoft	Windows Time service tools and settings	Last updated 2025-09-18	Current; applies to Server 2016–2025, Win10/11, Azure Local	Free, web
Microsoft	How the Windows Time Service works	Last updated 2025-07-25	Current	Free, web
Microsoft	Configuring systems for high accuracy; Accurate Time for Windows Server 2016	Server 2016-era content, still published	Current but dated	Free, web
Microsoft	Maximum tolerance for computer clock synchronization	Windows security policy reference	Current	Free, web
Microsoft	Virtualizing domain controllers with Hyper-V	Current Learn page	Current	Free, web

Publisher	Document / service	Date / version (as seen Oct 2026)	Status	Access
Microsoft (AskDS blog)	Synchronizing Time on Virtualized AD DS Environments – VMICTimeProvider vs AD	TechCommunity (2024)	Current blog	Free, web
NIST	Internet Time Service page; server list (tf.nist.gov/tf-cgi/servers.cgi)	ITS page updated 2026-06-09	Live service	Free
NIST	Authenticated NTP Service	Updated 2026-09-17	Live service	Free; written registration required
NIST	leap-seconds.list	Updated at least twice yearly	Live	Free
NIST	SP 800-53 Rev. 5 (Release 5.2.0)	Release 5.2.0 issued 2025-08-27	Current	Free; public domain
NIST	SP 800-92 (log management)	2006 final (9/13/2006); SP 800-92 Rev. 1 “Cybersecurity Log Management Planning Guide” is still a Draft (initial public draft 10/11/2023)	2006 version is the current final	Free
USNO (via CNMOC)	US Eastern Time Zone NTP Servers; DoD Customer Servers	Undated web pages, live Oct 2026	Live	Public page; DoD service by signed request
OMB	M-26-14 (logging requirements; rescinds M-21-31)	2026-05-22	Current; M-21-31 (2021-08-27) rescinded	Free

Publisher	Document / service	Date / version (as seen Oct 2026)	Status	Access
NSA	Network Infrastructure Security Guide	v1.2, Oct 2023 (U/OO/118623-22)	Current	Free
CISA + NSA/FBI (ASD-led)	Best Practices for Event Logging and Threat Detection	2024-08-21	Current	Free
CISA	Time – The Invisible Utility (resilient timing fact sheet)	Feb 2023	Current	Free
DISA	Active Directory Forest STIG, V-243504	V3R1-era rule SV-243504r1026204	Current	Free (public.cyber.mil)
DISA	Windows Server 2025 STIG, V-278029	V1R1 (Jan 2026)	Current	Free
DISA	Windows Server 2022 STIG, V-254281	Rule SV-254281r1051090 (2025 releases)	Current	Free
DISA	Windows Server 2019 STIG, V-205800; Server 2016 STIG, V-224862	Not re-verified this pass	See caveats	Free
CIS	CIS Controls v8.1, Safeguard 8.4	v8.1 (2024; v8.1.2 document Mar 2025)	Current	Free; CIS licence
CIS	CIS Microsoft Windows Server Benchmarks (W32Time items)	Not verified this pass	See caveats	Free PDF with registration
IETF	RFC 5905, 8633, 8915, 7822, 9109, 5906, 4330	2006–2021	See Section B	Free; IETF Trust

3. Section A: Microsoft official guidance by topic

A1. Support boundary for high accuracy time - **URL:**
learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/support-boundary-

high-accuracy-time. A parallel copy sits at /windows-server/networking/windows-time-service/support-boundary. - **Version:** last updated 2026-02-12. This is the successor to KB939322. The Learn articles still cite “Knowledge Base article 939322” by name. - **Applies to:** “Supported versions of Windows Server” and “Windows Server (All supported versions) including Azure Stack HCI, Windows client (All supported versions)”. Server 2025 is not named, but the “all supported versions” wording covers it. - **Scope:** systems before Windows 10 1607 / Server 2016 1607 “can’t guarantee highly accurate time”. They were designed only for Kerberos-level accuracy. - **Accuracy tiers:** Windows 10, Server 2016 and newer releases “can deliver 1 second (s), 50 milliseconds (ms), or 1 ms accuracy” under the right conditions. Accuracy is “highly dependent on using an accurate, stable root (stratum 1) time source”.

Target	Requirements
1 s	Windows 10 / Server 2016 or newer. Hierarchy ends at a highly accurate source. Every Windows node is configured per “Configuring Systems for High Accuracy”. Cumulative one-way latency ≤100 ms.
50 ms	Everything for 1 s, plus: <5 ms latency to the time source; no further than stratum 5; six or fewer network hops; one-day average CPU ≤90% (on the host too, if virtualized).
1 ms	Everything for 50 ms, plus: <0.1 ms latency; no further than stratum 5; four or fewer hops; CPU ≤80%.

- **Licence:** Microsoft Terms of Use.

A2. Accurate Time / Configuring systems for high accuracy - These pages back the “up to 1 ms” claim. The W32Time hub page says “you can maintain a 1-ms accuracy with respect to UTC or better” for Server 2016 / Windows 10 Anniversary Update domain members “under reasonable operating conditions”. - “Configuring systems for high accuracy” says “most customers don’t require highly accurate time”. - It requires every device in the chain, including the Hyper-V host and the upstream Windows time server, to be Windows 10 / Server 2016 or later. - It covers the W32Time startup type. Third-party summaries paraphrase this as “Automatic, always running”. I did not re-read the exact sentence in this pass. - The content is Server 2016-era but still the current publication.

A3. Secure Time Seeding recommendations for Windows Server - **URL:** learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/sts-recommendations-for-windows-server. Last updated 2026-02-12. - **Defaults (confirmed):** - STS is “enabled by default in all editions of Windows Server 2016, Windows Server 2019, and Windows Server 2022”, and in Windows clients from Windows 10 version 1511 onward. - It is “disabled by default in Windows Server 2025, based on customer feedback”. - **Recommendations:** - Disable STS on Server 2016+ machines running time-sensitive workloads, explicitly naming AD DS domain controllers and VM hosts. - “Consider disabling” it on all other Windows Server machines. - On Server 2025, verify that the settings meet your needs. - **Control:** - GPO: Computer ConfigurationTemplatesTime ServiceConfiguration Settings

→ UtilizeSslTimeData. - Registry: HKLM32Time(REG_DWORD; 0 = disabled, 1 = enabled). A reboot is required. - **Verification:** Time-Service Operational events 257/260/263, or the w32time debug log. - **Monitoring:** the page suggests watching System log Kernel-General Event 1 for large time changes. - **Scope:** the recommendation does not extend to client SKUs. - **Message center:** a Microsoft 365 message center post (MC1085489, mid-2025) was reported by third-party trackers as recommending disablement on Server 2016–2025. I did not view it on a Microsoft page.

A4. Maximum tolerance for computer clock synchronization - This is a Kerberos policy. It sets "the maximum time difference (in minutes) that Kerberos V5 tolerates" between client and DC clocks. - The current page advises 5 minutes. The legacy Server 2003 page states the policy "is set to 5 minutes by default" and explains the replay-attack rationale. - Location: Default Domain Policy → Computer ConfigurationSettingsSettingsPoliciesPolicy.

A5. Windows Time service tools and settings - **Version:** last updated 2025-09-18. Applies to Server 2025/2022/2019/2016, Windows 11/10 and Azure Local. - **Network:** W32Time uses UDP 123. The built-in client always uses 123 as its source port. /stripchart uses an ephemeral port. - **w32tm syntax (confirmed):** - `/config [/computer:] [/update] [/manualpeerlist:] [/syncfromflags:MANUAL|DOMHIER] [/reliable:YES|NO] [/largephaseoffset:]` - `/query {/source|/configuration|/peers|/status} [/verbose]` - `/monitor [/domain:] [/computers:] [/threads:]` - `/resync [/computer:] [/nowait] [/rediscover] [/soft]` - `/stripchart /computer: [/period:] [/dataonly] [/samples:] [/rdtsc]` - Also `/debug`, `/dumpreg` and `/tz`. - **Multiple peers:** with more than one peer, Microsoft recommends "three or more time servers". With only two, flag one as `UseAsFallbackOnly` (0x2).

Registry value	Meaning / default
AnnounceFlags	Bitmask: 0x1 always time server; 0x2 automatic; 0x4 always reliable; 0x8 automatic reliable. Default 10.
EventLogFlags	0x1 time jump; 0x2 source change. Default 2.
MaxPosPhaseCorrection / MaxNegPhaseCorrection	Domain members 0xFFFFFFFF (always correct); DCs 172,800 s (48 h); stand-alone 54,000 s (15 h).
SpecialPollInterval	GPO default 1024 s.
NtpServer	Default `time.windows.com,0x9`.
Type	NT5DS for domain-joined computers; NTP for non-joined. Also NoSync and AllSync.
UtilizeSslTimeData	Default 1, except Server 2025, where it is 0.

- **GPO caveat:** the "Global Configuration Settings" GPO table lists UtilizeSslTimeData = 1 as its default. Enabling that GPO without editing the value could re-enable STS. This is my inference from the published table, not a Microsoft warning.

A6. How the Windows Time Service works; AD time hierarchy - **Version:** last updated 2025-07-25. - **Protocol:** W32Time "isn't an exact implementation" of NTP. Its NTP provider "follows the standards specified by NTP version 3". It does not support broadcast or multicast

peers. - **Hierarchy:** - In a forest, the forest-root PDC emulator “holds the position of best time source, unless another reliable time source has been configured”. - The first DC is automatically a reliable source and should sync externally. - The PDC emulator of a child domain can sync from the parent domain. - **Ranking:** DCs are scored as follows: same site 8, reliable 4, parent domain 2, PDC emulator 1. - **Moving the PDC emulator role:** the external configuration does not follow the role. This comes from the legacy Server 2008 R2 page “Configuring a time source for the forest”, which tells admins to reconfigure both old and new PDC emulators when the role moves. As an alternative, it suggests configuring a non-PDC DC in the forest root as the reliable source. I found no current Learn page restating this, so treat it as legacy-sourced.

A7. NTP authentication and NTS - **Inside the forest:** packets are signed with the computer’s Kerberos session key, managed by Net Logon. Unsigned or badly signed replies are rejected. - **Outside the forest:** “Manually specified time sources are not authenticated unless a specific time provider is written for them”. Cross-forest sync “is not secure”. - **NTS:** no Microsoft page documents NTS (RFC 8915) support. Microsoft also documents no RFC 5905 symmetric-key (key ID / MAC) configuration for W32Time’s external peers. Autokey is not mentioned. NIST’s authenticated servers do not support Autokey either. - **Practical effect:** NIST’s and USNO’s authenticated services require an NTP implementation or appliance that supports keyed MACs, not built-in W32Time. This is my inference from the absence of any configuration surface.

A8. Virtualized domain controllers - “Virtualizing domain controllers with Hyper-V” (current) recommends disabling host-to-guest time sync for DC VMs, “If the guest DC doesn’t synchronize with the host system, then it synchronizes with the domain hierarchy instead”. The method is to turn off the VM, open Integration Services and clear Time synchronization. - The AskDS TechCommunity post “VMICTimeProvider vs AD” recommends disabling the VMICTimeProvider (W32Time, Enabled=0) on DCs so they follow the forest-root PDC. - Older archived Microsoft blogs recommended a “partial disable”: leave the integration service on but set VMICTimeProvider Enabled=0, so host time applies only after a restore from saved state. The two approaches differ, so check them against your hypervisor platform. - When the host is the source, `w32tm /query /status` shows “VM IC Time Synchronization Provider”.

A9. W32Time event IDs (System log, Microsoft-Windows-Time-Service)

ID	Meaning	Source page
24	Domain peer gave no valid response; it is discarded and NtpClient rediscovers.	Learn previous-versions
29	No configured sources are accessible.	Not confirmed on a Microsoft page; third-party wording only
35	Now synchronizing with time source %1.	Learn previous-versions
36	“Has not synchronized the system time for %1 seconds because none of the time service providers provided a usable time stamp.”	Learn previous-versions

ID	Meaning	Source page
37	NtpClient receiving valid time data; confirms sync.	Example log in a Learn troubleshooting article
47	Manual peer gave no valid response after 8 attempts; it is discarded.	Learn previous-versions
50	Time difference greater than %1 ms for %2 s; no longer synchronized.	Learn previous-versions
129	Domain peer discovery error; retry in 15 minutes.	Learn previous-versions
134	DNS resolution error for the manual peer.	Learn previous-versions
142	Stopped advertising as a time source because the local clock is not synchronized.	Learn previous-versions
144	Stopped advertising as a good time source; check AnnounceFlags.	Learn previous-versions

Most of these descriptions sit on Server 2008 R2 “previous-versions” pages, which are legacy but still the only Microsoft catalogue of these events. Events 137/138 indicate recovery, and 139/143 indicate the server started advertising.

4. Section B: US government and standards guidance by publisher

NIST (Time and Frequency Division, Boulder/Gaithersburg) - **Internet Time Service** (nist.gov/pml/time-and-frequency-division/time-distribution/internet-time-service-its; updated 2026-06-09): - NIST runs stratum-1 servers traceable to UTC(NIST) over NTP, DAYTIME and TIME. Users are urged to move from TIME/DAYTIME to NTP. - The status mailing list (a Google Group) is joined by emailing internet-time-service@nist.gov. - A NIST data-repository record puts ITS accuracy “on the order of 0.001 seconds (one millisecond)”, depending on network conditions. The ~1 ms claim is therefore confirmed as NIST’s own wording, about UTC(NIST) as distributed and not end-user accuracy. - **Server list** (tf.nist.gov/tf-cgi/servers.cgi; live):

Location	Servers
Gaithersburg	time-a-g to time-e-g; time-f-g is a “New implementation; NTP only”
Fort Collins (WWV)	time-a-wwv to time-e-wwv
Boulder	time-a-b to time-e-b
UT1	ut1-wwv.nist.gov, which serves UT1, not UTC

- Some hosts also have IPv6 addresses.

- time.nist.gov resolves round-robin across all servers, and NIST encourages using that name.
- Users must “NEVER” query more often than “once every 4 seconds”. Faster clients are refused, and extreme cases “may be considered as attempting a denial-of-service attack”.
- NIST also warns against hard-coding server names or addresses.
- **Authenticated NTP Service** (updated 2026-09-17):
  - It uses symmetric-key MACs per RFC 5905. Servers: ntp-b.nist.gov (Boulder), ntp-wwv.nist.gov (Fort Collins) and ntp-d.nist.gov (Gaithersburg).
  - It is free. Requests must arrive in writing by US mail or fax, with up to four static IPv4 addresses. NIST “will not use email for sending key data”.
  - Supported key types: MD5, SHA1, SHA256, HMAC-SHA256 and SHA3-256.
  - The servers answer only registered IPv4 addresses. NAT can complicate registration.
  - Keys with no logged use over a 30-day window near fiscal year-end (September 30) are deleted without notice.
  - Autokey: “No”. NTS key exchange: “Not yet”.
- **Discrepancy:** an older NIST data-repository record says the authenticated service “uses public key encryption”. The current service page says symmetric key. The service page is the authoritative one.
- **Leap seconds:**
  - tf.nist.gov/leap-seconds.list is confirmed. It lists past and announced leap seconds and is updated at least twice a year from IERS (International Earth Rotation and Reference Systems Service) bulletins.
  - NIST servers insert a positive leap second by repeating 23:59:59 and announce it from 00:00 UTC on the last day of the month.
- **SP 800-53 Rev. 5** (Release 5.2.0, 27 Aug 2025):
  - AU-8 “Time Stamps”: use internal system clocks to generate audit timestamps, at organization-defined granularity, in UTC, at a fixed UTC offset, or with the offset included.
  - AU-8(1) and AU-8(2) are “[Withdrawn: Moved to SC-45(1)]” and “[…SC-45(2)]”. This is a Rev. 5 change from 2020, not a 5.1.1 or 5.2.0 change.
  - SC-45(1) is compare-and-sync with an authoritative source. SC-45(2) is a secondary authoritative source in a different geographic region.
  - Third-party mappings report that SC-45 is not in the SP 800-53B Low, Moderate or High baselines, though it appears in SP 800-82r3 OT overlays. This should be checked against the 800-53B spreadsheet.
  - All are public domain US government works.
- **SP 800-92:** Guide to Computer Security Log Management (final, 13 September 2006) is still the current final version. NIST’s CSRC lists SP 800-92 Rev. 1, “Cybersecurity Log Management Planning Guide”, as “Status: Draft”, with an initial public draft dated 11 October 2023.

USNO (US Naval Observatory, via cnmoc.usff.navy.mil) - **Public servers:** the "US Eastern Time Zone NTP Servers" page is live and lists tick.usno.navy.mil, tock.usno.navy.mil and ntp2.usno.navy.mil. Each is described as "NTP V4 primary (USNO Master Clock H-masers)" with "Open access for MIL, GOV, and other stratum 2 servers". - **Other pages:** a "US Mountain Time Zone Servers" page also exists; I did not fetch it. The Network Time Foundation wiki entries for these hosts were updated by USNO on 10 Jul 2026. They list stratum 1, "Supports NTS · No" and no symmetric key on the public hosts. - **DoD Customer Servers page:** - DoD entities should use only the DoD authenticated USNO NTP servers "and NOT" the public tick, tock, ntp2, tick.usnogps or tock.usnogps. - The authenticated service covers DoD and US government agencies on NIPR and SIPR. Requests go by signed email to usno-ops-center@us.navy.mil. - SHA256 keys are "highly recommended". SHA1 and MD5 are legacy and "may soon be deprecated". - The NTS notice is stale: it still says "projected… beginning in 1QTR 2025" under "COMING SOON". - **URL change:** the old usno.navy.mil/USNO/time/ntp/dod-customers address has been replaced by the CNMOC pages. Some STIG text still cites the old URL. - **What could not be confirmed:** whether the hosts answer NTP right now, since I could not run a live NTP probe, and the details of the 2023 disruption. The publisher pages and the July 2026 directory updates suggest the service is operational.

CISA / NSA / OMB - **NSA, Network Infrastructure Security Guide** (v1.2, Oct 2023): sync devices "with at least two different NTP servers", enable NTP authentication with strong, unique keys, and verify synchronization after configuration. - **Best Practices for Event Logging and Threat Detection** (21 Aug 2024): led by Australia's ASD/ACSC and co-sealed by CISA, NSA and FBI. It recommends "an accurate and trustworthy time source" used consistently, "multiple accurate time sources", UTC as the "preferred time standard", and millisecond timestamps. Because the lead author is non-US, cite it via CISA's page. - **Enhanced Visibility and Hardening Guidance for Communications Infrastructure** (Dec 2024, multinational, CISA-hosted): apply secure authentication to NTP where possible. - **CISA "Time – The Invisible Utility"** (Feb 2023): general resilient-timing guidance. Not specific to logging. - **OMB M-26-14** (22 May 2026, signed by Director Russell T. Vought): states "Effective immediately, OMB Memorandum M-21-31 is rescinded." - Its Appendix B requires logs to "include a consistently accurate timestamp" with network time synchronized by NTP or equivalent "to a traceable time source designated within the agency". - It encourages "authoritative time sources traceable to the U.S. Naval Observatory or the National Institute of Standards (NIST), where feasible". - It does not apply to national security systems. - Its predecessor, M-21-31 (27 Aug 2021), had required a GPS master clock first, then NIST's authenticated service, with public unauthenticated NTP pools only as "an option of last resort". - No CISA or NSA item found is specific to DHCP or NTP server configuration on Windows.

DISA STIGs (free; public.cyber.mil)

Rule	STIG / version	Severity	What it requires
V-243504 (AD.0295, SV-243504r1026204)	Active Directory Forest	Medium / CAT II; maps to AU-8, CCI-001891	The forest-root PDC emulator must take time from an external source. It is a finding if NtpServer "is not an external

Rule	STIG / version	Severity	What it requires
			DOD time source".
V-278029 (WN25-00-000440, SV-278029r1182267)	Windows Server 2025, V1R1	Low / CAT III	"Must synchronize with an appropriate DOD time source". Fix text points to USNO stratum-1 servers via the legacy usno.navy.mil DoD-customers URL.
V-254281 (WN22-00-000440, SV-254281r1051090)	Windows Server 2022	Low / CAT III	Same requirement. Newer releases cite the CNMOC USNO URL.
V-205800	Windows Server 2019	Not re-verified	Rule ID confirmed (SV-205800r569188 in V2R2, 2021).
V-224862	Windows Server 2016	Not verified	—

- For the Windows Server rules, domain-joined systems must use NT5DS. The PDC emulator and stand-alone systems set to Type NTP must point at a DoD server.
- The Server 2025 V1R1 release removed draft rule V-277984 ("government-approved time source").
- Kerberos skew: Windows Server 2019 rule V-205706 (WN19-DC-000060, Medium) requires 5 minutes or less.

CIS (Center for Internet Security) - **CIS Controls v8.1, Safeguard 8.4 "Standardize Time Synchronization":** "Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported." It applies to IG2 and IG3. It replaced v7.1 6.1, "Utilize Three Synchronized Time Sources". The Controls are free under a CIS licence. - **CIS Windows Server Benchmarks:** I could not confirm the specific W32Time recommendations from the current benchmark documents, which are registration-gated PDFs. Treat the prior pass's list (EventLogFlags, MaxPos/NegPhaseCorrection, AnnounceFlags, NtpClient Type/SpecialPollInterval, NtpServer Enabled) as unverified.

IETF (primary for protocol)

RFC	Title	Date	Status / notes
RFC 5905	Network Time Protocol Version 4: Protocol and Algorithms Specification	June 2010	Proposed Standard. Obsoletes RFC 1305 and RFC 4330. Defines symmetric-key MACs.
RFC 8633 / BCP 223	Network Time Protocol Best Current Practices	July 2019	Best Current Practice. Covers multiple and diverse sources,

RFC	Title	Date	Status / notes
			restricting queries and ingress/egress filtering, broadcast mode only on trusted networks, leap-second files, and restart/panic-threshold defences.
RFC 8915	Network Time Security for the Network Time Protocol	September 2020	Proposed Standard. TLS key establishment on TCP/4460 plus AEAD-protected NTP.
RFC 7822	NTPv4 Extension Fields	March 2016	Proposed Standard; updates 5905.
RFC 9109	Network Time Protocol Version 4: Port Randomization	August 2021	Proposed Standard; updates 5905. Recommends ephemeral source-port randomization where the well-known port is not required. W32Time's built-in client uses source port 123, which does not follow this.
RFC 5906	Network Time Protocol Version 4: Autokey Specification	June 2010	Informational, not standards-track. Superseded in practice by NTS.
RFC 4330	SNTPv4	January 2006	Obsoleted by RFC 5905.

- RFCs are free under the IETF Trust Legal Provisions.
- pool.ntp.org is a volunteer community project, not US government. Rescinded OMB M-21-31 treated such pools as a last resort. Its successor, M-26-14, instead calls for an agency-designated traceable source and encourages USNO/NIST traceability.

5. Topic crosswalk

Topic	Microsoft	NIST	USNO	DISA	CIS	IETF	CISA/ NSA (+OMB)
Authorit	Forest-	—	—	V-	—	—	—

Topic	Microsoft	NIST	USNO	DISA	CIS	IETF	CISA/ NSA (+OMB)
ative internal source (PDC emulator)	root PDC emulator is the best source; first DC reliable; NT5DS hierarchy			243504: forest-root PDC uses external DoD source			
External upstream selection	External NTP, GPS or hardware device; three or more peers, or two with fallback flag	time.nist.gov; authenticated ntp-b/-wwv/-d	Public tick/tock /ntp2; DoD must use authenticated servers	“Appropriate DoD time source” (USNO)	At least two sources	Multiple, diverse sources (8633)	OMB M-26-14: agency-designated traceable source, USNO/NIST traceability encouraged; NSA: two or more servers
Stratum/ accuracy targets	1 s / 50 ms / 1 ms tiers; stratum ≤5; stratum-1 root	ITS about 1 ms (UTC(NIST))	Stratum 1, H-maser referenced	—	—	Stratum model (5905)	Logging guide: millisecond timestamps
Kerberos 5-minute skew	Policy; 5 minutes advised and default	—	—	V-205706: 5 minutes or less	—	—	—
Virtualized DC time	Disable host time sync or VMICTi	—	—	—	—	—	—

Topic	Microsoft	NIST	USNO	DISA	CIS	IETF	CISA/ NSA (+OMB)
	meProvider on DCs						
NTP authentication (NTS/symmetric/Autokey)	Domain-only Kerberos-signed; external peers unauthenticated; no NTS documented	Symmetric (MD5–SHA3-256); no Autokey; NTS “not yet”	Symmetric (SHA256 preferred); NTS “coming soon” (stale)	Authenticated DoD sources implied	—	NTS (8915) current; Autokey informational	NSA: enable NTP auth; OMB M-21-31 (rescinded) had specified NIST authenticated
Secure Time Seeding	On in 2016–2022, off in 2025; disable on DCs and VM hosts	—	—	Not addressed in rules reviewed	Not verified	—	—
Monitoring/drift alerting	w32tm /monitor, /stripchart; events 36/47/50/142; Kernel-General 1	Status mailing list	—	Check via w32tm /query	—	Monitoring guidance (8633)	NSA: verify sync after changes
Logging timestamp sync (AU-8)	—	AU-8; SC-45(1)/(2)	—	Rules mapped to AU-8(1) and new CCIs	8.4 under Control 8 (Audit Log Mgmt)	—	OMB M-26-14 timestamp/NTP requirement; joint logging guide (UTC)
Leap seconds	Not covered in	leap-seconds.list; NIST	Has leap-second pages	—	—	Leap indicator (5905);	—

Topic	Microsoft	NIST	USNO	DISA	CIS	IETF	CISA/ NSA (+OMB)
	reviewed pages	repeat-23:59:59 method				leap file (8633)	
NTP server hardening (restrict queries, port randomization)	W32Time server/client share UDP 123; client source port fixed	4-second minimum interval enforced	Access limited to MIL/GOV /stratum -2	—	Benchmark items unverified	Restrict queries and filtering (8633); port randomization (9109)	NSA: authenticated NTP on devices
SNTP/ client config	SNTP backward-compatible; NtpClientType/NtpServer/SpecialPollInterval	Notes SNTP clients do no averaging	—	NT5DS for members	—	RFC 4330 obsolete → 5905	—

6. Agreements, differences and conflicts

- **Default accuracy vs high accuracy.** All sources agree that "loose" sync is enough for Kerberos's 5 minutes. Microsoft supports tighter accuracy only under explicit conditions: Windows 10 / Server 2016 or later throughout, a stratum-1 root, stratum 5 or less, and latency and CPU caps. NIST's ~1 ms is the accuracy at the server, not what a Windows client is guaranteed. In practice, sub-second goals need the Microsoft support-boundary conditions, and audit granularity (AU-8) is set by the organization.
- **W32Time lacks NTS vs authenticated time in IETF and US government guidance.**
  - RFC 8915 is the current IETF standard. NSA, NIST and USNO all favour authenticated time, as did the now-rescinded OMB M-21-31.
  - W32Time authenticates only inside the forest. External peers, including the PDC emulator's upstream, are unauthenticated.
  - NIST does not offer NTS yet, and USNO's NTS is "coming soon". The authenticated US government options today are symmetric-key services that need a keyed-MAC-capable client or appliance, not built-in W32Time.
- **STS default debate.** Microsoft changed the Server 2025 default and recommends disabling STS on DCs and VM hosts. It does not extend this to Windows clients, where STS stays on by default. The DISA and CIS items reviewed say nothing about STS, which is a gap rather than a conflict.

- **Direct NIST/USNO vs internal hierarchy.** Every source agrees that only the top of the hierarchy (the PDC emulator or an appliance) should reach external sources. Everyone else uses NT5DS. NIST's 4-second limit and anti-hard-coding advice, and USNO's "stratum 2 servers" access policy, both assume enterprises run an internal tier and do not point every host at them.
- **pool.ntp.org.**
  - It is non-governmental. Rescinded OMB M-21-31 limited unauthenticated public pools to a last resort. Its successor, M-26-14 (22 May 2026), drops that wording and requires "a traceable time source designated within the agency", encouraging USNO- or NIST-traceable sources.
  - Microsoft's own default for non-domain machines is time.windows.com, not the pool.
  - STIG environments must use DoD sources.
- **Leap seconds.**
  - NIST still publishes leap-seconds.list and implements leap seconds by repeating 23:59:59.
  - The CGPM's 2022 Resolution 4 committed to ending leap seconds by or before 2035. The 28th CGPM (15 Oct 2026) adopted Resolution 5, which makes UTC continuous from 20 May 2027 with a one-hour long-term limit on |UT1−UTC|. This is confirmed in a BIPM statement by CCTF President Noël Dimarcq.
  - Leap-second handling becomes moot after May 2027. Until then the existing NIST and IETF mechanisms apply.
- **STIG severity vs importance.** DISA rates the forest-root PDC rule CAT II but the per-server "DOD time source" rules CAT III. This makes the PDC configuration the higher-priority control.

7. Caveats, corrections and unverified items

Corrections to the prior pass 1. **W32Time authentication.** W32Time's built-in authentication is not RFC 5905 symmetric-key. It is a Microsoft domain mechanism using Kerberos/Net Logon session keys, and it works only inside the forest. External peers are unauthenticated. "Symmetric-key" correctly describes the NIST and USNO services, not W32Time. 2. **STIG severity.** Windows Server 2022 V-254281 and Server 2025 V-278029 are Low / CAT III. Only AD Forest V-243504 is CAT II. The Server 2025 equivalent is V-278029 / WN25-00-000440. 3. **NIST 800-53.** AU-8(1)/(2) were withdrawn to SC-45(1)/(2) in Rev. 5 itself (2020). This is not a 5.1.1 or 5.2.0 change. Release 5.2.0 (Aug 2025) is current. 4. **Leap seconds.** "End by 2035" is outdated. The October 2026 CGPM Resolution 5 sets 20 May 2027, as confirmed in a BIPM statement by the CCTF President. 5. **USNO URLs.** The usno.navy.mil/USNO/time/ntp/dod-customers URL is legacy. The current pages are under cnmoc.usff.navy.mil. The public hostnames remain listed, but USNO tells DoD users not to use them. 6. **Support boundary applicability.** The support boundary's "applies to" now reads "all supported versions". Server 2025 is not listed by name.

Unverified or secondary-only - **OMB:** M-21-31 is no longer the controlling memo. OMB M-26-14 (22 May 2026, whitehouse.gov) states "Effective immediately, OMB Memorandum M-21-31 is rescinded", and its Appendix B now sets the logging timestamp/NTP requirement. - **USNO:** live

NTP reachability of the hosts was not tested. Details of the 2023 outage were not verified. - **CIS:** the CIS Windows Server Benchmark W32Time items were not confirmed. DISA V-224862 (Server 2016) and the V-205800 (Server 2019) severity were not re-verified. - **W32Time event 29:** no Microsoft page was found. Most event descriptions come from legacy Server 2008 R2 pages. - **Microsoft pages:** - The PDC-emulator role-transfer guidance comes from a legacy Server 2008 R2 page. - The STS message center item MC1085489 was seen only via third-party trackers. - The exact wording of the “always running” startup-type statement was not re-read. - **NIST:** SC-45’s absence from the 800-53B baselines is based on third-party mappings. NIST’s CSRC confirms SP 800-92 Rev. 1 is still a Draft (initial public draft 11 October 2023). - **Joint logging guide:** it is ASD-led with CISA, NSA and FBI co-sealing. It is included only as a CISA/NSA co-sealed product.

Licence and reuse notes - **US government works:** NIST, OMB, NSA, CISA, DISA and USNO materials are generally US government works not subject to US copyright (17 U.S.C. §105). Check individual pages for third-party content. - **Microsoft Learn:** governed by Microsoft’s Terms of Use. Some source repositories carry their own open licences. - **IETF RFCs:** IETF Trust Legal Provisions. - **CIS Controls and Benchmarks:** free under CIS’s own licence terms, which generally allow non-commercial use. Check before redistributing. - **Third-party STIG viewers** (stigviewer, Tenable, cyber.trackr.live) were used only to read rule text. Download the authoritative STIGs from DISA (public.cyber.mil).

US Reference Collection: Certificate Authority Design and Implementation with Microsoft AD CS (Windows PKI) — Status as of October 2026

The US baseline for a Windows enterprise PKI comes from three kinds of source that fit together. Microsoft's guidance supplies the AD CS–specific design and configuration rules. NIST supplies the cryptographic and key-management rules. CISA/NSA and DISA supply the hardening and detection expectations. The most consistent message across all of them is that **AD CS is Tier 0 identity infrastructure**. Its CA keys, templates and enrollment endpoints can compromise an entire domain, which is why the 2025 Microsoft enforcement changes (strong certificate mapping and NTAuth chaining) are now mandatory with no registry bypass.

1. TL;DR — summary of the US guidance baseline

- **Design baseline (Microsoft):** use a two-tier hierarchy (offline standalone root plus online enterprise issuing CA) for most organizations; avoid single-tier in production; configure CDP/AIA (HTTP-first) before issuing any certificate; renew the CA certificate at half-life; protect CA keys with an HSM where feasible. Since KB5014754 (registry bypass removed September 9, 2025) and KB5057784 (NTAuth bypass support removed October 14, 2025), certificate-based logon fails unless certificates are strongly mapped and chain to a CA in NTAuth. AD CS on Windows Server 2025 gained ML-DSA issuance in May 2026 (KB5087539).
- **Government baseline (US):** NIST SP 800-57 Pt 1 Rev 5 is still the final key-management reference (Rev 6 was in draft from December 2025). SP 800-131A Rev 2 is the algorithm-transition rule in force (the Rev 3 draft would retire SHA-1/SHA-224 after 2030). The draft NIST IR 8547 proposes deprecating RSA/ECDSA at 112-bit strength after 2030 and disallowing quantum-vulnerable algorithms after 2035. CISA/NSA (jointly with Five Eyes partners) treat AD CS compromise and "Golden Certificate" theft as top-17 AD attack techniques. DISA's AD Forest STIG makes CA certificate-manager approval and Tier 0 PAW management CAT I (high) requirements.
- **What is *not* binding on internal PKI:** the CA/Browser Forum Baseline Requirements, including the 200-day maximum for public TLS since March 15, 2026, falling to 47 days in 2029. Internal AD CS CAs set their own policy. The authorities differ most on validity periods, whether OCSP is required (no US authority mandates it for internal PKI), and how fast to drop RSA/SHA-1. Note also that NIST timelines in late 2026 rest partly on drafts.

---

2. Guidance landscape overview

Publisher	Key document(s)	Date / version	Status (Oct 2026)	Access / licence
Microsoft (Learn)	PKI design considerations using AD CS	ms.date 2023-08-09; metadata updated 2025-06-05; applies to WS 2016–2025	Current	Free; Microsoft Terms of Use

Publisher	Key document(s)	Date / version	Status (Oct 2026)	Access / licence
Microsoft (Learn)	What is AD CS (overview)	Current page	Current	Free
Microsoft (Learn)	Prepare the CAPolicy.inf file	Current page (Core Network Guide)	Current	Free
Microsoft (Learn)	Install-AdcsCertificationAuthority (ADCSDeployment module)	windowsserver2025-ps view	Current	Free
Microsoft (Learn, previous-versions)	Securing Public Key Infrastructure (PKI), incl. Appendices A–F	WS 2012/2012 R2 era (2014)	Legacy, archived; still the deepest Microsoft hardening text	Free
Microsoft (Learn, previous-versions)	Test Lab Guide: Deploying an AD CS Two-Tier PKI Hierarchy	WS 2012/2012 R2 era	Legacy	Free
Microsoft Support	KB5014754 Certificate-based authentication changes on Windows DCs	May 10, 2022; revised 9/10/2025	Current; final phase complete Sept 9, 2025	Free
Microsoft Support	KB5057784 Protections for CVE-2025-26647	April 8, 2025	Current; final phase Oct 14, 2025	Free
Microsoft Support / MSRC	KB5005413 / ADV210003 NTLM relay to AD CS	July 23, 2021 (revised July 28, 2021)	Current mitigation	Free
MSRC	CVE-2024-49019 (AD CS EoP, “ESC15”)	Nov 12, 2024	Current	Free
Microsoft TechCommunity	Secure Configuration and Hardening of AD CS (Core Infrastructure & Security blog)	Oct 22, 2025	Current (blog, not formal docs)	Free

Publisher	Key document(s)	Date / version	Status (Oct 2026)	Access / licence
Microsoft TechCommunity	New Windows Features to Secure Today's Data in a Post-Quantum World; PQC APIs GA	Nov 2025 (APIs GA); May 2026 (AD CS ML-DSA GA)	Current	Free
NIST	SP 800-57 Part 1 Rev 5	May 2020	Final, current; Rev 6 ipd Dec 5, 2025 (comments closed Feb 5, 2026)	Free; US Government work
NIST	SP 800-131A Rev 2 / Rev 3 ipd	Rev 2 March 2019; Rev 3 ipd Oct 21, 2024	Rev 2 in force; Rev 3 draft	Free; US Gov work
NIST	IR 8547 Transition to PQC Standards	ipd Nov 12, 2024	Draft	Free
NIST	FIPS 186-5; FIPS 204 (ML-DSA); SP 800-208	Feb 3, 2023; Aug 13, 2024; Oct 29, 2020	Final	Free
NIST	SP 1800-16 Securing Web Transactions: TLS Server Certificate Management (Vols A–D)	June 16, 2020	Final	Free; contains industry-contributed content
NIST	SP 800-32 Introduction to Public Key Technology and the Federal PKI Infrastructure	Feb 26, 2001	Withdrawn (legacy)	Free
NIST	SP 800-53 Rev 5 (IA-5(2), SC-12, SC-17)	Sept 2020 (upd. Dec 10, 2020); online release 5.2.0 Aug 27, 2025	Final, current	Free
CISA/NSA (joint, ASD-led with Five Eyes partners)	Detecting and Mitigating Active Directory Compromises	Sept 25, 2024	Current	Free; joint international publication (check licence

Publisher	Key document(s)	Date / version	Status (Oct 2026)	Access / licence
				statement in PDF)
CISA	Alert: Microsoft Releases Guidance for Mitigating PetitPotam	July 27, 2021	Historical/ current pointer	Free; public domain
NSA	Eliminating Obsolete TLS Protocol Configurations (CSI U/OO/197443-20)	Jan 5, 2021	Current	Free
NSA	CNSA 2.0 announcement	Sept 7, 2022; current PDF May 30, 2025	Current	Free
DISA	Active Directory Forest STIG (V-269098, V-269099)	Rules added V3R1 (Sept 13, 2024); V3R2 dated May 15, 2025	Current (latest release to be confirmed at public.cyber.mil)	Free; public release
DISA	Windows Server 2022 STIG (e.g., V-254413 DC certificates from DoD PKI)	Periodic releases	Current	Free
DoD	DoDI 8520.02 Public Key Infrastructure and Public Key Enabling	May 18, 2023	Current	Free
CIS	CIS Controls v8.1 (guide v8.1.2)	March 2025	Current	Free with registration; CC BY-NC-ND 4.0
CIS	CIS Microsoft Windows Server 2022 / 2025 Benchmarks	WS2025 v1.0.0 (Mar 19, 2025), v2.0.0 (Feb 24, 2026); WS2022 v5.0.0	Current	Free PDF for non-commercial use (registration); CC BY-NC-SA 4.0
CA/Browser Forum	TLS Baseline Requirements;	Ballot approved April 2025	Current (public trust only)	Free

Publisher	Key document(s)	Date / version	Status (Oct 2026)	Access / licence
	Ballot SC-081v3			
IETF	RFC 5280, 6960, 5019, 4556, 8894, 8555	2006–2020	Current (see notes)	Free; IETF Trust Legal Provisions
SpecterOps (US practitioner)	Certified Pre-Owned (ESC1–ESC8); Certify 2.0 (ESC1–ESC16)	June 17, 2021; Aug 11, 2025	Current practitioner reference	Free
Mandiant / Google Cloud (US practitioner)	AD CS: Modern Attack Paths, Mitigations, and Hardening; Destructive Attacks 2026 Edition	2023 (AD CS guide); March 2026	Current practitioner reference	Free (some downloads gated)

3. Section A — Microsoft official guidance (by topic)

A1. AD CS role overview and what's new (Windows Server 2022/2025, PQC)

What is Active Directory Certificate Services? — Microsoft Learn — https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/active-directory-certificate-services-overview — current; free. - *Scope:* describes AD CS as a Windows Server role for issuing and managing PKI certificates. Role services covered: Certification Authority (root/subordinate), Web Enrollment, Online Responder, NDES, Certificate Enrollment Policy Web Service (CEP), and Certificate Enrollment Web Service (CES). Also covers TPM key attestation. - *Key points:* certificates bind an identity to a private key. Enterprise integration uses Active Directory identity data and Group Policy to control which users and machines get which certificate types. TPM key attestation prevents export to unauthorized devices.

Post-quantum (ML-DSA) in AD CS — Microsoft Security blog on TechCommunity, "New Windows Features to Secure Today's Data in a Post-Quantum World" (2026) and "Post-Quantum Cryptography APIs Now Generally Available on Microsoft Platforms" (November 2025) — current; free. - *Timeline:* - ML-KEM and ML-DSA became generally available in the CNG/SymCrypt libraries and certificate functions on Windows 11 (24H2/25H2) and Windows Server 2025 in the November 2025 update. - Microsoft states that "ADCS support for issuance of ML-DSA certificates in Windows Server 2025 is now generally available as of May 2026." Microsoft's own KB5087539 release notes (May 12, 2026; OS Build 26100.32860) confirm this; the AD CS entry, added May 15, 2026, says the update "adds support for Module-Lattice-Based Digital Signature Algorithm (ML-DSA) post-quantum signatures in Active Directory Certificate Services (AD CS)." The Windows Server release-information table on Microsoft Learn lists the same date, build and KB. - *Capabilities stated:* three parameter sets (ML-DSA-44, -65, -87). Quantum-resistant signing across CAs and OCSP Responders. Microsoft frames this as a way to

evaluate PQC issuance and validation workflows. - *Coming next:* composite ML-KEM and composite ML-DSA are in Windows Insider preview and are expected to reach general availability later. - *Practitioner claims (not Microsoft-verified here):* US practitioner sources (Richard Hicks, Microsoft MVP; Encryption Consulting, a vendor) state that existing CAs cannot be converted in place, so a parallel ML-DSA hierarchy is needed. They also report that late-2025 updates added CRL partitioning and 16K database page support. Treat these as secondary until confirmed in Microsoft's AD CS "What's new" documentation.

A2. PKI design considerations (hierarchy, CA types, validity, CDP/AIA)

PKI design considerations using Active Directory Certificate Services — Microsoft Learn (author metadata: Orin Thomas) — https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/pki-design-considerations — ms.date 2023-08-09, metadata updated 2025-06-05; applies to Windows Server 2016/2019/2022/2025; **current**; free. Verified directly. - *Scope:* a high-level planning checklist covering PKI plan, HSM, CAPolicy.inf, cryptographic options, CA name, validity period, CA database, AIA/CDP. - *Key recommendations (paraphrased):* - Decide the number and configuration of CAs before installing any. For example, decide between an Enterprise and a Standalone root, and how approval and revocation will work. - If using an HSM, install and configure it *before* setting up any CA whose key it will hold. One network HSM can be shared across CAs. - CAPolicy.inf is optional. If used, it must be in `%systemroot%` before install or renewal. The example root CAPolicy.inf sets RenewalKeyLength=4096, a 20-year renewal validity and LoadDefaultTemplates=0. - Choose provider, hash and key length for what relying applications support. The page lists built-in CSP/KSP capabilities, including the RSA/ECDSA P-256/P-384/P-521 software and smart-card KSPs. - Do not use the FQDN as the CA common name, and do not make the CA name identical to the computer name. A server cannot be renamed after install without invalidating issued certificates. - A CA cannot issue certificates valid beyond its own validity. Best practice is to renew the CA certificate at half its validity period. - Consider separate volumes for the CA database and its logs. Locations are set under `HKLM\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration`. - Configure AIA and CDP *before* the CA issues any certificates, because URL changes affect only newly issued certificates. - Avoid delta CRLs on offline roots. Publish CRLs at an HTTP location for external and non-Windows clients. Windows clients try URLs in order. - *Note:* this page does not prescribe one-, two- or three-tier designs. That tiering guidance is in the legacy Securing PKI text (A12).

A3. CAPolicy.inf

Prepare the CAPolicy.inf File — Microsoft Learn (Core Network Guide, server certificates) — https://learn.microsoft.com/en-us/windows-server/networking/core-network-guide/cncg/server-certs/prepare-the-capolicy-inf-file — current; free. - *Scope:* CAPolicy.inf syntax ([Version] required; [PolicyStatementExtension], [CRLDistributionPoint], [AuthorityInformationAccess], [certsrv_server], [Extensions] etc.) and creation steps. - *Key points:* the file must exist on the host *before* the root CA setup routine runs. It must be saved with an `.inf` extension, not `.txt`. It controls renewal key length and validity, CRL periods, the CPS/policy OIDs, whether default templates load, and which CDP/AIA entries appear in the root certificate. Microsoft's examples use fictitious domains; an internal policy OID in an example is illustrative only.

A4. Deployment cmdlets

Install-AdcsCertificationAuthority (ADCSDeployment module) — Microsoft Learn PowerShell reference — https://learn.microsoft.com/en-us/powershell/module/adcsdeployment/install-adcscertificationauthority?view=windowsserver2025-ps — current; free. - *Scope:* installs and configures the CA role service after `Install-WindowsFeature Adcs-Cert-Authority`. Uninstall is via `Uninstall-AdcsCertificationAuthority`. - *Key points:* - `-CAType` selects EnterpriseRootCa, EnterpriseSubordinateCa, StandaloneRootCa or StandaloneSubordinateCa. - Parameters cover crypto provider (e.g., `RSA#Microsoft Software Key Storage Provider`, `ECDSA_P256#...`), key length, hash algorithm, validity period, parent CA, existing key or certificate reuse, and `-AllowAdministratorInteraction` (used with HSM prompts).

A5. CDP/AIA, CRLs, delta CRLs, overlap, Online Responder

- **Current guidance (A2 page):** configure AIA/CDP before issuance. Prefer HTTP for broad reach; LDAP is usable for domain clients. Avoid delta CRLs on offline roots.
- **Legacy deep guidance:** the Windows Server 2012 R2 "Certification Authority Guidance" page (previous-versions, hh831574) covers configuring CDP/AIA after a root install and validating publication with **Enterprise PKI (PKIView.msc)**. Status: legacy.
- **Online Responder (OCSP):** an AD CS role service that answers certificate status requests (RFC 6960 profile). After the May 2026 update it can sign responses with ML-DSA (A1). Microsoft's detailed "Online Responder Installation, Configuration, and Troubleshooting Guide" dates from the Windows Server 2008 era and is legacy. It was not re-fetched for this collection.
- **CRL overlap and validity settings** (CRLPeriod, CRLOverlapPeriod, CRLDeltaPeriod) are set in CAPolicy.inf (A3) or the CA registry. No current Microsoft page reviewed here prescribes specific values; the legacy TLG examples use weekly base CRLs.

A6. NTAuth store and Enterprise PKI view

- **NTAuth:** the forest-level NTAuthCertificates object lists CAs trusted to issue logon certificates (smart card, PKINIT, and similar) for mapping to AD accounts. Since **KB5057784** (A8), DCs require that logon certificates chain to an issuing CA in NTAuth. Enterprise CAs are published to NTAuth automatically at install. Third-party or standalone CAs must be added explicitly (e.g., `certutil -dspublish -f <cert> NTAuthCA`).
- **PKIView.msc (Enterprise PKI):** an MMC snap-in showing the health of CA certificates, AIA and CDP locations across the hierarchy. Microsoft documents it as the tool to verify publication (hh831574, legacy).

A7. Certificate templates, least privilege, autoenrollment

- **CVE-2024-49019 (MSRC, Nov 12, 2024)** is the clearest current Microsoft statement on template hygiene. Certificates from **version 1 templates** with *Source of subject name = "Supplied in the request"* are potentially vulnerable unless secured per the "Securing Certificate Templates" section of the legacy Securing PKI text. MSRC's recommendations:

  - remove unused templates from CAs;
  - restrict enrollment permissions;
  - require **certificate manager approval** (and/or authorized signatures) for templates that allow enrollee-supplied subjects;
  - monitor what those templates issue.
- **Microsoft Core Infrastructure & Security blog, "Secure Configuration and Hardening of AD CS" (Oct 22, 2025)** — practitioner-level guidance from Microsoft staff, not formal documentation:
  - never allow "Enrollee Supplied Subject" without manager approval;
  - assign approvers through a role group;
  - use the four CA permissions (Read, Manage CA, Issue and Manage Certificates, Request Certificates) in a role-based way;
  - use an offline root and HSMs "if financially feasible."
- **Autoenrollment:** Microsoft's documented model is template permissions (Read + Enroll + Autoenroll) plus the Group Policy setting *Certificate Services Client – Auto-Enrollment* (Computer/User Configuration → Policies → Windows Settings → Security Settings → Public Key Policies). A current Learn page was not re-fetched for this collection.

A8. Domain controller certificates, PKINIT, LDAPS, WHfB, strong mapping, NTAuth chaining

KB5014754 — Certificate-based authentication changes on Windows domain controllers — Microsoft Support — https://support.microsoft.com/en-us/topic/kb5014754-certificate-based-authentication-changes-on-windows-domain-controllers-ad2c23b0-15d8-4340-a468-4d4f3b188f16 — first published May 10, 2022; latest revision 9/10/2025, which corrected the enforcement date to September 9, 2025; **current**; free. - *Scope:* fixes for CVE-2022-26923 ("Certifried"), CVE-2022-26931 and CVE-2022-34691. Enterprise CAs embed the requester's SID in a new certificate extension (OID 1.3.6.1.4.1.311.25.2), and the KDC validates strong mappings. - *Timeline:* - May 10, 2022: Compatibility mode, which logs KDC events 39/40/41 for weak mappings. - **February 11, 2025:** DCs move to Full Enforcement by default unless already configured. Rollback to Compatibility remains possible via `StrongCertificateBindingEnforcement`. - **September 9, 2025:** that registry value is no longer supported. Certificates that cannot be strongly mapped (SID extension or explicit strong `altSecurityIdentities` mapping) are denied. - *Implication for design:* templates used for authentication must be online templates that receive the SID extension, or accounts need explicit strong mappings. This matters especially for offline/SCEP/Intune-issued certificates.

KB5057784 — Protections for CVE-2025-26647 (Kerberos Authentication) — Microsoft Support / MSRC — April 8, 2025; **current**; free. - *Scope:* the KDC now requires that certificates used for Kerberos certificate logon chain to an issuing CA in the **NTAuth** store. The risk arises when a CA is in the root store but not NTAuth and a Subject Key Identifier mapping exists on a privileged account. - *Phases:* - April 8, 2025: Audit. Event 45 is logged when a valid certificate doesn't chain to NTAuth. - July 8, 2025: Enforced by default. `AllowNtAuthPolicyBypass` can revert to audit. - **October 14, 2025:** Microsoft support for `AllowNtAuthPolicyBypass` is discontinued.

DC certificates, LDAPS, PKINIT, Windows Hello for Business (concepts). - DCs need a certificate with KDC Authentication/Server Authentication EKUs. The current default template for this is *Kerberos Authentication*, which supersedes the older *Domain Controller* and *Domain Controller Authentication* templates. - The same certificate enables LDAPS on port 636 and PKINIT (RFC 4556) smart card/WHfB certificate-trust and key-trust logon. - WHfB key trust and cloud Kerberos trust still require DCs to hold valid KDC certificates chaining to NTAuth. - *These template-specific Learn pages were not re-fetched in this collection; verify against current WHfB deployment docs.*

A9. Role separation, auditing, backup, key protection

- **Role separation (Common Criteria):** AD CS defines CA Administrator (Manage CA), Certificate Manager (Issue and Manage Certificates), Auditor (Manage auditing and security log) and Backup Operator. `certutil -setreg CA\RoleSeparationEnabled 1` plus a service restart enforces one role per user. Users holding two roles are then blocked until a local administrator disables enforcement (`certutil -delreg CA\RoleSeparationEnabled`).
  - Securing PKI Appendix A flags Event **4897** ("Role separation enabled") and registry changes to `RoleSeparationEnabled` as alert-worthy.
- **CA auditing:** enable the CA audit filter with all seven categories, value **127**: `certutil -setreg CA\AuditFilter 127`. Also enable *Audit Certification Services* (Object Access) in advanced audit policy.
  - Securing PKI Appendix A lists the Security-log events: **4885** (audit filter changed, high), **4886** (request received), **4887** (approved and issued), 4888 (denied), 4889 (pending), 4890–4892 (settings), 4896 (rows deleted), **4897** (role separation), **4898** (template loaded), **4899** (template updated), **4900** (template security updated), plus **4876/4877** (backup started/completed).
  - Appendix B explains the audit filter values.
- **Backup:** back up the CA database *and* the CA private key/certificate (`certutil -backup` / `Backup-CARoleService`), protect backups like the key itself, and audit backup events (4876). CISA/NSA flag backups as the Golden Certificate exfiltration vector.
- **Key protection:** the legacy Securing PKI text says to use hardware-protected keys and to avoid software keys for CAs unless the PKI is low assurance (lab or proof-of-concept) or an HSM is not operationally or fiscally feasible. It recommends multi-person control and tamper-evident storage of artifacts. The current design page (A2) treats an HSM as optional but requires it to be configured before CA setup. The software KSP keeps the key on the CA's disk, protected by DPAPI, so a CA administrator or SYSTEM-level attacker can export it. TPM key attestation (A1) applies to *subscriber* keys, not CA keys.

A10. Web enrollment, CES/CEP, NDES/SCEP — and ESC8

KB5005413 / ADV210003 — Mitigating NTLM Relay Attacks on AD CS ("PetitPotam") — Microsoft Support and MSRC — released July 23, 2021, revised July 28, 2021; **current**; free. - *Scope:* you are potentially vulnerable if you run **Certificate Authority Web Enrollment** or **Certificate Enrollment Web Service** with NTLM. - *Mitigations:* - enable **Extended Protection for Authentication (EPA)** and **Require SSL** on these IIS sites; - disable NTLM on

AD CS servers (GPO *Network security: Restrict NTLM: Incoming NTLM traffic*) and/or in IIS for these role services; - consider disabling NTLM domain-wide. - *Related guidance:* the legacy Securing PKI text recommends removing role services that are not justified by a business need. CISA amplified the advisory on July 27, 2021. - **NDES/SCEP (RFC 8894):** NDES lets non-domain devices enroll via SCEP using a one-time challenge password. - Securing NDES means a dedicated service account, restricting the NDES templates, HTTPS, and protecting the RA certificates. - SCEP-issued certificates normally carry requester-supplied subjects. Under KB5014754 they therefore need strong mapping (e.g., SID URL in SAN, or explicit mapping) if used for AD authentication. - Use NDES only where devices cannot use autoenrollment or CEP/CES. - *The current Learn NDES overview was not re-fetched here.*

A11. Monitoring CA events to a SIEM

- Forward CA Security-log events (A9) and KDC System-log events 39/40/41/45 to a SIEM.
- Correlate requester identity against the certificate SAN; Mandiant (practitioner) recommends alerting when they differ.
- Alert on template ACL changes (4899/4900), audit-filter changes (4885) and CA backups (4876).

A12. Legacy "Securing PKI" and the Test Lab Guide (Brian Komar–era)

Securing Public Key Infrastructure (PKI) — Microsoft Learn previous-versions (Windows Server 2012/2012 R2) — https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-r2-and-2012/dn786443(v=ws.11) — circa 2014; **legacy/archived**, but still the deepest Microsoft hardening text. MSRC cited it in Nov 2024 (CVE-2024-49019). Free. - *Chapters:* Planning a CA Hierarchy; Physical Controls; PKI Process Security; Technical Controls; Algorithms and Usages; Protecting CA Keys and Critical Artifacts; Monitoring; Compromise Response; Appendices A (events), B (audit filter), C (delegating AD PKI permissions), F (recommendations by impact level). - *Key recommendations:* - One-tier is "not recommended for any production scenario." - Two-tier is "the recommended design for most PKI solutions." Three-tier fits policy-CA or high-assurance separation needs. - Constrain issuing CAs with path length and EKU constraints. - Any CA expiring more than 15 years out should use RSA ≥ 4096 or ECC P-384/P-521. Avoid MD5 and other weak algorithms, and don't mix algorithms across the hierarchy. - Prefer HSMs, with multi-person control. - Harden online CAs (firewall, disable LM/NTLMv1, Restricted Admin RDP) and treat them as high-value assets. - Require smart cards for PKI administrators. - Maintain a CP/CPS and a Policy Authority. - *Caveat:* it predates the ESC research, strong mapping, and Windows Server 2016+ features. Use it as a design and governance text, not a current configuration baseline.

Test Lab Guide: Deploying an AD CS Two-Tier PKI Hierarchy — previous-versions hh831348 — legacy. A step-by-step offline standalone root plus enterprise subordinate walkthrough with fictitious names. Useful only as an illustrative sequence.

A13. Relevant CVEs and advisories (Microsoft)

ID	Date	AD CS relevance	Microsoft fix / guidance
CVE-2021-40469	Oct 2021	Windows DNS Server RCE (DnsAdmins-	Patch; restrict DnsAdmins

ID	Date	AD CS relevance	Microsoft fix / guidance
		adjacent); **tangential**, not an AD CS flaw	
ADV210003 / KB5005413 (PetitPotam, ESC8)	July 2021	NTLM relay to Web Enrollment/CES	EPA + HTTPS, disable NTLM, remove unused role services
CVE-2022-26923 “Certifried” (+ CVE-2022-26931, CVE-2022-34691)	May 10, 2022	Machine-account dNSHostName spoofing → DC impersonation; weak mapping	KB5014754 SID extension + strong mapping (fully enforced Sept 9, 2025)
CVE-2024-49019 (“ESC15”/EKUwu)	Nov 12, 2024	V1 templates with request-supplied subject; application-policy injection. Found by Justin Bollinger of TrustedSec and published as “EKUwu: Not just another AD CS ESC” (Oct 9, 2024); per a LimaCharlie recap, Bollinger reported it in about 80% of environments tested	Patch; restrict V1 template enrollment; manager approval; remove unused templates
CVE-2025-26647 / KB5057784	Apr 8, 2025	Logon certs not chaining to NTAuth	NTAuth enforcement (bypass support ended Oct 14, 2025)

4. Section B — US government and standards guidance (by publisher)

B1. NIST

SP 800-57 Part 1 Rev 5, Recommendation for Key Management: Part 1 – General — NIST (Barker) — May 2020 — **final, current**; Rev 6 initial public draft released Dec 5, 2025, comments closed Feb 5, 2026. Free; US Government work, not subject to US copyright. - *Scope:* key types, cryptoperiods, security strengths, protection requirements, key-management lifecycle and policy. - *Key points:* - Defines security strength (112-bit minimum through 2030; RSA-2048 ≈ 112 bits, RSA-3072/P-256 ≈ 128 bits). - Gives cryptoperiod guidance, e.g., private signature keys typically 1–3 years. CA keys are long-lived but are bounded by the strength needed over the full validity of issued certificates. - Requires protecting keys and metadata, and

inventorying keys and certificates. - *Rev 6 draft changes:* adds Ascon (SP 800-232) and FIPS 203/204/205 PQC algorithms and security categories; separates key-establishment keys from key-storage keys; moves algorithm approval timeframes out to SP 800-131A; adds a keying-material storage section.

SP 800-131A Rev 2, Transitioning the Use of Cryptographic Algorithms and Key Lengths — March 2019 — **in force**. **Rev 3 initial public draft** — Oct 21, 2024 — draft. - SHA-1 is already disallowed for digital signature generation and allowed only for legacy verification. - The Rev 3 draft would deprecate SHA-1, SHA-224, SHA-512/224 and SHA3-224 through 2030 and disallow them after Dec 31, 2030. It would also mark 112-bit RSA/ECDSA "acceptable until 2030." - *Relevance:* AD CS CAs should not sign with SHA-1. The CSP table on Microsoft's design page still lists SHA-1/MD5 as *selectable*, which is not an endorsement.

NIST IR 8547 (ipd), Transition to Post-Quantum Cryptography Standards — Nov 12, 2024 — **draft**. - Proposes deprecating quantum-vulnerable public-key algorithms (RSA, ECDSA, EdDSA, DH, ECDH) at 112-bit strength after 2030, and disallowing all quantum-vulnerable public-key algorithms after 2035. - For AD CS this frames ML-DSA hierarchy planning (A1).

FIPS 186-5, Digital Signature Standard — Feb 3, 2023 — final. Approves RSA, ECDSA (including deterministic ECDSA) and EdDSA; curves move to SP 800-186. Per the research summary, DSA is retained only for verifying existing signatures; confirm in the standard. **FIPS 204, ML-DSA** — Aug 13, 2024 — final. The lattice-based signature scheme that AD CS now issues (A1). **SP 800-208, Stateful Hash-Based Signature Schemes (LMS/HSS, XMSS/XMSS^MT)** — Oct 29, 2020 — final. Relevant mainly to firmware and code signing, not general CA hierarchies. Its state-management burden makes it unsuitable for AD CS issuing CAs, and AD CS does not offer it.

SP 1800-16, Securing Web Transactions: TLS Server Certificate Management (NCCoE; Vols A–D) — June 16, 2020 — final; free (contains industry-contributed content). - *Scope:* an enterprise TLS certificate management program covering inventory, ownership, automation, policy, and private-CA plus public-CA operations. - *Key points:* establish a certificate services team; maintain a complete inventory; automate issuance and renewal; protect private keys; plan for CA compromise and algorithm change. It applies directly to AD CS-issued TLS certificates.

SP 800-32, Introduction to Public Key Technology and the Federal PKI Infrastructure — Feb 26, 2001 — **withdrawn**. A conceptual primer only; still cited as a reference in SP 800-53 SC-17.

SP 800-53 Rev 5 — Sept 2020 (updated Dec 10, 2020); online release **5.2.0** (Aug 27, 2025) did not change these controls. - **IA-5(2) Public Key-Based Authentication:** enforce authorized access to the private key; map the authenticated identity to the account; validate certificates by building a path to an accepted trust anchor, including status checking; keep a local cache of revocation data for path validation. - **SC-12 Cryptographic Key Establishment and Management:** establish and manage keys per defined requirements for generation, distribution, storage, access and destruction. - **SC-17 Public Key Infrastructure Certificates:** issue certificates under a defined certificate policy, or obtain them from an approved provider; include only approved trust anchors in managed trust stores. - *Mapping to AD CS:* SC-17's trust-

store requirement aligns with controlling NTAuth and enterprise root publication. IA-5(2)'s revocation cache aligns with CRL/OCSP availability design.

B2. CISA / NSA

Detecting and Mitigating Active Directory Compromises — authored by ASD's ACSC with **CISA, NSA**, CCCS, NCSC-NZ and NCSC-UK (joint Five Eyes) — Sept 25, 2024 — current. US mirror: https://media.defense.gov/2024/Sep/25/2003553985/-1/-1/0/CTR-DETECTING-AND-MITIGATING-AD-COMPROMISES.PDF. Free; joint international publication, so check the PDF's licence statement before reuse. Treated here as a CISA/NSA source for its AD CS content. - *AD CS compromise:* covers 17 techniques, including AD CS template misconfiguration (ESC1-style enrollee-supplied SAN) and web-enrollment relay. The appendix checklist includes "Remove vulnerable AD CS CA configurations." - *Golden Certificate:* "a persistence technique that expands upon an AD CS compromise." An attacker with administrative access to a CA extracts the CA certificate and private key and forges client-authentication certificates for any user. The forged certificates stay valid until the CA certificate expires or is revoked. - *Mitigations (paraphrased):* secure both root and subordinate CAs; treat CAs as Tier 0; minimize users with privileged access; don't use CA servers for anything other than AD CS; implement application control on CAs; centrally log and analyse CA logs promptly. - *Detection:* Golden Certificates are hard to detect because CA backup and exfiltration visibility is limited. CA audit logging is not enabled by default. Watch 4876 (backup started), 4886, 4887, 4899, 4900 and 1102 (log cleared) on CAs, and KDC events 39/40/41 on DCs.

CISA alert, "Microsoft Releases Guidance for Mitigating PetitPotam NTLM Relay Attacks" — July 27, 2021 — urges review and application of KB5005413. Free; public domain.

NSA, "Eliminating Obsolete Transport Layer Security (TLS) Protocol Configurations" (CSI U/OO/197443-20) — Jan 5, 2021 — current. - Use only TLS 1.2/1.3. Remove SSL 2.0/3.0 and TLS 1.0/1.1. Block weak cipher suites and key exchange. - *Relevance:* applies to CDP/AIA/OCSP/CES/NDES web endpoints and to the TLS certificates AD CS issues.

NSA, CNSA 2.0 — first released Sept 7, 2022; current PDF May 30, 2025. - For National Security Systems: ML-DSA-87 for signatures, LMS/XMSS for software and firmware signing, ML-KEM-1024, AES-256 and SHA-384/512. - Exclusive-use milestones run through 2030–2033 by category, with all NSS quantum-resistant by 2035. - NSA sets no separate "PKI deadline." It is binding only on NSS, but is a useful planning signal for ML-DSA parameter choice.

B3. DISA / DoD

Active Directory Forest STIG — DISA — rules added in V3R1 (Sept 13, 2024); third-party viewers and NIST NCP show **V3R2 dated May 15, 2025**. Confirm the latest release at public.cyber.mil. Free; public release. - **V-269098 (AD.3145_AD, CAT I/high):** "Windows Server hosting Active Directory Certificate Services (AD CS) must enforce Certificate Authority (CA) certificate management approval for certificate requests." Manual approval is required for templates with authentication-capable EKUs (e.g., Smart Card Logon, Any Purpose, subordinate CA) where the requester can supply the subject. Mapped to CCI-000366 / CM-6. - **V-269099 (CAT I/high):** AD CS "must be managed by a PAW tier 0." A dedicated CA admin account usable only on a Tier 0 PAW or the CA itself must be used to manage the CA and approve requests.

Windows Server STIGs — e.g., Windows Server 2022 STIG **V-254413**: DC PKI certificates must be issued by the DoD PKI or an approved External Certificate Authority.

DoD PKI context (brief): DoD runs its own PKI under **DoDI 8520.02, Public Key Infrastructure and Public Key Enabling** (May 18, 2023). PKI-enabling requirements are spread across STIGs (e.g., Application Security and Development STIG). No current standalone "PKI/PKE STIG" for operating a Windows enterprise CA was identified; older PKI documents sit in a "PKI-Sunset" area of the cyber.mil library.

B4. CIS

CIS Controls v8.1 (guide v8.1.2, March 2025) — free with registration; CC BY-NC-ND 4.0. - **3.10** Encrypt Sensitive Data in Transit (TLS/SSH examples) and **3.11** Encrypt Sensitive Data at Rest are the closest safeguards. **16.11** says to use vetted modules for identity and encryption, and **12.6** covers secure network management protocols. - **No CIS v8.1 safeguard explicitly addresses certificate/PKI or CA management.** Certificate-inventory language often attributed to CIS in vendor blogs does not appear in the safeguard text.

CIS Microsoft Windows Server 2022 / 2025 Benchmarks — WS2025 v1.0.0 (Mar 19, 2025) and v2.0.0 (Feb 24, 2026); WS2022 v5.0.0 — free PDF for non-commercial use (CC BY-NC-SA 4.0). - The Level 1 Member Server profile states it also covers servers running the AD Certificate Services role. - **No AD CS–specific recommendations** (templates, CA permissions, audit filter) were identified. CIS applies general OS hardening to CA hosts.

B5. CA/Browser Forum (context only)

Baseline Requirements for publicly-trusted TLS certificates; Ballot SC-081v3 — free. The CA/B Forum Server Certificate Working Group approved the ballot on April 11, 2025. Clint Wilson of Apple proposed it, with Sectigo, Google Chrome and Mozilla endorsing. SSL.com reports "29 votes in favor and none opposed," and the IPR review ran April 13 to May 13, 2025. - Maximum public TLS validity: **200 days** for certificates issued from Mar 15, 2026; **100 days** from Mar 15, 2027; **47 days** from Mar 15, 2029. Domain-validation reuse falls to 10 days by 2029. - *Internal PKI is not bound by the BRs.* An AD CS CA chaining to a private root is governed by the organization's own CP/CPS. Browsers enforce BR limits only for publicly trusted roots.

B6. IETF RFCs

RFC	Title	Date / status	AD CS relevance
RFC 5280	Internet X.509 PKI Certificate and CRL Profile	May 2008; Proposed Standard (updated by later RFCs)	Certificate/CRL fields, basicConstraints, pathLen, name constraints, CDP/AIA extensions, path validation
RFC 6960	X.509 Internet PKI Online Certificate Status Protocol – OCSP	June 2013; Proposed Standard (nonce updated by RFC 8954)	Profile implemented by AD CS Online Responder

RFC	Title	Date / status	AD CS relevance
RFC 5019	Lightweight OCSP Profile for High-Volume Environments	Sept 2007	Pre-signed responses, HTTP GET caching (Online Responder behaviour)
RFC 4556	PKINIT (Public Key Cryptography for Initial Authentication in Kerberos)	June 2006; Proposed Standard	Smart card/WHfB logon; KDC certificate requirements
RFC 8894	Simple Certificate Enrolment Protocol (SCEP)	Sept 2020; **Informational**	Protocol implemented by NDES
RFC 8555	Automatic Certificate Management Environment (ACME)	March 2019; Proposed Standard	Context for modern automation; AD CS has no native ACME server

B7. US practitioner (non-governmental) research — clearly labeled

SpecterOps, "Certified Pre-Owned: Abusing Active Directory Certificate Services" (Will Schroeder and Lee Christensen) — June 17, 2021 — free. - Defines ESC1–ESC8, theft (THEFT1–5) and persistence (PERSIST1–3, DPERSIST1–3, including "Golden Certificate" as DPERSIST1), plus PREVENT/DETECT guidance. - **Certify 2.0** (SpecterOps, Aug 11, 2025) covers ESC1–ESC16. Per the Certipy and GhostPack Certify wikis, the later techniques have these sources: - ESC9/ESC10: Oliver Lyak (Aug 4, 2022). - ESC11: Sylvain Heiniger. - ESC12: Hans-Joachim Knobloch. - ESC13 (Feb 14, 2024) and ESC14 (Feb 28, 2024): Jonas Bülow Knudsen of SpecterOps. - ESC15 "EKUwu": Justin Bollinger of TrustedSec (Oct 9, 2024); this is CVE-2024-49019. - ESC16: Oliver Lyak (May 13, 2025); it covers the CA-wide disabling of the SID security extension. - *Status:* a practitioner reference, widely cited by Microsoft blogs and by the CISA/NSA joint guidance's technique descriptions.

Mandiant / Google Cloud — "Defend Against the Latest Active Directory Certificate Services Threats" (blog) and the hardening white paper "Active Directory Certificate Services: Modern Attack Paths, Mitigations, and Hardening" (2023, aimed at the February 2025 enforcement); "Proactive Preparation and Hardening Against Destructive Attacks: 2026 Edition" (March 2026) — free; some downloads gated. - Covers ESC1/SAN abuse, relay to web enrollment and Golden Certificate. - *Detection:* KDC events 39/41 and CA event 4887; alert when the requester differs from the SAN.

---

5. Topic crosswalk

Legend: ● explicit guidance; ◐ indirect/general; — no relevant guidance identified.

Topic	Microsoft	NIST	CISA/NSA	DISA	CIS	IETF
PKI hierarchy (tiers)	● Two-tier recommended; one-tier not for production (Securing PKI, legacy); plan CA count first (design page)	◐ SP 800-57 trust-anchor/CA key concepts; SP 800-32 (withdrawn)	◐ Secure root *and* subordinate CAs	—	—	◐ RFC 5280 pathLen/name constraints
Offline root CA	● Offline standalone root; no delta CRLs on offline root; TLG walkthrough	◐ SP 800-57 key protection	◐ Tier 0 treatment of CAs	◐ Tier 0 PAW (V-269099)	—	—
CA types (enterprise vs standalone)	● Install-AdcsCertificationAuthority -CAType; design page	—	—	—	—	—
Key length / algorithms	● KSP options; RSA 4096 or P-384/P-521 for CAs >15 yrs (legacy); ML-DSA-44/65/87 (2026)	● SP 800-57, SP 800-131A Rev 2 (Rev 3 draft), FIPS 186-5	◐ NSA TLS CSI; CNSA 2.0 (NSS)	—	—	◐ RFC 5280 algorithm identifiers
Validity / renewal	● Renew CA cert at half-life; CAPolicy.inf renewal settings	● Cryptoperiods (SP 800-57)	—	—	—	◐ RFC 5280 validity semantics

Topic	Microsoft	NIST	CISA/NSA	DISA	CIS	IETF
CDP/AIA & HTTP publication	● Configure before issuance; HTTP for non-Windows/ external; PKIView	◐ IA-5(2) path validation	—	—	—	● RFC 5280 CDP/AIA
CRL / delta CRL	● Delta CRLs optional, avoid on offline root; CAPolicy.inf periods	◐ IA-5(2) revocation cache	—	—	—	● RFC 5280 CRL profile
OCSP / Online Responder	● Online Responder role; ML-DSA-signed responses (2026)	◐ Status checking in IA-5(2) (CRL or OCSP)	—	—	—	● RFC 6960, RFC 5019
Templates & least-privilege permissions	● CVE-2024-49019 guidance; manager approval; remove unused templates	◐ SC-17 certificate policy	● Remove vulnerable AD CS configurations	● V-269098 manager approval (CAT I)	—	—
Autoenrollment	● GPO + template Autoenroll permission	◐ SP 1800-16 automation	—	—	—	◐ RFC 8555 (ACME, context)
DC/ Kerberos certs & PKINIT	● Kerberos Authentication template; LDAPS; WHfB	◐ IA-5(2)	◐ KDC events 39/40/41	● WS2022 STIG V-254413 (DoD PKI-issued DC certs)	—	● RFC 4556
Strong certificate	● KB5014754	◐ IA-5(2) identity	◐ Events 39/40/41	—	—	—

Topic	Microsoft	NIST	CISA/NSA	DISA	CIS	IETF
mapping	(full enforcement Feb 11, 2025; bypass removed Sept 9, 2025); KB5057784 NTAuth (Oct 14, 2025)	mapping				
Role separation (CA admin vs cert manager)	● Common Criteria roles; RoleSeparationEnabled; event 4897	◐ SP 800-57 / 800-53 separation of duties	◐ Limit privileged CA users	● V-269099 dedicated CA admin on Tier 0 PAW	—	—
CA auditing / logging	● AuditFilter 127; events 4885–4900, 4876/4877	◐ AU family (800-53)	● Centrally log CA events; 4876/4886/4887/4899/4900/1102	◐ General audit STIG rules	◐ General audit settings in benchmarks	—
Key protection (HSM/KSP)	● HSM preferred; configure before CA; software KSP only for low assurance	● SP 800-57 key protection; SC-12	● Protect CA private keys (Golden Certificate)	◐ Tier 0 management	—	—
NDES / SCEP	● NDES role; strong-mapping implications	—	—	—	—	● RFC 8894 (Informational)
Web enrollment	● KB5005413	—	● CISA alert	—	◐ NTLM restriction	—

Topic	Microsoft	NIST	CISA/NSA	DISA	CIS	IETF
/ ESC8	/ADV210003: EPA + HTTPS, disable NTLM, remove unused roles		(2021); joint guidance on relay		settings in benchmarks	
AD CS attack paths (ESC1–16) / Golden Certificate	● MSRC CVEs; Core Infra blog; MDI sensor	—	● AD CS compromise + Golden Certificate sections	● V-269098/V-269099	—	—
Post-quantum readiness	● ML-DSA in AD CS (WS2025, May 2026); composite algorithms in preview	● FIPS 204, SP 800-208, IR 8547 (draft), SP 800-57 Rev 6 (draft)	● CNSA 2.0 (NSS)	—	—	◐ (PQC certificate RFCs outside this collection's scope)

6. Where authorities agree, differ, or conflict

1. **Internal PKI vs CA/B Forum public-trust rules.**
   - The CA/B Forum's 200→100→47-day schedule binds only publicly trusted TLS certificates. No US government source reviewed here imposes a maximum validity on internal enterprise certificates.
   - Microsoft's examples use long CA lifetimes (a 20-year renewal validity in the design-page root example) and leave end-entity lifetimes to template policy.
   - *Interpretation:* internal PKI teams can legitimately issue longer-lived internal TLS certificates. The direction of travel (NIST SP 1800-16 automation, CA/B Forum), however, favours shorter lifetimes with autoenrollment, and that is the defensible default.
2. **SHA-1 and weak algorithm timelines.**
   - All sources agree that SHA-1 must not be used for new signatures. NIST disallowed SHA-1 signature generation years ago, and the Rev 3 draft disallows SHA-1/SHA-224 for remaining uses after 2030.
   - Microsoft's design page still lists SHA-1/MD5 among *selectable* provider options without a deprecation warning. This is a gap in documentation, not a conflict in policy.

- RSA-2048 is acceptable under SP 800-131A Rev 2. Under the drafts it becomes "acceptable until 2030" (131A Rev 3) and deprecated after 2030 (IR 8547).
- Microsoft's legacy RSA-4096-for-long-lived-CAs rule is consistent with that trajectory. A root CA created in 2026 with a 20-year life will outlast every proposed RSA/ECDSA deadline, which strengthens the case for planning a parallel ML-DSA hierarchy.

3. **Is OCSP required?**
   - No US authority reviewed mandates OCSP for internal PKI.
   - NIST IA-5(2) requires certificate *status* checking and a local revocation cache, which CRLs satisfy.
   - Microsoft presents the Online Responder as optional, and its own design guidance centres on CDP/CRL configuration.
   - OCSP is an operational choice, useful for large CRLs or non-Windows relying parties.
4. **Validity-period guidance.**
   - Microsoft says renew the CA at half-life and sets no fixed lifetimes. NIST frames lifetimes through cryptoperiods and the security strength needed for the protected data's life. The CA/B Forum sets hard maximums for public TLS only.
   - These approaches complement each other rather than conflict, but they do not converge on one number.
5. **Manager approval vs automation.**
   - DISA V-269098 requires manual certificate-manager approval for authentication-capable templates with requester-supplied subjects. Microsoft (MSRC and the Core Infra blog) recommends manager approval *or* tight enrollment permissions and authorized signatures.
   - DISA is therefore stricter than Microsoft. Both converge on avoiding enrollee-supplied subjects on authentication templates altogether, which removes the need for manual approval.
6. **HSM: required or recommended?**
   - Microsoft's legacy text strongly prefers HSMs except for low-assurance PKI. The current design page treats HSMs as optional. NIST requires key protection commensurate with impact.
   - CISA/NSA's Golden Certificate guidance implies CA key extraction is the primary risk, without (in the content reviewed) mandating hardware.
   - *Interpretation:* for any production AD CS that issues authentication certificates, the combined guidance points toward hardware-protected CA keys.

---

7. Caveats and items that could not be verified

- **Microsoft pages not directly verified:** current pages for NTAuth, PKIView, template design, autoenrollment, DC certificate templates, LDAPS, WHfB PKI requirements, Online Responder, CES/CEP, NDES, and an AD CS "What's new in Windows Server 2025" page were **not fetched in this research session**. Descriptions reflect long-standing

documented Microsoft behaviour and should be checked against the live pages; no URLs are given for them.

- **ML-DSA in AD CS:** general availability (May 2026) and the three parameter sets are confirmed by Microsoft's Security blog on TechCommunity. The KB number (KB5087539) and build number come from practitioner sources quoting release notes. The claims about no in-place migration, CRL partitioning and 16K database pages are practitioner/vendor claims.
- **KB5014754 dates:** Microsoft's article went through several revisions. A September 2025 revision corrected the final date from September 10 to **September 9, 2025**; older copies still show September 10.
- **NIST drafts:** SP 800-57 Pt 1 Rev 6, SP 800-131A Rev 3 and IR 8547 were drafts at last confirmation. Whether any were finalized between early 2026 and October 2026 was not verified. Treat their dates as proposed.
- **SP 800-53 IA-5(2) and SC-12 wording** is paraphrased from secondary copies and general knowledge, not the official CPRT text. The FIPS 186-5 treatment of DSA is likewise unconfirmed against the standard text.
- **CISA/NSA joint guidance:** the US-hosted PDF (media.defense.gov) blocked automated retrieval. Content here comes from search extracts of the US and partner-hosted copies. The document is ASD-led; it is used here only as a CISA/NSA co-authored source. Its exact licence statement was not confirmed.
- **DISA:** the current Active Directory Forest STIG release (V3R2, May 15, 2025, or later) needs confirming at public.cyber.mil; NIST NCP shows an anomalous 2026 "original publication date." V-269098/V-269099 text was taken from third-party STIG viewers that mirror DISA content. No current standalone DoD PKI/PKE STIG was found.
- **CIS:** the conclusion that the benchmarks contain no AD CS–specific recommendations rests on profile descriptions and unofficial copies, not a full-text review of the official PDFs. A reported WS2025 v2.1.0 (Sept 2026) is unconfirmed.
- **Practitioner sources** (SpecterOps, Mandiant, Microsoft staff blogs, MVP blogs) are not authoritative policy. ESC9–ESC16 originate from several researchers, some outside the US.

DHCP for Windows/Enterprise Environments: US-Only Verified Reference Collection (as of October 2026)

There is no dedicated US-government DHCP security standard. The US baseline for Windows DHCP is made up of Microsoft's product documentation, the IETF protocol RFCs, scattered rules in DISA STIGs and one CIS Controls safeguard, with Akamai's practitioner research filling the security gap. Several items in the prior pass need correcting, notably the failover OS minimum, which mode the reserve percentage belongs to, and the current DHCPv6 RFC.

TL;DR

- **No US-gov DHCP baseline exists; the guidance is operational, not prescriptive.** NIST has no DHCP Special Publication, CISA/NSA have nothing DHCP-specific, and DISA has no stand-alone DHCP STIG. DHCP shows up only indirectly: in NIST SP 800-81r3 (DNS, March 2026), the DISA Network Infrastructure Policy STIG (DHCP log retention), DISA Layer 2 switch STIGs (DHCP snooping), and CIS Controls v8.1 Safeguard 1.4 (DHCP logging for asset inventory). Microsoft Learn and the IETF RFCs are therefore the primary technical sources.
- **Microsoft's operational model is confirmed, with corrections.** Microsoft calls DHCP Failover "the preferred option," with two modes: load balance (the default, 50:50) and hot standby. The default 5% reserve percentage belongs to *hot standby*, not load balance. The shared secret is optional. The current Learn page requires both partners to run *at least Windows Server 2016* (the feature first shipped in Server 2012). Microsoft also confirms the BPA statement "Name protection requires secure update to work. Without name protection DNS names may be hijacked."
- **The main security risk is in DHCP-to-DNS integration, and the vendor won't patch it.** Akamai (US company; non-governmental research) found that DHCP DNS Dynamic Updates "don't require any credentials, and work with the default configuration" and that Microsoft does not plan a fix. A follow-on post showed DHCP Administrators can reach domain admin when DHCP runs on a domain controller. Logging is the one control that every source agrees on.

Guidance landscape overview

Publisher	Document	Date / version	Status (Oct 2026)	Access / licence
Microsoft Learn	DHCP failover overview (Windows Server)	ms.date 2025-03-11; last updated 2025-03-27; applies to WS 2016–2025	Current	Free; Microsoft Terms of Use
Microsoft Learn (training)	"Deploy and manage DHCP" module, including units "Select DHCP high availability	Unit ms.date 2024-04-15	Current (the HA unit is marked noindex but is live)	Free

Publisher	Document	Date / version	Status (Oct 2026)	Access / licence
	options” and “Implement DHCP Failover”			
Microsoft Learn (training)	Learning path “Implement and manage an on-premises and hybrid networking infrastructure” (includes IPAM)	Undated on page	Current	Free
Microsoft Learn	Dynamic DNS Update in Windows and Windows Server	Current page	Current	Free
Microsoft Learn	Troubleshoot problems on the DHCP server; DHCP troubleshooting guidance	Current pages	Current	Free
Microsoft Open Specifications	[MS-DHCPE] §7.1 / §7.8 (AD authorization)	Current spec	Current	Free; Open Specifications terms
Microsoft (previous-versions)	BPA topic ee941152 “Secure DNS updates should be configured if Name Protection is enabled…”	Applies to WS 2008 R2 / 2012	Legacy, still applicable	Free
Microsoft (archived TeamDHCP blog)	“What is Name Protection”; “DHCP Server Best Practice Analyzer…”; “DHCP Failover Load Balance Mode”	Archived	Legacy	Free
Microsoft (previous-versions)	Event ID 1060/1030 — DHCP Audit	WS 2008/2008 R2	Legacy	Free

Publisher	Document	Date / version	Status (Oct 2026)	Access / licence
	Logging			
MSRC	Security Update Guide (DHCP Server CVEs)	2023–2026	Current	Free
NIST	SP 800-81r3, Secure DNS Deployment Guide	March 2026; supersedes SP 800-81-2 (Sept 2013)	Current final	Free; US government work
NIST	SP 800-53 Rev. 5 (control mapping only)	Rev. 5	Current (latest release number not re-verified)	Free; US government work
DISA	Network Infrastructure Policy STIG (V-251361, V-251362)	Releases 2021-11-22 to 2024-08-02 confirmed on mirrors	Current family	Free, public
DISA	Layer 2 Switch SRG and vendor L2S STIGs (DHCP snooping)	SRG V3R1; vendor STIGs 2020–2025	Current	Free, public
DISA	Windows Server 2022 STIG V2R10; Windows Server 2025 STIG V1R3	Aug–Sep 2026 (mirror dates differ)	Current	Free, public
DISA	Windows DNS STIG (2000/2003), V-4501	2013-04-12	Legacy/sunset	Free
CIS	CIS Controls v8.1 (Safeguard 1.4 etc.)	v8.1 June 2024; v8.1.2 March 2025	Current	Free with registration; CC BY-NC-ND 4.0
IETF	RFC 2131, 2132, 3046, 3118, 3942, 4388, 4701/4702, 7610, 8415 (now obsoleted by RFC 9915)	1997–2018+	See Section B	Free; IETF Trust (BCP 78)
Akamai (non-governmental)	“Spoofing DNS Records by	Dec 7, 2023	Current research	Free; Akamai copyright

Publisher	Document	Date / version	Status (Oct 2026)	Access / licence
	Abusing DHCP DNS Dynamic Updates"			
Akamai (non-governmental)	"Abusing the DHCP Administrators Group to Escalate Privileges in Windows Domains"	Mar 20, 2024	Current research	Free; Akamai copyright

Section A — Microsoft official guidance by topic

A1. DHCP Server role and training

- **Title:** Deploy and manage DHCP (training module). **Publisher:** Microsoft Learn. **URL:** https://learn.microsoft.com/en-us/training/modules/deploy-manage-dynamic-host-configuration-protocol/ . **Status:** current; free.
- **Scope:** the DORA lease process, role installation "including server authorization in AD DS," options at server/scope/reservation level, scopes with "address ranges, exclusions, and reservations," HA choices and failover. Units include "Configure DHCP options," "Configure DHCP scopes," "Select DHCP high availability options," and "Implement DHCP Failover."
- **Parent learning path:** "Implement and manage an on-premises and hybrid networking infrastructure" (https://learn.microsoft.com/en-us/training/paths/implement-manage-premises-hybrid-networking-infrastructure/). It also uses IPAM "to centrally manage your DNS and DHCP infrastructure."
- **Not re-verified:** the standalone DHCP role overview URL (historically under /windows-server/networking/technologies/dhcp/) was not fetched this pass; treat the URL as unconfirmed.

A2. High availability (failover, clustering, split scope)

- **Training unit "Select DHCP high availability options."** URL: https://learn.microsoft.com/en-us/training/modules/deploy-manage-dynamic-host-configuration-protocol/6-select-dynamic-host-configuration-protocol-high-availability-options (ms.date 2024-04-15).
  - It lists three options: DHCP Failover, the DHCP role in a Windows Server failover cluster (config on shared storage), and split scopes.
  - It states: "DHCP Failover is the preferred option for highly available DHCP service," and calls it "the only high availability method in which the DHCP servers actively coordinate."

  - Split scope: each server holds part of the range, and the secondary uses the scope **Delay configuration** attribute so the primary answers first.
- **"DHCP failover overview."** URL: https://learn.microsoft.com/en-us/windows-server/networking/technologies/dhcp/dhcp-failover (ms.date 2025-03-11). Verified points:
  - Two modes. **Hot standby:** an active/standby pair. The reserve percentage applies here, defaulting to "5%"; after MCLT expires, the standby may use the whole pool. **Load balance:** "the default mode," with both servers serving clients and a default "50:50" ratio, using the RFC 3074 MAC-hash buckets.
  - IPv4 only; "DHCPv6 scopes can't be failover-enabled." For DHCPv6 HA, Microsoft recommends identical stateless option configuration or split scope.
  - "DHCP failover partners must both be running at least Windows Server 2016." **Correction:** the prior pass said "Server 2012+". Failover was introduced in Server 2012 (legacy page dn338983), but the current page sets a 2016 minimum.
  - **Correction on "matching scopes":** Microsoft says scopes are *replicated* from the primary to the partner when failover is configured, and later changes "must be manually replicated." The partner doesn't need pre-built matching scopes.
  - The shared secret is optional (message authentication). Failover uses TCP 647. Server clocks must be within one minute of each other. Both partners must use the same DNS dynamic-update credentials. Clustered DHCP can be a failover partner, provided you reference it by cluster name/IP.
  - Microsoft's failover is based on the IETF failover draft (draft-ietf-dhc-failover-12), which never became an RFC.
- **Training unit "Implement DHCP Failover."** It confirms MCLT ("how long a DHCP server should wait when a partner is unavailable before it assumes control"), the 5% hot-standby default, the shared secret and TCP 647.

A3. Scopes, options, reservations, exclusions

- The training module explicitly covers scopes, exclusions, reservations and server/scope/reservation-level options for "DNS servers, default gateways."
- The option code numbers (003 Router, 006 DNS Servers, 015 DNS Domain Name) come from RFC 2132. I didn't re-fetch them from a Microsoft page this pass; they are consistent with RFC 2132 but not re-verified here.

A4. AD authorization (rogue Windows DHCP control)

- **[MS-DHCPE] §7.1, "Windows DHCP Server Authorization in Domain Joined Scenario."**
  - A domain-joined DHCP server "is authorized by a domain administrator in Active Directory Domain Services."
  - Any domain-joined server that needs to serve clients must have an AD object.
  - The server "validates its authorization in AD DS every hour" over LDAP.
- **"Troubleshoot problems on the DHCP server"** (https://learn.microsoft.com/en-us/windows-server/troubleshoot/troubleshoot-problems-on-dhcp-server) lists "The DHCP server is authorized" as a checklist item.

- **Limitation:** authorization only governs Windows DHCP servers. Non-Windows or workgroup rogue servers are not stopped by it, which is why network-layer controls appear in Section B.

A5. DNS dynamic updates, Name Protection (DHCID), DnsUpdateProxy

- **"Dynamic DNS Update in Windows and Windows Server"** (https://learn.microsoft.com/en-us/windows-server/networking/dns/dynamic-update):
  - When a DHCP server performs a secure update, "it becomes the owner of that name."
  - A DHCP server in the DnsUpdateProxy group "doesn't secure the DNS domain names it registers."
  - Microsoft advises creating "a dedicated user account" for DHCP DNS updates.
  - It warns: "When installed on a domain controller, the DHCP Server service inherits the security permissions of the domain controller."
- **BPA topic ee941152** (WS 2008 R2/2012). The exact quote is confirmed: "Name protection requires secure update to work. Without name protection DNS names may be hijacked." The remedy is AD-integrated zones with "Secure only" updates.
- **Archived TeamDHCP "What is Name Protection":** Name Protection relies on the DHCID RR; "Secure Dynamic DNS updates must be enabled for name protection to work"; it prevents server/client name squatting.
- **Default behavior:** Akamai documents (with screenshots) that DHCP DNS dynamic updates are on by default, and that the default setting registers records only when the client asks (FQDN option, RFC 4702). I did not find a current Microsoft page stating the default explicitly; this is flagged in Caveats.

A6. Built-in groups (DHCP Administrators / DHCP Users)

- DHCP Administrators is described in Akamai's research: it lets members "query and modify the configuration of the DHCP service" but grants no rights over the host itself.
- **Not verified on a Microsoft page this pass:** the Microsoft definitions of DHCP Administrators and DHCP Users (read-only). Treat the groups' existence as well established, but Microsoft's exact wording as unconfirmed.

A7. Relay / IP helper / RRAS

- The failover overview confirms that relay agents are "commonly configured" on network devices via **ip helper-address**, or on Windows Server with the Remote Access role ("Deploy the DHCP Relay Agent").
- Failover deployments need a helper address for *both* partners.
- VRRP/HSRP can produce duplicate relayed requests.
- Azure Learn guidance notes that broadcast DHCP doesn't work in an Azure VNet, so a relay is required there.

A8. Policies and filtering

- The failover overview confirms **policy-based assignment**: clients can be grouped by vendor class, user class, client identifier, or MAC address, and given different options or ranges.
- **Not re-verified this pass:** the dedicated Microsoft page for link-layer (MAC) allow/deny filtering.

A9. Audit logging

- Microsoft's Event ID 1060 topic says "DHCP audit logs are located by default at %windir %". On log-size limits, Microsoft's archived blog "All about DHCP Auditing" (Nov 2, 2006) defines `DhcpLogFilesMaxSize` (REG_DWORD, MB) as "the maximum combined size of one week's worth of Dynamic Host Configuration Protocol (DHCP) audit logs. If the audit logs exceed the size specified by this value, DHCP stops writing to the audit log until sufficient space becomes available."
- A current Microsoft KB shows the file pattern `DhcpSrvLog-<Day>.log`.
- The DHCP-Server event channels (Operational, Admin, Audit, Filter Notification) are listed in the DHCP troubleshooting guidance.
- **"On by default"** is supported only by third-party sources: TechTarget's "Use advanced DHCP logging techniques for troubleshooting" says "Windows enables DHCP logging by default." ManageEngine's KB disagrees: "On some Windows Server installations, it's enabled by default; on others it isn't." I did not see the default stated on a current Microsoft page.

A10. IPAM

- The Microsoft Learn path confirms IPAM for central DNS/DHCP management (module "Implement IP Address Management").

A11. DHCPv6 and mitm6

- **mitm6 origin:** Fox-IT published mitm6 on Jan 11, 2018 (author Dirk-jan Mollema). Fox-IT is non-US; it's cited here only to identify the origin. The tool answers Windows DHCPv6 solicitations and makes the attacker the victim's IPv6 DNS server.
- **Mitigations:** Fox-IT's original post called disabling IPv6 when it isn't used "the only defense… we are currently aware of." Later practitioner guidance adds:
  - blocking inbound DHCPv6 and Router Advertisements via Windows Firewall GPO;
  - RA Guard / DHCPv6 Guard on switches (US standards anchor: RFC 7610);
  - LDAP signing/channel binding and SMB signing to break the NTLM relay step.
- I found no Microsoft or US-gov page codifying mitm6 mitigations.

A12. Windows DHCP Server CVEs (2023–2026)

- **Confirmed on MSRC (title and release date seen in the Security Update Guide):**
  - CVE-2023-38162 (DoS, Sep 12, 2023). MSRC notes servers not configured for failover are not affected.
  - CVE-2024-26215 (DoS, Apr 9, 2024).
  - CVE-2024-38236 (DoS, Sep 10, 2024).

  - 2026 RCEs: CVE-2026-69847 (heap overflow, "authorized attacker… adjacent network," Sep 8, 2026); CVE-2026-69876 (use-after-free, adjacent, Sep 8, 2026); CVE-2026-70058 (out-of-bounds write, "unauthorized attacker… over a network," Oct 13, 2026); CVE-2026-88120 (rated Critical, Oct 13, 2026).
- **Secondary-source only (not opened on MSRC):**
  - CVE-2023-28231 (Apr 2023, DHCPv6 relay-forward RCE).
  - CVE-2023-35638 (Dec 2023 DoS); CVE-2023-38152 and CVE-2023-36801 (info disclosure, Sep 2023); CVE-2024-30019 (May 2024 DoS).
  - CVE-2026-50518 (Jul 2026; reported CVSS 9.8 Critical); CVE-2026-72979 (Sep 2026, Critical); CVE-2026-69620 (Important); CVE-2026-77889 (DoS).
- **Out of scope:** CVE-2025-21379 is a DHCP *Client* issue, not Server.
- **Relevance:** network-reachable RCEs in a service that runs on many DCs (Akamai: 57%) make this a high-priority patching surface.

Section B — US government and standards guidance

B1. NIST

- **No DHCP Special Publication was found.** That absence is itself a finding.
- **SP 800-81r3, *Secure Domain Name System (DNS) Deployment Guide*.**
  - URL: https://doi.org/10.6028/NIST.SP.800-81r3 . Published March 2026 (approved 2026-03-04); supersedes SP 800-81-2 (Sept 2013). Free; US government work.
  - Authors: the title page lists Rose, Liu, Gibson, while the suggested citation lists "Nodurft." This internal inconsistency is in the PDF.
  - DHCP-relevant statements:
    - Mapping an IP to an asset during an incident needs allocation history "such as a Dynamic Host Configuration Protocol (DHCP) lease history."
    - On co-location: "If having systems dedicated only to DNS is not feasible, then incorporating related core services (e.g., DHCP) may be appropriate."
    - Dynamic updates "generally originate from hosts (e.g., DHCP servers)" and "should only be accepted from authorized senders (e.g., by TSIG or ACL)."
    - Threats listed: unauthorized updates, tampering, replay and update-flood DoS. Hidden primaries are "strongly encouraged" for zones that accept dynamic updates.
- **SP 800-53 Rev. 5 mapping (this document's interpretation; NIST does not name DHCP):**
  - AU-2/AU-3/AU-11/AU-12 for audit-log content and retention;
  - CM-6/CM-7 for configuration and least functionality (e.g., disabling DDNS if unneeded);
  - CM-8 for inventory (DHCP leases);
  - SC-7 and AC-4 for boundary protection and flow control (relay, segmentation, snooping);

  - AC-6 for least privilege (DHCP Administrators, DNS credential);
  - SI-4 for monitoring (rogue offers).

B2. CISA / NSA

- **No DHCP-specific CISA or NSA guidance was found.**
- SP 800-81r3 cites CISA's Protective DNS program and the FCEB encrypted-DNS requirement; neither is DHCP guidance.
- "Foundations for OT Cybersecurity: Asset Inventory Guidance for Owners and Operators" was released Aug 13, 2025 by CISA, NSA, FBI and EPA, co-sealed with ASD's ACSC, the Canadian Centre for Cyber Security, BSI, NCSC-NL and NCSC-NZ (per NSA's press release "NSA Joins CISA and Others to Share OT Asset Inventory Guidance"). I did not confirm any DHCP text in it, and its foreign co-seals put it at the edge of the US-only scope.

B3. DISA

- **No stand-alone DHCP STIG or SRG was found.** This comes from searching mirrors (stigviewer, cyber.trackr, NIST NCP); cyber.mil itself could not be fully crawled.
- **DHCP-relevant rules found:**
  - **Network Infrastructure Policy STIG.** V-251361 / NET0198 (Medium): "DHCP audit and event logs must record sufficient forensic data to be stored online for thirty days and offline for one year," including hostname and MAC. V-251362 / NET0199 (Low): SIPRNet DHCP minimum lease of 30 days.
  - **Layer 2 Switch SRG and vendor L2S STIGs:** DHCP snooping "for all user VLANs." Examples: Cisco IOS V-220633 (CISC-L2-000130), Cisco IOS XE V-220659, NX-OS V-220684, Arista V-255973, Juniper EX V-253959, HP FlexFabric V-66071 (which also requires rate-limiting). The same STIGs include IP Source Guard and DAI rules that rely on the snooping binding table.
  - **Legacy Windows DNS STIG (2013-04-12).** V-4501 / DNS0805 (High) requires DHCP disabled on 2000/2003 DNS servers supporting dynamic updates, because a DC-hosted DHCP can alter DC SRV records. This is the closest DISA analogue to the Akamai DC finding. No DHCP rule was found in later Windows DNS STIGs (not exhaustively checked).
  - **Infoblox 7.x DNS STIG.** V-68621: DHCP must not run on an external authoritative name server.
- **Windows Server OS STIGs** (2022 V2R10, 278 rules, Aug–Sep 2026; 2025 V1R3, 291 rules, Aug 2026) contain no DHCP-specific rule. The host is hardened through the general OS rules. The WS2008 R2 Member Server STIG V-3487 lists "DHCP Server" only as a documented service.

B4. CIS (US nonprofit)

- **CIS Controls v8.1 (June 2024; v8.1.2 March 2025).**
  - **Safeguard 1.4 (IG2/IG3):** "Use DHCP logging on all DHCP servers or Internet Protocol (IP) address management tools to update the enterprise's asset inventory. Review and use logs to update the enterprise's asset inventory weekly, or more frequently." This is the only DHCP-named safeguard.

  - Related safeguards (my mapping): 1.1/1.2 asset inventory and unauthorized assets; 4.1/4.2 secure configuration of assets and network infrastructure; 8.2/8.10 audit log collection and retention; 12.2 secure network architecture; 13.x network monitoring (rogue DHCP detection).
  - Licence: CC BY-NC-ND 4.0.
- **CIS Microsoft Windows Server Benchmarks (Member Server profile):** not verified this pass. I'm not aware of a DHCP-role benchmark; the DHCP host would be covered by the general Member Server profile.

B5. IETF (primary for the protocol)

RFC	Title	Date	Status / notes
2131	Dynamic Host Configuration Protocol	Mar 1997	Draft Standard; obsoletes 1541; updated by 3396, 4361, 5494, 6842
2132	DHCP Options and BOOTP Vendor Extensions	Mar 1997	Draft Standard; defines Router (3), DNS Servers (6), Domain Name (15); updated by 3442, 3942, 4361, 4833, 5494
3046	DHCP Relay Agent Information Option (option 82)	Jan 2001	Proposed Standard (not re-fetched)
3118	Authentication for DHCP Messages	Jun 2001	Proposed Standard; Microsoft DHCP doesn't implement it (not re-fetched); effectively unused
3942	Reclassifying DHCPv4 Options	Nov 2004	Updates 2132
4388	DHCP Leasequery	Feb 2006	Proposed Standard
4701 / 4702	DHCID RR / Client FQDN Option	Oct 2006	Underpin Name Protection and DHCP DDNS
7610 (BCP 199)	DHCPv6-Shield: Protecting against Rogue DHCPv6 Servers	Aug 2015	Best Current Practice; layer-2 filtering, the analogue of IPv4 "DHCP snooping"
8415	DHCP for IPv6 (DHCPv6)	Nov 2018	Obsoletes 3315, 3633, 3736, 4242, 7083, 7283, 7550. **Correction: the**

RFC	Title	Date	Status / notes
			IETF datatracker now shows RFC 8415 “Obsoleted by RFC 9915”

Section B6 — Akamai practitioner research (US company; NON-GOVERNMENTAL)

1. “Spoofing DNS Records by Abusing DHCP DNS Dynamic Updates.” Ori David, Akamai, Dec 7, 2023. URL: https://www.akamai.com/blog/security-research/spoofing-dns-by-abusing-dhcp . Free; Akamai copyright.

Confirmed findings: - The attacks “don’t require any credentials, and work with the default configuration of Microsoft DHCP server.” Microsoft DHCP servers “have this feature enabled by default.” - Attackers can create records and can overwrite DHCP-managed records, the DHCP server’s own record, and, when DHCP runs on a DC, “any DNS A record inside the ADI zone.” This works because ENTERPRISE DOMAIN CONTROLLERS has write rights on every record. - “57% have a DHCP server installed on a DC.” - “We reported our findings to Microsoft, but a fix is not planned.” - Name Protection can be bypassed with a spoofed DHCP Release carrying the victim’s MAC, or by brute-forcing the DHCID. - Akamai found the DnsUpdateProxy group to be both a risk and apparently buggy. - The “40%” figure appears in two forms: the summary says “40% of the networks monitored by Akamai,” while the body says “40% of the data center networks we monitor.”

Mitigations: - Confirmed: disable DHCP DNS Dynamic Updates if not needed; avoid DnsUpdateProxy; use static records for sensitive non-Windows hosts (“Managed records can’t be protected from spoofing with any configuration”). - Partly confirmed (the page was truncated): use a weak DNS credential and use the same credential on all DHCP servers.

Tooling: Invoke-DHCPCheckup (detection, PowerShell) and DDSpoof (offensive).

2. “Abusing the DHCP Administrators Group to Escalate Privileges in Windows Domains.” Ori David, Mar 20, 2024. URL: https://www.akamai.com/blog/security-research/abusing-dhcp-administrators-group-for-privilege-escalation-in-windows-domains . - Findings: DHCP options (WPAD 252, DNS Server) can be abused to run code on DHCP servers and coerce Kerberos authentication. Where DHCP runs on a DC, this gives domain admin. - “doesn’t rely on any vulnerability. Therefore, a fix for it doesn’t exist.” - Mitigations: treat DHCP Administrators as high-value and limit membership; avoid DHCP on DCs; segment; detect DNS anomalies (DHCP updates going to non-standard DNS servers). - Akamai uses the “DHCP Coerce” label in the post itself: a section is headed “DHCP Coerce to Kerberos relay,” and the text says “DHCP Coerce opens an opportunity for a Kerberos relay attack.” The related script in Akamai’s DDSpoof repo is `dhcp_coerce.py`.

Topic crosswalk

Topic	Microsoft	NIST	CISA/ NSA	DISA	CIS	IETF	Akamai
Scopes/ options/ reservations	Training module (scopes, exclusions, reservations, options)	—	—	V-251362 lease (SIPRNet only)	—	RFC 2131/2132	—
HA failover (modes)	Preferred; load balance default 50:50; hot standby 5% reserve; MCLT; optional shared secret; WS2016+	—	—	—	—	Failover draft only (never RFC); RFC 3074	Same DNS credential on partners
Split scope/clustering	Alternatives; split scope via Delay; cluster on shared storage	—	—	—	—	—	—
AD authorization (rogue control)	Required for domain-joined; hourly LDAP check	—	—	—	—	—	—
DNS dynamic updates/ credential	Dedicated user account; DC-hosted	800-81r3: accept only authorized senders	—	Legacy V-4501	—	RFC 4702	Unauthenticated by design; disable if

Topic	Microsoft	NIST	CISA/ NSA	DISA	CIS	IETF	Akamai
	DHCP inherits DC rights	(TSIG/ACL)					unneeded; weak shared credential
Name Protection (DHCID)	Requires secure updates (BPA)	—	—	—	—	RFC 4701	Bypassable (Release spoof/brute force)
DnsUpdateProxy risk	Records unsecured	—	—	—	—	—	Avoid; bug noted
DHCP Administrators/Users	Groups exist (wording not re-verified)	AC-6 (mapped)	—	—	Control 5/6 (mapped)	—	DHCP Admins → DA on DCs
Relay (IP helper/option 82)	ip helper-address; RRAS relay; both partners	SC-7 (mapped)	—	—	12.x (mapped)	RFC 3046	Relay-agent option abuse noted
Rogue DHCP mitigation (snooping)	AD authorization only (Windows)	SI-4 (mapped)	None found	L2S STIGs: snooping on all user VLANs	13.x (mapped)	RFC 7610 (v6)	—
IPv6/ DHCPv6/ mitm6	Failover not supported for v6; no mitm6 guidance found	—	None found	—	—	RFC 8415–9915; RFC 7610	—
Audit logging	%windir%; DhcpSrvLog-.log	800-81r3: DHCP lease history for DFIR;	None found	NET0198: 30 days online / 1 year offline	Safeguard 1.4; Control 8	—	DNS-anomaly detection

Topic	Microsoft	NIST	CISA/ NSA	DISA	CIS	IETF	Akamai
		AU family					
IPAM/ central governance	IPAM module	CM-8 (mapped)	—	—	1.4 ("IP address management tools")	RFC 4388 leasequery	—
Host hardening	Patch DHCP CVEs; avoid DC co-location (implied)	800-81r3 dedicated servers, DHCP co-location acceptable	—	WS2022/ 2025 OS STIGs (generic)	4.1; Benchmarks (unverified)	—	Keep DHCP off DCs
Protocol authentication	Failover shared secret only	TSIG for DNS updates	—	—	—	RFC 3118 (unused); RFC 8415 auth option	—

Agreements, differences and conflicts

1. **No US-gov DHCP baseline.** Every federal source treats DHCP indirectly: as a DNS client (NIST), a log source (DISA, CIS), or a switch-layer threat (DISA L2S). Microsoft's product documentation is effectively the configuration baseline.
2. **DDNS is unauthenticated by design, and Microsoft won't patch it.** Microsoft's documentation frames the risk as record ownership. Akamai shows unauthenticated overwrite under default settings and reports that no fix is planned. NIST's "authorized senders only" principle is satisfied only at the DHCP→DNS hop, not client→DHCP. That gap is the core conflict.
3. **DHCP on a DC vs. tiering.**
   - Microsoft documents that DC-hosted DHCP "inherits the security permissions of the domain controller" but does not forbid it.
   - DISA's legacy V-4501 and both Akamai posts argue against it.
   - NIST 800-81r3 allows co-locating DHCP with DNS when dedicated servers aren't feasible. That speaks to DNS servers, not DCs, so it is not a direct contradiction.
   - **Position:** keep DHCP off DCs. If you can't, set a dedicated low-privilege DNS credential.
4. **Rogue defense is layered, and no single source covers it all.**
   - AD authorization (Microsoft) stops only Windows servers.
   - DHCP snooping (DISA L2S) and RFC 7610 / RA Guard cover IPv4/IPv6 at layer 2.
   - Monitoring (CIS 13) adds detection.
   - You need all three.

5. **There is no usable DHCP protocol authentication.** RFC 3118 is effectively unused, and DHCPv6 delayed authentication was obsoleted in RFC 8415. The only "authentication" in Windows DHCP is the optional failover shared secret.
6. **Logging is the one clean agreement.** Microsoft (on by default, %windir%), NIST (lease history for DFIR), DISA (30 days online / 1 year offline, with MAC and hostname) and CIS (Safeguard 1.4, weekly inventory reconciliation) all point the same way.
    - **Practical caveat:** Windows keeps one audit file per weekday. Per Microsoft's archived "All about DHCP Auditing" blog, at each day change "DhcpSrvLog-Wed.log is closed and the file named DhcpSrvLog-Thu.log is opened," and "If the audit log file has existed without modification for more than 24 hours, it is overwritten." That leaves about a week of logs locally, which cannot meet DISA retention without forwarding logs to a SIEM.

Caveats and unverified items

- **Corrections to the prior pass:**
    - The failover minimum is Windows Server 2016 on the current page, not 2012.
    - The reserve percentage belongs to hot standby, not load balance.
    - The shared secret is optional.
    - Scopes are replicated, not pre-matched.
    - RFC 8415 is now obsoleted by RFC 9915.
    - CVE-2025-21379 is a DHCP Client CVE.
- **Not verified on a primary page this pass:**
    - Microsoft's explicit statement of the DDNS default and of audit logging being on by default.
    - Microsoft's definitions of the DHCP Administrators/Users groups.
    - The link-layer filtering page.
    - The current DHCP role overview URL.
    - Exact text of RFCs 3046, 3118, 3942, 4388 (from IETF records/knowledge; not re-fetched).
    - CIS Benchmark DHCP coverage.
    - The latest SP 800-53 release number.
- **MSRC pages render client-side.** CVE details came from MSRC search-index snippets. The CVEs marked secondary-source (including CVSS 9.8 claims) should be confirmed in the Security Update Guide before being cited.
- **DISA:** the "no DHCP STIG" conclusion and the WS2022 V2R10 / WS2025 V1R3 dates come from mirrors (cyber.trackr, NIST NCP, Tenable). They disagree on exact dates (e.g., 10 Aug vs. 10 Sep 2026).
- **Akamai's prevalence figures** (40%, 57%) come from its own customer telemetry and are not independently verifiable. Its mitigation list was only partly visible.
- **Scope:** mitm6 originated at Fox-IT (Netherlands). It's referenced only to identify the attack; no non-US government sources were used.

DISA STIGs and DISA STIG GPO Packages: A US-Only Reference Collection (verified as of October 19, 2026)

DISA's Security Technical Implementation Guides (STIGs) are the DoD's product-specific configuration standards, derived from DISA Security Requirements Guides (SRGs) that are in turn derived from NIST SP 800-53 via Control Correlation Identifiers (CCIs); the current quarterly DISA GPO package is "Group Policy Objects (GPOs) - October 2026," uploaded to the DoD Cyber Exchange on 2026-10-16, and the current STIG Viewer is 3.8.1 (released October 2, 2026).

1. TL;DR — the US guidance baseline

- **What and who:** STIGs (XCCDF-formatted, rule-by-rule hardening requirements rated CAT I/II/III) and SRGs (technology-class requirements that "are derived from the NIST 800-53 and related documents") are published by the Defense Information Systems Agency (DISA) on the DoD Cyber Exchange (cyber.mil, formerly public.cyber.mil). DoDI 8510.01 (RMF for DoD; 2014 text, RMF Step 3) requires that products in a system boundary "be configured in accordance with applicable STIGs or SRGs where STIGs are not available." The DISA GPO package (latest: October 2026, uploaded 2026-10-16) is an implementation aid containing ADMX templates, GPO backup exports, GPO reports, WMI filter exports and STIG checklist files that cover "most applicable GPO STIG settings". It is not the STIG itself.
- **How it fits RMF/800-53:** each STIG rule cites one or more CCIs, and each CCI decomposes an SP 800-53 control into a single, actionable statement. NIST's National Checklist Program (NCP) re-lists DISA STIGs (with SCAP 1.4 content and links to the DISA GPO package) alongside CIS and vendor checklists. Assessment is done with DISA STIG Viewer 3.8.1 (CKL/CKLB checklists), the Navy's SCAP Compliance Checker (SCC 5.15, NIWC Atlantic, released 09/01/2026), and optionally the Navy's Evaluate-STIG (NSWC Crane/NAVSEA) and STIG Manager (NUWC Newport, open source).
- **How to get them:** unclassified STIGs, SRGs, SCAP benchmarks, the GPO package, STIG Viewer and SCC are free, public downloads from cyber.mil. CAC/PKI is needed only for restricted content and some tools' distribution points (e.g., Evaluate-STIG on NAVSEA's SPORK). The comparison baselines are CIS Benchmarks (consensus-based, free PDF under CC BY-NC-SA 4.0, with a STIG profile that replaced the former Level 3) and Microsoft security baselines in the Security Compliance Toolkit (SCT 1.0, Download Center page dated 10/8/2026). The Windows STIGs build on the Microsoft baselines and generally exceed them.

2. Guidance landscape overview

Publisher	Key document / tool	Version / date (as verified)	Status	Access
DISA	STIGs & SRGs (A–Z list, STIG Document Library)	Quarterly; October 2026 quarterly release announced Oct 6, 2026 (e.g.,	Current	Public (unclassified); restricted items need CAC/PKI

Publisher	Key document / tool	Version / date (as verified)	Status	Access
		Windows 11 STIG V2R11, Windows Server 2022 STIG V2R11, Windows Server 2025 STIG V1R4)		
DISA	Group Policy Objects (GPOs) package	"Group Policy Objects (GPOs) - October 2026," uploaded 2026-10-16; July 2026 package announced July 22, 2026	Current (October 2026)	Public
DISA	Intune Policy package	"Intune Policy - October 2026," uploaded 2026-10-16	Current	Public
DISA	STIG Viewer 3.x	3.8.1 (Oct 2, 2026; dependency refresh, no functional change); 3.8.0 + User Guide V1R8 (Aug 18, 2026)	Current; 2.x legacy	Public
DISA	CKLB JSON schema	"Stig Viewer 3 CKLB JSON Schema," uploaded 2024-01-10	Current	Public
DISA	SRG/STIG Applicability Guide	Built into STIG Viewer 3.x	Current (standalone tool superseded)	Public
DISA	CCI List / CCI process	CCI process doc (draft V1R0.1, legacy); CCI data exportable from STIGs via STIG Viewer	Current data; publication location has moved	Public
NIWC Atlantic (U.S. Navy)	SCAP Compliance	5.15, released 09/01/2026	Current	Public since 5.4

Publisher	Key document / tool	Version / date (as verified)	Status	Access
	Checker (SCC)	(cyber.mil upload 2026-09-09); supports SCAP 1.0–1.4		
NSWC Crane / NAVSEA (U.S. Navy)	Evaluate-STIG (PowerShell)	Current 2026 build not verifiable (CAC-gated repository)	Active	CAC/PKI (NAVSEA SPORK; Intelink for SIPR)
NUWC Division Newport (U.S. Navy)	STIG Manager (open source)	1.6.17 (requires MySQL 8.4.0+); active development in Oct 2026	Current	Public (GitHub)
NIST	SP 800-53 Rev 5	Sept 2020 (updated Dec 2020)	Current control catalog	Public domain
NIST	National Checklist Program (ncp.nist.gov / nvd.nist.gov/ncp/repository)	Live repository; e.g., Windows 10 STIG V3R7 (Checklist ID 629)	Current	Public
NIST	SP 800-70 (NCP guidelines)	Rev 5 final May 8, 2026 (IPD Dec 9, 2025); supersedes Rev 4 (Feb 15, 2018)	Rev 5 current; Rev 4 superseded	Public domain
NIST	SP 800-126 (SCAP)	Rev 4 / SCAP 1.4 final June 8, 2026 (draft Dec 11, 2025)	Current; SCAP 1.3 (Rev 3) superseded	Public domain
NIST	SP 800-37 Rev 2 (RMF), SP 800-137 (ISCM), SP 800-117 (SCAP adoption)	Dec 20, 2018 (supersedes Rev 1, June 5, 2014); Sept 30, 2011 (companion SP 800-137A); 2010	Current / current / legacy (SP 800-117 not re-verified)	Public domain
DoD CIO	DoDI 8500.01 “Cybersecurity”	March 14, 2014, as amended	Current	Public
DoD CIO	DoDI 8510.01 “Risk	Effective July 19, 2022 (reissued	Current; 2014 version	Public

Publisher	Key document / tool	Version / date (as verified)	Status	Access
	Management Framework for DoD Systems"	and cancelled the March 12, 2014 version)	superseded	
CNSS	CNSSI 1253 (NSS categorization/control selection)	Cited in STIG Overview documents	Current (version not re-verified)	Public
NSA	Legacy configuration guides; Windows Secure Host Baseline (code.nsa.gov); Cybersecurity Information Sheets	e.g., "Best Practices Guide for Cyber Hygiene" CSI (Sept 2026)	Legacy baselines; CSIs current	Public
CIS (US nonprofit)	CIS Benchmarks incl. STIG Benchmarks; CIS-CAT Lite/Pro	e.g., Windows 11 STIG 1.2.0; Windows Server 2022 STIG 3.0.0; 2019 STIG 4.0.0; 2016 STIG 4.0.0	Current	Free PDF (CC BY-NC-SA 4.0); CIS-CAT Pro and build kits need SecureSuite membership
Microsoft	Security Compliance Toolkit 1.0 (baselines, LGPO, Policy Analyzer, SetObjectSecurity)	Download Center page dated 10/8/2026; Windows 11 v26H2 baseline (Sept 2026), Windows Server 2025 baseline "2602" (Feb 2026), Edge v151, M365 Apps 2512	Current; Security Compliance Manager (SCM) retired	Free; Microsoft terms

3. Section A — DISA's own artifacts and tooling

A.1 What a STIG is, and the SRG → STIG hierarchy

- **Source:** DoD Cyber Exchange STIG pages (https://www.cyber.mil/stigs/); DoDI 8510.01; STIG Overview documents (e.g., Amazon Linux 2023 STIG Overview V1R4, 01 July 2026, "Developed by Amazon and DISA for the DOD"). Publisher: DISA (Risk Management Executive). Free; unclassified. Status: current.
- **Definition (DoD policy):** DoDI 8510.01 describes STIGs as product-specific documents that capture applicable DoD policies and security requirements as well as best practices

and configuration guidelines. SRGs are developed by DISA to give general security compliance guidelines and "serve as source guidance documents for STIGs"; "When a STIG is not available for a product, an SRG may be used."

- **Derivation from NIST SP 800-53:** SRG overviews state the requirements "are derived from the NIST 800-53 and related documents." STIG Overview documents add that "All technical NIST SP 800-53 requirements were considered while developing this STIG" and that applicable 800-53 controls are applied based on CNSSI 1253.
- **Example SRGs:** General Purpose Operating System (GPOS) SRG (a third-party tracker lists V3R4 dated 2026-10-05; not confirmed on cyber.mil); Application Server SRG (V4R5/V4R6 in 2026 per third-party trackers); Network Device Management SRG; Application Security and Development (ASD) STIG/SRG. DISA released a draft **General Application (GAPP) SRG** for review on August 18, 2026.
- **Vendor-developed STIGs:** DISA's Risk Management Executive runs a process in which product vendors author STIGs that DISA reviews and publishes (e.g., the Amazon Linux 2023 STIG is labeled "Developed by Amazon and DISA for the DOD").
- **Example rule counts:** Windows Server 2025 STIG V1R1 (26 Jan 2026) contains 284 rules — 29 CAT I, 243 CAT II, 12 CAT III (per a third-party STIG tracker that mirrors DISA content).

A.2 STIG structure and identifiers

- **Format:** STIGs ship as ZIP packages containing an XCCDF (Extensible Configuration Checklist Description Format) XML benchmark plus PDF companions (Overview, Revision History, Read Me, Release Memo). The XCCDF is a "manual" (human-checked) benchmark; automated checks ship separately as SCAP benchmarks (XCCDF + OVAL data streams). NIST NCP listings show DISA now publishing **SCAP 1.4** content (e.g., "U_MS_Windows_10_V3R7_STIG_SCAP_1-4_Benchmark") and "Standalone XCCDF 1.1.4" STIG files.
- **Versioning:** "Version X, Release Y" (VxRy), e.g., Windows 11 STIG V2R11. New Versions generally mean major restructuring; Releases are incremental updates.
- **Per-rule fields** (as exposed by STIG Viewer 3.x, which sorts/searches on them): Group ID (Vuln ID, form V-######, e.g., V-279922), Rule ID (form SV-######r######_rule), STIG ID (product-prefixed, e.g., WN25-00-000070 for Windows Server 2025), Rule Title, Severity, Discussion, Check (check text), Fix (fix text), CCI references, and Legacy IDs. SRG-based rules also carry an SRG requirement ID (e.g., SRG-OS-000327-GPOS-00127) and often a "Satisfies:" list of multiple SRG IDs.
- **Numbering transition:** current STIGs use the V-/SV- identifiers; older identifiers are retained in the Legacy ID field so assessors can map findings across revisions. (The exact date DISA re-baselined numbering was not re-verified in this research.)

A.3 Severity Category Codes (CAT I / II / III)

- **Source:** "Vulnerability Severity Category Code Definitions" table in every STIG Overview (e.g., Amazon Linux 2023 STIG Overview V1R4, July 2026). Each security policy in a STIG "is assigned a Severity Category Code of CAT I, II, or III."
- **CAT I (High):** any vulnerability whose exploitation "will directly and immediately result in loss of Confidentiality, Availability, or Integrity."

- **CAT II (Medium):** any vulnerability whose exploitation "has a potential to result in loss of" confidentiality, availability, or integrity.
- **CAT III (Low):** any vulnerability whose exploitation "degrades measures to protect against loss of" confidentiality, availability, or integrity.
- **XCCDF mapping:** in XCCDF, CAT I/II/III appear as severity high/medium/low. STIG Viewer 3.x allows a reviewer to override severity in a checklist (with justification). Vendor documentation notes that most rules are CAT II and that "During STIG development DISA may modify severity."
- **Not CVSS:** CAT codes rate the impact of a misconfiguration/weakness in DoD context; they are not CVSS scores and are not computed from CVSS metrics.

A.4 The DISA STIG GPO package

- **Title / location:** "Group Policy Objects (GPOs)" — https://www.cyber.mil/stigs/gpo/. Publisher: DISA Risk Management Executive. Free, unclassified, public. Status: **current release "Group Policy Objects (GPOs) - October 2026," uploaded 2026-10-16**, alongside a separate "Intune Policy - October 2026" package (same date). Prior release: July 2026 (announced July 22, 2026, with "Change Log document included in the .zip files"). July 2026 ZIP name: U_STIG_GPO_Package_July_2026.zip (per NIST NCP; NCP publishes a SHA-256 hash for it).
- **Contents (DISA's description):** "This package contains ADMX template files, GPO backup exports, GPO reports, and WMI filter exports and STIG Checklist files." Earlier packages (e.g., January 2022) also contained a ReadMe.txt, Change Log, and Known Issues file; per-product folders are named like "DoD Windows 11 vXrY" / "DoD Microsoft Edge VxRy," each holding a GPO backup and report (gpreport.xml). In 2022 the Intune policies were inside the ZIP; in 2026 they are a separate download.
- **LGPO / scripts:** No evidence was found that Microsoft's LGPO.exe is bundled in the DISA package; third-party guides instruct users to download LGPO from Microsoft's SCT and point it at the DISA GPO folder for standalone (non-domain) systems. Import scripts and a version table could not be confirmed for 2026.
- **Coverage (as verifiable):** DISA's July 2026 announcement lists Windows 10, Windows 11, Office 2019–M365 Apps, Microsoft Edge, and Microsoft Defender Antivirus; NIST NCP pages link the 2026 GPO package from the Windows 11 STIG (V2R11), Windows 10 STIG (V3R7), Windows Defender Firewall with Advanced Security, Office 365 ProPlus, OneDrive, and Office System 2016 checklists. Third-party guides show Windows Server 2022 domain controller/member server GPOs and Firefox in recent packages. Windows Server 2016/2019/2025, Active Directory Domain/Forest, IE11, Chrome and Adobe GPOs were **not** confirmed for 2026 in this research.
- **Relationship to STIG rules:** the GPOs "contain most applicable GPO STIG settings contained in STIG files" — i.e., only settings that are expressible as Group Policy, and not all of those (organization-specific values such as some User Rights Assignments are placeholders). Manual/procedural rules (documentation, account reviews, file permissions requiring local judgement) are outside the GPOs. DISA warns the GPOs must be evaluated in a representative test environment before production.
- **Timing:** GPO and STIG dates can differ; DISA aims for the gap to be no more than "a few weeks" (e.g., October 2026 STIGs announced Oct 6; GPOs uploaded Oct 16).

A.5 Release cadence, Sunset STIGs, document library

- **Quarterly Release Schedule and Summary page** (https://www.cyber.mil/stigs/quarterly-release-schedule-and-summary): Q1 "End of January 2026," Q2 "End of April 2026," Q3 "End of July 2026"; the Q4 row still reads "End of October 2025" (page not updated at time of research). Actual 2026 announcements were earlier in the month: July 2026 Quarterly Release (July 10, 2026) and October 2026 Quarterly Release (October 6, 2026). Out-of-cycle updates and draft SRGs (e.g., GAPP SRG draft, Aug 18, 2026) appear between quarters.
- **STIG Announcements page** (https://www.cyber.mil/stigs/stig-announcements) is the authoritative change feed (quarterly releases, tool releases, GPO/Intune updates).
- **Sunset STIGs:** superseded or end-of-life products are moved to "Sunset" status (e.g., NCP lists "Sunset - Microsoft Windows 10 STIG - Ver 2, Rel 9" and "Sunset-Microsoft Windows 10 STIG - Ver 3, Rel 6" as prior XCCDF files). Sunset content remains downloadable but is no longer maintained.
- **Libraries:** the STIGs Document Library (https://www.cyber.mil/stigs/downloads/) and quarterly STIG Library Compilation ZIPs (which STIG Viewer and STIG Manager can import wholesale).

A.6 STIG Viewer 3.x

- **Title / location:** STIG Viewer 3.x — "SRG and STIG Tools" page (https://www.cyber.mil/stigs/srg-stig-tools/). Publisher: DISA. Free, public; Windows (ZIP and MSI) and Linux builds plus a hash file.
- **Current version: 3.8.1, uploaded/announced October 2, 2026** ("refreshes software dependencies… There are no changes to functionality"). 3.8.0 and the **STIG Viewer 3.x User Guide V1R8** were released August 18, 2026. Adaptiva's third-party patch library lists 3.7.0 with a release date of 2/11/2026; its release notes include an "Updated CCI List" and "Updated Applicability Guide content as of January 2026."
- **What it does (User Guide V1R6, 15 Aug 2025):** views one or more XCCDF STIGs in human-readable form; maintains a STIG library; imports compilation ZIPs; searches by Content, Rule Title, Severity, STIG ID, Group ID, Rule ID, CCI or Legacy ID; displays CCI data; compares STIG versions; builds checklists; imports SCAP/XCCDF results into checklists so the manual portion can be completed; exports HTML/CSV; and includes the SRG/STIG Applicability Guide (build an asset collection and determine which SRGs/STIGs apply).
- **Checklist formats:** CKL (legacy XML, used by STIG Viewer 2.x and eMASS; 3.4 renamed "eMass CKL" export to "CKL") and **CKLB** (JSON; DISA publishes the "Stig Viewer 3 CKLB JSON Schema").
- **Legacy:** "STIG Viewer Version 3.x is a replacement for the previous DISA tools STIG Viewer 2.x and STIG-SRG Applicability Guide." 3.x is not Java-based; DISA's FAQ states there will be no JAR release. Windows EXE/MSI files have been DoD code-signed since 2.15.

A.7 SCAP content and the SCAP Compliance Checker (SCC)

- **Title / location:** SCAP Compliance Checker — NIWC Atlantic page (https://www.niwcatlantic.navy.mil/Technology/SCAP/) and DISA SCAP page (https://www.cyber.mil/stigs/SCAP/). Developer: **Naval Information Warfare**

Center (NIWC) Atlantic, U.S. Navy; distributed via the DoD Cyber Exchange and a public GitHub archive (niwc-atlantic/scap-scc). Free; governed by an end-user licence agreement.

- **Current version: SCC 5.15, release date 09/01/2026** (NIWC); cyber.mil files uploaded 2026-09-09 for Windows, Linux x86_64 and AArch64, Solaris 11 (i386/SPARC), macOS ARM64, plus a UNIX remote-scanning plugin. SCC 5.14.1 Ubuntu builds remain (2026-05-05).
- **Capabilities:** "SCC is a SCAP Validated Authenticated Configuration Scanner, with support for SCAP versions 1.0, 1.1, 1.2, 1.3 and 1.4"; local and remote scanning of Windows and Linux/Solaris; Cisco IOS/IOS XE offline and SSH scanning; GUI and CLI. NIST's SCAP 1.3 validation record (#147) is for SCC 5.6.0.1, validated 11/04/2022.
- **Public availability and history:** "Starting with version 5.4, SCC is publicly available and can be downloaded from" DISA (Navy press release, 2021, "free for public use"); funding credits run IRS (2008–2010), NSA (2010–2012), DISA (2013–2022).
- **DISA SCAP benchmarks:** published on the SCAP page per product (e.g., "Microsoft Windows 11 STIG SCAP Benchmark - Ver 2, Rel 11," uploaded 2026-10-05). SCAP benchmarks automate only a subset of each STIG's rules; the remainder must be checked manually (STIG Viewer) or with tools such as Evaluate-STIG.

A.8 Evaluate-STIG (separate from DISA)

- **Developer:** Naval Surface Warfare Center (NSWC) Crane Division, under NAVSEA (U.S. Navy) — a US government tool, not a DISA product.
- **Distribution:** NAVSEA GitLab "SPORK" (spork.navsea.navy.mil/nswc-crane-division/evaluate-stig), which requires DoD CAC/PKI; classified networks via Intelink (NAVSEA-RMF). Not distributed on cyber.mil.
- **What it does:** PowerShell (with a Bash variant for Linux) that detects applicable STIGs on an asset, evaluates the checks it has logic for (including many manual checks), and writes CKL/CKLB checklists; supports -ListSupportedProducts/-ListApplicableProducts and can upload results directly to STIG Manager (requires PowerShell 7 for that integration).
- **Version:** the current 2026 build could not be verified from public sources.

A.9 STIG Manager (open source)

- **Developer:** Naval Undersea Warfare Center Division Newport (NUWCDIVNPT), U.S. Navy; GitHub (NUWCDIVNPT/stig-manager), container images including an Iron Bank variant.
- **What it does:** API and web client for managing STIG assessments across collections of assets; imports DISA STIG library compilations, CKL/CKLB and XCCDF results; exports CKL(B).
- **Current state:** release 1.6.17 raised the minimum database to MySQL 8.4.0; active development through October 2026 (e.g., merges dated Oct 5 and Oct 14, 2026).

A.10 Control Correlation Identifiers (CCIs)

- **Definition (DISA):** CCI "provides a standard identifier and description for each of the singular, actionable statements that comprise an IA control or IA best practice," bridging "high-level policy expressions and low-level technical implementations."

- **Role:** STIG and SRG rules cite CCIs (e.g., CCI-001453 maps to AC-17); CCIs map to SP 800-53 controls (current Rev 5 CCIs include IDs in the CCI-004xxx range). DoDI 8510.01 tasks DISA to ensure CCIs, SRGs and STIGs are consistent with DoD security controls and assessment procedures.
- **Governance:** DISA's CCI process document (draft V1R0.1) states DISA established the initial CCI List from SP 800-53 and accepts proposed changes by email (cci@disa.mil).
- **Where to get the list (conflicting sources):** one DAU Acquipedia version says that "As of 2021, the CCI List is no longer published on the DOD Cyber Exchange" and directs users to export CCIs from STIGs via STIG Viewer; another version says the CCI list "has moved to the STIG Document Library downloads section." STIG Viewer 3.7 release notes cite an "Updated CCI List" bundled in the tool. Treat STIG Viewer and the STIG Document Library as the current routes.

A.11 Access notes (public vs CAC/PKI)

- DISA's legacy download page describes two tiers: "DoD Cyber Exchange Public (public.cyber.mil)," with "limited access to publicly releasable cyber training and guidance to all Internet users," and "DoD Cyber Exchange NIPR (cyber.mil)," with exclusive access for DoD PKI credential holders. Current www.cyber.mil pages carry the banner "Login with DoD CAC for full access."
- Unclassified STIGs, SRGs, SCAP benchmarks, the GPO and Intune packages, STIG Viewer and SCC are listed as "Unclassified" and are publicly downloadable. Some STIGs and supporting content (and Evaluate-STIG) require DoD PKI.
- Recent DISA documents use "Department of War (DoW)" wording in places alongside "DOD"; cyber.mil content is being migrated, and some legacy pages (e.g., Cyber Workforce content) are slated to sunset December 31, 2026.

4. Section B — Related US government and standards guidance

B.1 NIST

- **SP 800-53 Rev 5, *Security and Privacy Controls for Information Systems and Organizations*** — NIST; Sept 2020 (updated Dec 2020); current; free, US government work (public domain in the US). Scope: the control catalog the SRGs/STIGs implement via CCIs. Key point: controls are outcome-oriented, not product settings; STIGs supply the product-level settings for configuration controls such as CM-6 (configuration settings) and CM-7 (least functionality).
- **National Checklist Program (NCP)** — https://ncp.nist.gov (also reachable via nvd.nist.gov/ncp/repository); current; free. Scope: centralized repository of security configuration checklists from authoritative sources. Key points: lists DISA STIGs with authority "Governmental Authority: Defense Information Systems Agency," review status, type (Compliance), and links to SCAP content, standalone XCCDF, GPO and Intune packages — e.g., Windows 10 STIG V3R7 (Checklist ID 629) links "Group Policy Objects (GPOs) - July 2026" and SCAP 1.4 content. NCP also hosts CIS Benchmarks, which carry CIS's CC BY-NC-SA 4.0 licence text.
- **SP 800-70, *National Checklist Program for IT Products: Guidelines for Checklist Users and Developers*** — NIST. The Rev 5 IPD was released Dec 9, 2025, with comments due Jan 16, 2026. NIST CSRC lists Rev 5 as final on May 8, 2026 (authors

Stephen Quinn and Blair Heiserman, DOI 10.6028/NIST.SP.800-70r5), superseding Rev 4 (02/15/2018). Rev 5 adds mappings between checklist settings, CSF 2.0 outcomes, SP 800-53 controls and CCE identifiers. **Note on tiers:** the Tier I–IV scheme (Tier I prose-based through Tier IV complete SCAP-validated content) is from Rev 3; Rev 4 "Removed the checklist 'tier' and 'SCAP Expressed' concepts," so NCP listings now describe automation by content type (prose vs SCAP) rather than tier. The NCP participant page still listed Rev 5 as an initial public draft at time of research.

- **SP 800-126 Rev 4, *Technical Specification for SCAP: SCAP Version 1.4*** — NIST; final June 8, 2026 (draft Dec 11, 2025); current; with annex SP 800-126A Rev 4. Key points: SCAP 1.4 "is the current final release"; Rev 4 removes backward-compatibility requirements for earlier SCAP versions, revises digital-signature requirements, and redirects OVAL references to the OVAL Community GitHub. NIST credits NIWC Atlantic's team (Jack Vander Pol is a co-author) with shaping the revision. SCAP 1.3 (Rev 3) is superseded; NIST's SCAP Content Validation Tool supports 1.2, 1.3 and 1.4.
- **RMF publications** — these frame where STIG compliance evidence is used (the Implement, Assess and Monitor steps). SP 800-37 Rev 2 (RMF, Joint Task Force) was finalized 12/20/2018 and supersedes Rev 1 (06/05/2014). SP 800-137 (ISCM; Dempsey, Johnston of DoD, Stine et al.) was finalized 09/30/2011, with SP 800-137A as a companion. SP 800-117 (SCAP adoption guide, 2010) is legacy and was not re-verified.

B.2 DoD policy

- **DoDI 8500.01, "Cybersecurity"** — DoD CIO; March 14, 2014, as amended; current; public. It establishes the DoD cybersecurity program. As quoted in NIST NCP's DISA checklist entry, it says all DoD IT "will be […] configured […] consistent with applicable DoD cybersecurity policies, standards, and architectures," and that DISA "develops and maintains control correlation identifiers (CCIs), security requirements guides (SRGs), security technical implementation guides (STIGs)…"
- **DoDI 8510.01, "Risk Management Framework for DoD Systems"** — DoD CIO; effective July 19, 2022 (reissued and cancelled the March 12, 2014 "RMF for DoD IT" version); current; public. Key points (2014 text, carried forward in substance): DISA ensures CCIs, SRGs and STIGs are consistent with DoD controls and assessment procedures; systems are configured per applicable STIGs, or SRGs where STIGs are unavailable; assessment is performed at the CCI level.
- **CNSSI 1253** — Committee on National Security Systems; cited in STIG Overviews as the basis for applying SP 800-53 controls to DoD/NSS systems.

B.3 NSA

- **Posture:** NSA historically published security configuration guides (now archived) and the Windows Secure Host Baseline repository on code.nsa.gov ("Configuration guidance for implementing the Windows 10 and Windows Server 2016 DoD Secure Host Baseline settings"), now legacy. No current, comprehensive NSA Windows baseline separate from DISA was found; DISA owns STIGs.
- **Current outputs:** NSA Cybersecurity Information Sheets (CSIs) on targeted hardening topics, e.g., "Guidance for Managing UEFI Secure Boot" and "Best Practices Guide for Cyber Hygiene" (Sept 2026). These are free US government publications and complementary to, not substitutes for, STIGs.

- **Tool relationship:** NSA funded SCC development in 2010–2012.

B.4 CIS (Center for Internet Security, US nonprofit)

- **CIS Benchmarks** — https://www.cisecurity.org/cis-benchmarks; "more than 100 CIS Benchmarks across 25+ vendor product families," developed "through a unique consensus-based process." Free PDFs for non-commercial use under **CC BY-NC-SA 4.0**; commercial use requires CIS approval; CIS Controls use CC BY-NC-ND 4.0.
- **Profiles:** Level 1 (base hardening with minimal functional impact), Level 2 (defense in depth), and a **STIG profile** that "replaces the previous Level 3" and "provides all recommendations that are STIG specific"; where a STIG recommendation contradicts a CIS recommendation, this is noted in the recommendation description, and the STIG ID is listed in each recommendation's additional information.
- **CIS STIG Benchmarks (current versions listed):** Microsoft Windows 11 STIG 1.2.0, Windows 10 STIG 1.0.0, Windows Server 2022 STIG 3.0.0, Windows Server 2019 STIG 4.0.0, Windows Server 2016 STIG 4.0.0, Windows Server DNS STIG 1.0.0, SQL Server 2022 Instance STIG 1.0.0, Apple macOS 26 Tahoe STIG 1.0.0, among others; CIS also sells STIG Hardened Images on cloud marketplaces.
- **CIS-CAT:** CIS-CAT Pro (automated assessment against benchmarks, including the STIG benchmarks) and build kits (GPOs) require CIS SecureSuite membership (paid); CIS-CAT Lite is free with limited content.
- **Cadence:** CIS commits to cover the latest Windows build "within 90 days of a new Windows version release."

B.5 Microsoft

- **Security Compliance Toolkit (SCT) 1.0** — https://www.microsoft.com/en-us/download/details.aspx?id=55319; Download Center page dated **10/8/2026**; free under Microsoft's Download Center terms (not public domain). Current files include Windows 11 v26H2 Security Baseline v2, v25H2, v24H2, v23H2; Windows Server 2025 Security Baseline – 2602; Windows Server 2022; Windows 10 22H2 and older; Microsoft Edge v151; Microsoft 365 Apps for Enterprise 2512; **LGPO.zip**; **PolicyAnalyzer.zip**; SetObjectSecurity.zip.
- **Baselines:** Microsoft's version matrix shows Windows 11 26H2 (September 2026) and Windows Server 2025 (February 2026). Each baseline ZIP contains "GPO Backups, GPO reports, Excel spreadsheets, WMI filters, and scripts to apply the settings to local policy." SCT replaced the retired Security Compliance Manager.
- **LGPO.exe:** command-line tool to apply/export local policy — imports GPO backups, registry.pol, security templates (GptTmpl.inf) and audit CSVs, and converts registry.pol to/from "LGPO text."
- **Policy Analyzer:** read-only comparison of GPO sets (and local policy/registry), highlighting redundancies and conflicts; exports to Excel — the standard way to diff a DISA GPO against the Microsoft baseline.
- **Relationship to STIGs:** Microsoft's baselines are Microsoft's recommended enterprise settings; Windows STIGs cover most of the same settings and add DoD-specific requirements (e.g., DoD banners, stricter audit and account policies, DoD PKI/certificate rules) plus non-GPO procedural checks, so a STIG-configured system generally exceeds the Microsoft baseline, with some differing values.

B.6 IETF

- Not applicable as a source of STIG requirements. STIGs reference protocols (e.g., TLS, SNMP, NTP) by name and version and occasionally cite RFCs within individual rules, but no IETF document defines or governs STIGs.

5. Topic crosswalk

Topic	DISA STIG	NIST (NCP / CCI context)	NSA	CIS Benchmark	Microsoft Security Baseline
What it is / source of truth	DoD-mandated product configuration standard; cyber.mil is authoritative	NCP is a repository of others' checklists; SP 800-53 is the control catalog; CCIs (DISA-maintained) bridge the two	Targeted hardening CSIs; legacy guides	Consensus best-practice configuration guide; cisecurity.org	Vendor-recommended enterprise baseline; Microsoft Download Center (SCT)
Format	XCCDF XML (+ SCAP 1.4 data streams); PDFs; checklists CKL/CKLB	SCAP/XCCDF or prose as supplied by authors	PDF prose; some scripts/configs	PDF/Word/Excel; XCCDF/SCAP for members	GPO backups, Excel spreadsheets, reports, scripts
Severity scheme	CAT I / II / III (high/medium/low)	None of its own; NVD uses CVSS for CVEs, not configuration settings	None standard	Level 1 / Level 2 / STIG profile (scope tiers, not severity)	None (settings are recommended or not)
Automation / GPO package	Quarterly DISA GPO package + Intune package	Links to DISA GPO packages from STIG entries	None	Build kits (GPOs) for SecureSuite members	Baseline GPOs + LGPO.exe for local application
Scanning / assessment tool	SCC (NIWC Atlantic), STIG Viewer, Evaluate-STIG (NSWC Crane), STIG Manager	SCAP-validated tools (validation program)	None	CIS-CAT Pro (paid) / CIS-CAT Lite (free, limited)	Policy Analyzer (compare); no compliance scanner in SCT

Topic	DISA STIG	NIST (NCP / CCI context)	NSA	CIS Benchmark	Microsoft Security Baseline
	(NUWC Newport)				
Control mapping	CCIs → SP 800-53 Rev 5 per rule	SP 800-70 Rev 5 adds mapping to CSF 2.0, 800-53, CCE	Not systematic	Maps to CIS Controls (and STIG IDs in the STIG profile)	Not mapped to 800-53 in the baseline
Release cadence	Quarterly (Jan/Apr/Jul/Oct) plus out-of-cycle; GPOs within weeks of STIGs	Continuous as authors submit	Ad hoc	Per-benchmark; Windows within 90 days of new build	Per Windows/Server/Edge/M365 release
Access & licence	Free, public (unclassified); some CAC-only; US government work	Free; public domain (NIST) but listed checklists keep authors' licences	Free; US government work	Free PDF CC BY-NC-SA 4.0; paid membership for tools/formats	Free; Microsoft terms
Consensus vs authoritative	Authoritative (DoD policy via DoDI 8500.01/8510.01)	Neutral host; doesn't author most content	Advisory	Consensus (community + vendors)	Vendor guidance
Learner/ portfolio use	Download STIG + GPO package; apply in lab; scan with SCC; complete CKLB in STIG Viewer	Find current checklist versions and links; cite CCI→800-53 mappings	Supplementary hardening topics	Compare Level 1/2 vs STIG profile; CIS-CAT Lite for scoring	Start from baseline; diff vs DISA GPO in Policy Analyzer; LGPO for standalone hosts

6. Where authorities agree, differ, or conflict

- **DISA STIG vs CIS Benchmark:** both target secure configuration and overlap heavily on Windows/Linux settings. The difference is authority and process: STIGs are DoD-mandated and DISA-approved (often vendor-authored); CIS Benchmarks are consensus products. CIS's STIG profile explicitly bridges the two and flags contradictions with CIS recommendations — the clearest sign the baselines are not identical. CIS STIG

Benchmark versions (e.g., Windows Server 2022 STIG 3.0.0) track specific DISA releases and can lag DISA's quarterly updates.

- **STIG GPO package vs Microsoft baseline:** both are delivered as GPO backups with reports and WMI filters, and DISA's Windows GPOs largely start from the same Windows settings. DISA adds DoD-specific and stricter values and omits settings that need organizational values (placeholders); Microsoft ships LGPO and Policy Analyzer, while DISA's package (per available evidence) does not bundle LGPO. Use Policy Analyzer to see exact deltas for a given release pair.
- **Severity models are not comparable:** CAT I–III rates DoD impact of a weakness; CVSS scores software vulnerabilities (CVEs); CIS Level 1/2/STIG are profile scopes; CIS Implementation Groups (IG1–IG3) belong to the CIS Controls, not the Benchmarks. A CAT I finding is not equivalent to a "critical" CVSS score.
- **Cadence:** DISA is quarterly (2026 releases arrived early in Jan/Apr/Jul/Oct months, e.g., Oct 6), with GPOs a few weeks later (Oct 16); Microsoft ships per OS/app release (e.g., Windows 11 26H2 baseline in September 2026, ahead of a DISA STIG for that build); CIS targets 90 days after a Windows release. Expect periods when the newest Windows build has a Microsoft baseline but not yet a matching STIG update.
- **Manual vs SCAP-automatable checks:** SCAP benchmarks (SCC) automate only part of a STIG; the remainder is manual (STIG Viewer) or semi-automated (Evaluate-STIG). A clean SCC score is not full STIG compliance.
- **Applicability outside DoD:** STIGs are required for DoD systems per DoDI 8510.01, but are freely usable elsewhere as hardening references; NIST NCP lists them for broad use. Non-DoD frameworks (e.g., NIST SP 800-171/CMMC) do not name STIGs as the required baseline (per secondary sources).
- **Internal DISA inconsistencies to note:** the Quarterly Release Schedule page's Q4 row still reads "End of October 2025"; Windows Server 2025 versioning differs between the October announcement (STIG V1R4) and the SCAP benchmark (V1R2, uploaded 2026-10-05) — SCAP benchmark release numbers are tracked separately from STIG release numbers, so always match the benchmark to the STIG release named in its readme.

7. Caveats and items that could not be verified

- cyber.mil pages render via JavaScript and could not be fetched in full; DISA facts were verified from indexed page text of cyber.mil, DISA PDFs (dl.dod.cyber.mil), and NIST NCP listings.
- The exact October 2026 GPO package file tree, ZIP name, hash, product list, presence of LGPO.exe, import scripts, a "Support Files" folder or a README version table were not verifiable; download the ZIP and read its ReadMe/Change Log to confirm.
- Coverage of Windows Server 2016/2019/2025, Active Directory Domain/Forest, IE11, Chrome and Adobe in the 2026 GPO package was not confirmed.
- The Windows Server 2025 STIG release is reported as V1R4 (October 6 announcement snippet) by one source and V1R2 by trackers; the SCAP benchmark is V1R2. Confirm on the STIG Document Library.
- Evaluate-STIG's current version is behind CAC; not verified. STIG Manager's and SCC's licence terms were not reviewed in detail.

- One third-party source claims SCC downloads are CAC-gated; NIWC Atlantic states SCC has been publicly available from DISA since 5.4 — the primary source is preferred.
- CCI list publication location is described inconsistently by DAU sources; the date of DISA's V-/SV- renumbering was not re-verified.
- SP 800-70 Rev 5 is listed as final on NIST CSRC (May 8, 2026, superseding Rev 4 of 02/15/2018), but the NCP participant page still shows the draft. SP 800-37 Rev 2 (final 12/20/2018) and SP 800-137 (final 09/30/2011) dates are confirmed on CSRC. SP 800-53 Rev 5 minor releases, SP 800-117 and CNSSI 1253 versions were not re-verified in this session.
- DoDI 8500.01's configuration and DISA-tasking wording was confirmed from the quotation in NIST NCP's DISA checklist entry rather than from the instruction itself. DoDI 8510.01's STIG/SRG language ("configured in accordance with applicable STIGs or SRGs where STIGs are not available") was confirmed from the 2014 text, and the 2022 reissue's existence and effective date were confirmed separately.
- Third-party trackers (stigviewer.com, cyber.trackr.live, stigaview.com) were used only for rule counts and SRG versions and are not authoritative.
- US government works (DISA, NIST, NSA, DoD) are generally not subject to US copyright, but vendor-co-developed STIGs and bundled third-party files may carry other terms; DISA does not publish a single explicit reuse licence that was verified here.